Parisar Society Onboarding: Implementation Report

Date: 7 November 2026. Branch: `feat/saas-onboarding` (local only, nothing committed). Scope: web app and backend. The mobile app was not changed.

0. Read this first: local test data was lost

During the security review, an agent ran the full `tests/isolation` suite. An old test helper (`tests/isolation/helpers/phase3.js`, `resetTestState()`, around lines 233-267) deletes **every society except two fixed seed IDs**, plus all audit log, code redemption and family member rows. That wiped the societies and memberships you had created by hand for testing.

The backup taken before the work started was saved in a temporary folder. The machine rebooted at 11:44 on 7 November, which cleared that folder, so **the backup is gone too**. Saving it there was a mistake.

What survives: 23 sign-in accounts and 20 profiles. **What is gone:** the 3 earlier societies (wings, flats, memberships, complaints, notices) and the audit history. The database now holds the society QA created (`QA Sunrise Heights`) and its test records.

To do before running isolation tests again: limit `resetTestState()` to rows the tests created, or run those tests only against an empty database. Until then, never run the full isolation suite, or `code-rate-limit`, `bootstrap-structure`, `list-structure`, `member-onboarding` and `society-setup`, against a database with data you want to keep.

1. Existing architecture

- **Monorepo:** pnpm and Turbo. `apps/web` (Next.js 15 App Router, JavaScript only), `apps/mobile` (Expo, not touched), shared `packages/api-client`, `i18n`, `shared-types`, `ui-tokens`.
- **Backend:** Supabase (Postgres, Auth, Storage). There is no separate API server. Business rules live in `SECURITY DEFINER` database functions (RPCs) with row-level security on every table.
- **Login:** phone OTP (dev code `123456` for test numbers) plus a PIN for returning users. A JWT hook adds the active society and role.
- **UI:** Tailwind 4, shadcn/base-ui primitives, shared components in `components/kit`, translations in English, Hindi and Marathi.

Much of the brief already existed in some form: enrollment requests, the admin console, society authorities, structure setup, resident onboarding, family members, staff, guard, visitors. The work extended these rather than replacing them.

2. Screens and routes

Area	Routes
Public	`/` landing, `/connect`, `/connect/success`, `/enroll` (redirects to `/connect`), `/invite/[token]`
Login	`/login` (Resident / Society authority toggle), `/verify` (OTP, authority society picker, PIN)

Area	Routes
Platform Admin	`/c/[routeId]` console: overview metrics, connect requests table and detail drawer, Register Society, result screen, societies, catalogue, people
Society setup	`/setup` five-step wizard; old `/setup/*` routes redirect to it
Excel import	`/import`
Verification	`/verification` (resident), `/verification/admin` (authorities)
Resident onboarding	`/onboarding`, `/onboarding/status`, `/join/invite/[token]`
Household and approvals	`/household`, `/approvals`
Residents	`/residents/[type]` (owners, tenants, family)
Staff	`/staff/manage`, `/staff/manage/new`, `/staff/manage/[id]`
Dashboards	`/dashboard` (society admin and resident), `/society-dashboard`, `/guard` (security)

3. Completed functionality

- **Landing page:** product introduction, benefits, feature overview, Connect With Us and Login calls to action, responsive navigation and footer. It only claims features that exist.
- **Connect With Us:** society name, several authority numbers (add and remove), contact name, mobile, email, preferred date and time, alternative slot, message. The success page shows a request ID (`PR-XXXX-XXXX`) with a copy button, scheduled date and time, and status. Duplicate open requests and rate limits get clear messages.
- **Platform Admin:** five metrics (total and active societies, pending requests, pending calls, total residents). The requests table has search, filters and pagination. Actions: View Details, Call (phone link plus mark called), Reschedule, Reject with reason and confirmation, Register Society.
- **Register Society:** prefilled from the request; society information, full address, authorities, feature toggles from the catalogue. The result screen shows the society name, generated society code with copy button and registration status. The previously dead "Create staff / Create sales" buttons now work.
- **Authority first login:** authority number, then OTP, then society detection. Only the caller's OTP-verified phone is matched, and no function accepts a phone number from the client, so a number alone never reveals or grants a society. Incomplete setup goes to the wizard; complete goes to personal onboarding or the dashboard.
- **Setup wizard:** society details (read-only; only Parisar staff can edit them), wings (name, code, floors), floors (number, name, flat count), flats (number, type, area, bedrooms, parking slot, status) with bulk generation, optional configuration. Stepper, Save Draft, Previous, Continue, Skip, Complete Setup, and resume where left off. Completing requires at least one wing, floor and flat.
- **Excel import:** download a real .xlsx template, upload, server-side validation, preview with total, valid, warning and error counts and row-level messages, download an error report, import only valid rows, cancel. Invalid rows are never imported. Spreadsheet formula injection in the error report is neutralised.

- **Resident verification:** after OTP the resident sees only their own imported record and can choose Everything Is Correct, Edit Details or Report Incorrect. The admin dashboard has status counts (pending, verified, rejected, needs correction) and filters.
- **Personal onboarding:** Wing, Floor and Flat dropdowns backed by the database (no free text), resident type, owner details, tenant details.
- **Owners:** primary or co-owner, start date, membership number, proof uploads; several owners per flat.
- **Tenants:** all brief fields and documents. The chain is registered, then owner approved, then society approved, then active, with rejection at each step, and the progress is shown on screen.
- **Family:** the owner adds members with relationship. An invite link is created to copy and share; the screen says plainly that nothing was sent automatically. Accepting is OTP, accept, complete profile, linked to the flat.
- **Same-flat household:** select the flat; if a household exists, "Are you already part of this household?" with Yes or No. Access needs approval by the owner or an authorised member. Unverified people see only masked initials and never phone numbers. No duplicate resident records are created.
- **Staff Management:** all brief fields, staff types (Security, Plumber, Electrician, Cleaner, Gardener, Maintenance Staff, Other), ID proof upload. A staff record grants no login.
- **Navigation:** a role-based sidebar following the brief's groups. Items are hidden when the feature is off for the society or no real module exists.
- **Dashboards:** society admin (residents, flats, occupied, vacant, pending requests, pending verification, open complaints, today's visitors), resident, and a simplified security screen with large tap targets.
- **Design system:** Inter as the single interface font with Noto Sans Devanagari for Hindi and Marathi, colour, type, spacing and status tokens, and new shared components (form field, phone input, date picker, searchable select, file upload, stepper, data table, metric card, status badge, confirm dialog, loading, error and empty states, copy button).
- **Translations:** every new screen in English, Hindi and Marathi; the coverage check passes.

4. Backend and API changes

22 new migrations (`supabase/migrations/20261106000058` to `...092`), all additive, applied to the local database. Main new database functions:

- **Connect requests:** `submit_connect_request`, `get_connect_request_status` (public, rate limited); `admin_list_connect_requests`, `admin_get_connect_request`, reschedule, reject, mark called, `admin_onboarding_metrics`.
- **Registration:** `admin_register_society`, `get_society_registration`.
- **Authority login:** `my_authority_societies`, `claim_authority_for_society`, `authority_skip_personal_onboarding`.
- **Setup:** wing, floor and flat save and delete functions, draft progress, `setup_complete`.
- **Import:** `import_validate_rows`, confirm and cancel functions.
- **Verification:** `my_resident_records`, `resident_confirm_record`, `resident_submit_correction`, report incorrect, admin list and decisions.
- **Owners, tenants, proofs:** `attach_proof`, `list_proofs`, `remove_proof`, the tenant chain decision functions, flat owner functions.

- **Family and household:** invite create, preview and accept, `household_lookup`, access request and decision.
- **Staff:** `manager_save_staff`, `manager_list_staff`, `manager_get_staff`.
- **Dashboards:** `society_admin_dashboard`, `resident_dashboard`, `security_dashboard`, `my_society_features`, `manager_list_society_residents`.

Client wrappers are in 11 new `packages/api-client/src` modules. The full contract, with parameters, return shapes, error codes and who may call each function, is in `docs/onboarding/API.md`.

5. Database changes

- **Extended tables:** `society_enrollment_requests` gains a request code, authority numbers, email, alternative slot, message and new statuses. `societies` gains registration fields, country and setup completion. `wings` gains a code. `flats` gains type, area, bedrooms, parking slot and status.
- **New tables:** floors, setup progress, import batches and rows, resident records, flat owners, tenant registrations, proof documents, family invites (hashed token, 14-day expiry), household access requests, staff details.
- **Storage:** a private `parisar-proofs` bucket, readable only by the uploader and that society's managers.
- **Rules:** every new table has row-level security with no direct client access; writes go only through the functions above.

6. Roles and permissions

The three role concepts are separate fields, so one person can hold several:

Concept	Values	Where
Resident type	Owner, Tenant, Family Member	membership `resident_type`
Society title	Resident, Chairman, Secretary, Treasurer, Committee Member	membership title, mapped to the existing permission role
Staff role	Security, Plumber, Electrician, Cleaner, Gardener, Maintenance Staff, Other	staff record category

- **Authorities** (the chairman or any member chosen to run the app) get the top permission role and the Society Dashboard, whatever their title. This matches the definition you confirmed.
- **Platform admin and sales:** sales cannot see billing, payments or list prices, or appoint users. Platform staff are deliberately refused residents' names, phones, imports and proofs; only the society's own managers see those.
- **Security guards** see the security screen only.
- **Staff records** grant no access.

7. Working: verified in the browser

QA drove these flows in a real browser with Playwright and checked the screenshots:

- Landing page (desktop; mobile in English, Hindi and Marathi)
- Connect With Us with multiple authority numbers, validation, date picker, success page, status lookup, duplicate request message
- Admin console: requests table, request detail, reschedule, Register Society, generated code
- Authority login with OTP, society detection, PIN setup
- Setup wizard, every step, including duplicate wing code rejection, optional step skip and completion
- Excel template download, upload, preview and import
- Resident verification
- Owner registration, including a second owner
- Tenant registration, validation, proof upload, owner and society approval, move-in
- Same-flat household flow, before and after approval
- Family invite and acceptance
- Staff Management: create, update, ID proof upload and removal with confirmation
- Authority role: dashboard, Society Dashboard, society profile, complaints, notices, polls

8. Unit tested only, not checked in the browser

- The security guard screen
- The platform admin as a separate role walkthrough beyond the console screens above
- Resident and tenant dashboards (one screenshot each, no full click-through)
- Tablet (768px) and phone (375px) views of most signed-in screens; only the landing and connect pages were shot at those widths
- A full button-by-button sweep of every new screen

QA was interrupted by the reboot and session restarts before these were done.

9. Needs backend integration or a decision

- **SMS and email delivery:** no provider is chosen, so OTPs use the dev code and invitations are copy-a-link only.
- **Modules with no backend, hidden from navigation:** parking, accounting, maintenance bills, payments and dues, expenses, vendors, events, documents library, reports, staff attendance, pre-approved (expected) visitors and visitor check-in/check-out counts.
- **Editing society details:** only Parisar staff can edit them; authorities see them read-only.
- **Upload limits:** proof uploads have a 10 MB per-file cap but no total cap per person (decision needed).
- **Authority numbers from requests:** every number a visitor typed is added as an authority at registration; the form has no way to drop one (product change needed).

10. Bugs and risks

Fixed during this work: - HIGH: anyone with the society code could become an active tenant of a vacant flat, skipping both approvals. - HIGH: a flat counted as free when it had an imported resident or recorded owner, so a stranger could claim it. - HIGH: open redirect on login through an encoded tab character. - MEDIUM: Excel formula injection in the error report. - MEDIUM: public form rate limits could be bypassed by writing to the table directly. - MEDIUM: older claim functions accepted a phone that was never verified by OTP. - Tenant self-approval on the owner step. - `/settings/notifications` crashed with a server error (bug from before this work, `allMuted` missing). - The setup-wizard translations had been left in a half-written file.

Open, MEDIUM: - The connect form's per-address rate limit trusts proxy headers that a client can forge (per-phone limits back it up). - An imported tenant becomes active without the owner's approval step once they confirm their record. - The "treasurer" title maps to the manager role, so treasurers see all resident data without being an authority.

Open, LOW: - Members of a flat see invitees' phone numbers. - Anyone with the society code sees masked initials per flat. - Every member, including tenants, can see the join code. - Delete functions reveal whether an ID exists. - The invite token appears in the URL. - Staff Management is hidden in the sidebar when the staff feature is off, but the page is still reachable by URL.

Housekeeping: - Several migration files exceed 400 lines. - `StructureSetup.jsx` is now unused. - The old admin leads query in `app/c/[routeId]/page.jsx` is dead code. - Proof files are not deleted from storage when a member is removed.

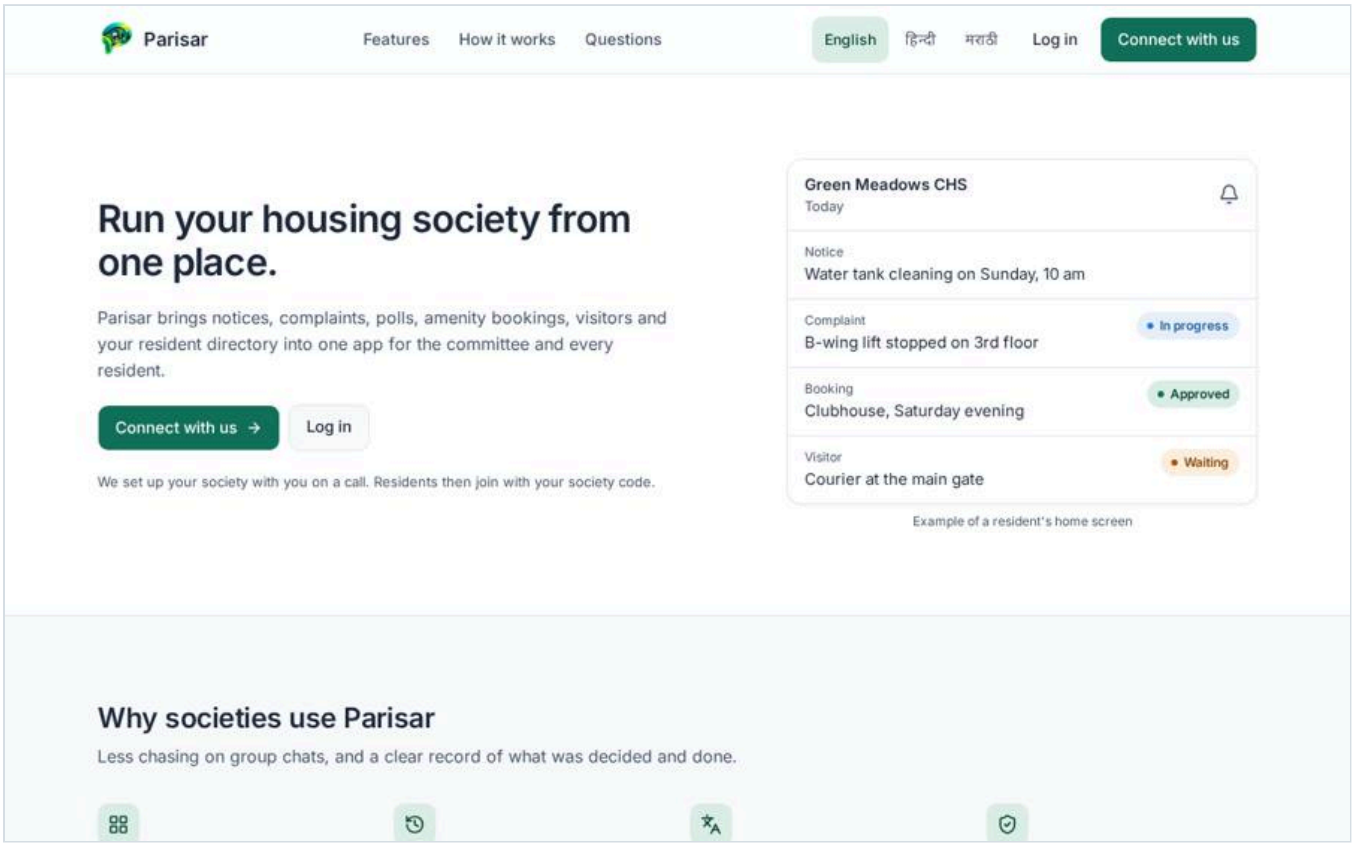
11. Testing results

Check	Result
Web unit tests (`apps/web`, vitest)	876 passed, 5 failed. All 5 failures are in `app/__tests__/admin-screens-03-10.test.jsx` (ReviewQueue and RoleTransfer text checks) and were failing before this work (baseline: 7 failed, 306 passed).
api-client tests	345 passed, 0 failed (baseline 244)
i18n package tests	20 passed, 1 todo
i18n coverage check (en, hi, mr)	Passed
Production build (`next build`)	Succeeded
Lint (Biome, 147 changed files)	No errors, 2 warnings
Onboarding isolation tests (security)	108 passed across 9 suites, plus 15 adversarial tests. The older isolation suites fail at setup because their seed societies are missing; see section 0.
Mobile app	Unchanged (no files under `apps/mobile` modified)
Browser QA	143 screenshots; flows listed in section 7

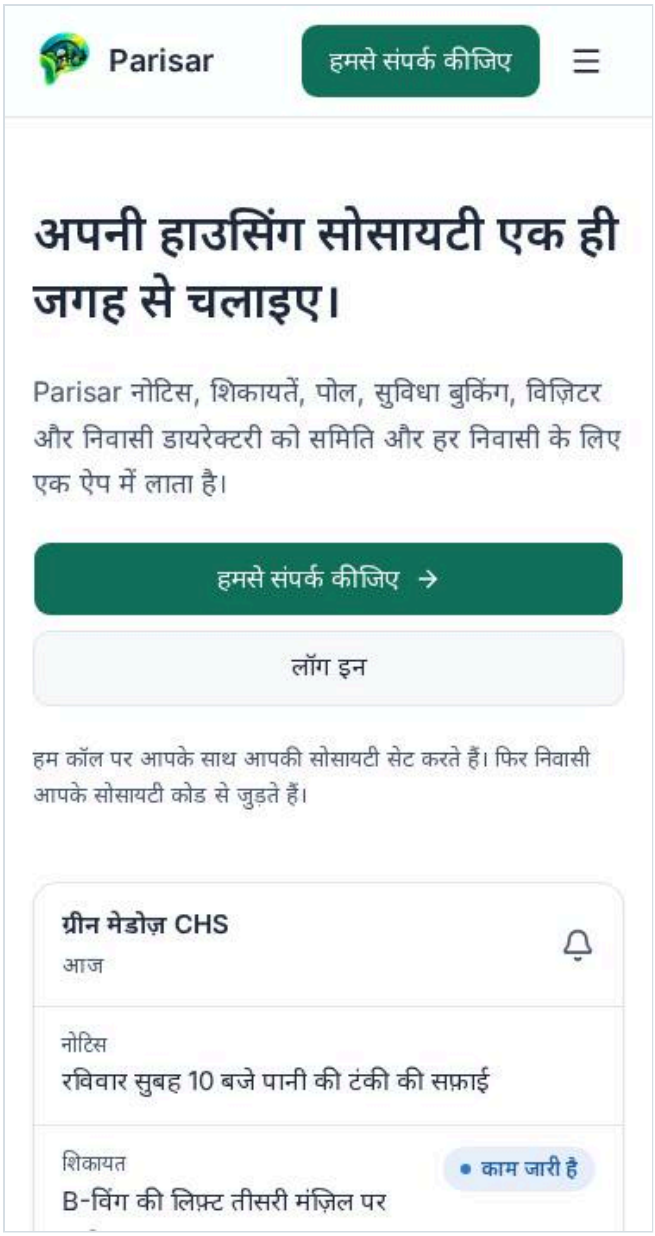
12. Screenshots

143 screenshots from the browser QA run, grouped by area. File names give the screen and the viewport width.

Landing page



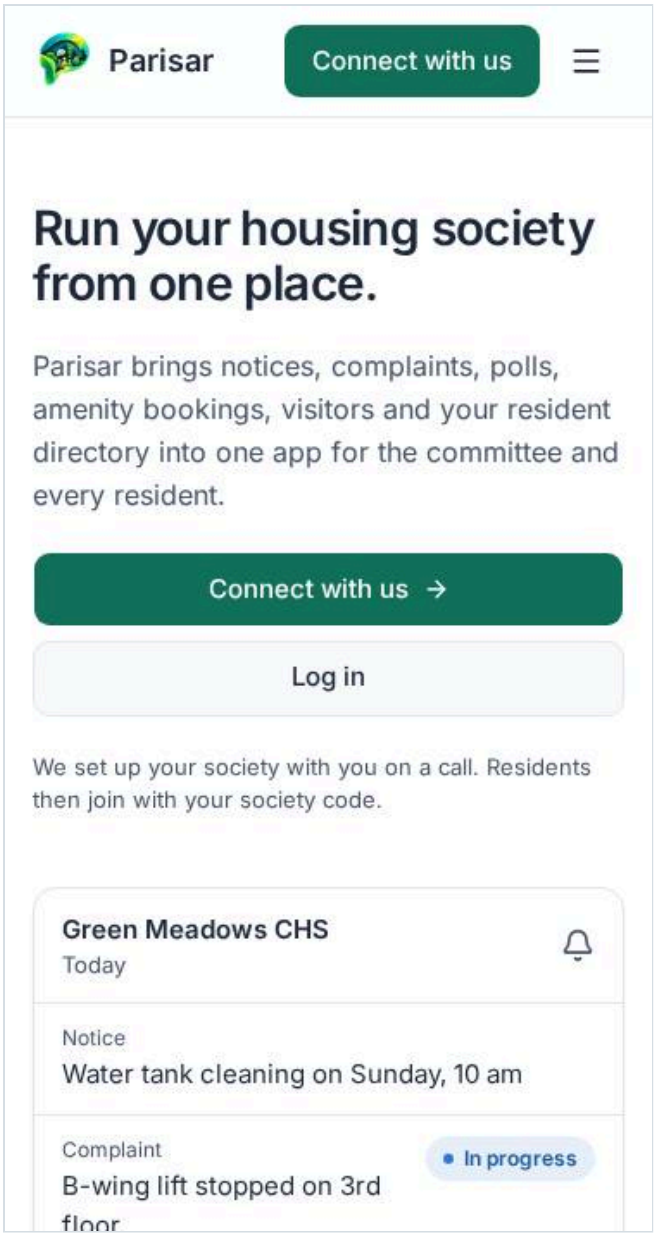
landing-1280.png



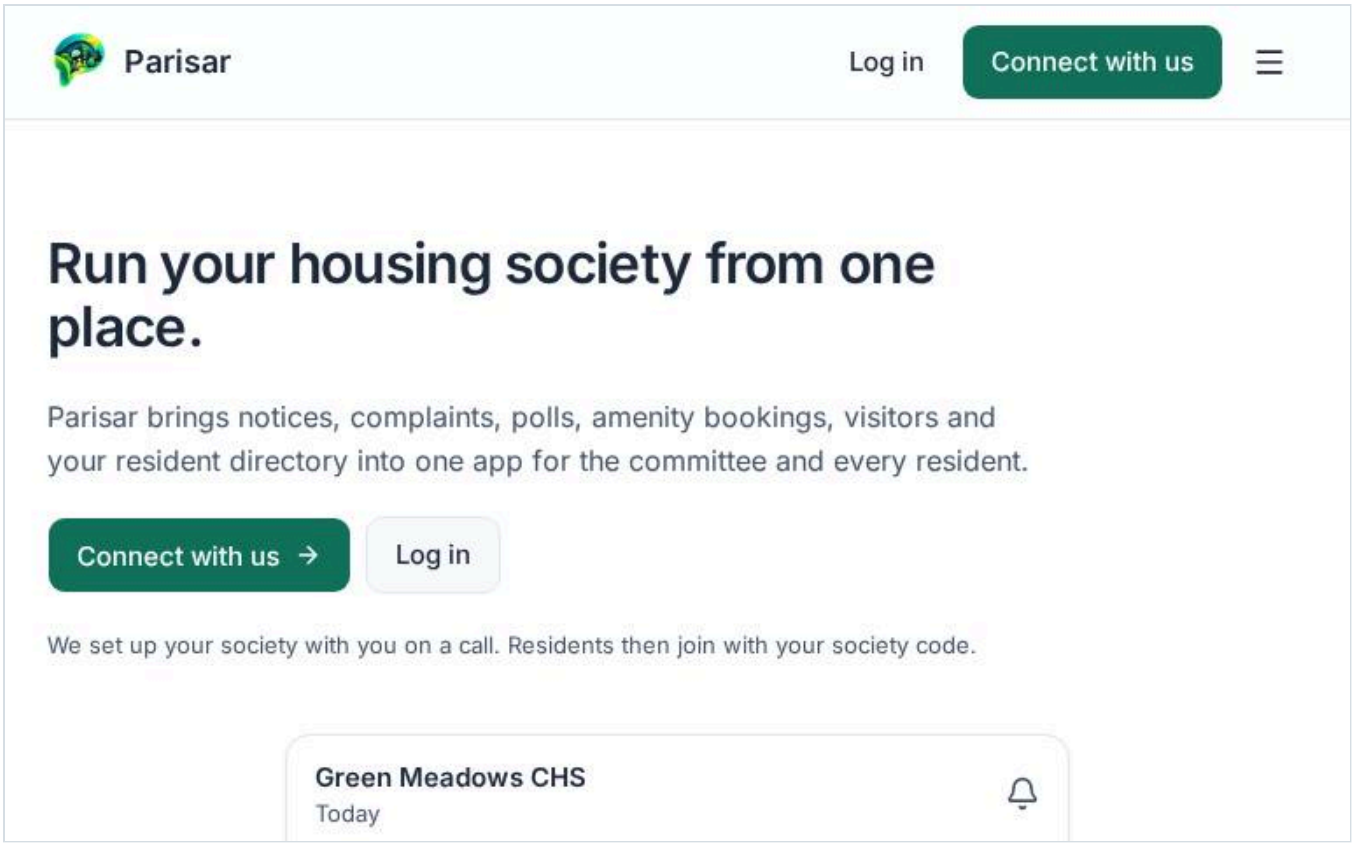
landing-375-hi.png



landing-375-mr.png

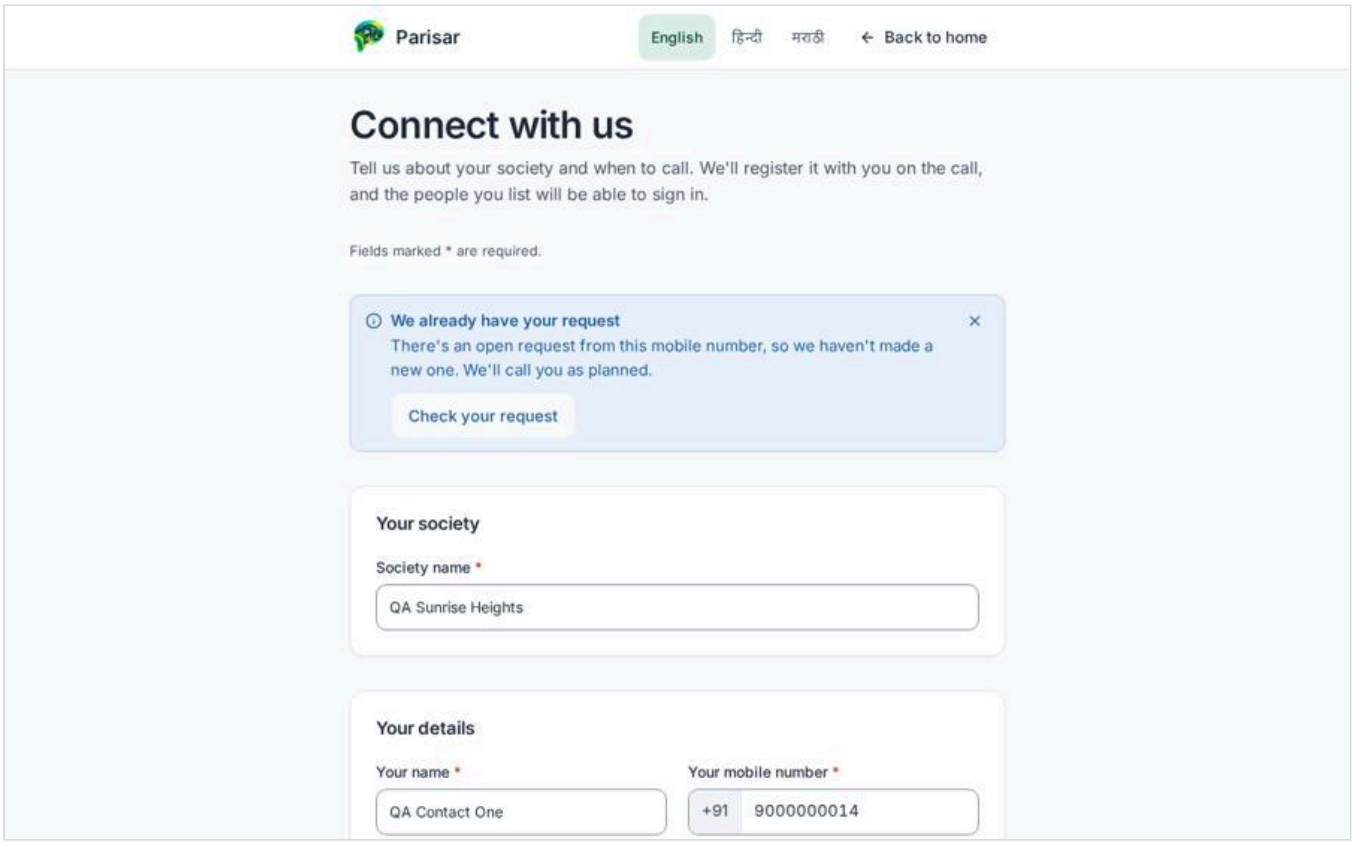


landing-375.png

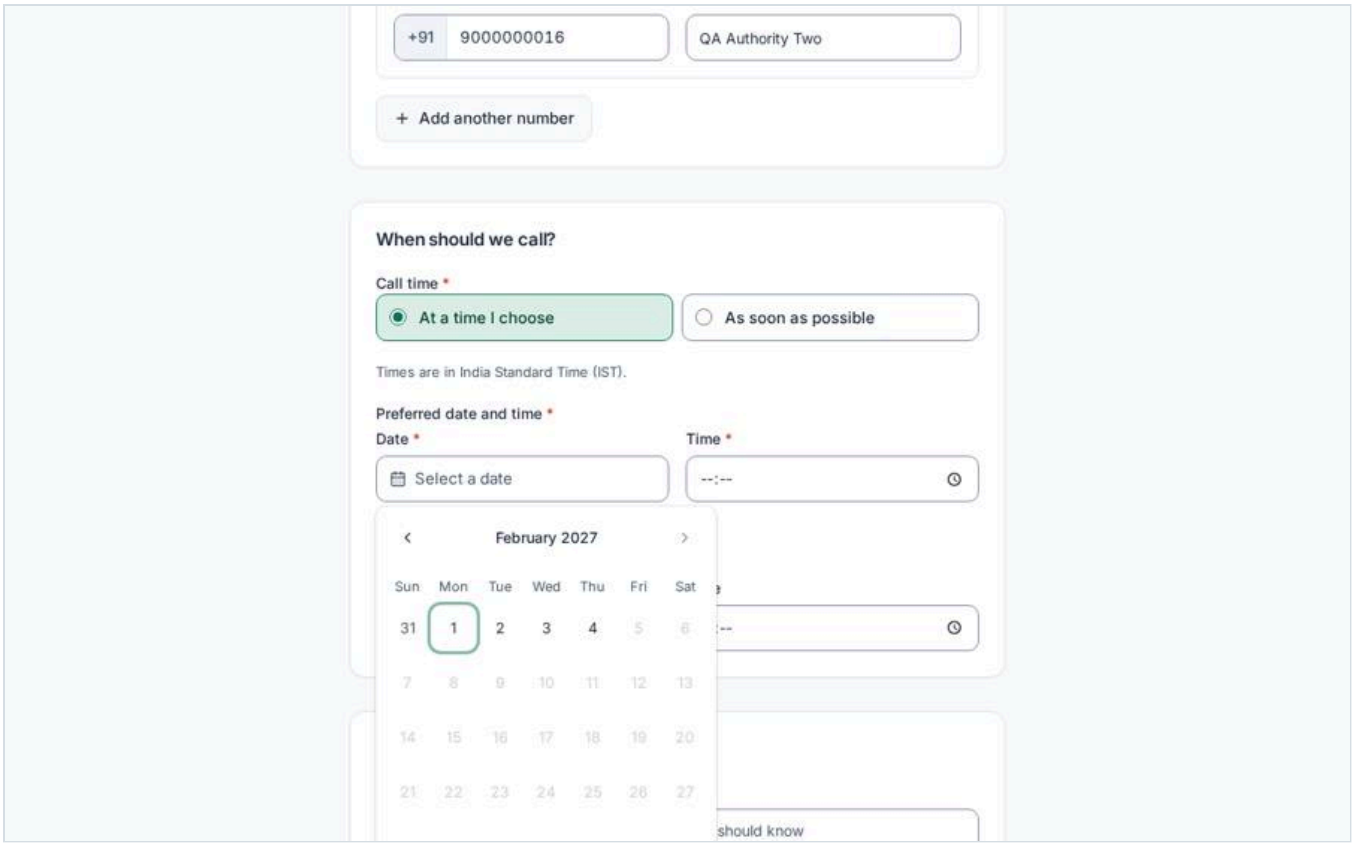


landing-768.png

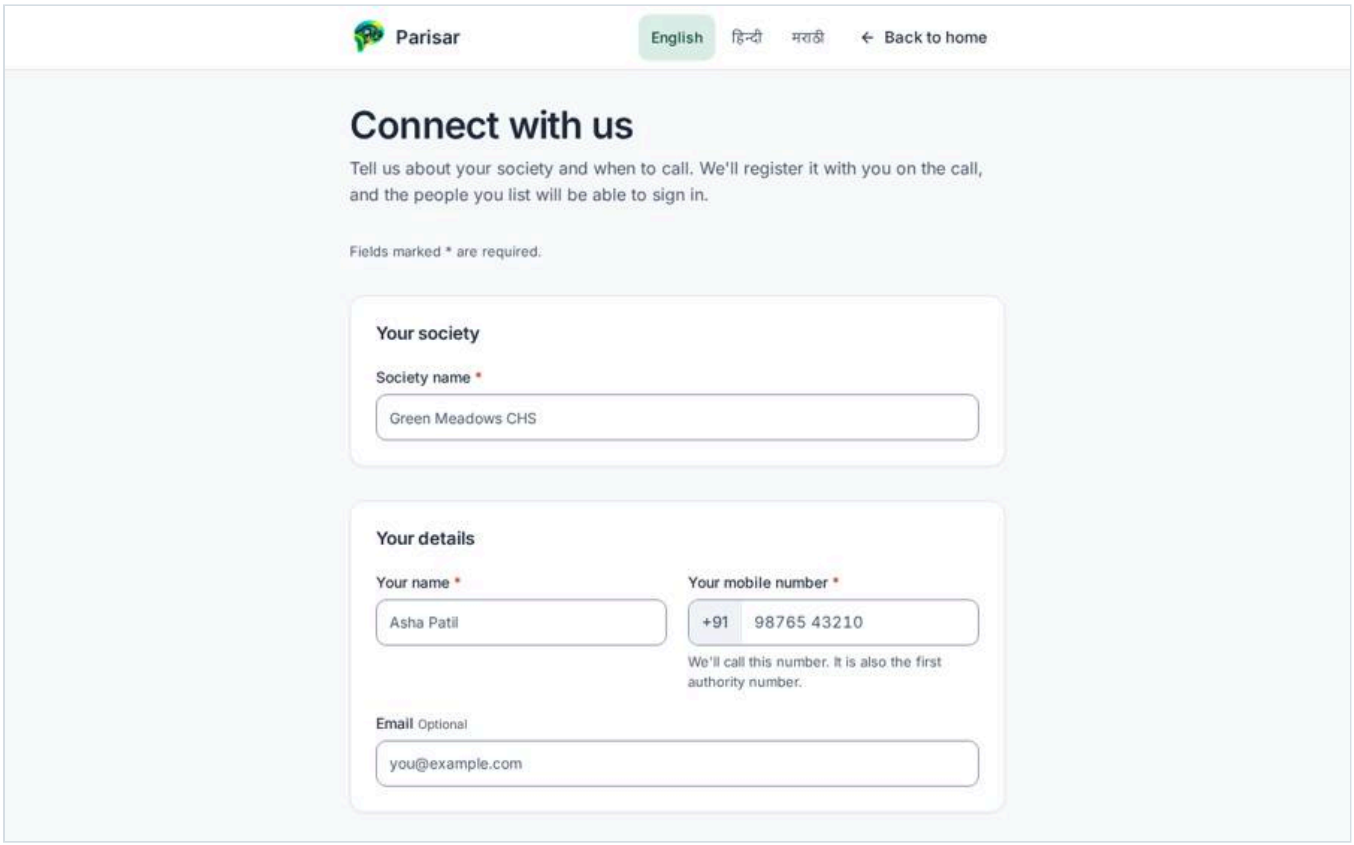
Connect With Us



connect-already-open-1280.png



connect-datepicker-open-1280.png



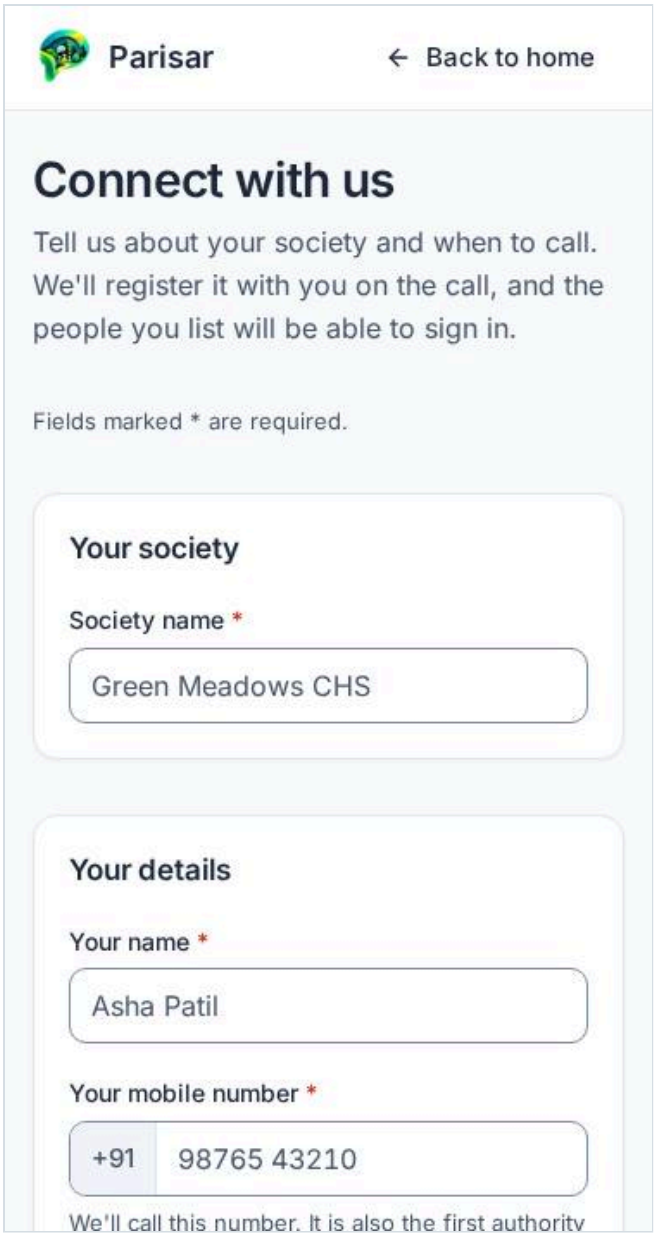
connect-form-1280.png



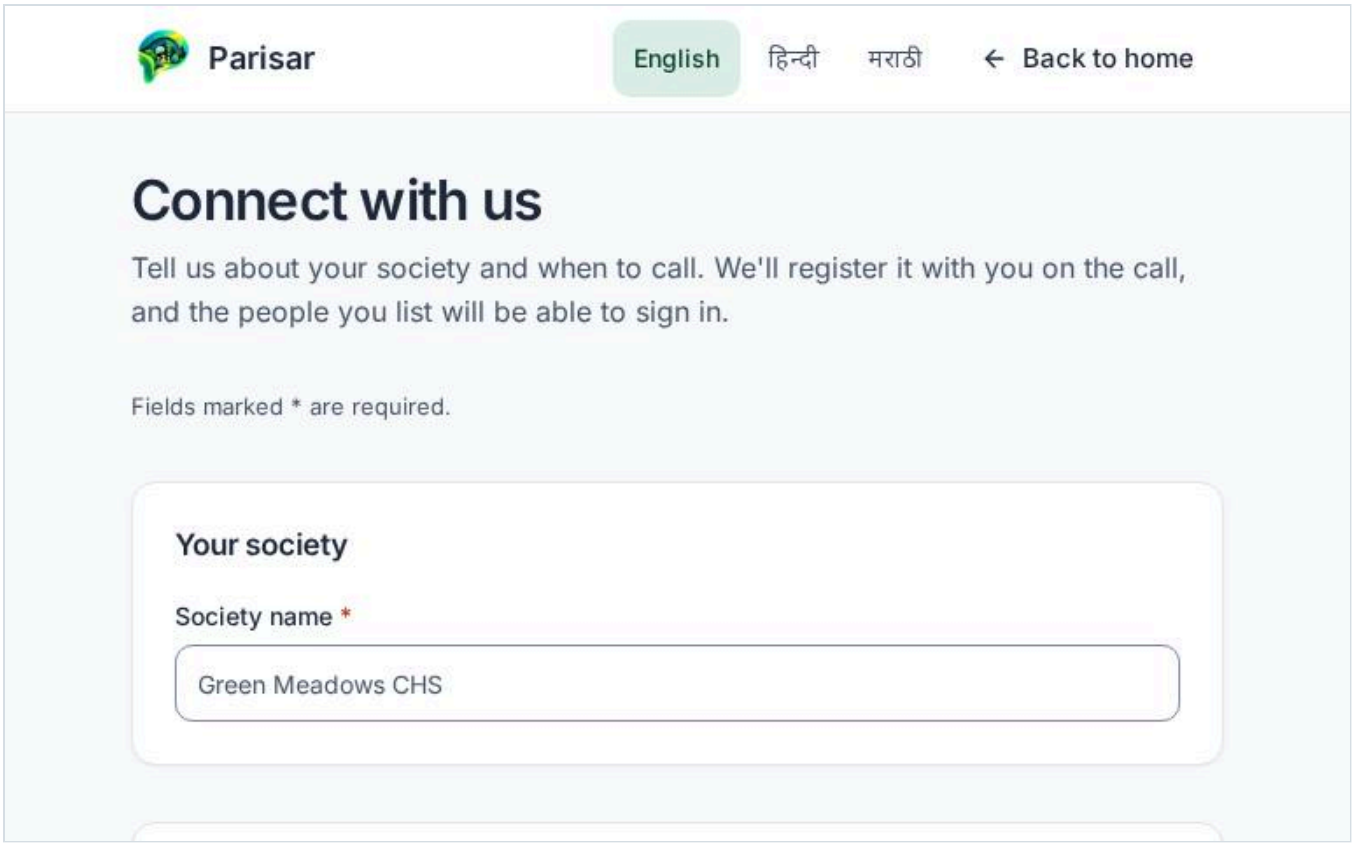
connect-form-375-hi.png



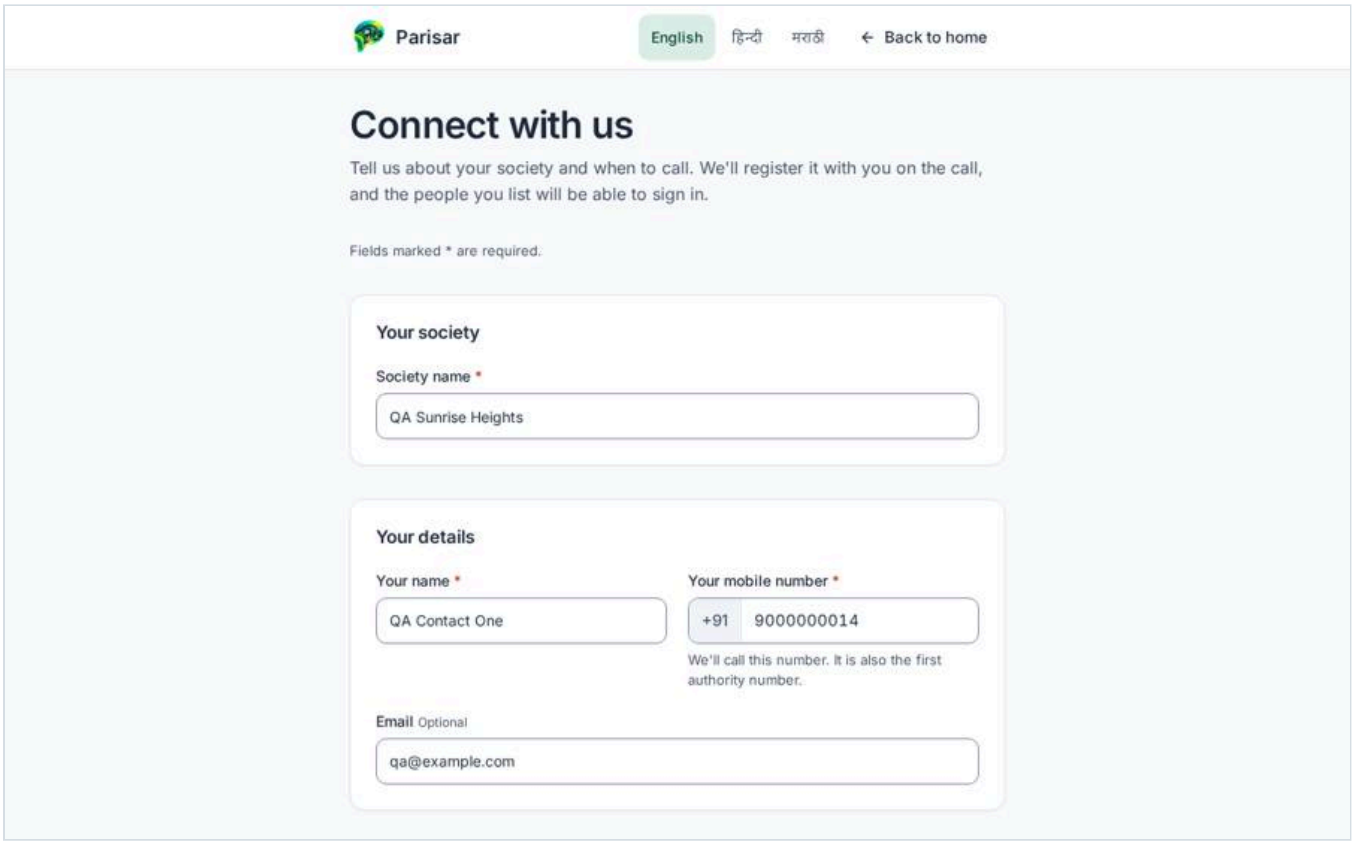
connect-form-375-mr.png



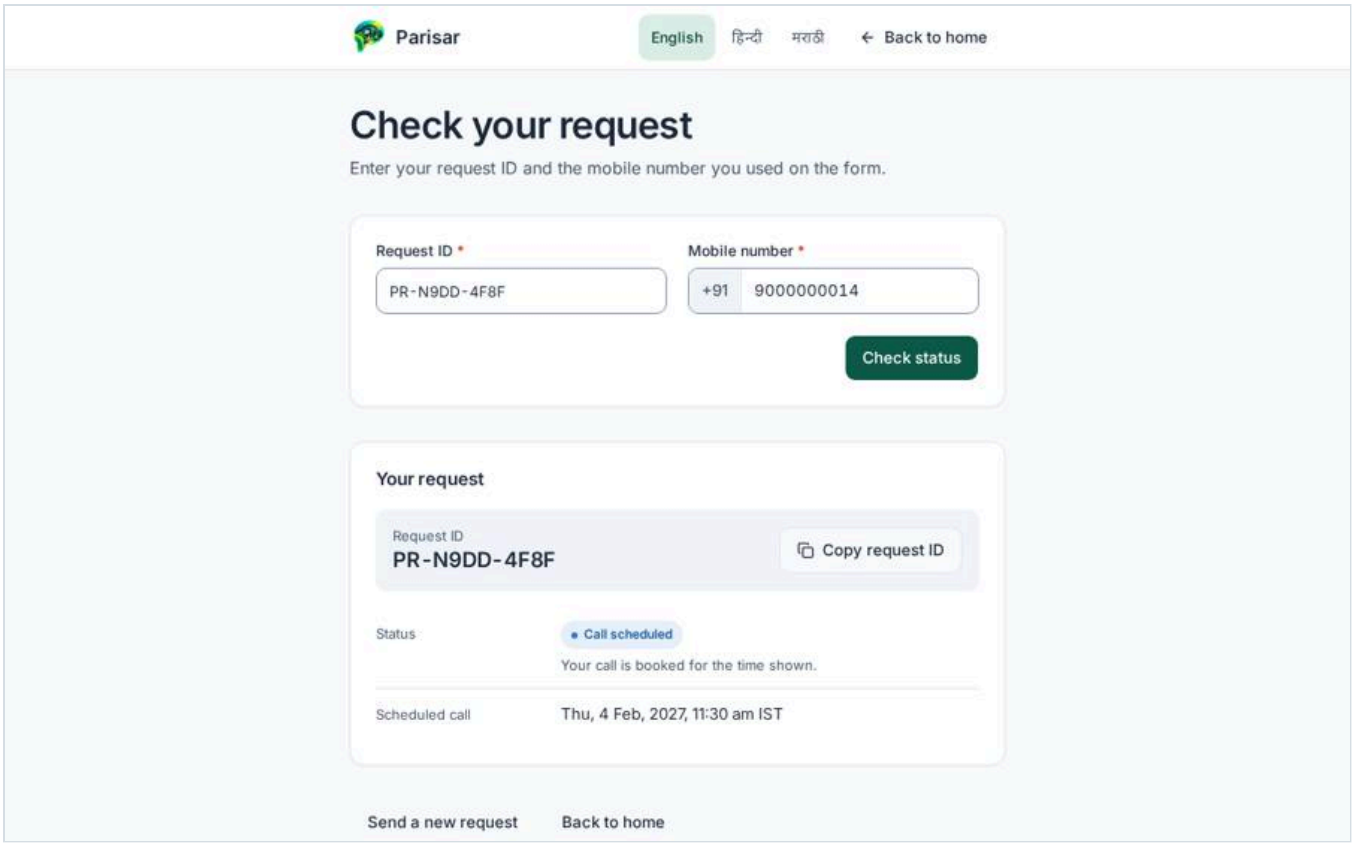
connect-form-375.png



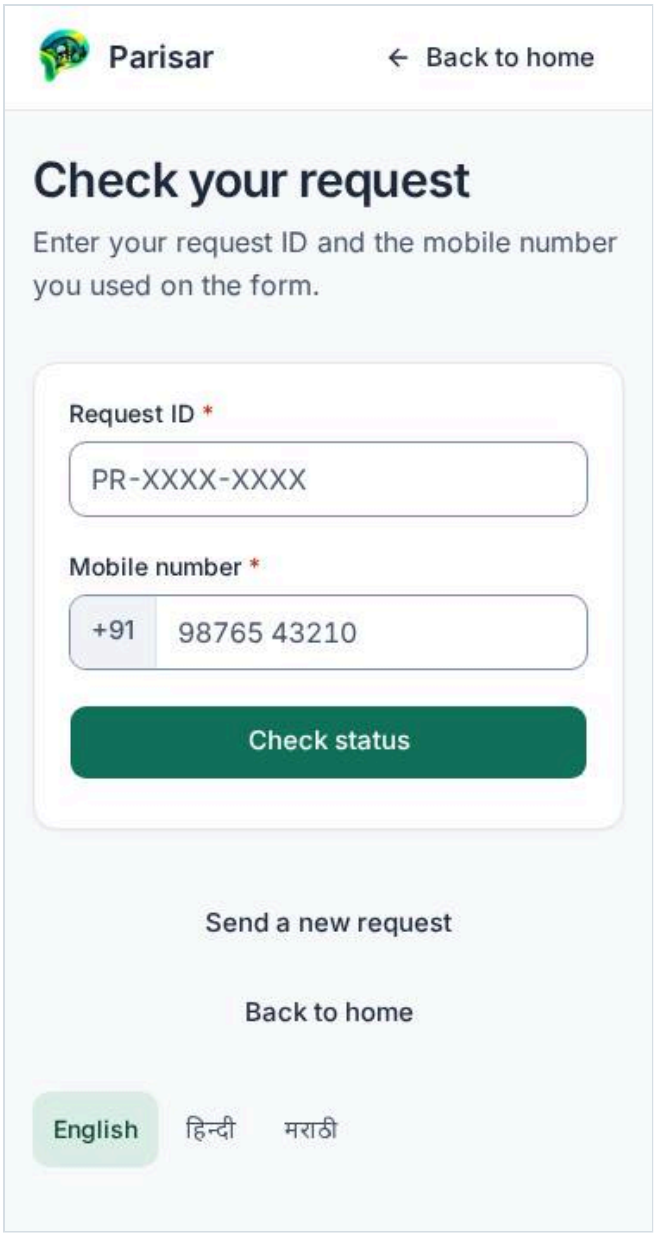
connect-form-768.png



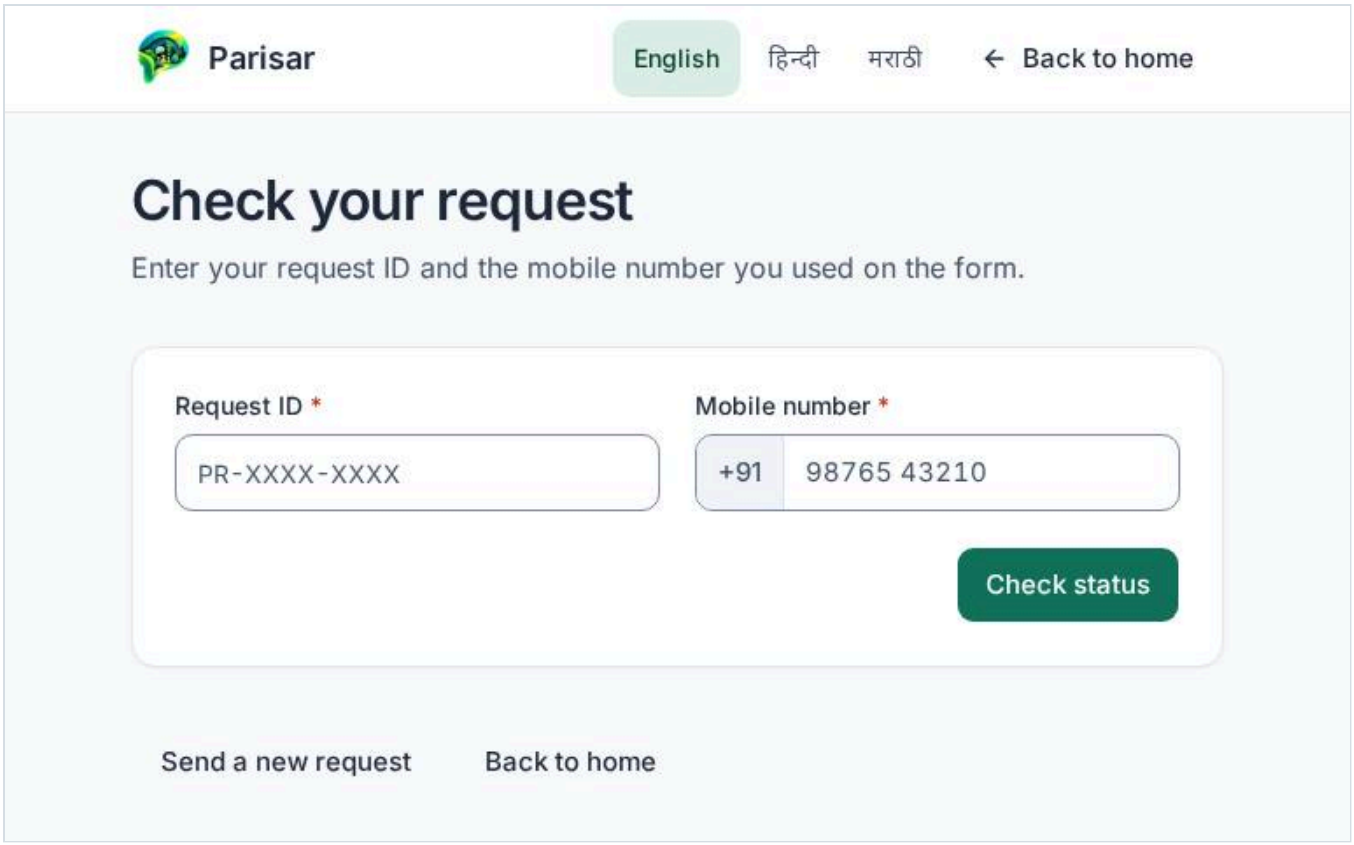
connect-form-filled-1280.png



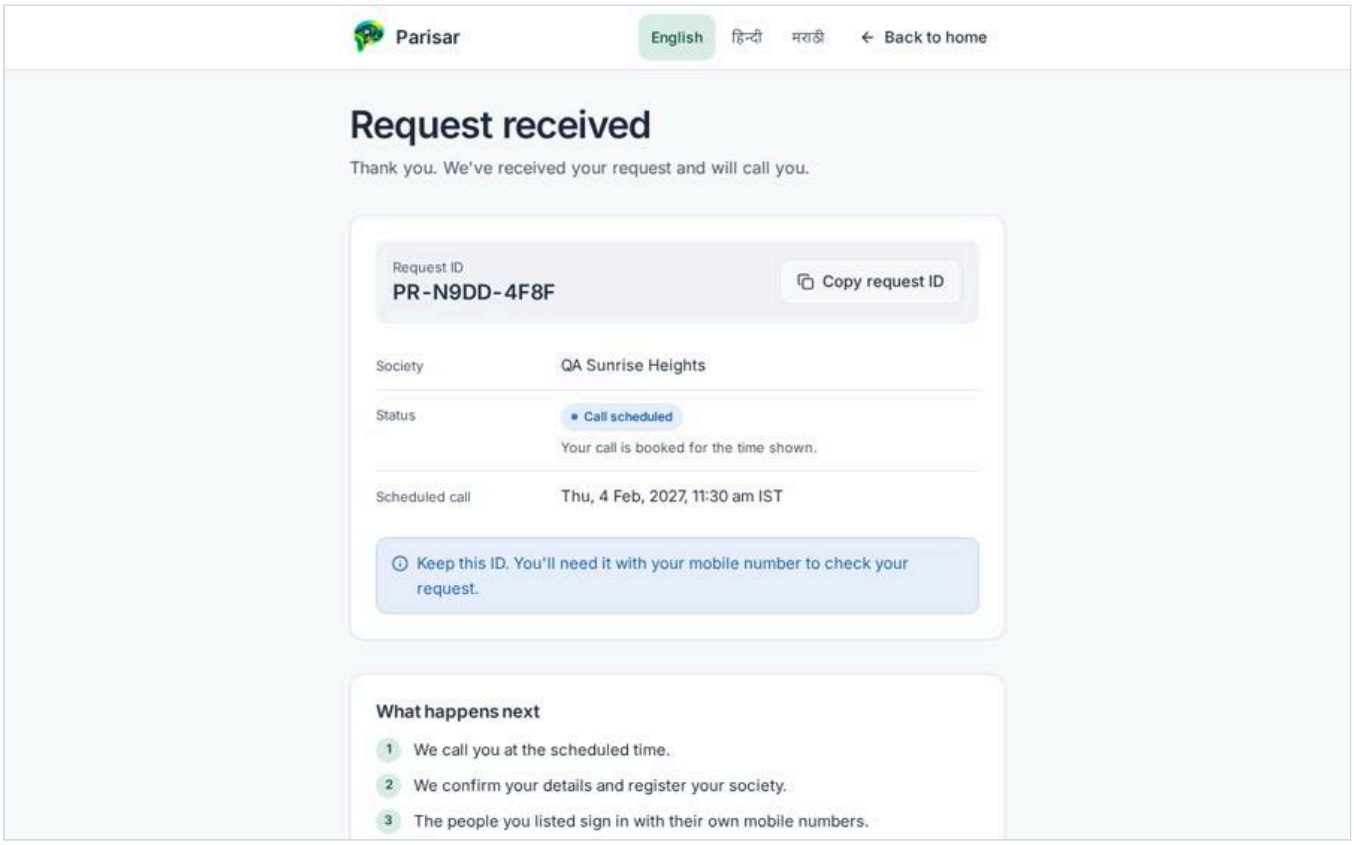
connect-status-lookup-1280.png



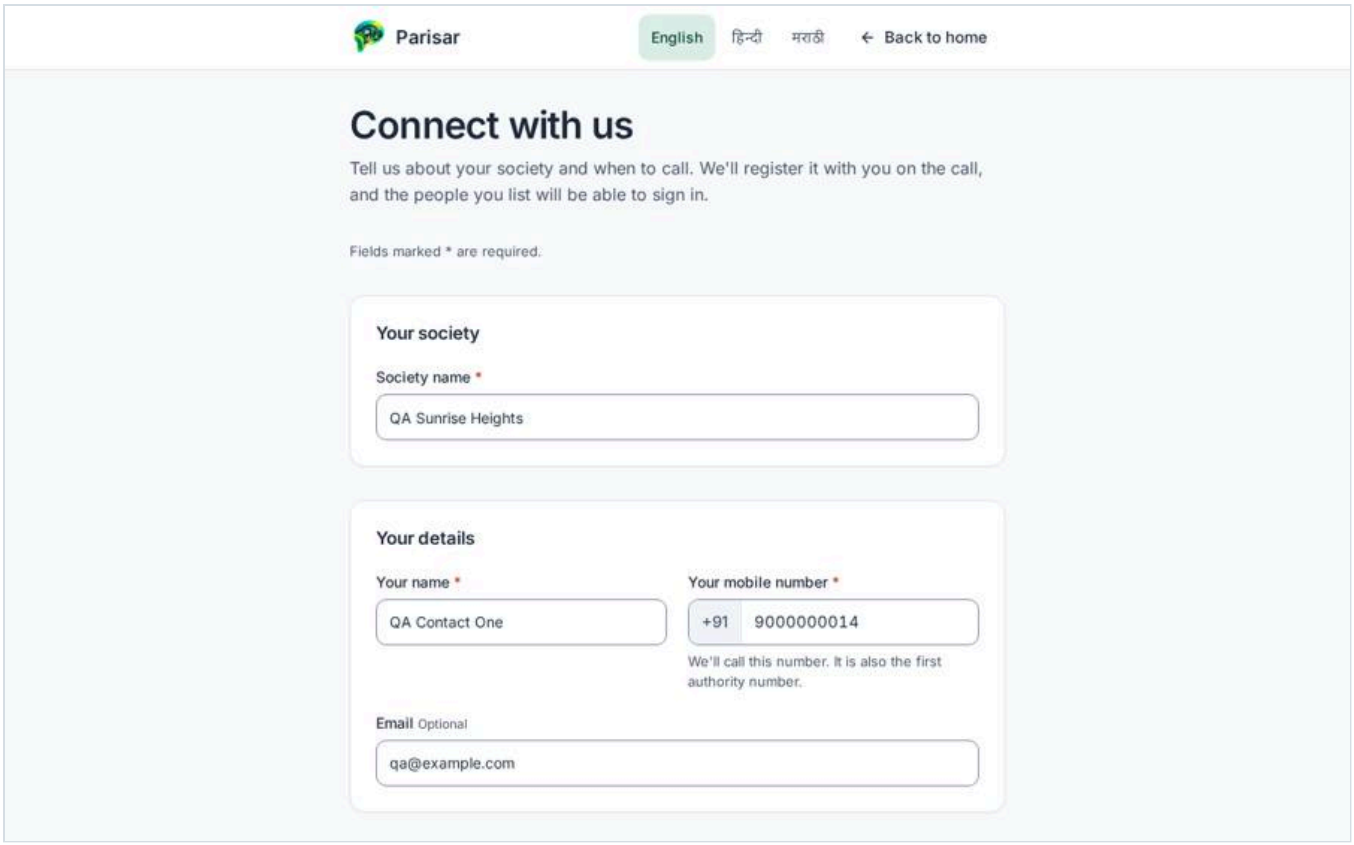
connect-status-lookup-375.png



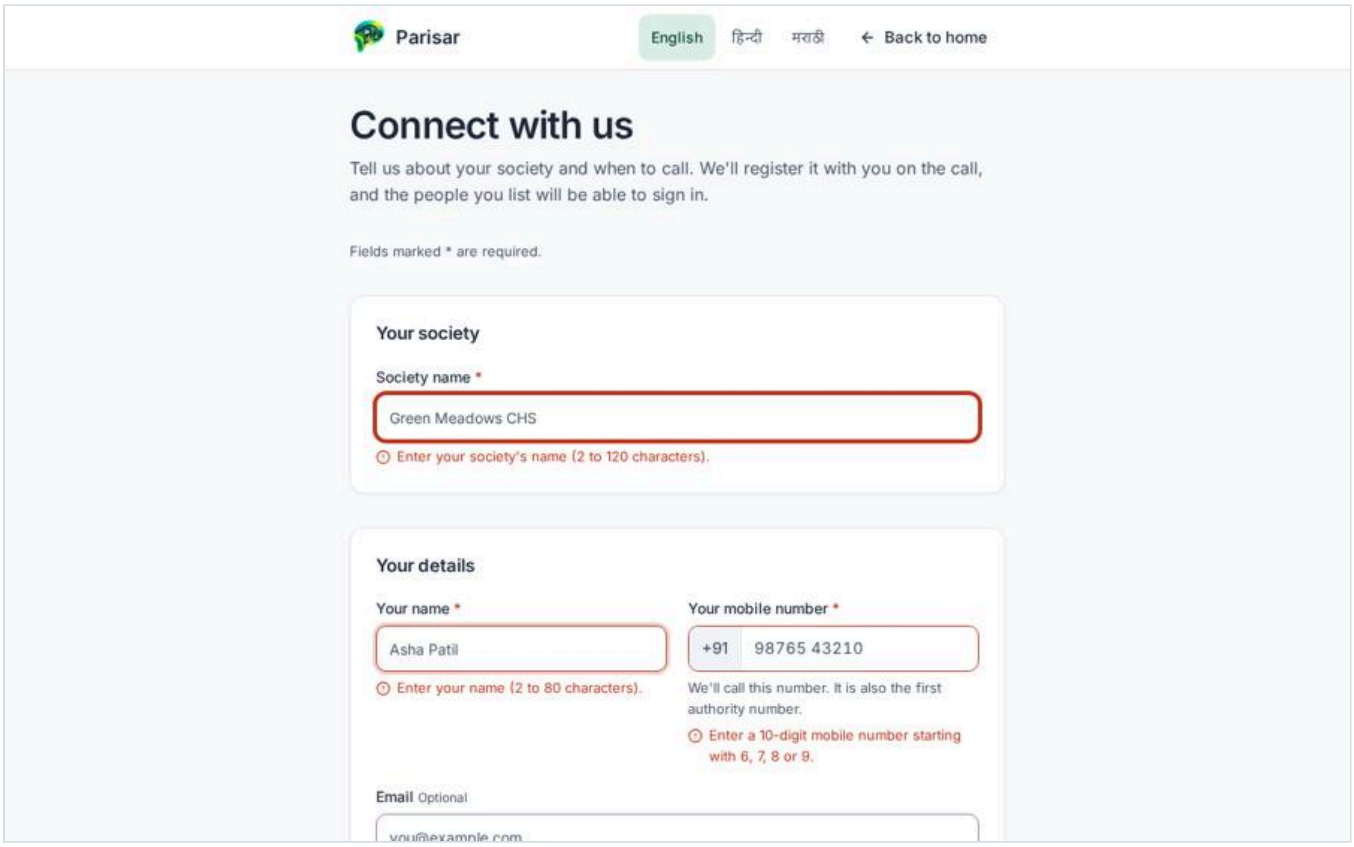
connect-status-lookup-768.png



connect-success-1280.png

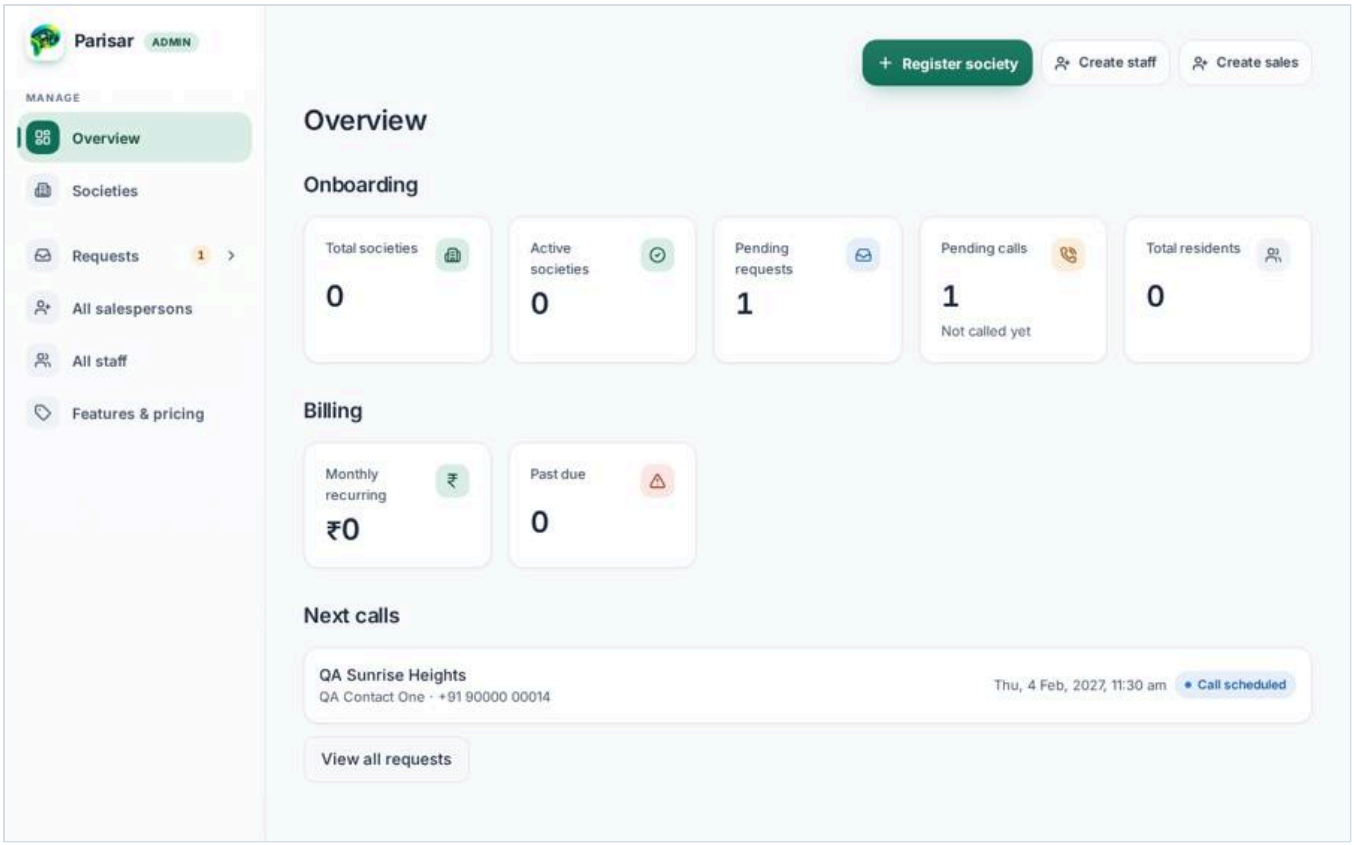


connect-validation-duplicate-1280.png

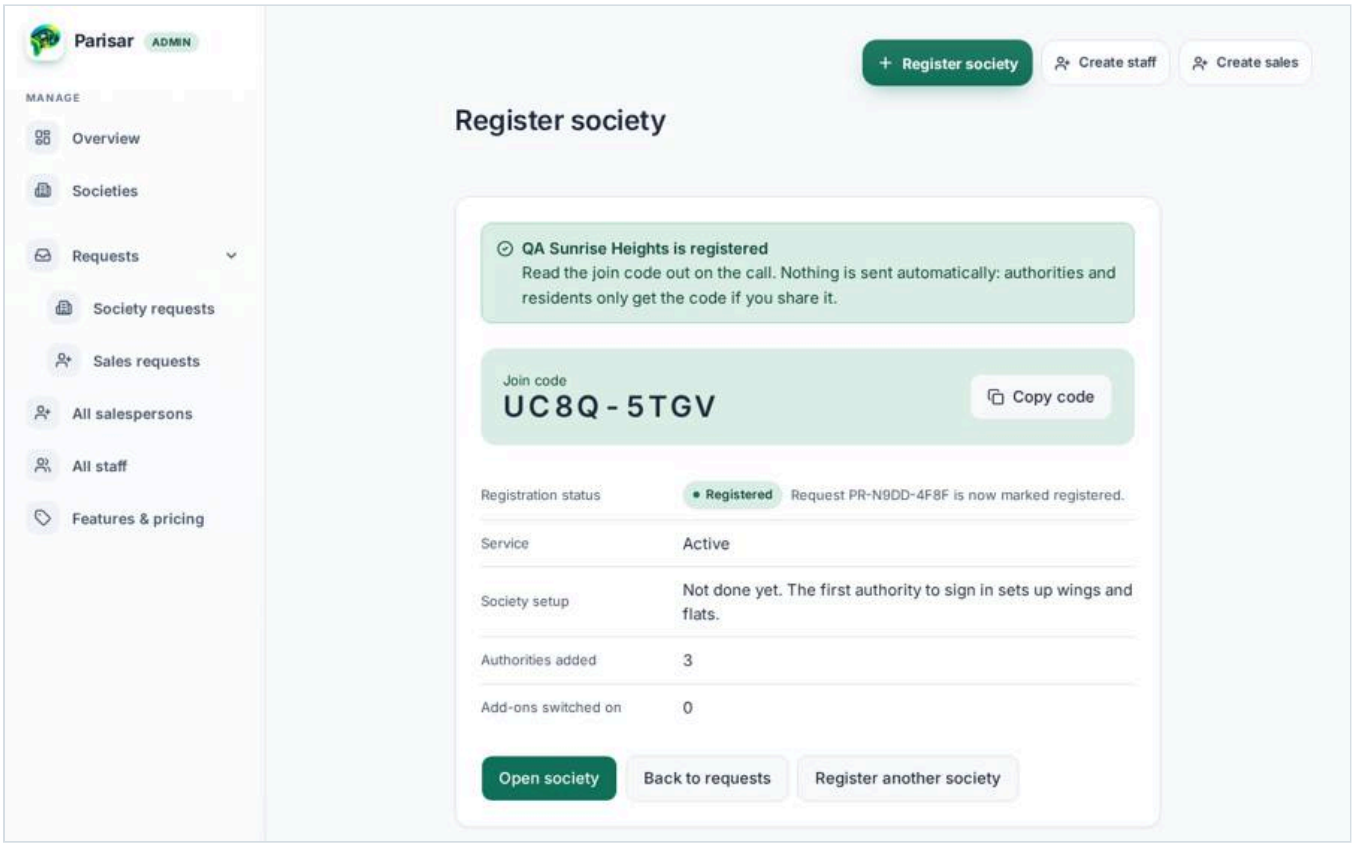


connect-validation-empty-1280.png

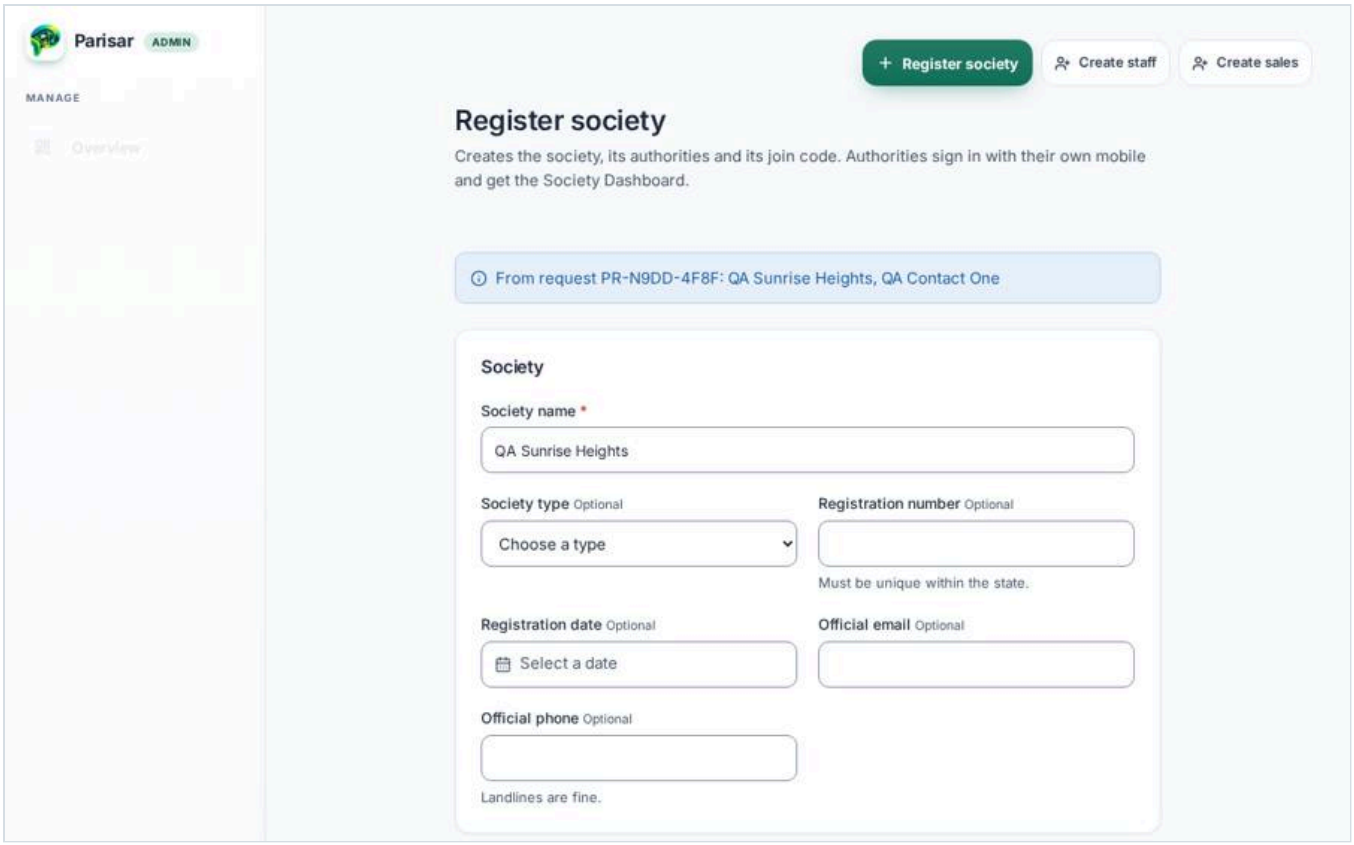
Platform Admin



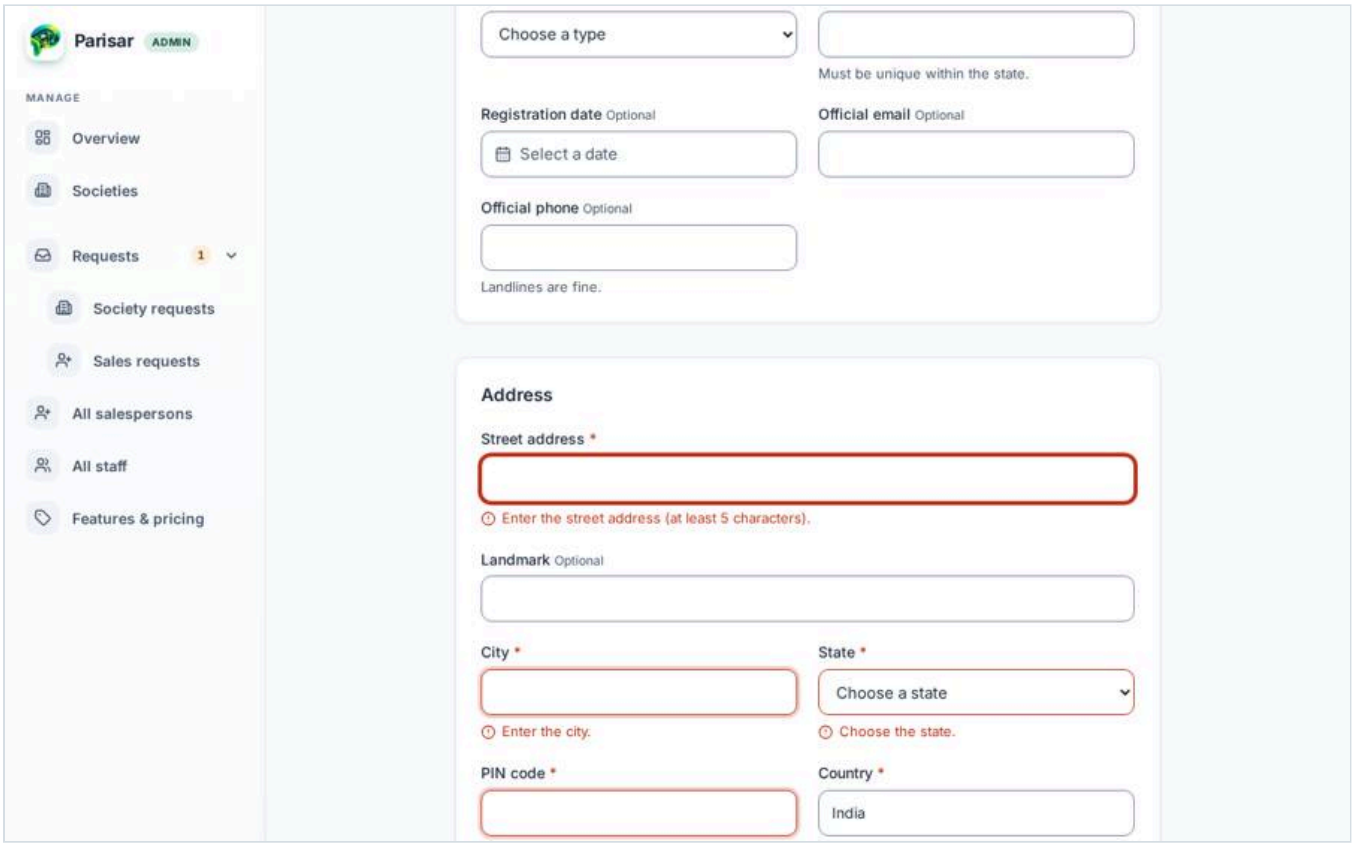
admin-console-overview-1280.png



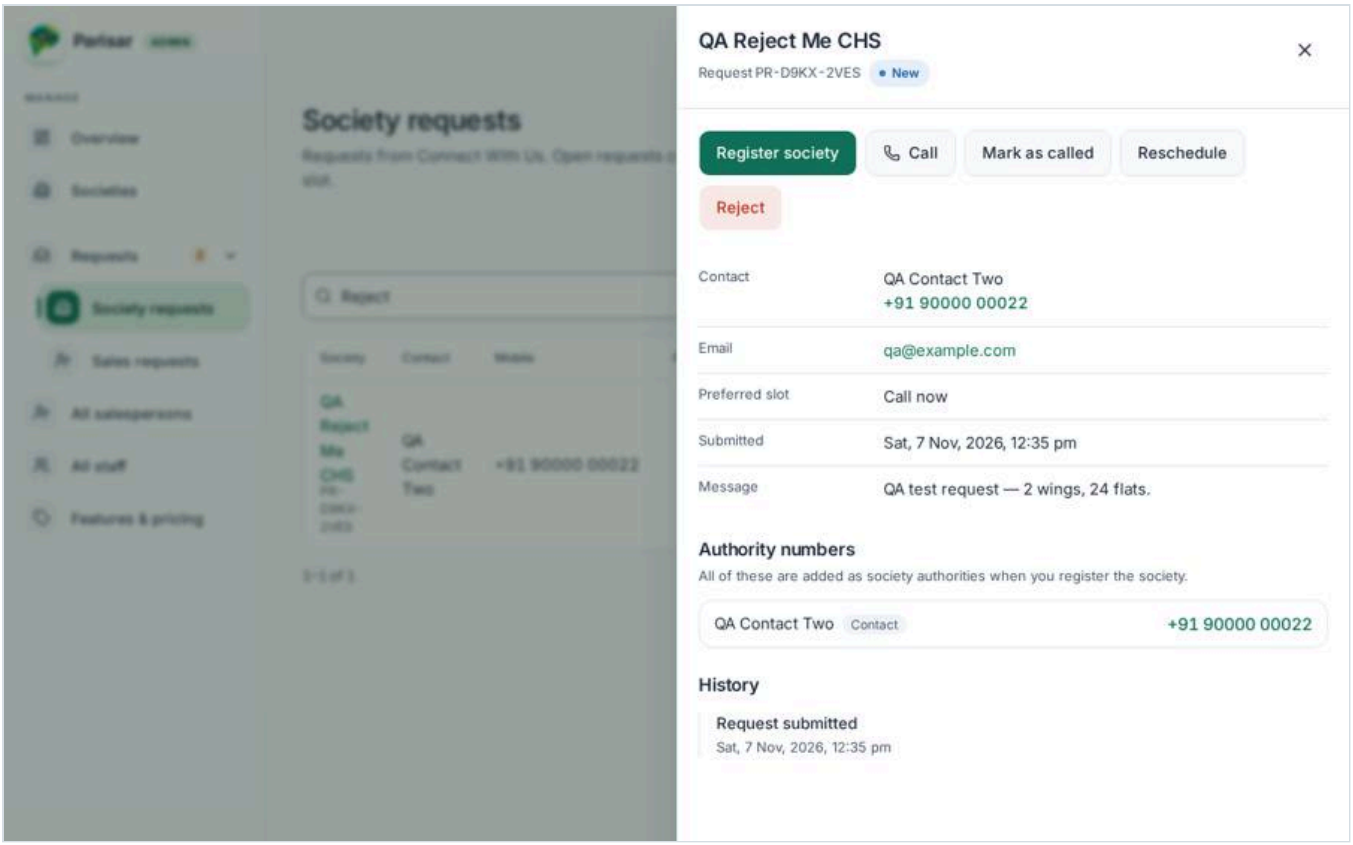
admin-register-result-1280.png



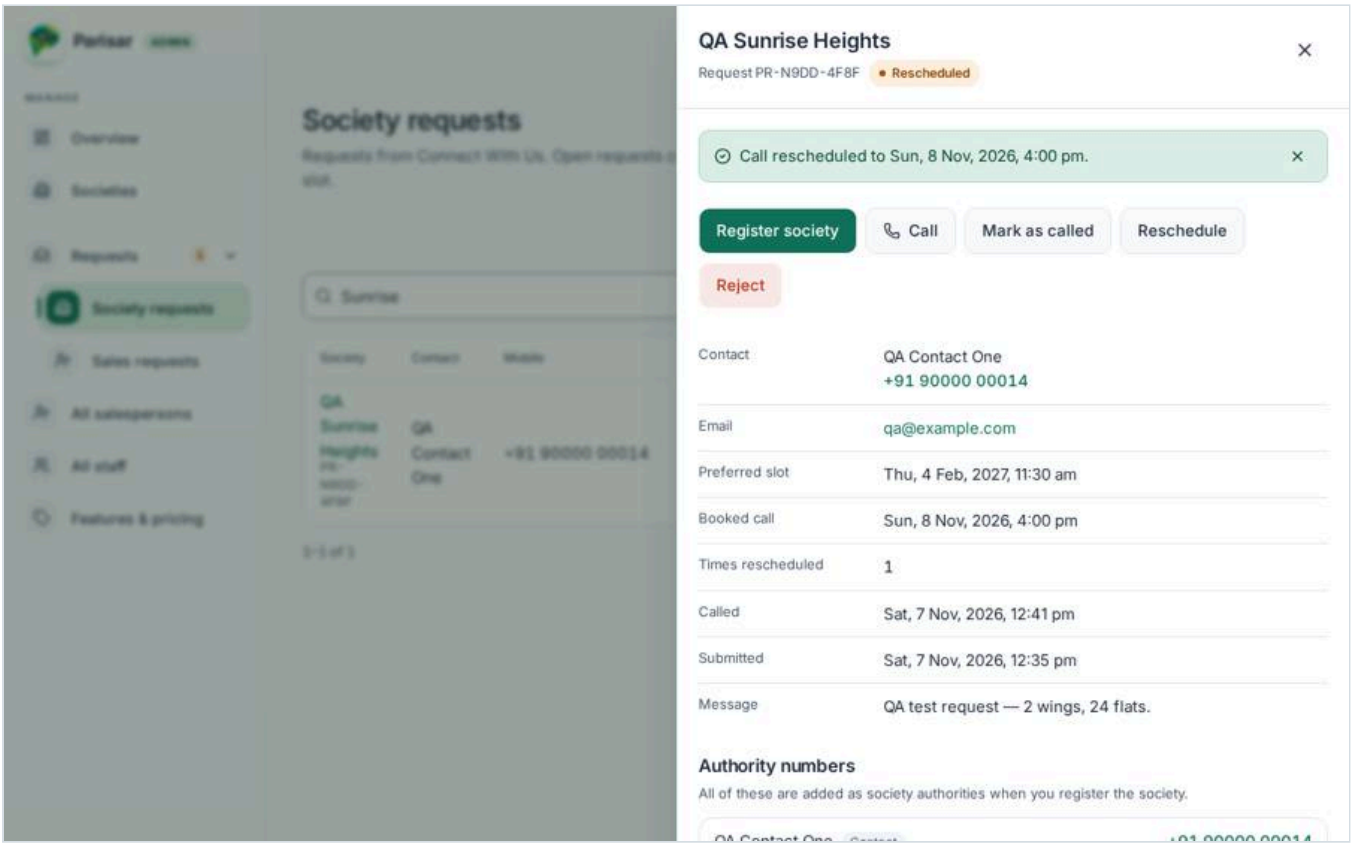
admin-register-society-form-1280.png



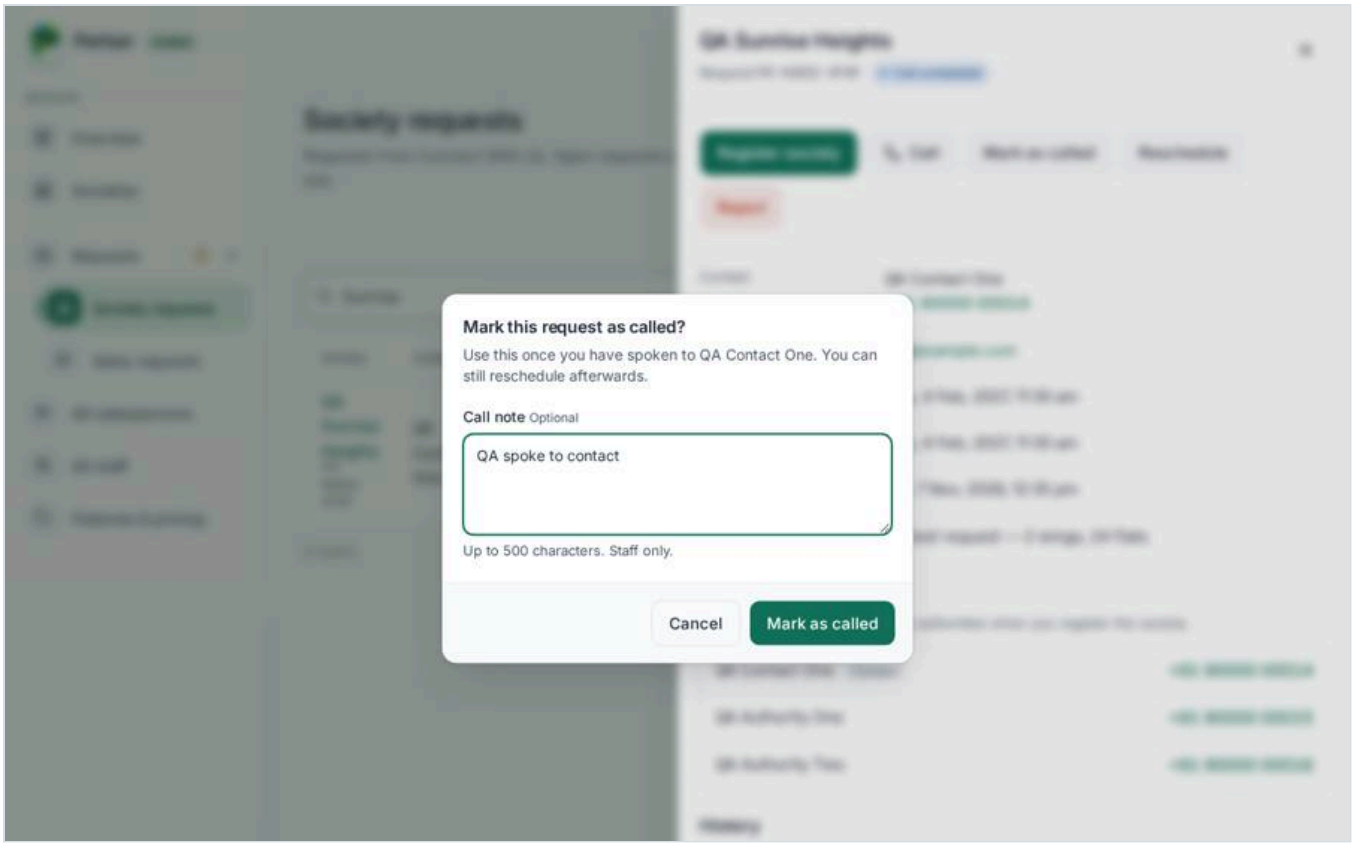
admin-register-society-validation-1280.png



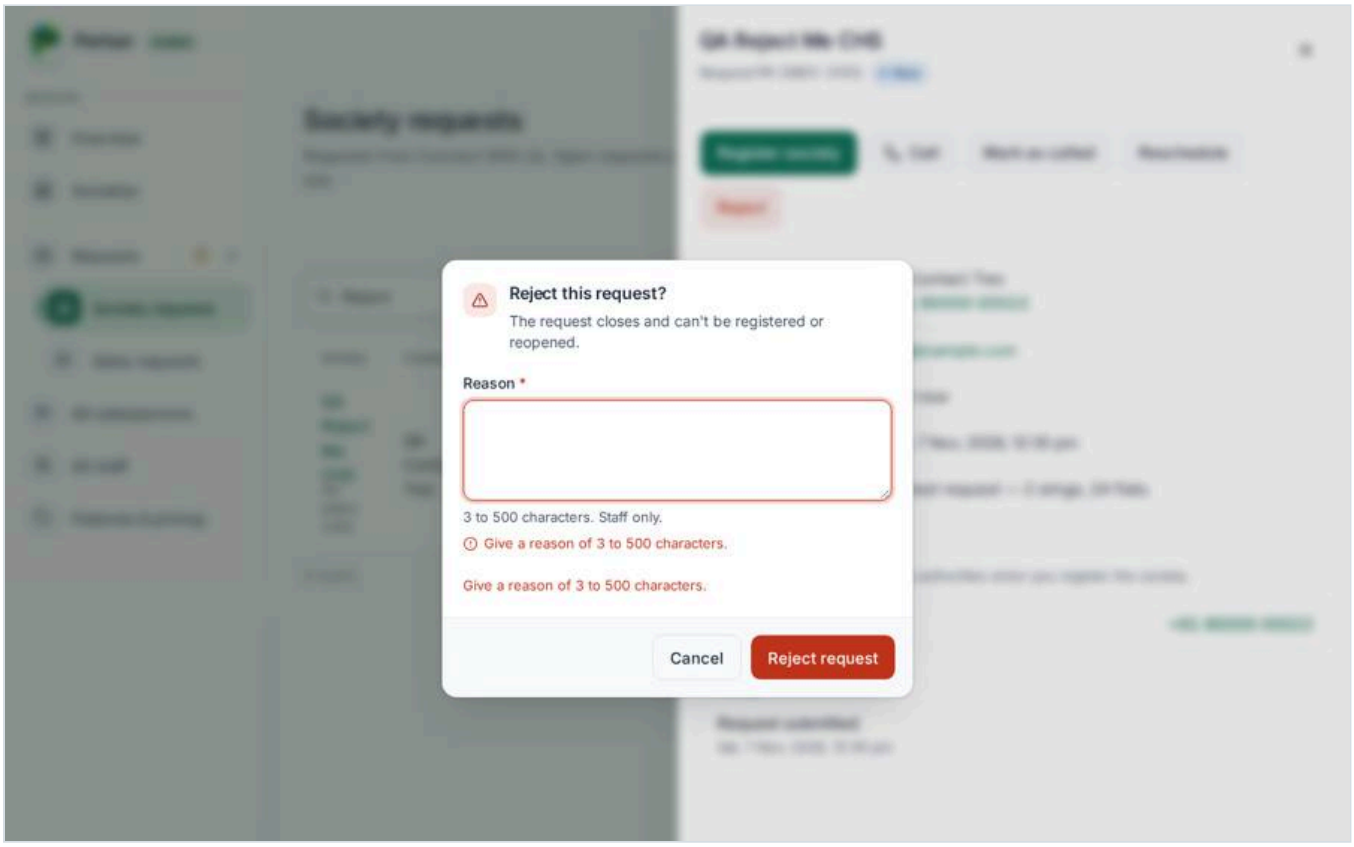
admin-request-detail-1280.png



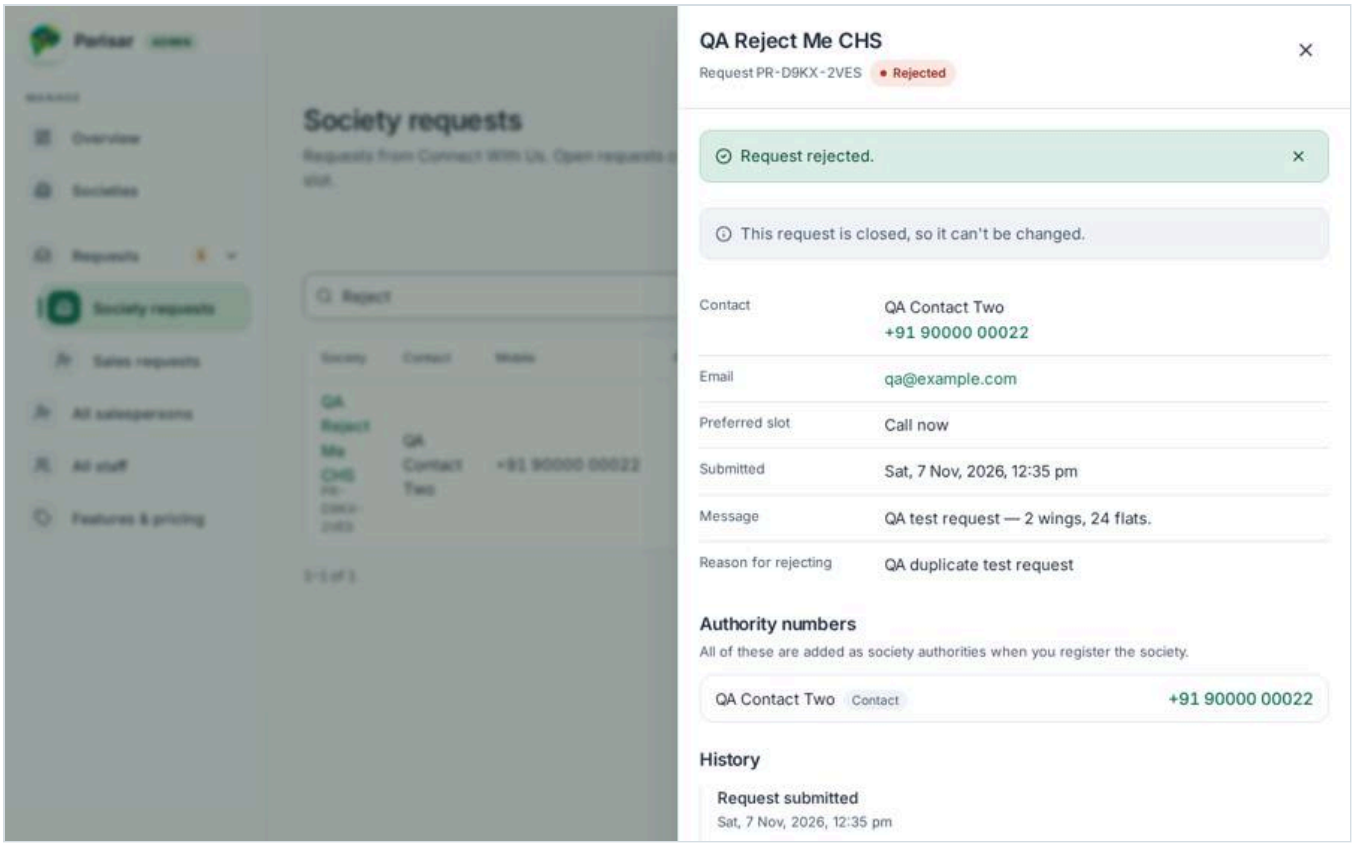
admin-request-detail-after-actions-1280.png



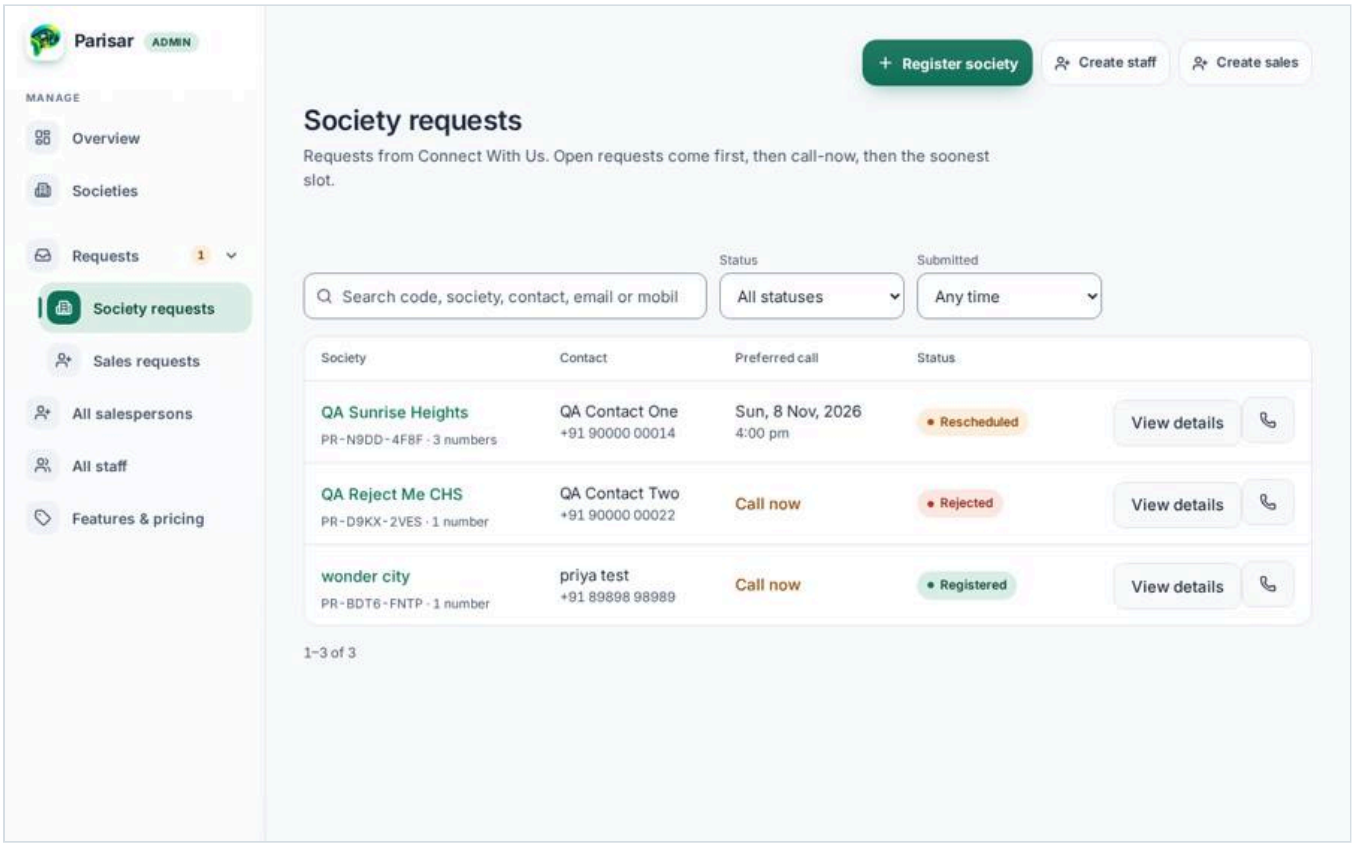
admin-request-markcalled-dialog-1280.png



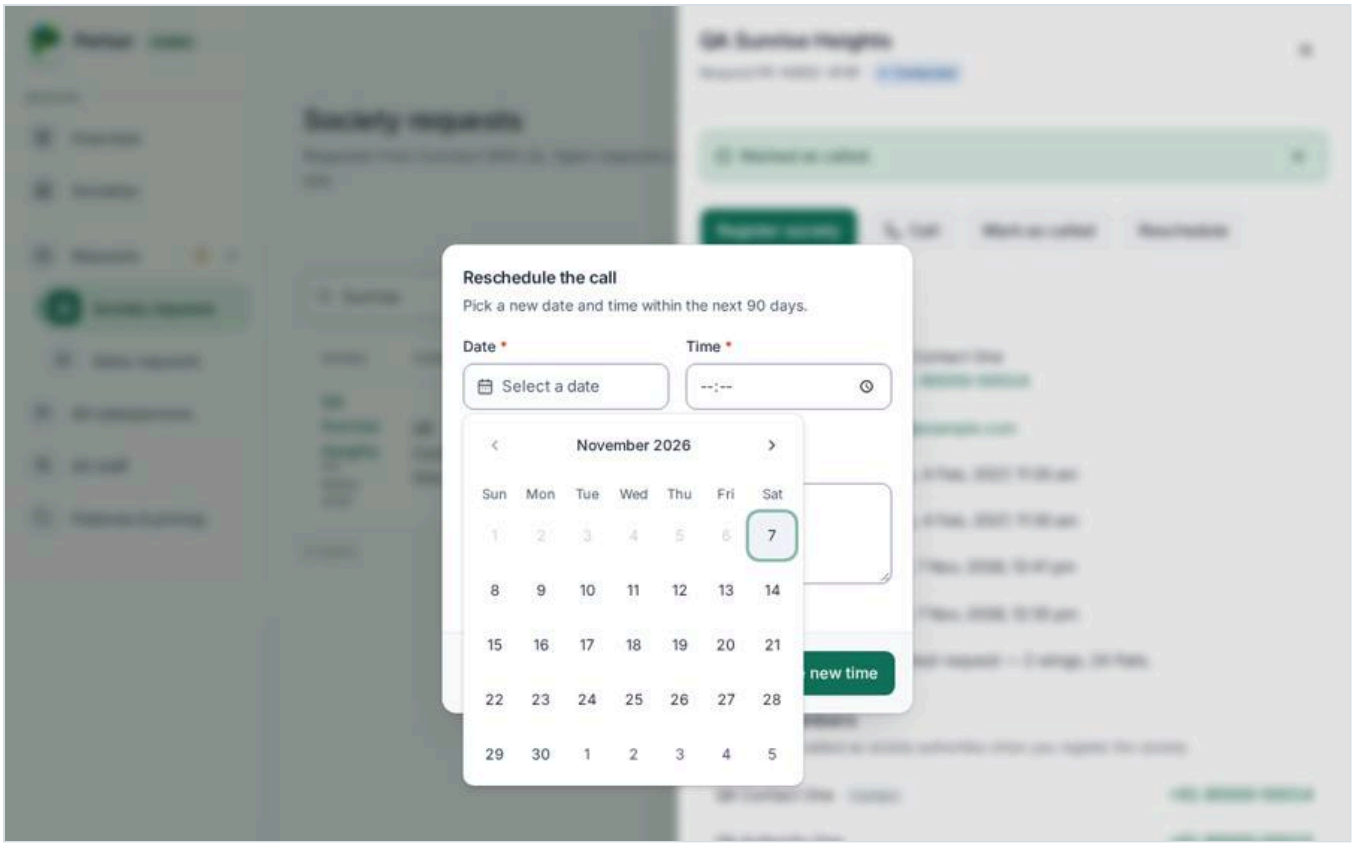
admin-request-reject-dialog-1280.png



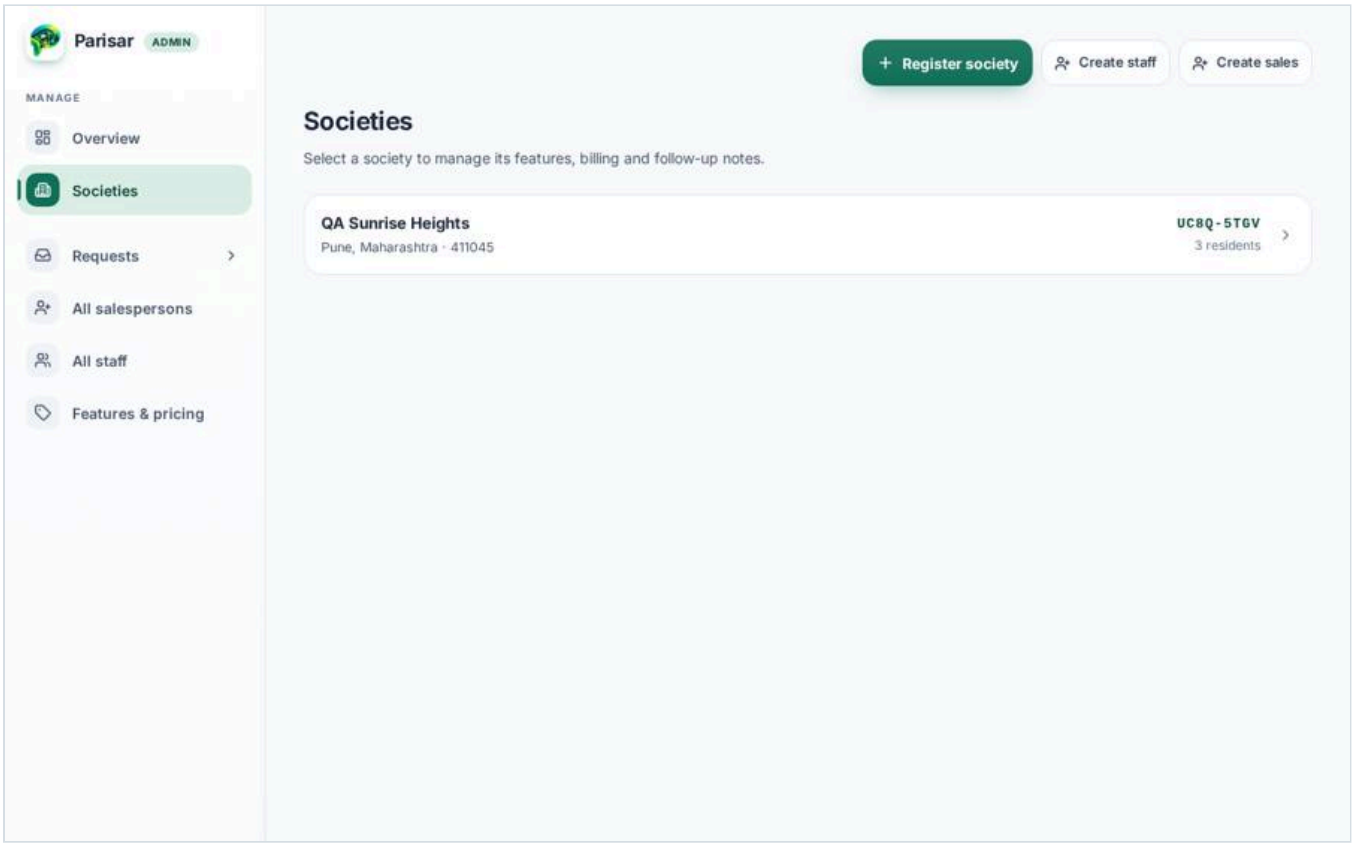
admin-request-rejected-1280.png



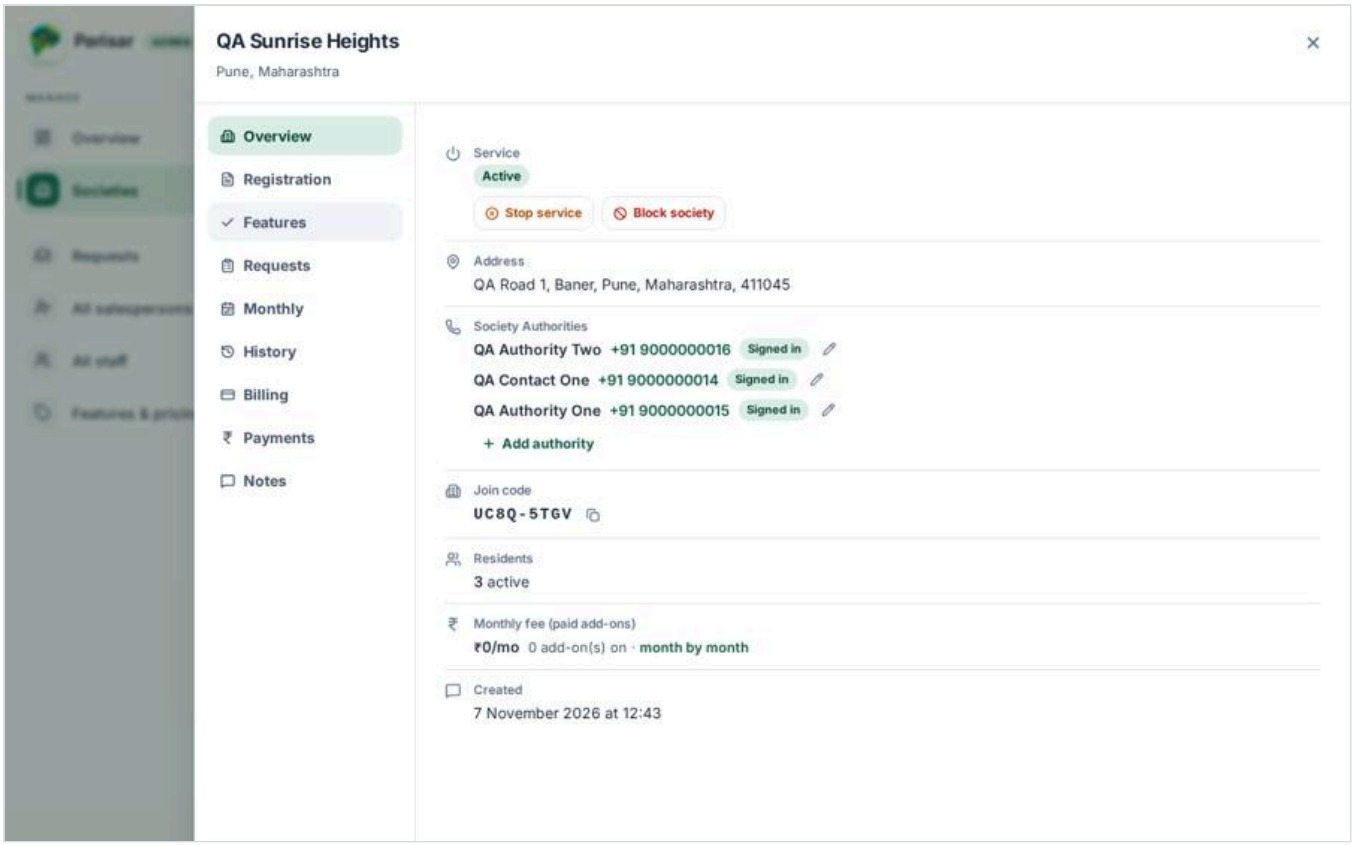
admin-requests-table-1280.png



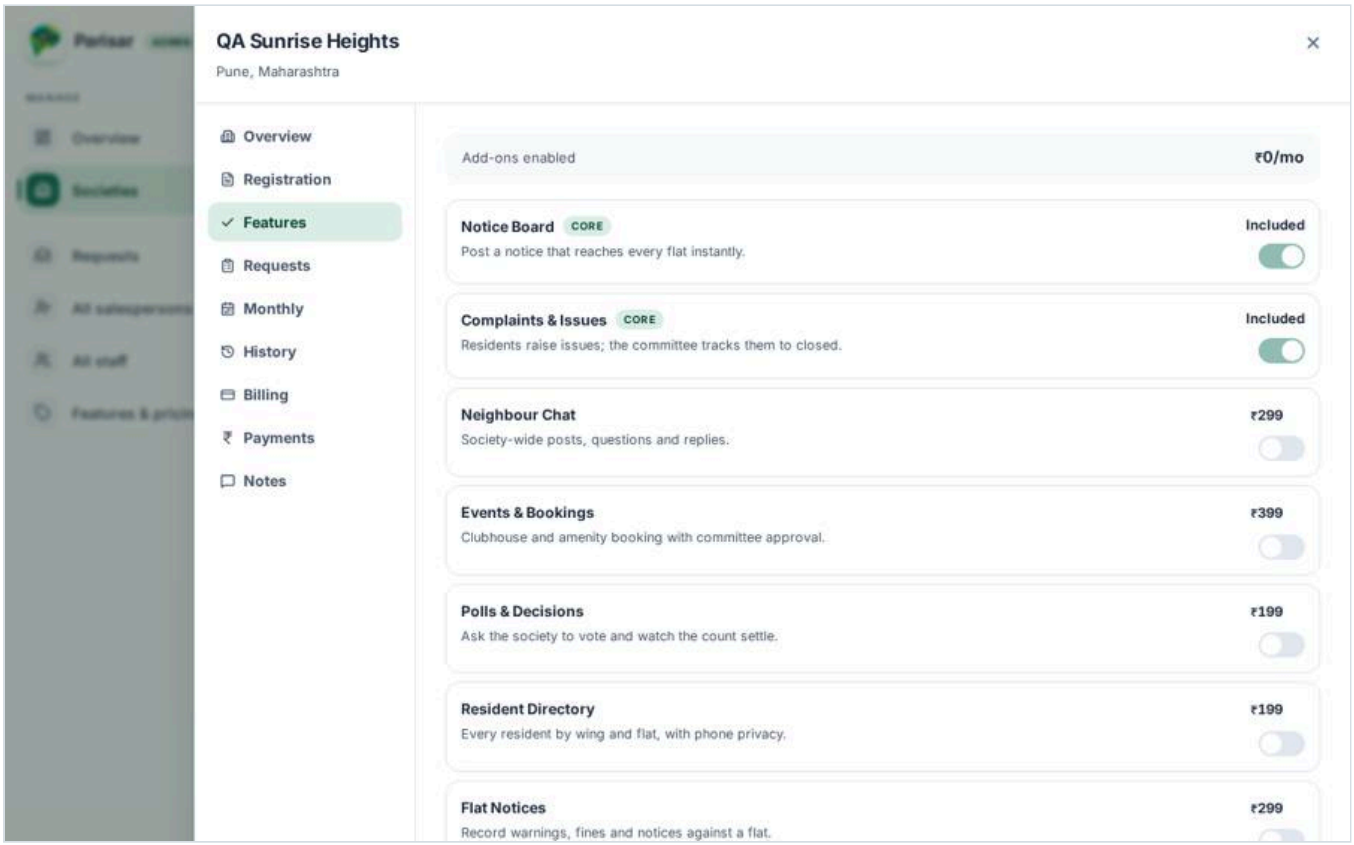
admin-reschedule-datepicker-1280.png



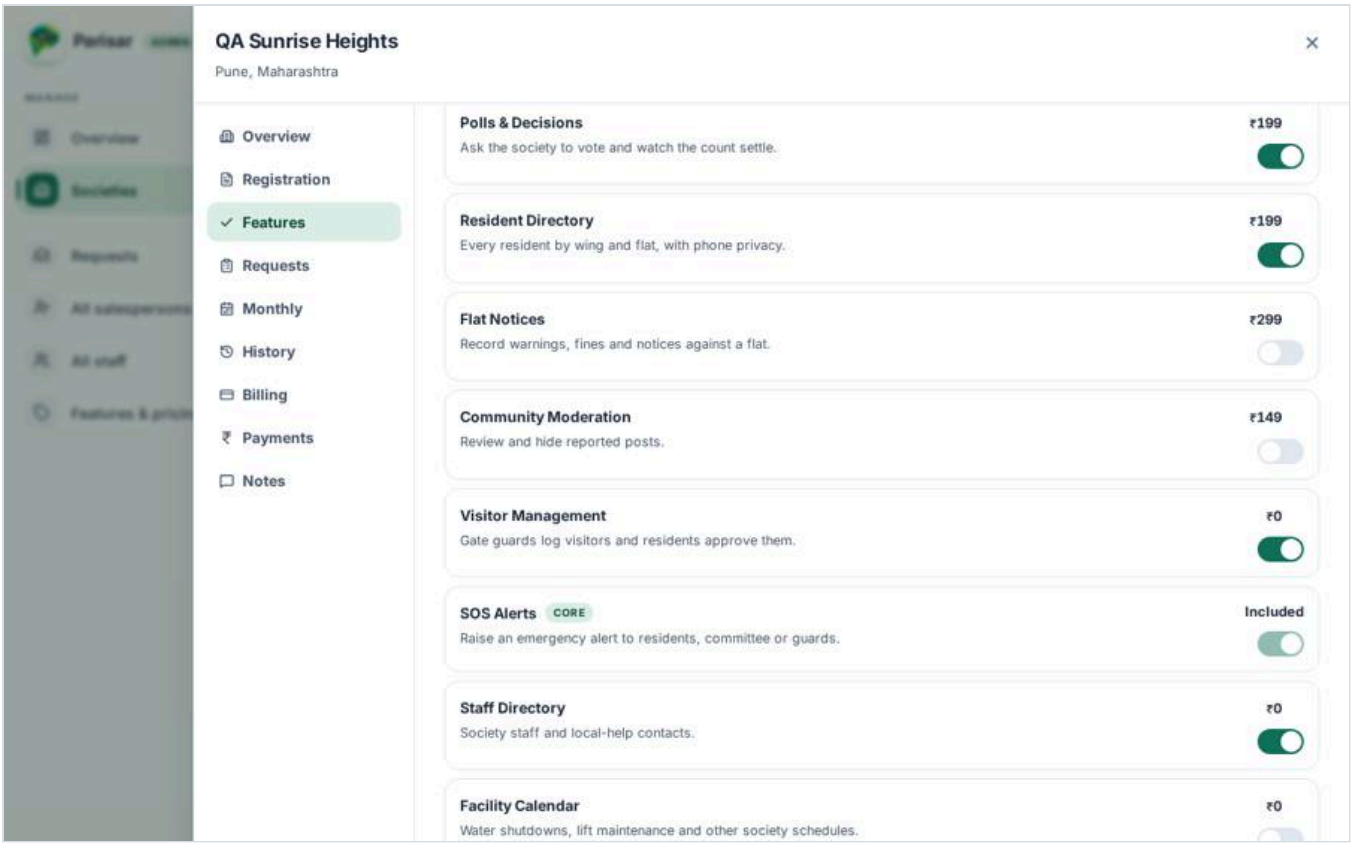
admin-societies-1280.png



admin-society-drawer-1280.png

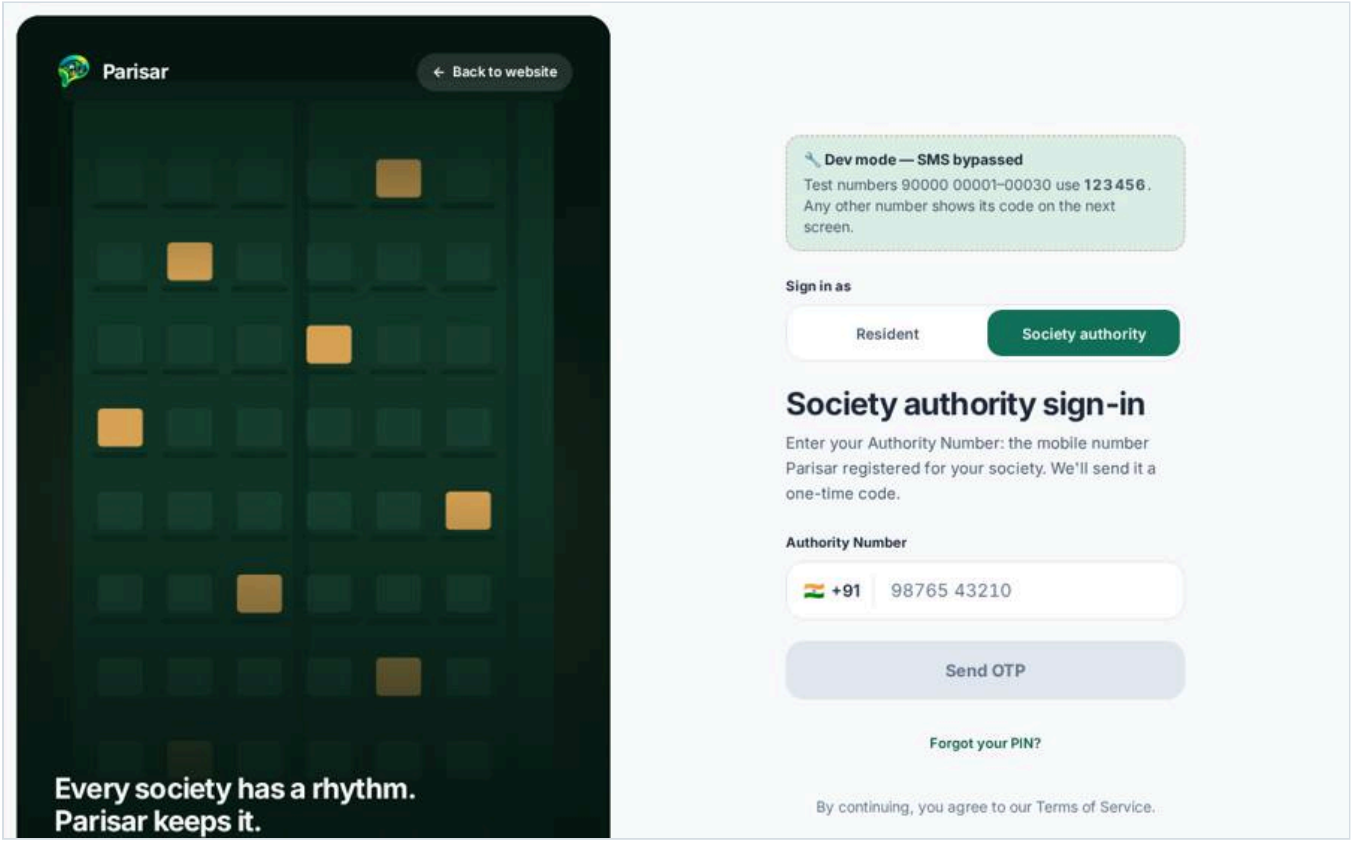


admin-society-features-1280.png



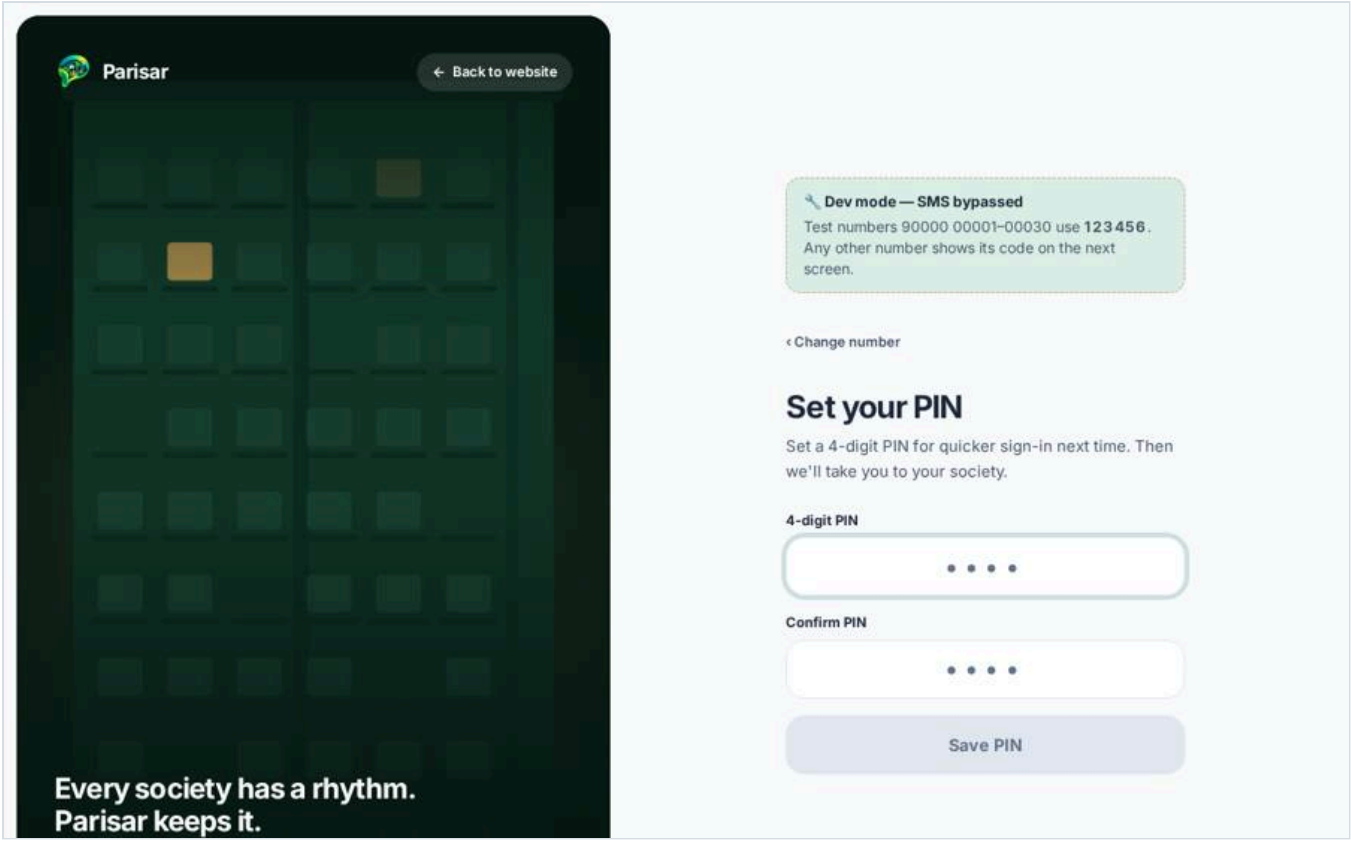
admin-society-features-on-1280.png

Login

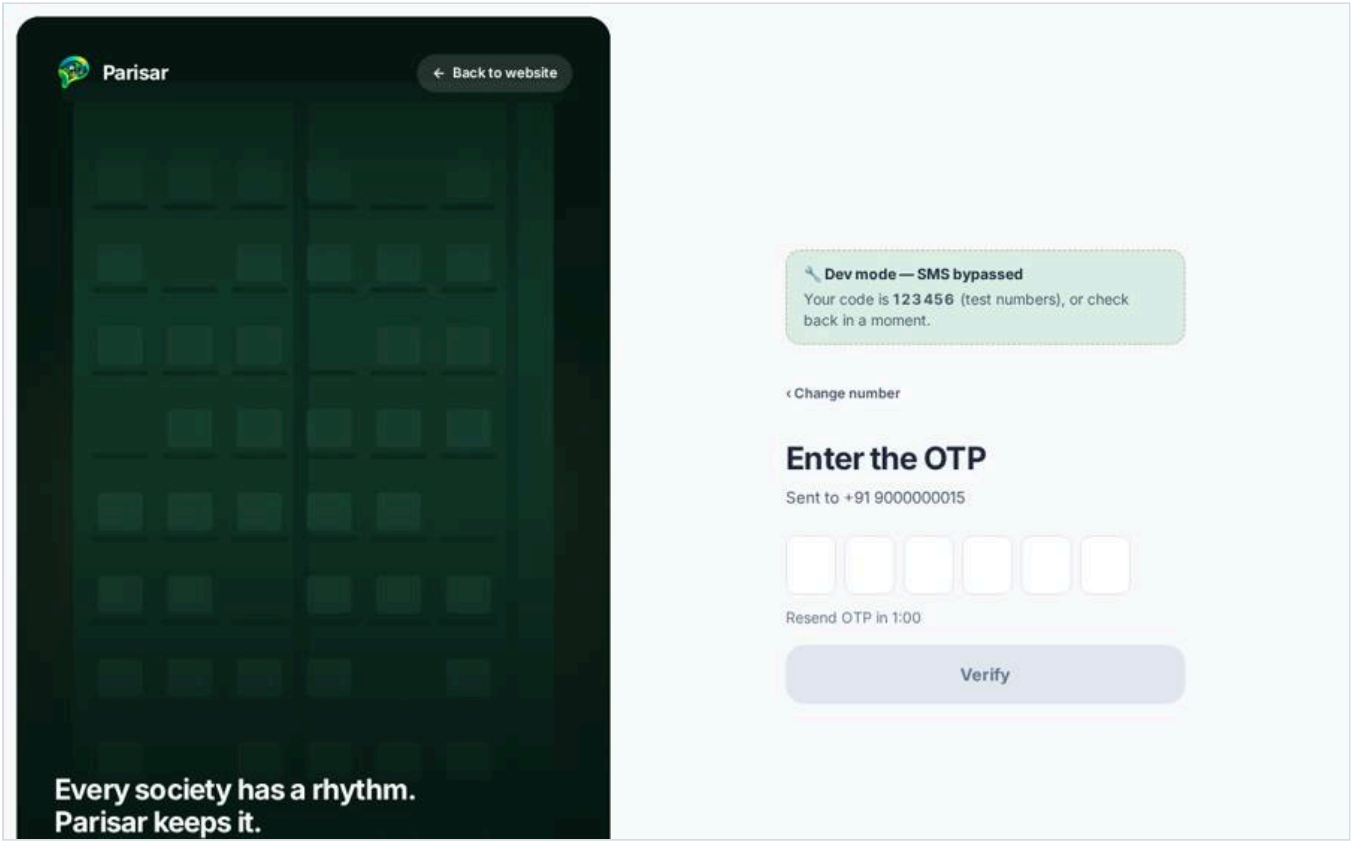


login-authority-1280.png

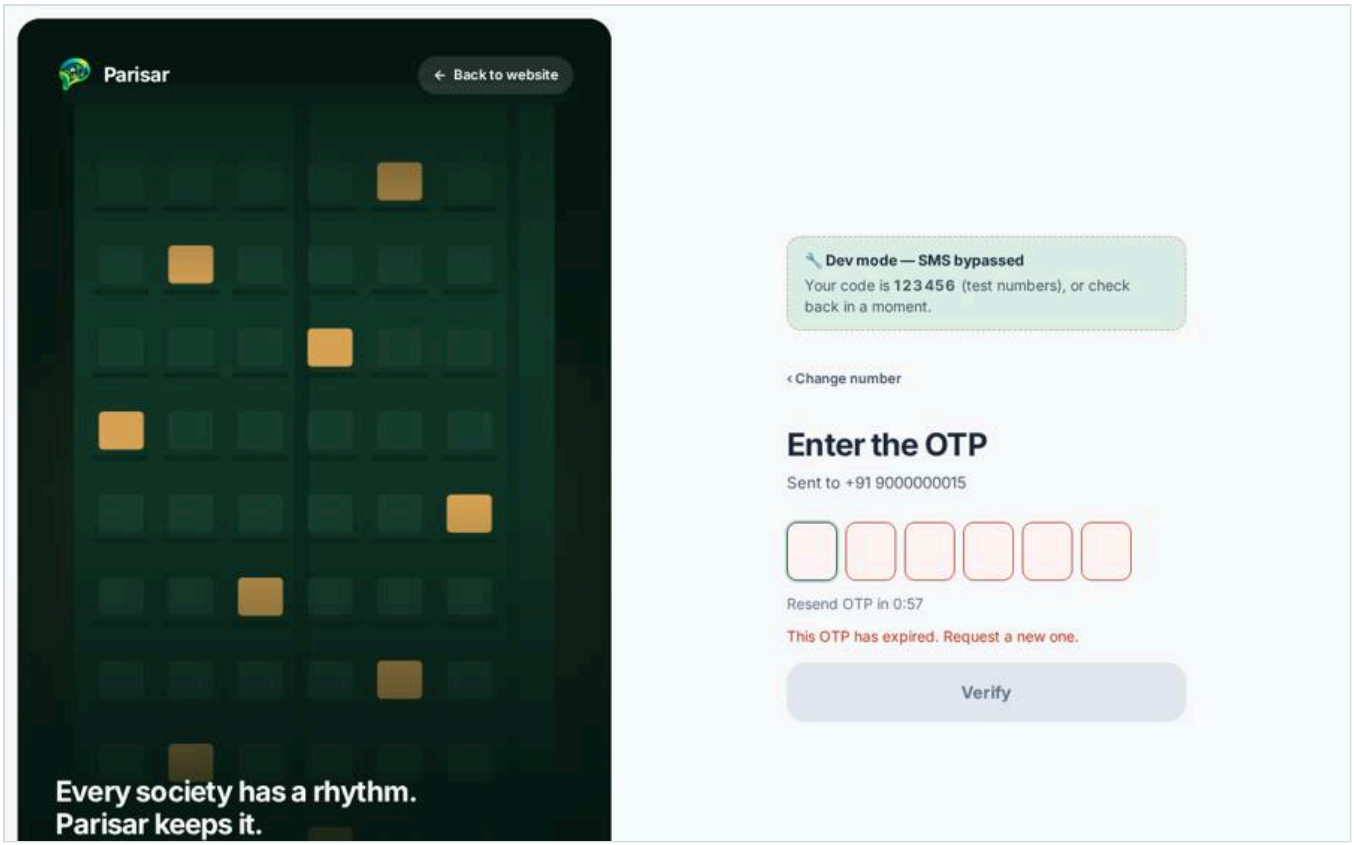
OTP and PIN



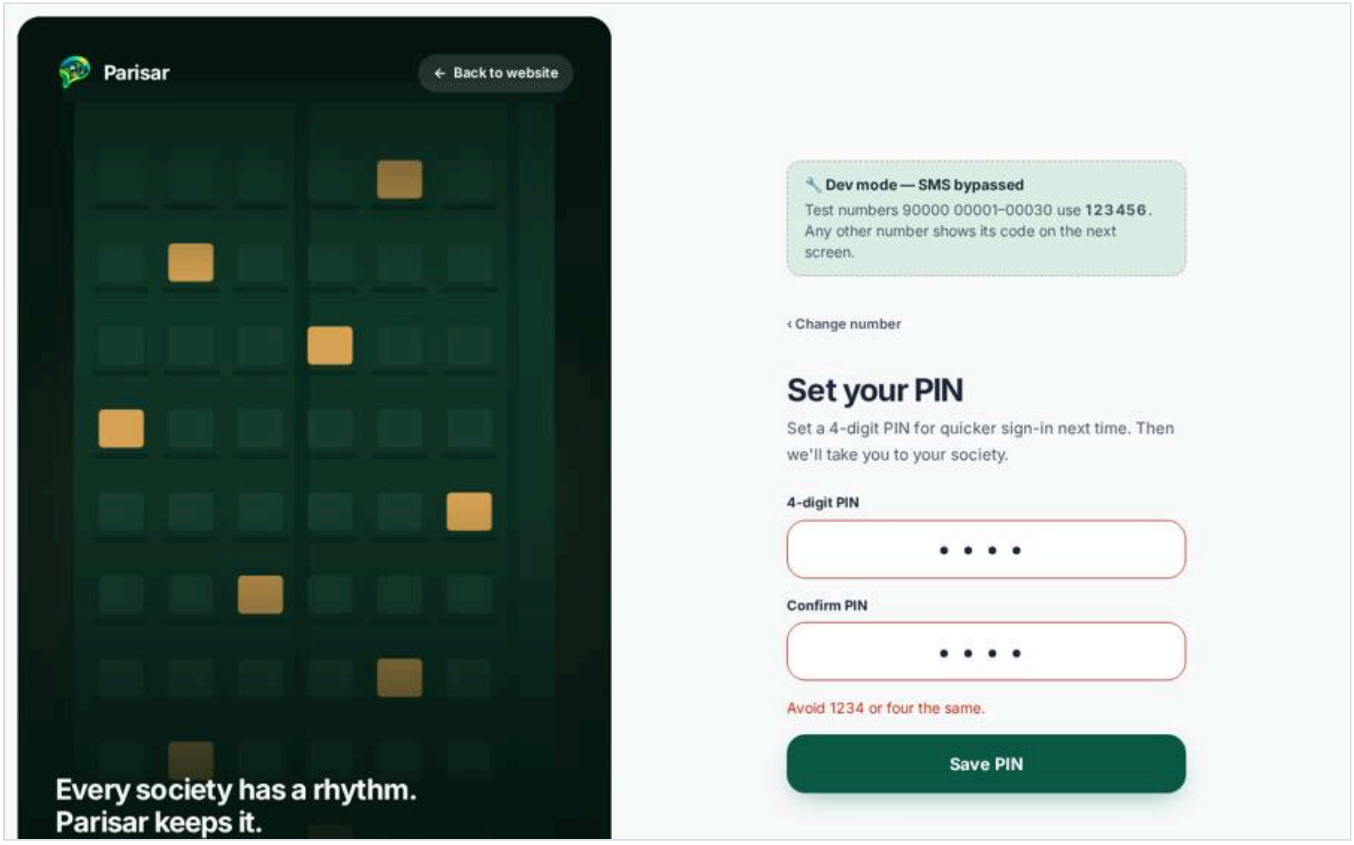
verify-authority-setpin-1280.png



verify-otp-1280.png

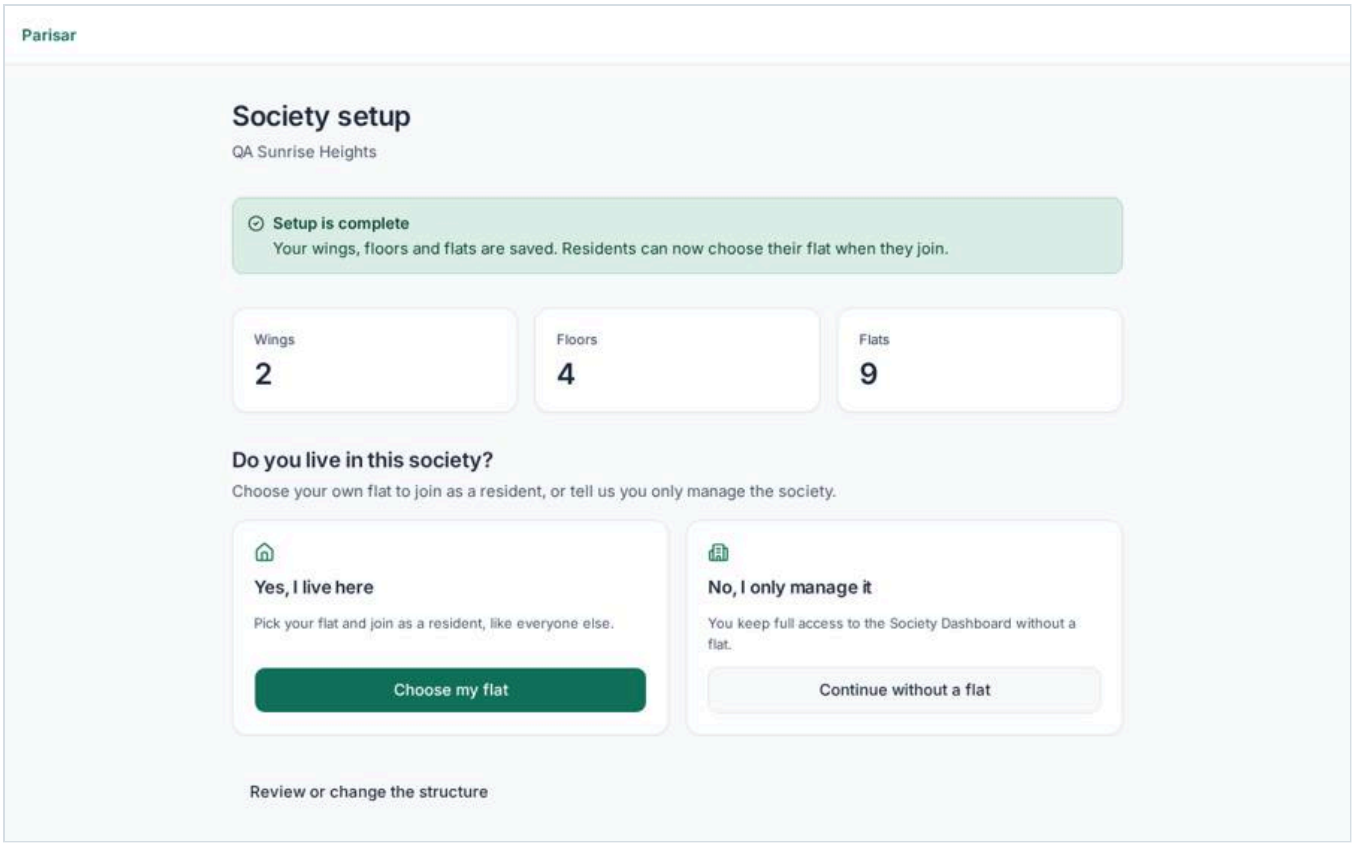


verify-otp-wrong-1280.png

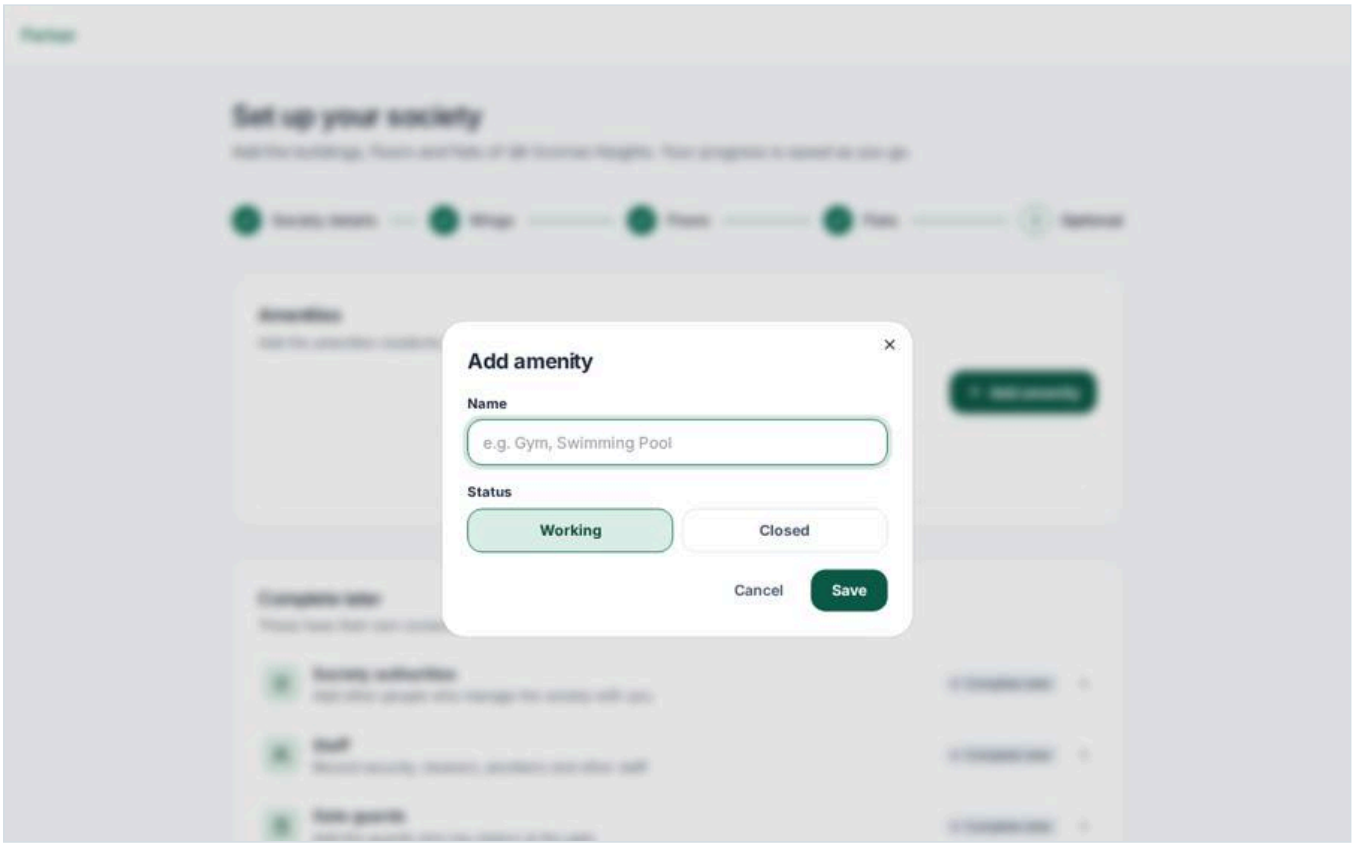


verify-setpin-weak-1280.png

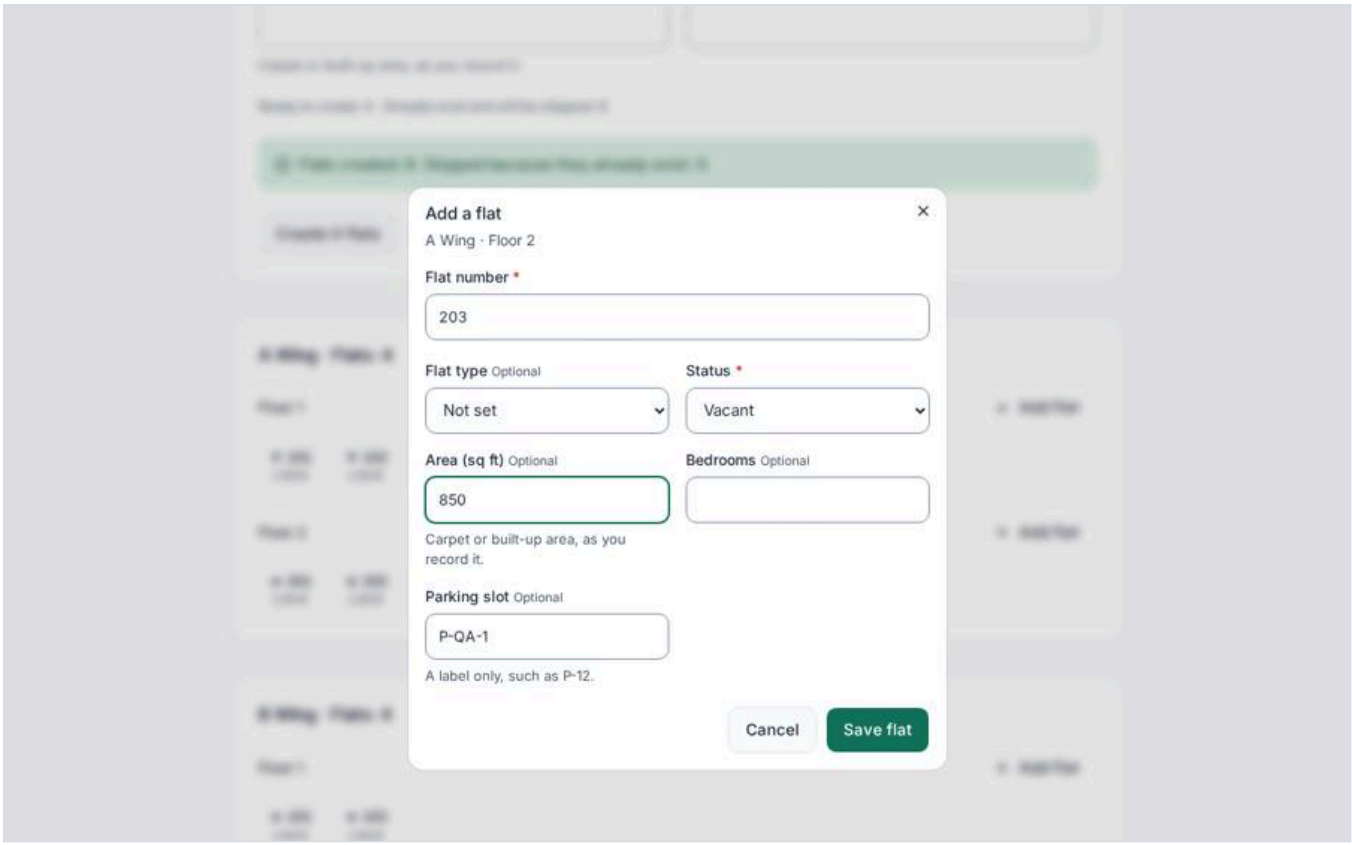
Society setup wizard



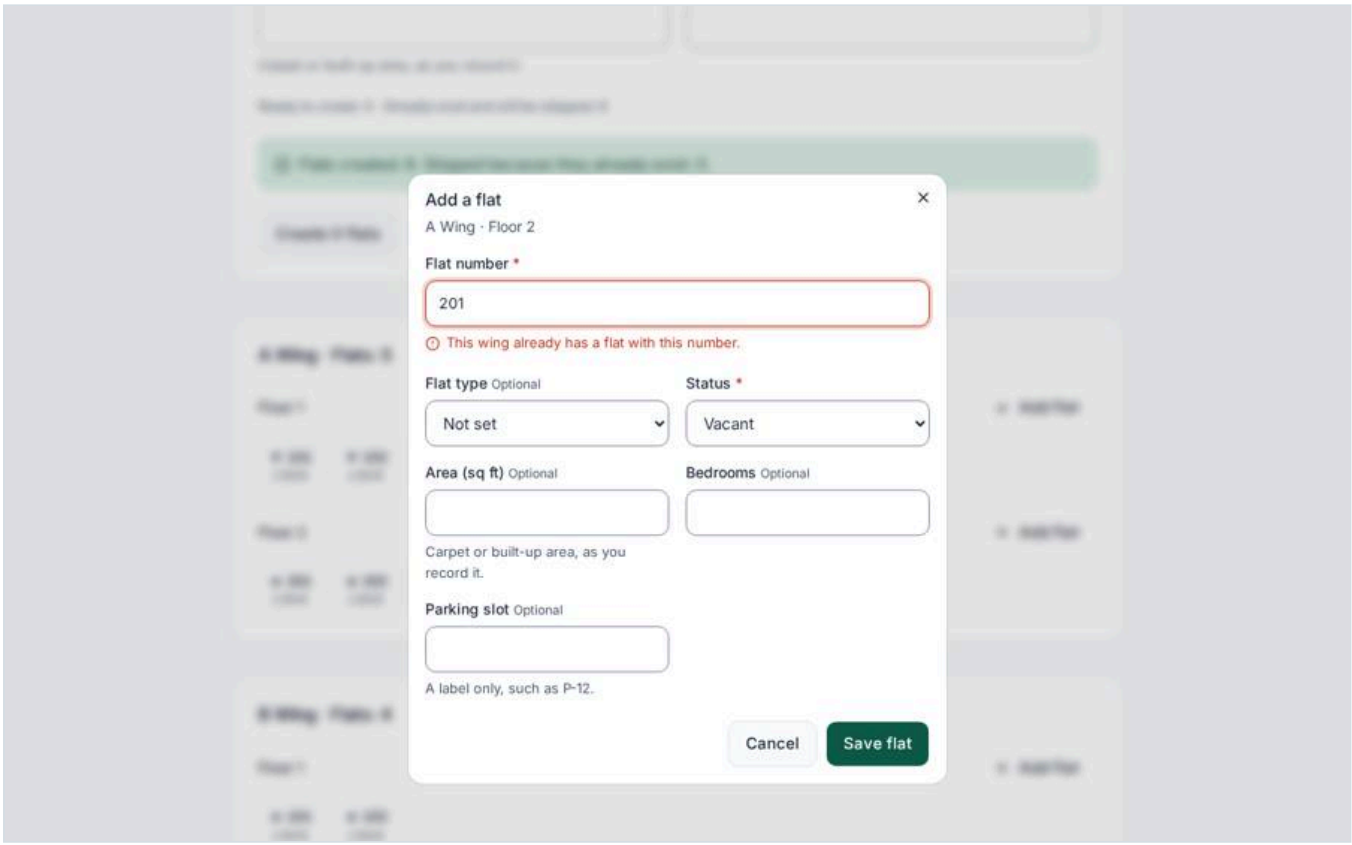
setup-done-1280.png



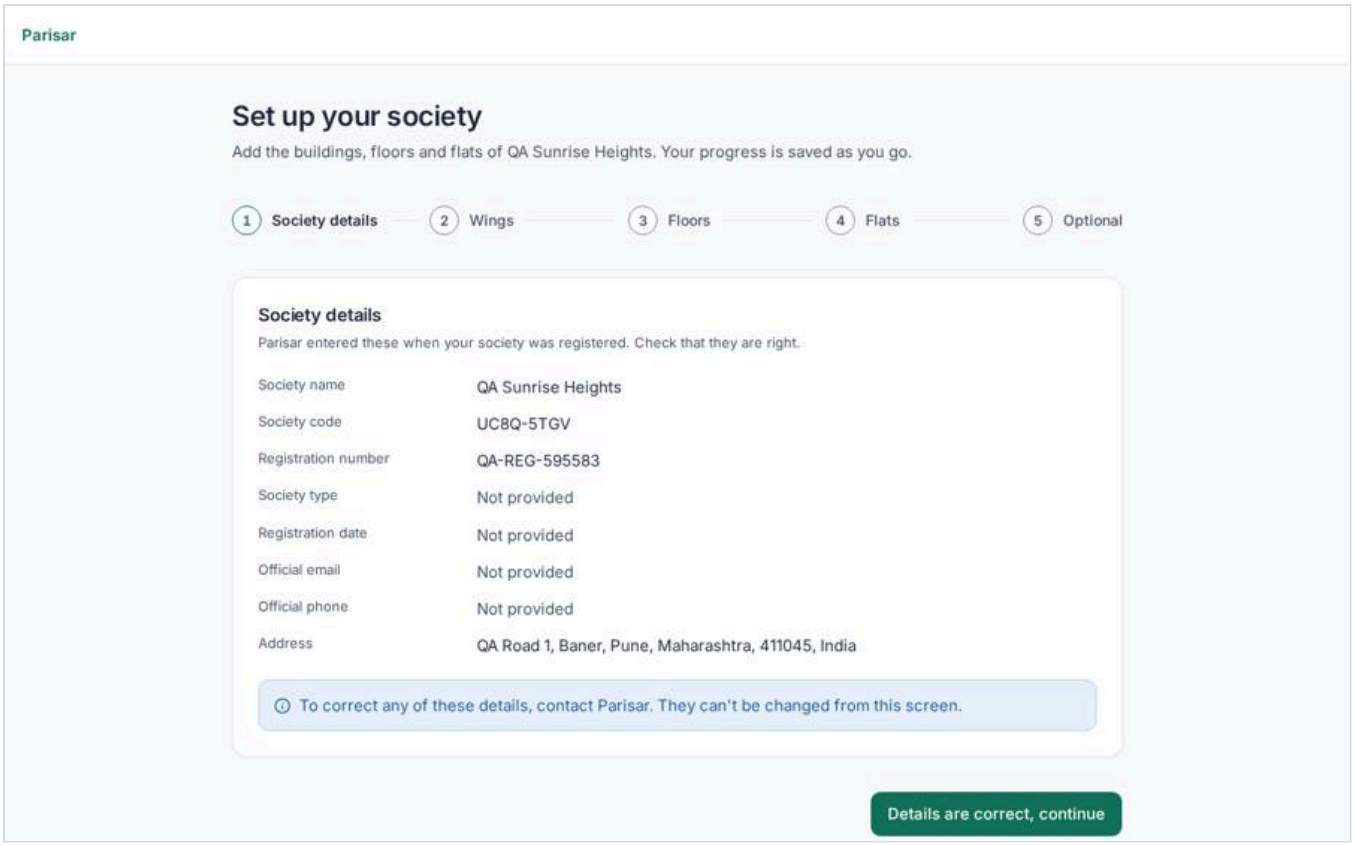
setup-wizard-amenity-dialog-1280.png



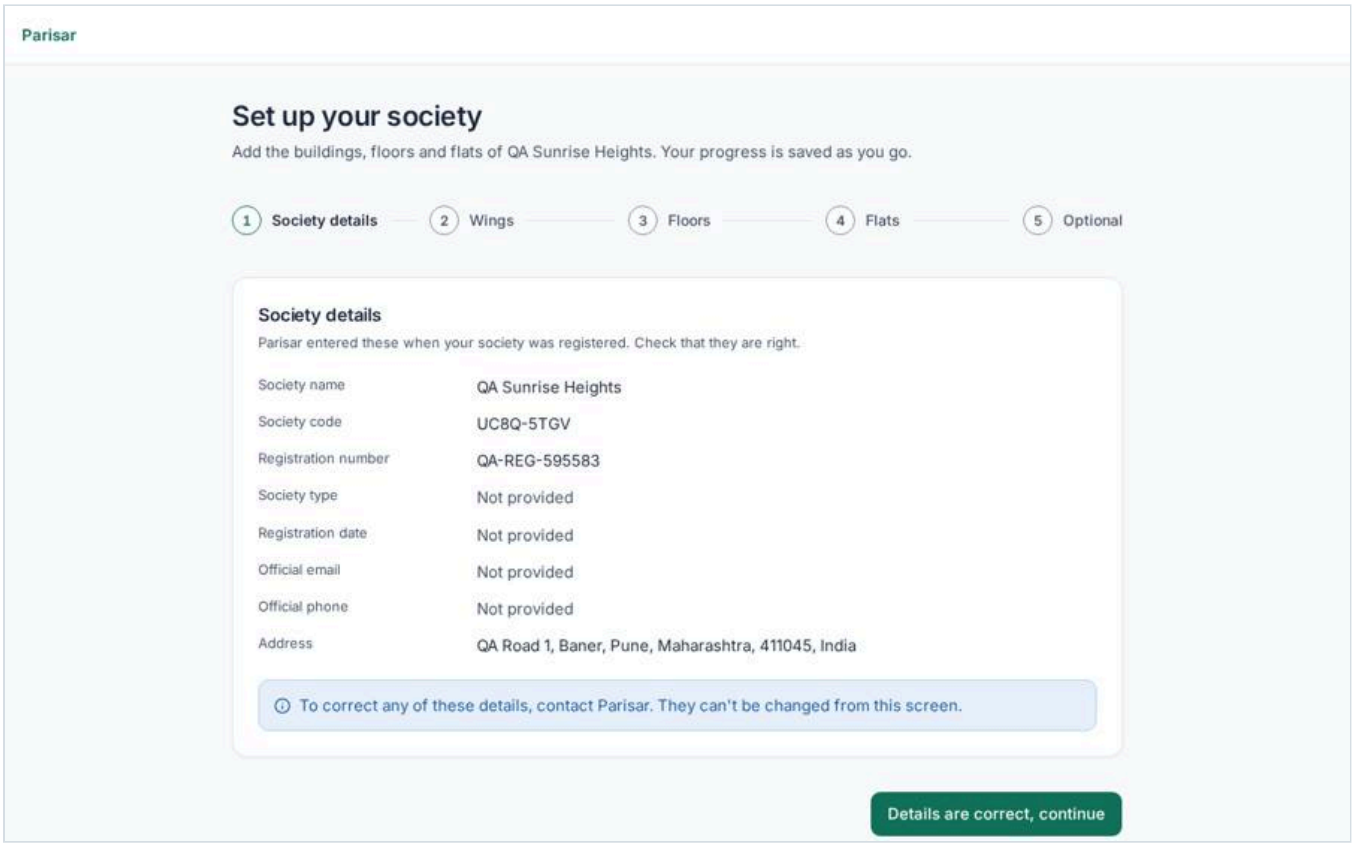
setup-wizard-flat-dialog-1280.png



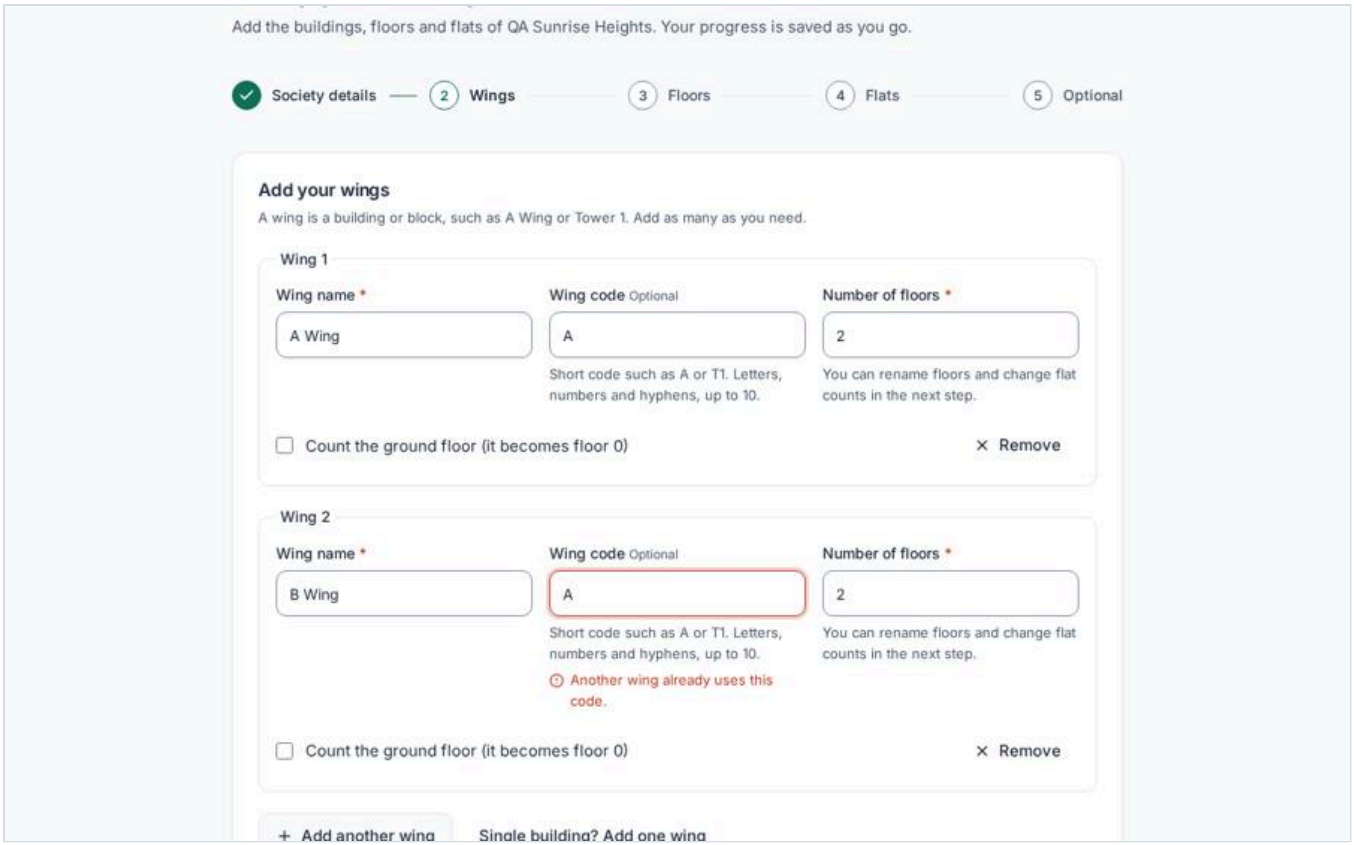
setup-wizard-flat-dialog-duplicate-1280.png



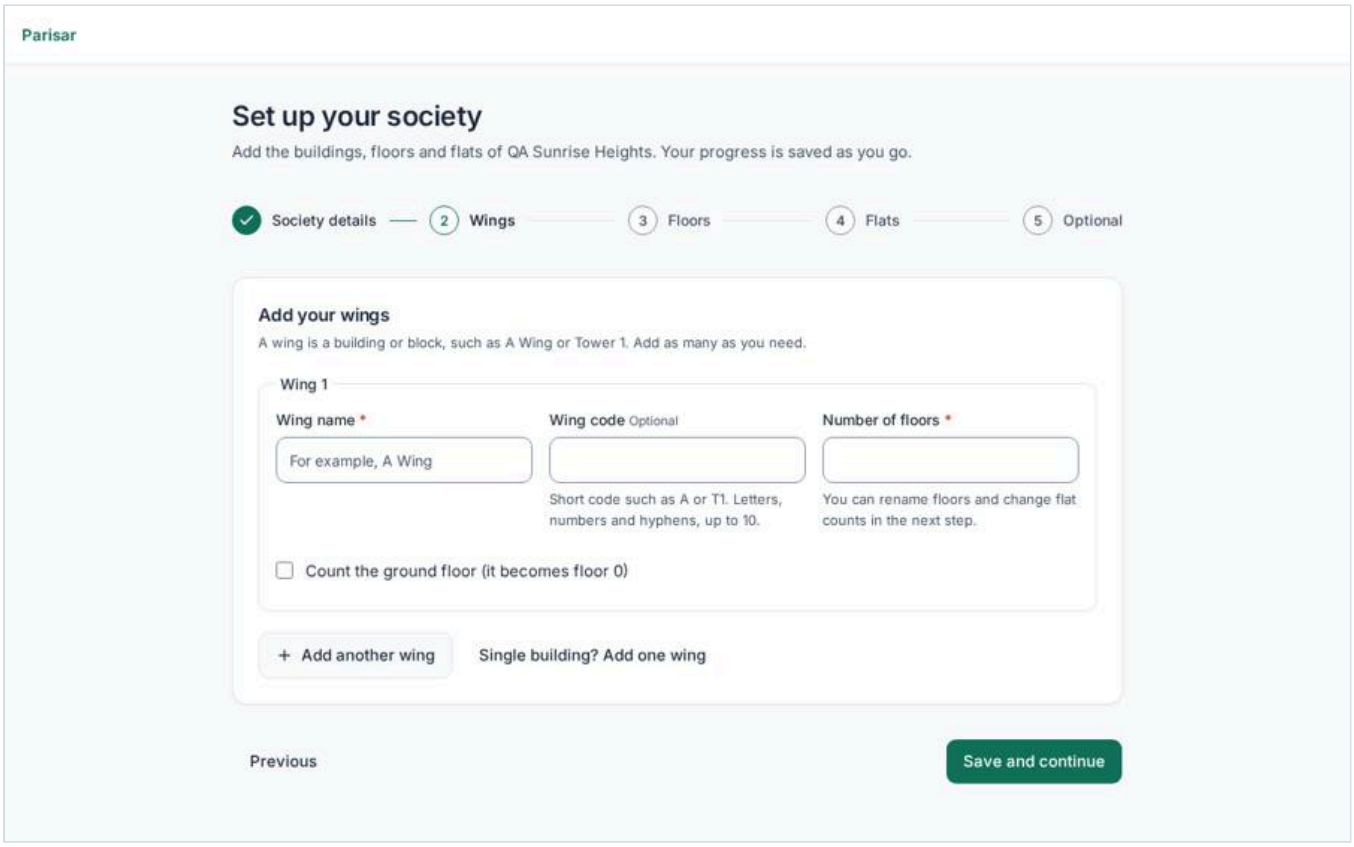
setup-wizard-step1-1280.png



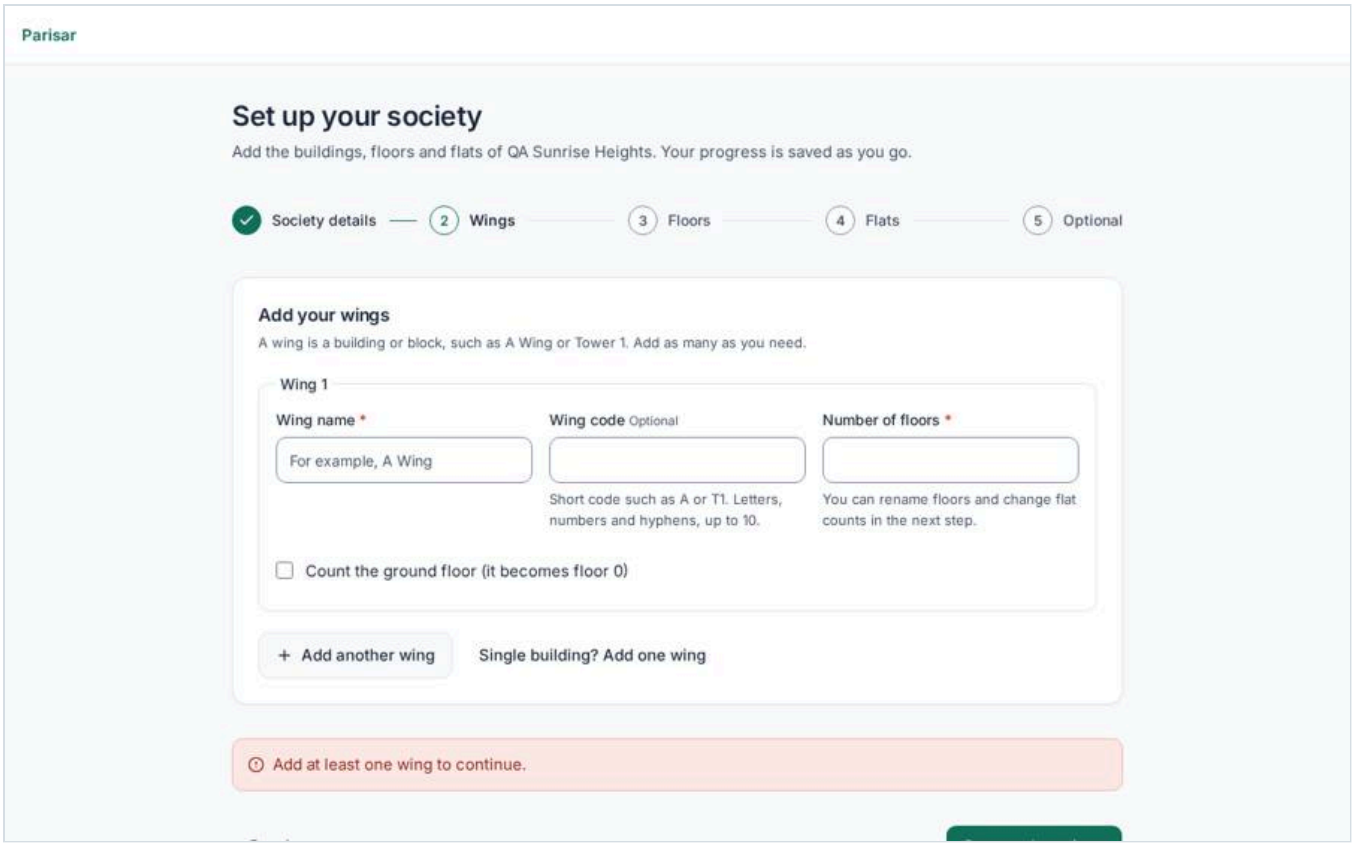
setup-wizard-step1-details-1280.png



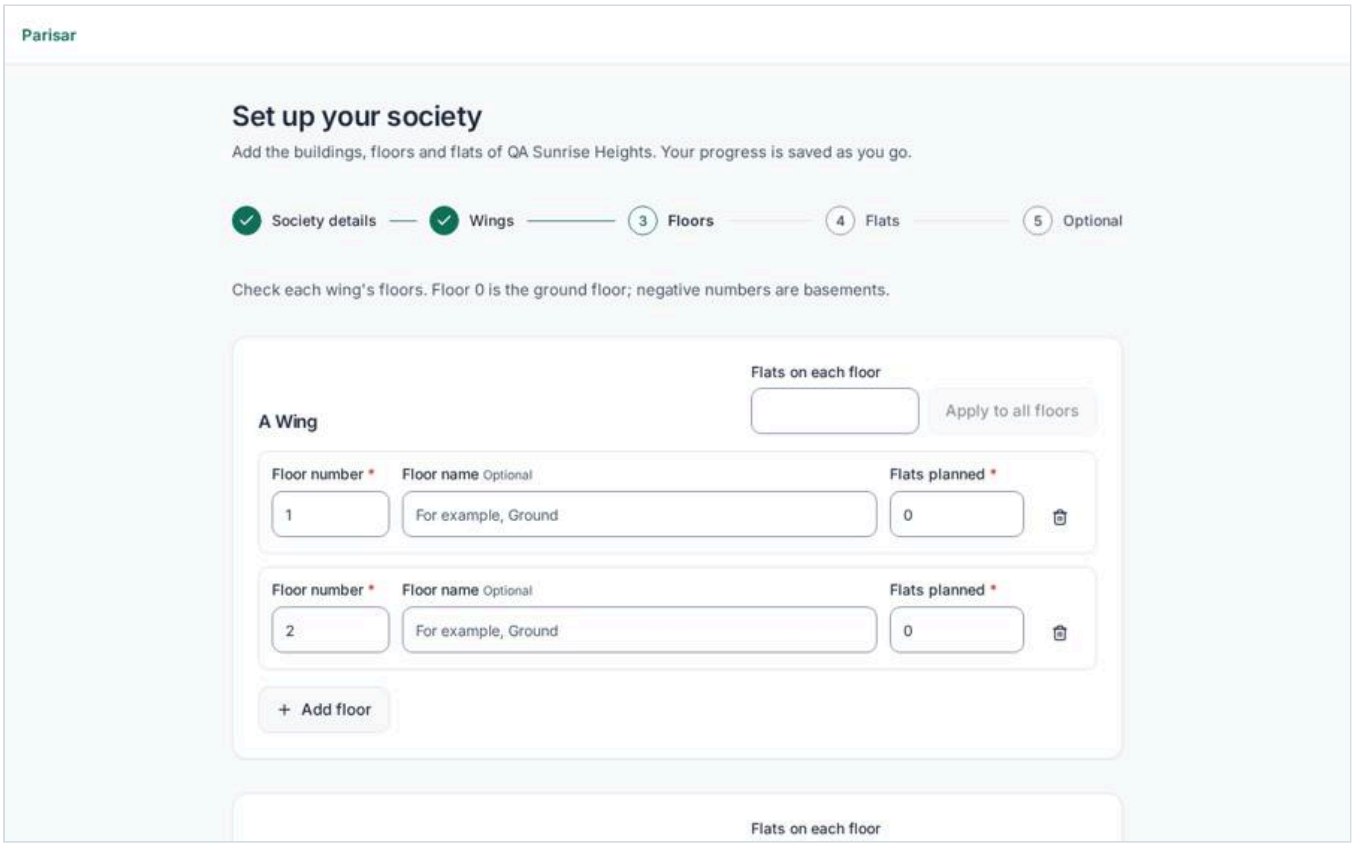
setup-wizard-step2-wings-dupcode-1280.png



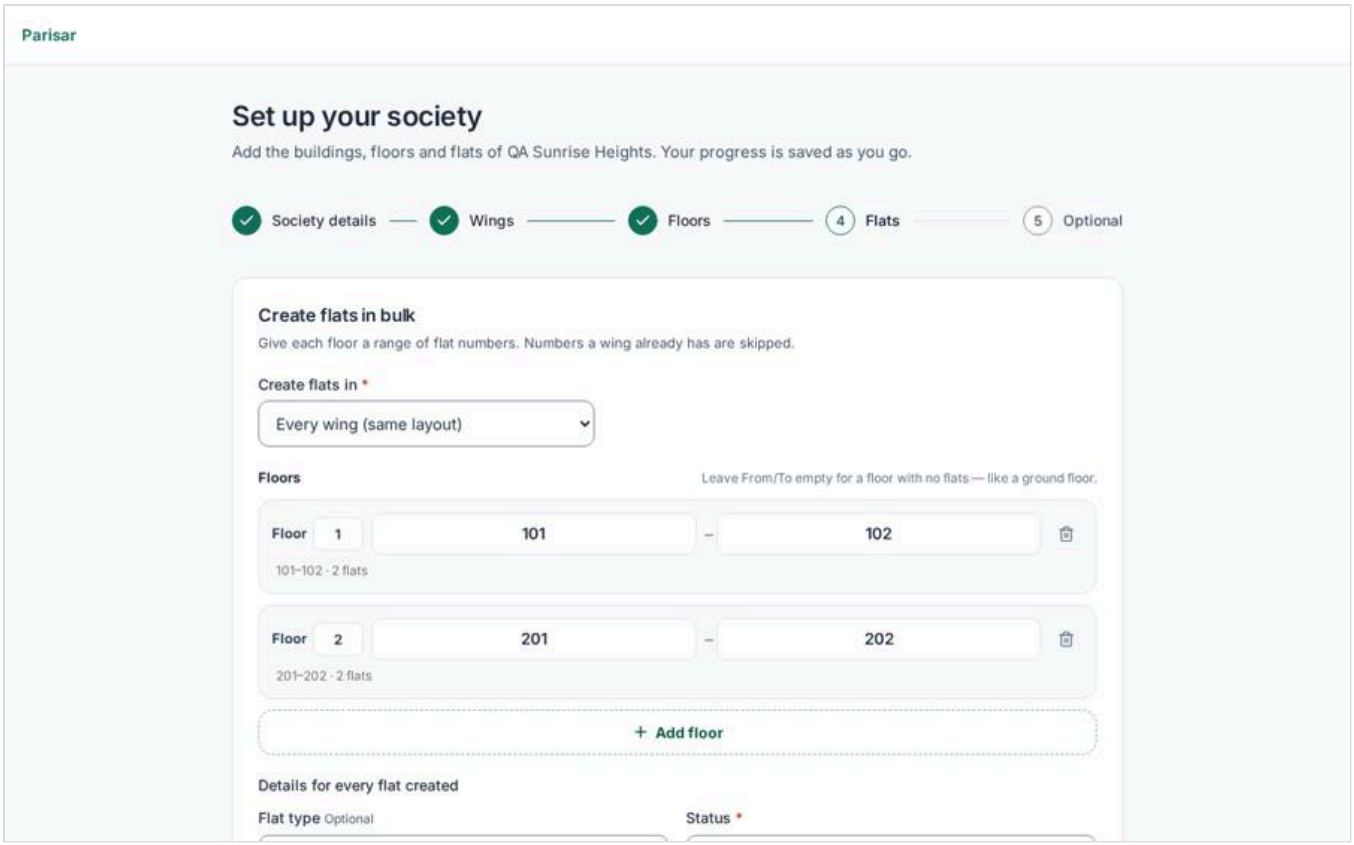
setup-wizard-step2-wings-empty-1280.png



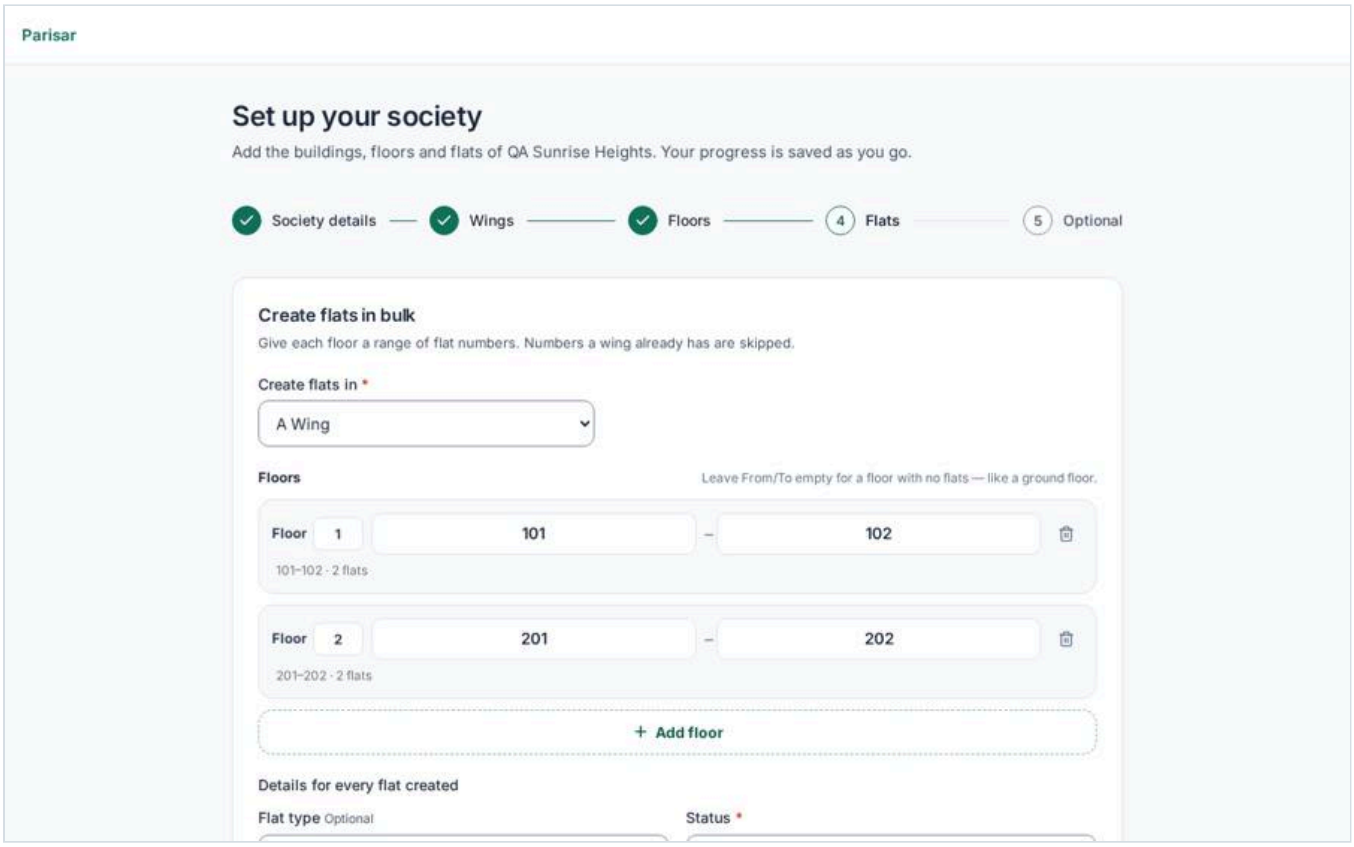
setup-wizard-step2-wings-validation-1280.png



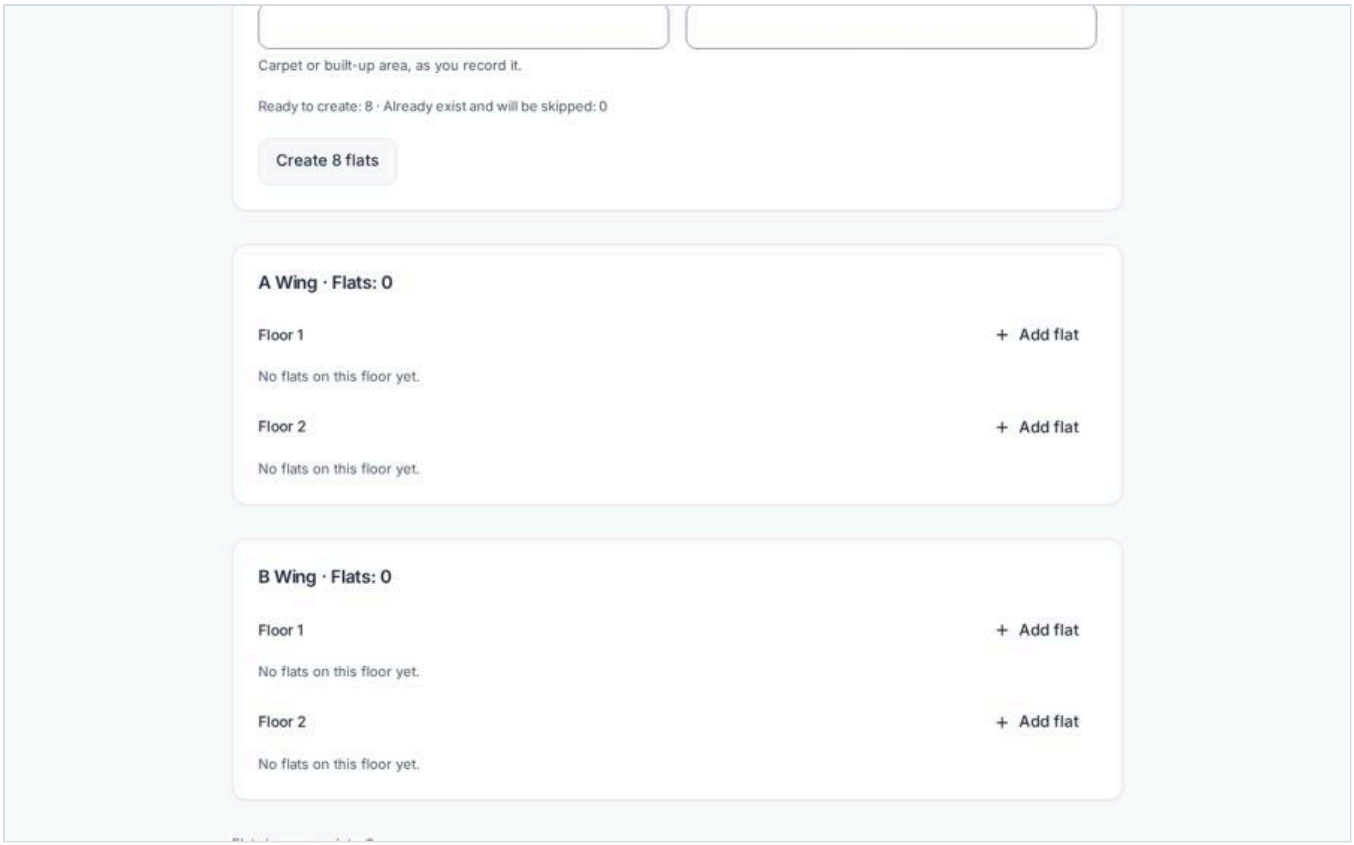
setup-wizard-step3-floors-1280.png



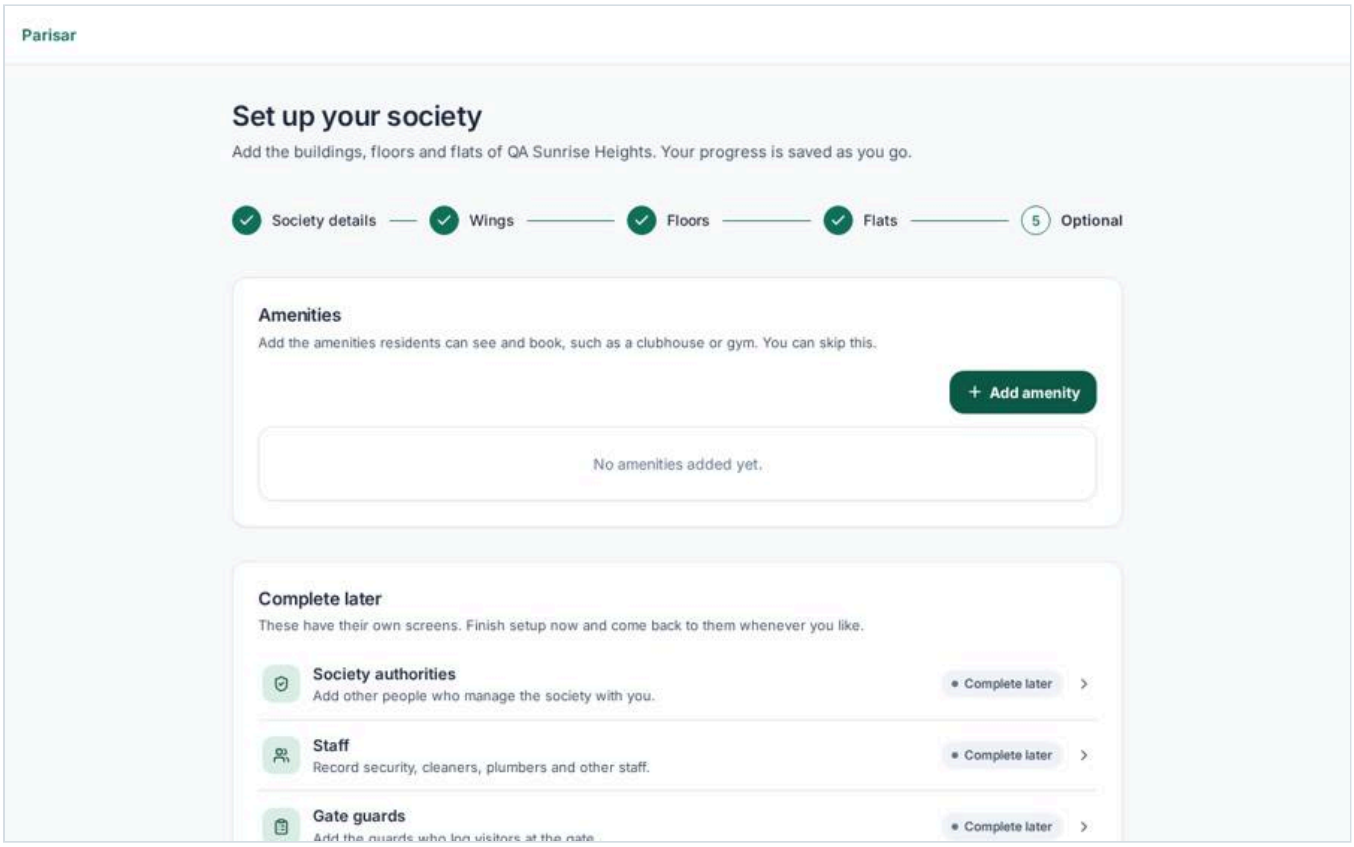
setup-wizard-step4-flats-created-1280.png



setup-wizard-step4-flats-empty-1280.png

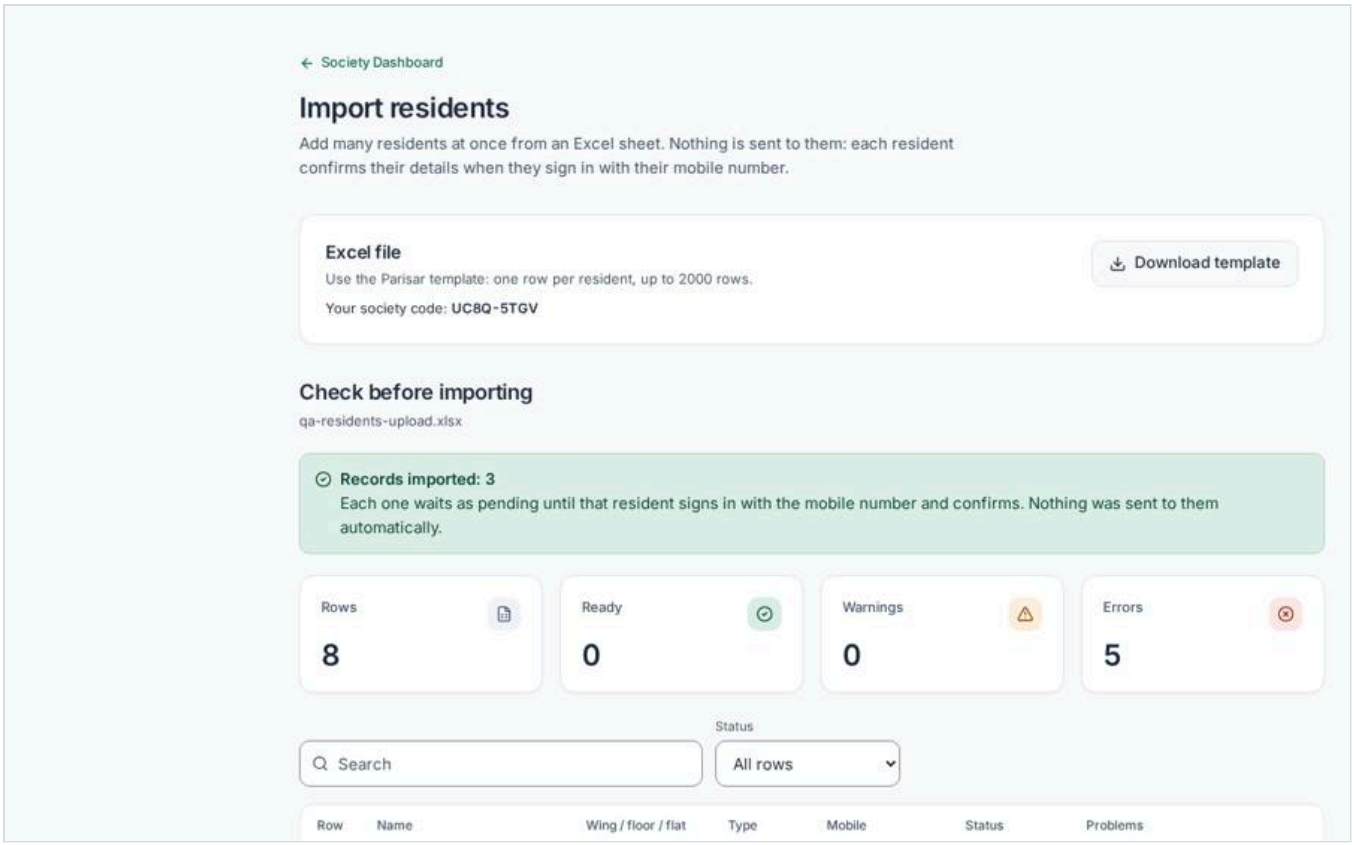


setup-wizard-step4-flats-plan-1280.png

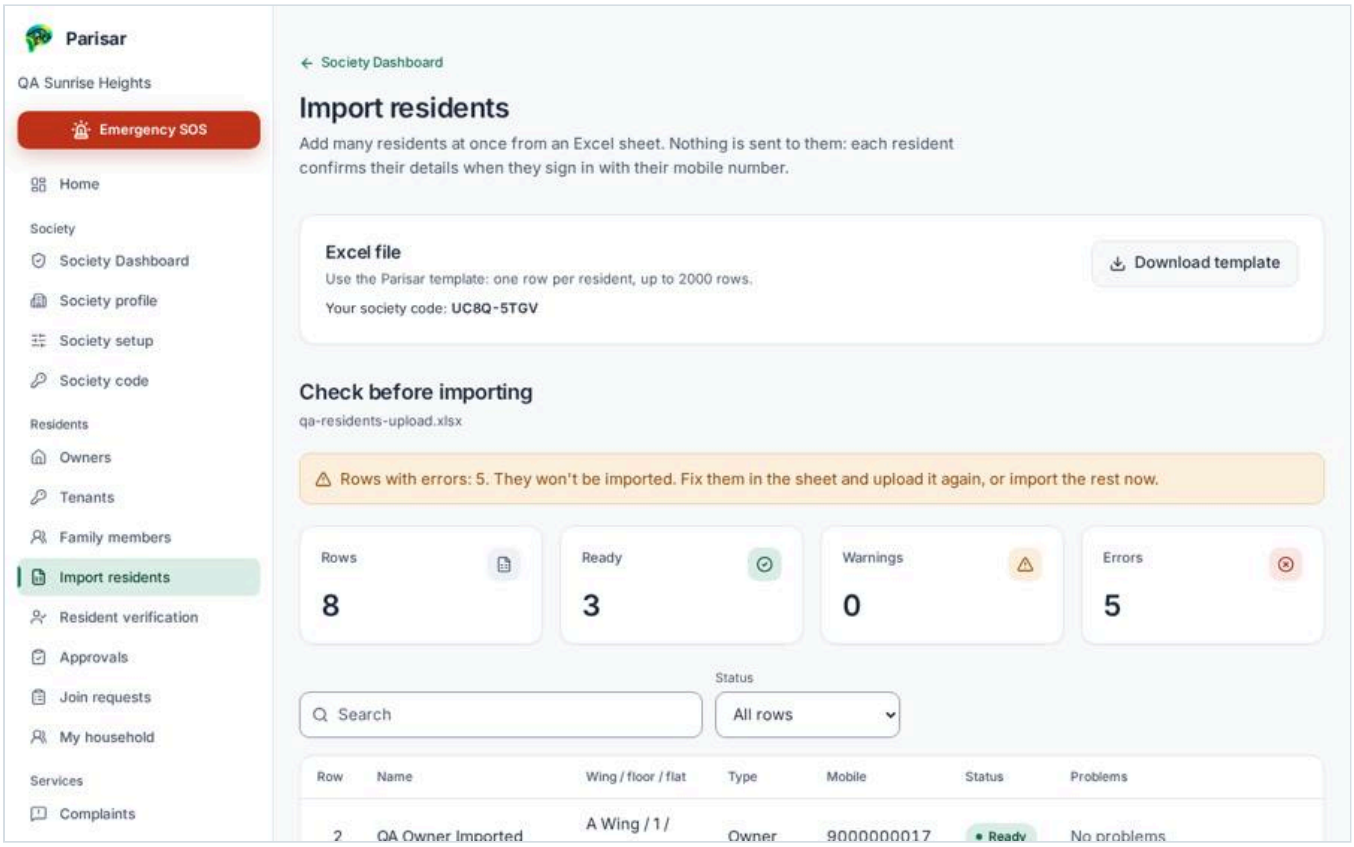


setup-wizard-step5-optional-1280.png

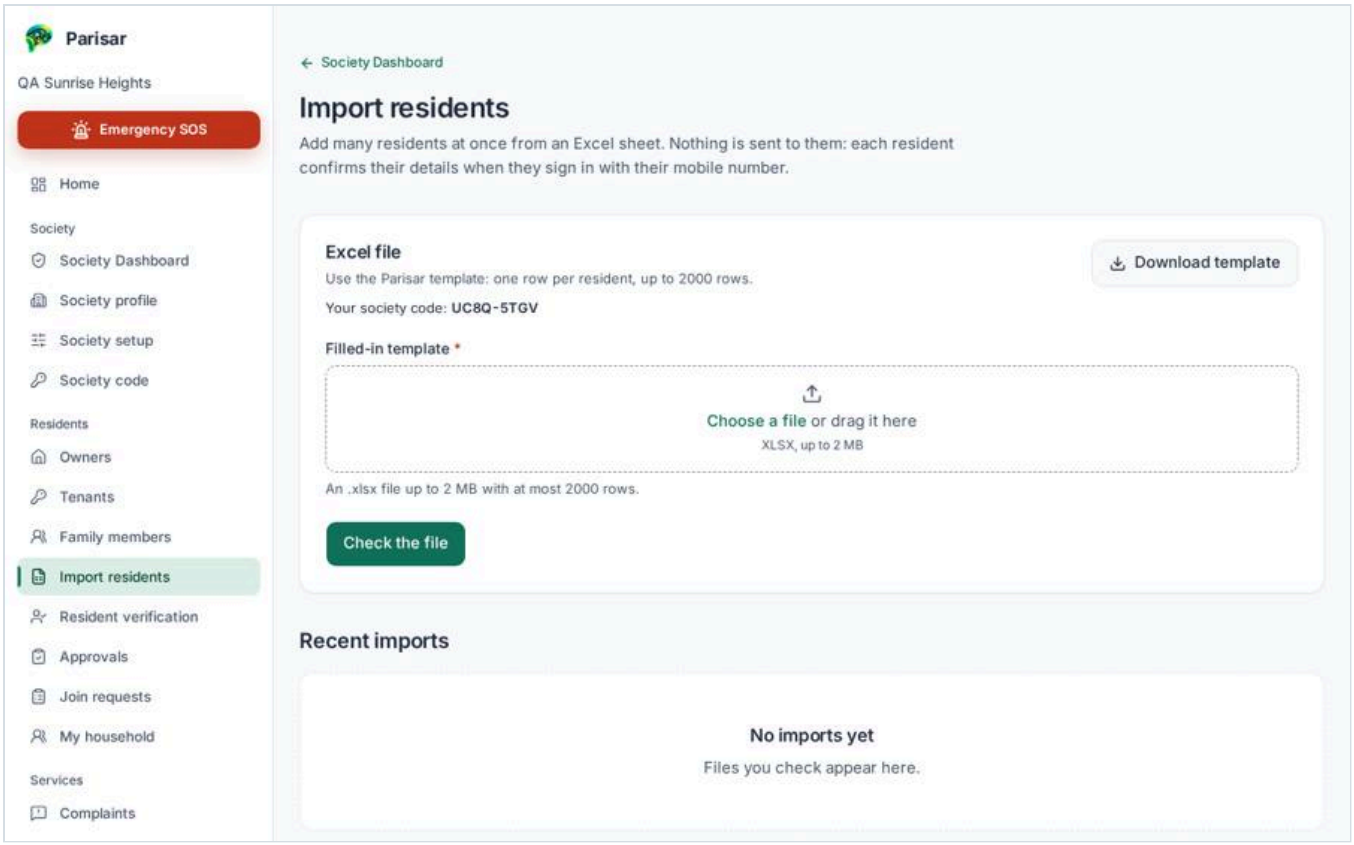
Excel import



import-done-1280.png

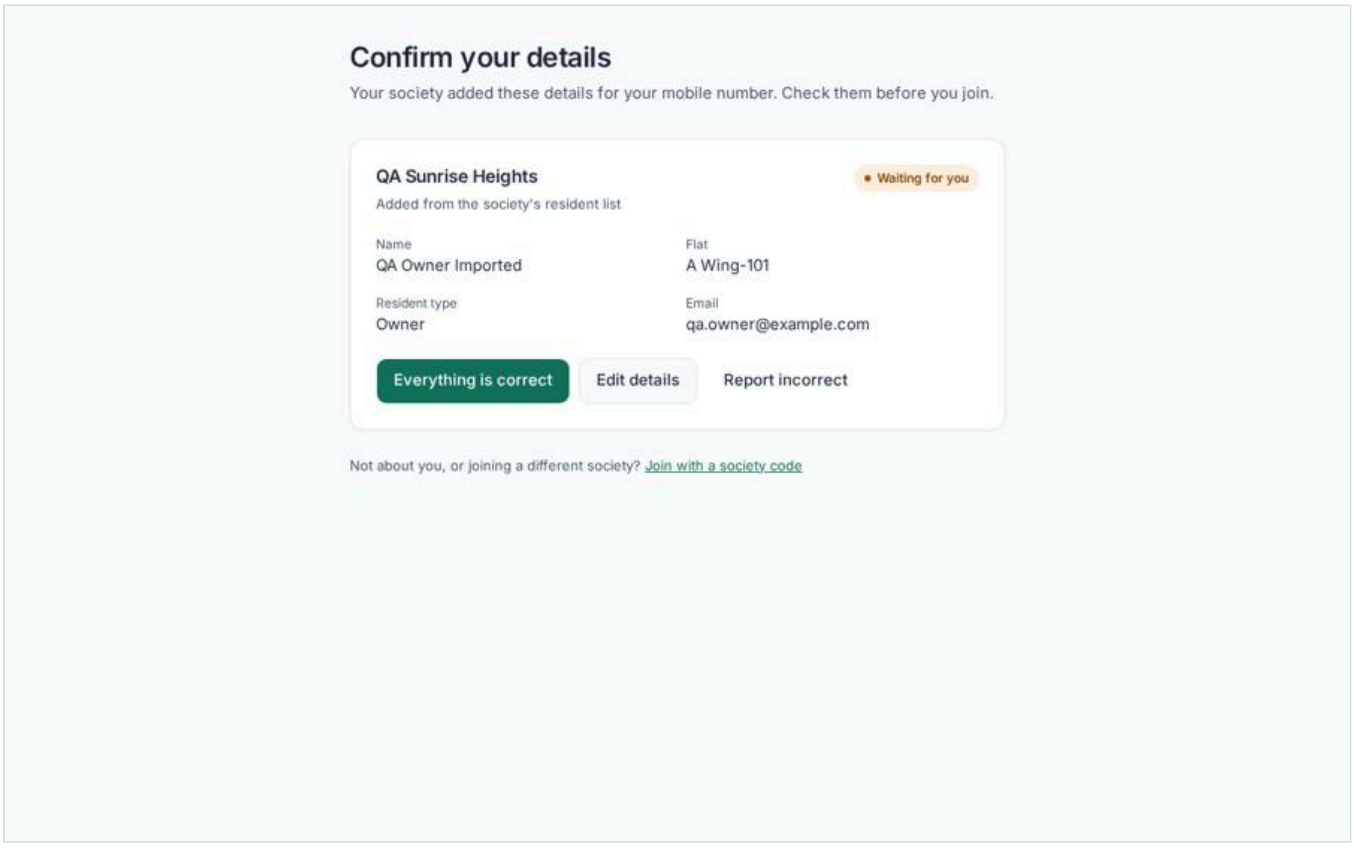


import-preview-1280.png

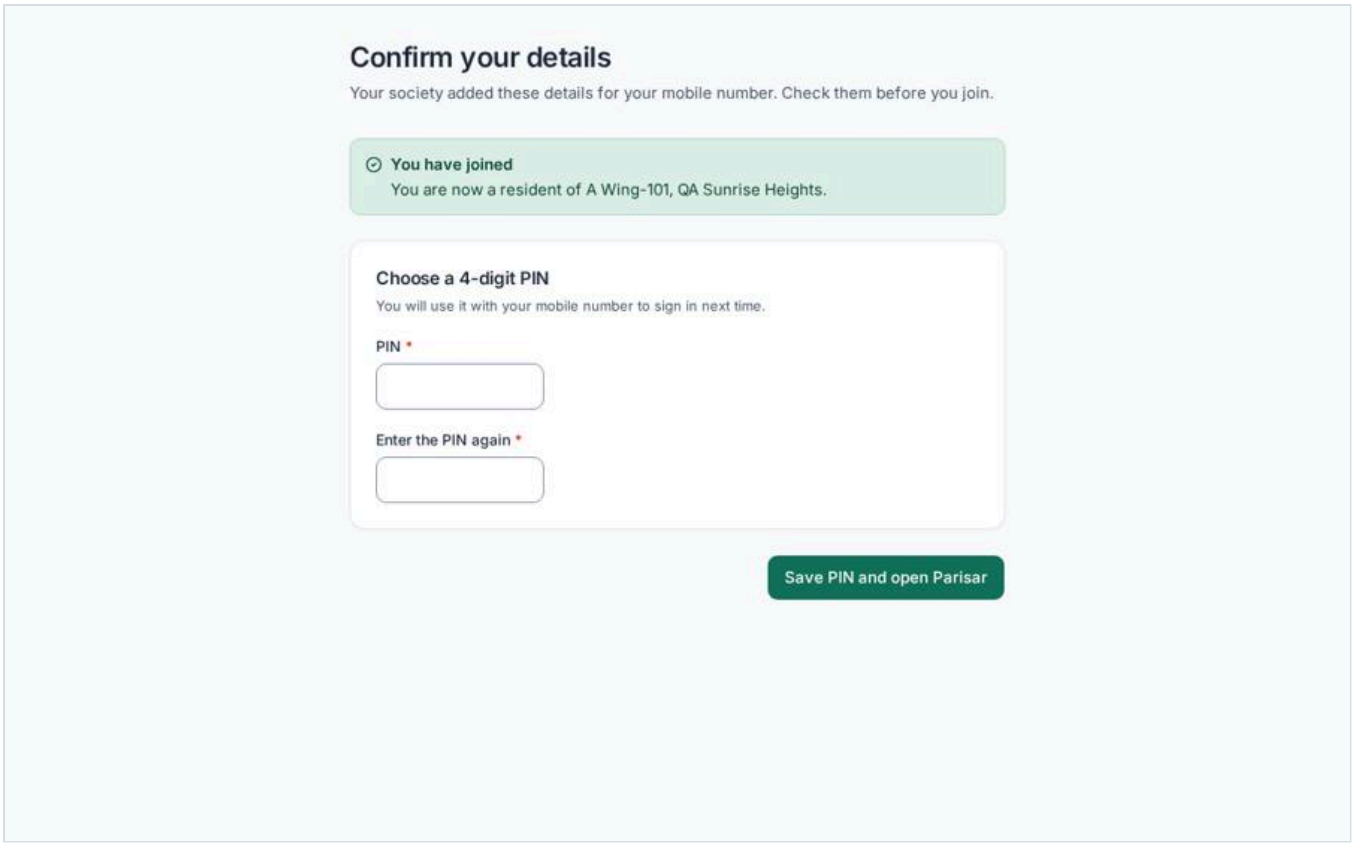


import-start-1280.png

Resident verification

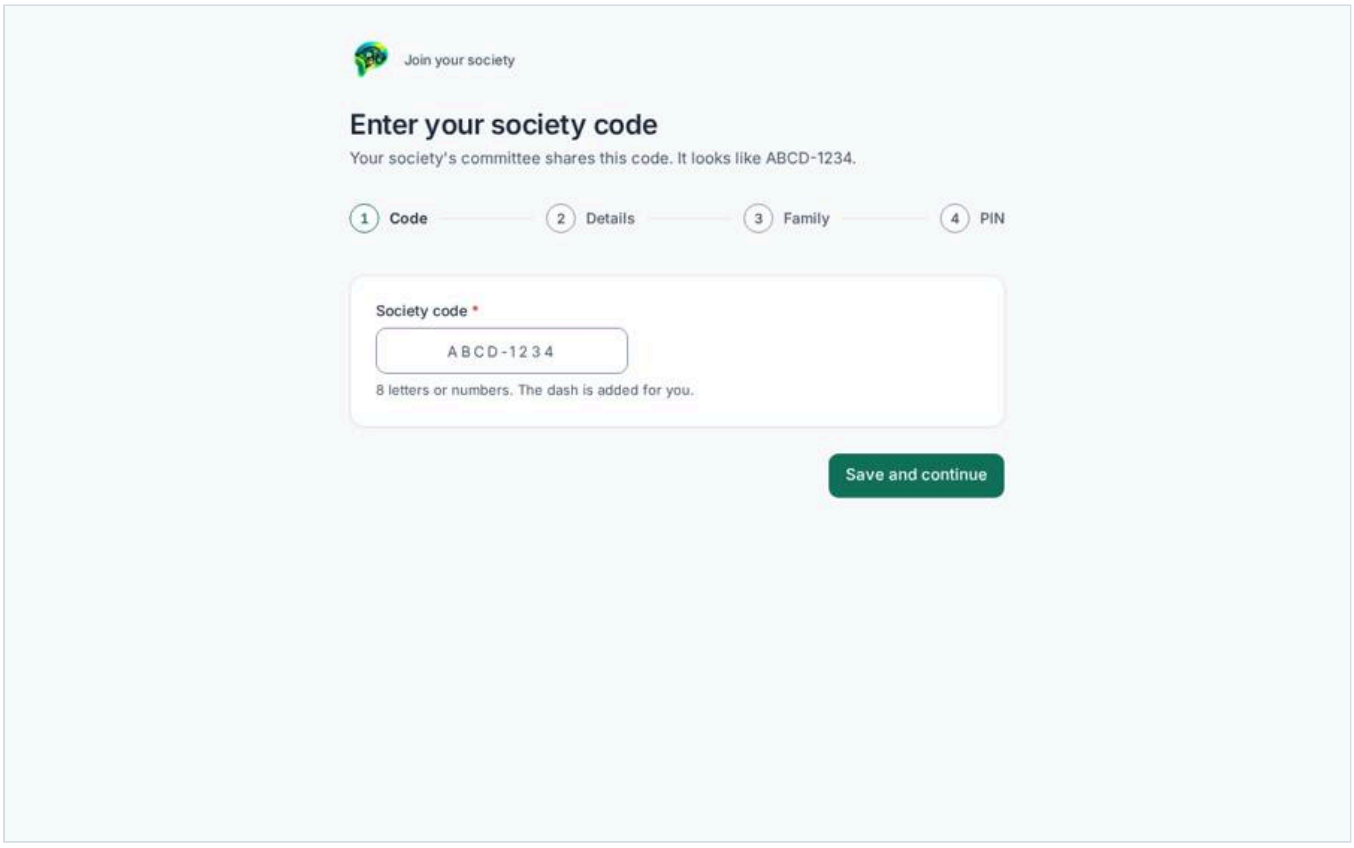


resident-verification-1280.png

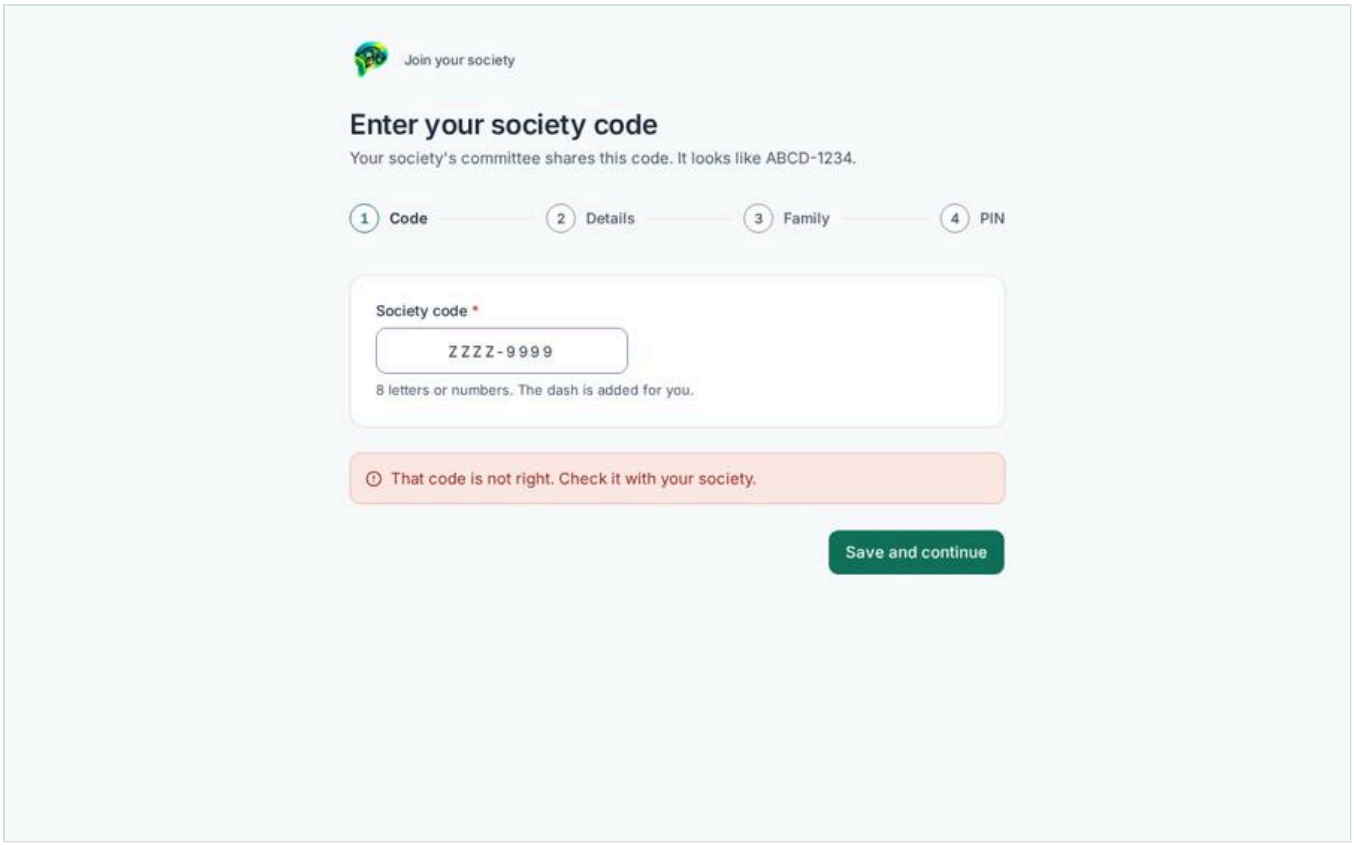


resident-verification-confirmed-1280.png

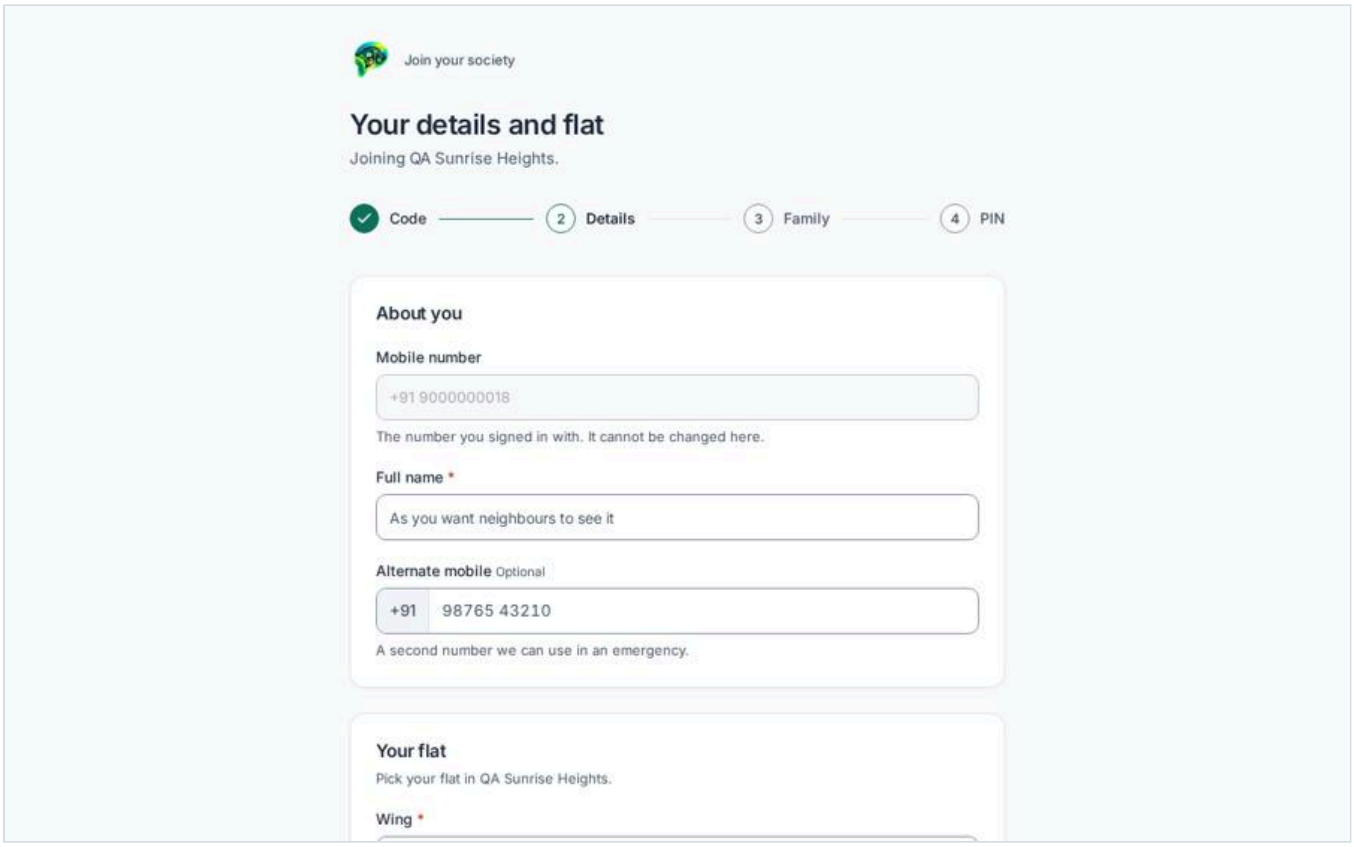
Personal, owner and tenant onboarding



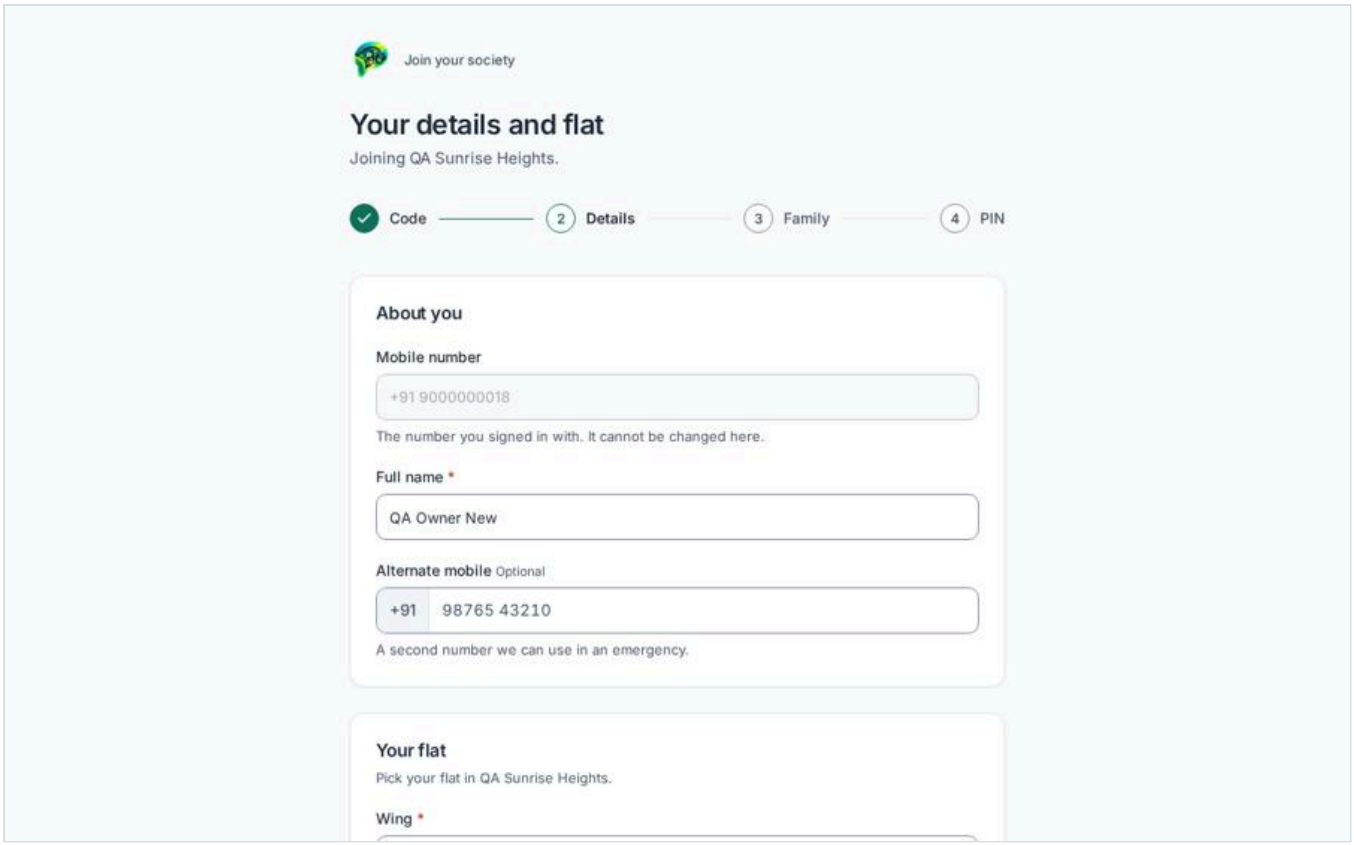
onboarding-code-1280.png



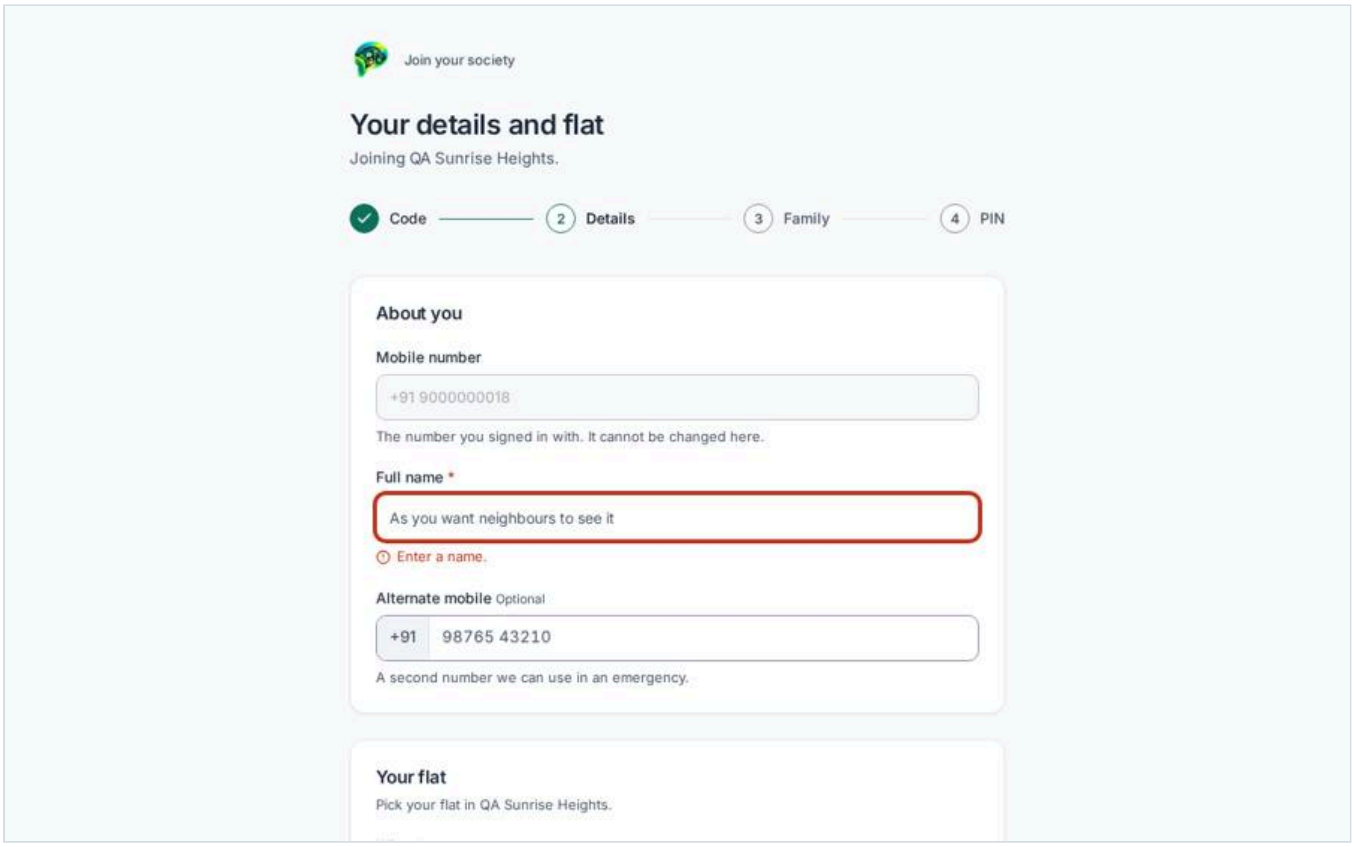
onboarding-code-invalid-1280.png



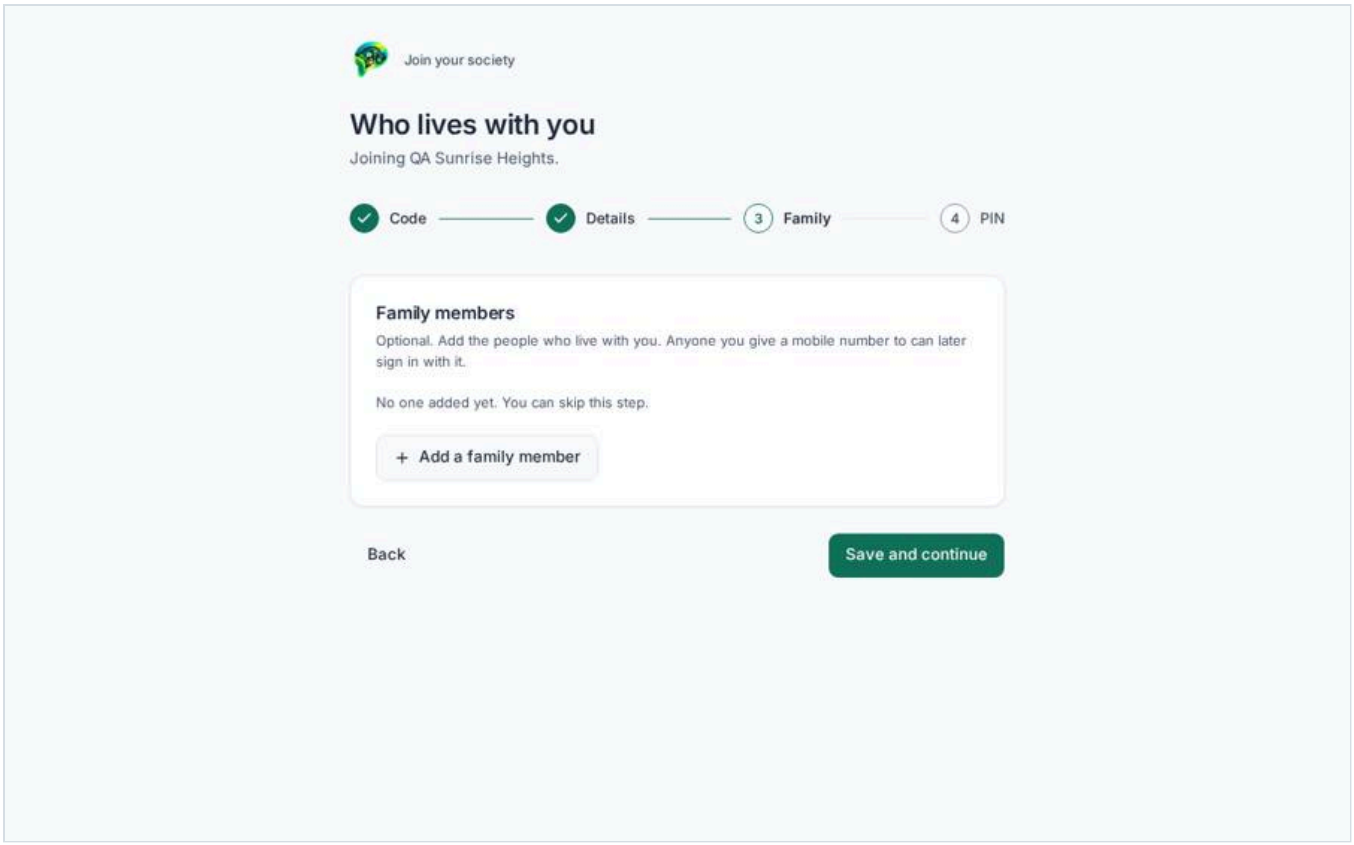
onboarding-details-1280.png



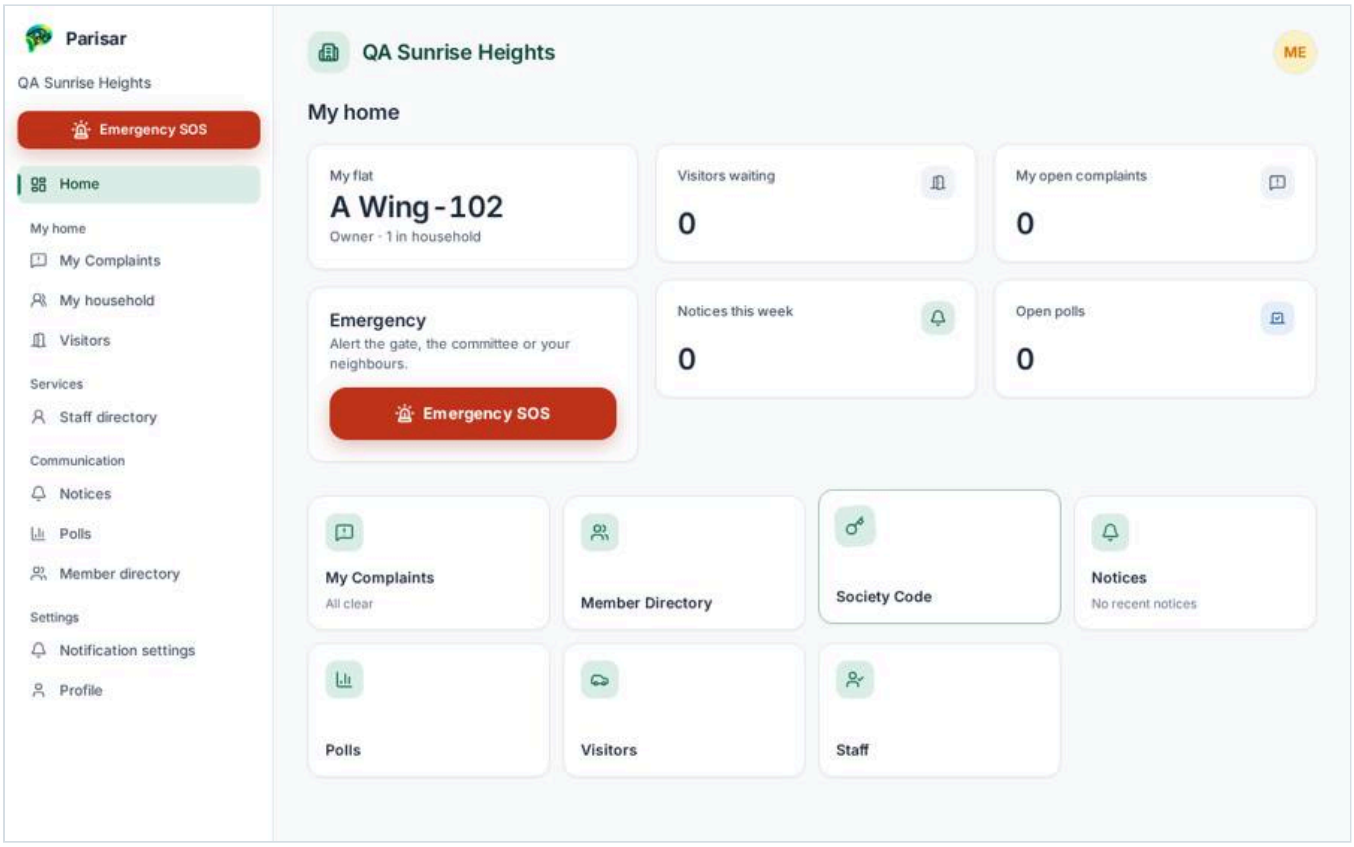
onboarding-details-filled-1280.png



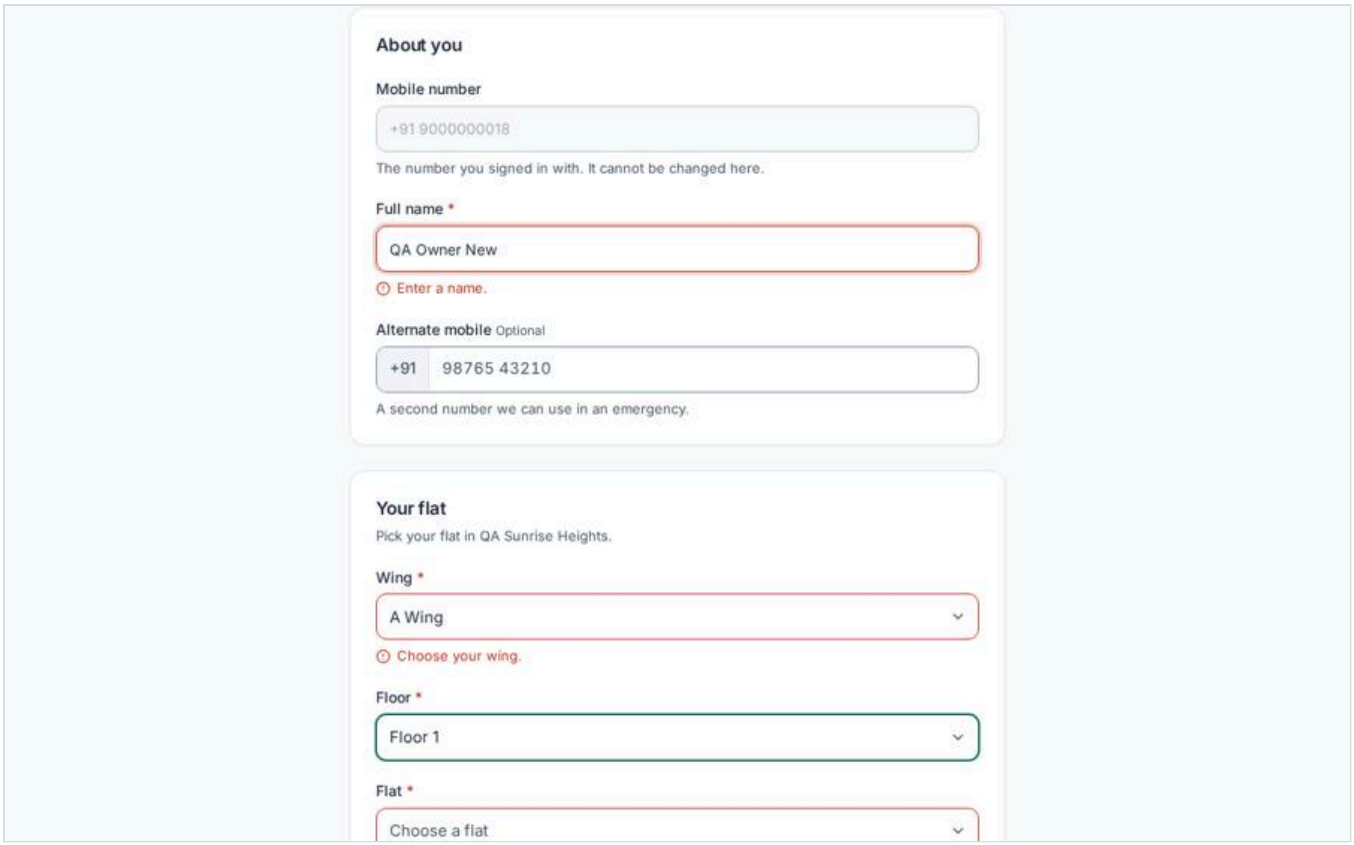
onboarding-details-validation-1280.png



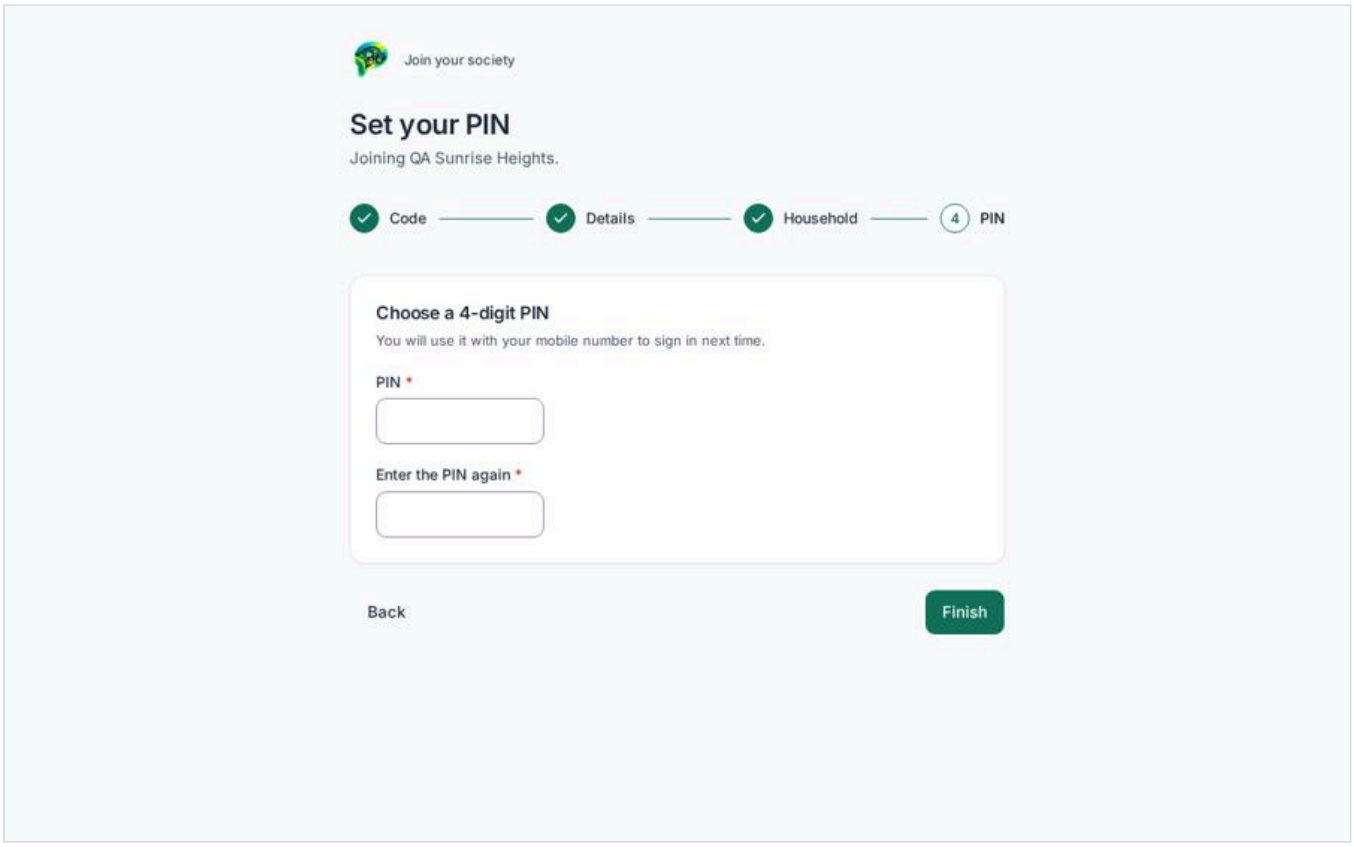
onboarding-family-1280.png



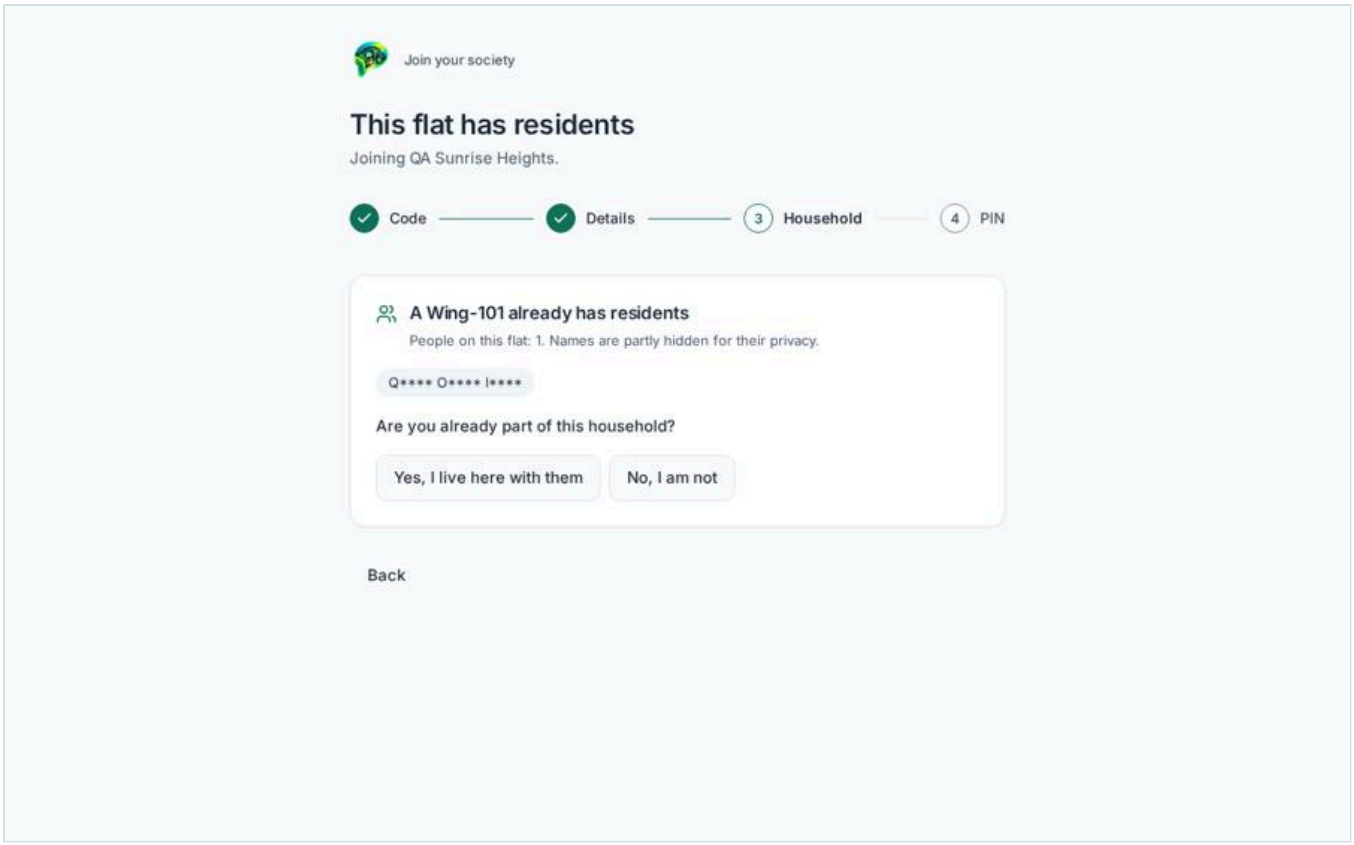
onboarding-finished-1280.png



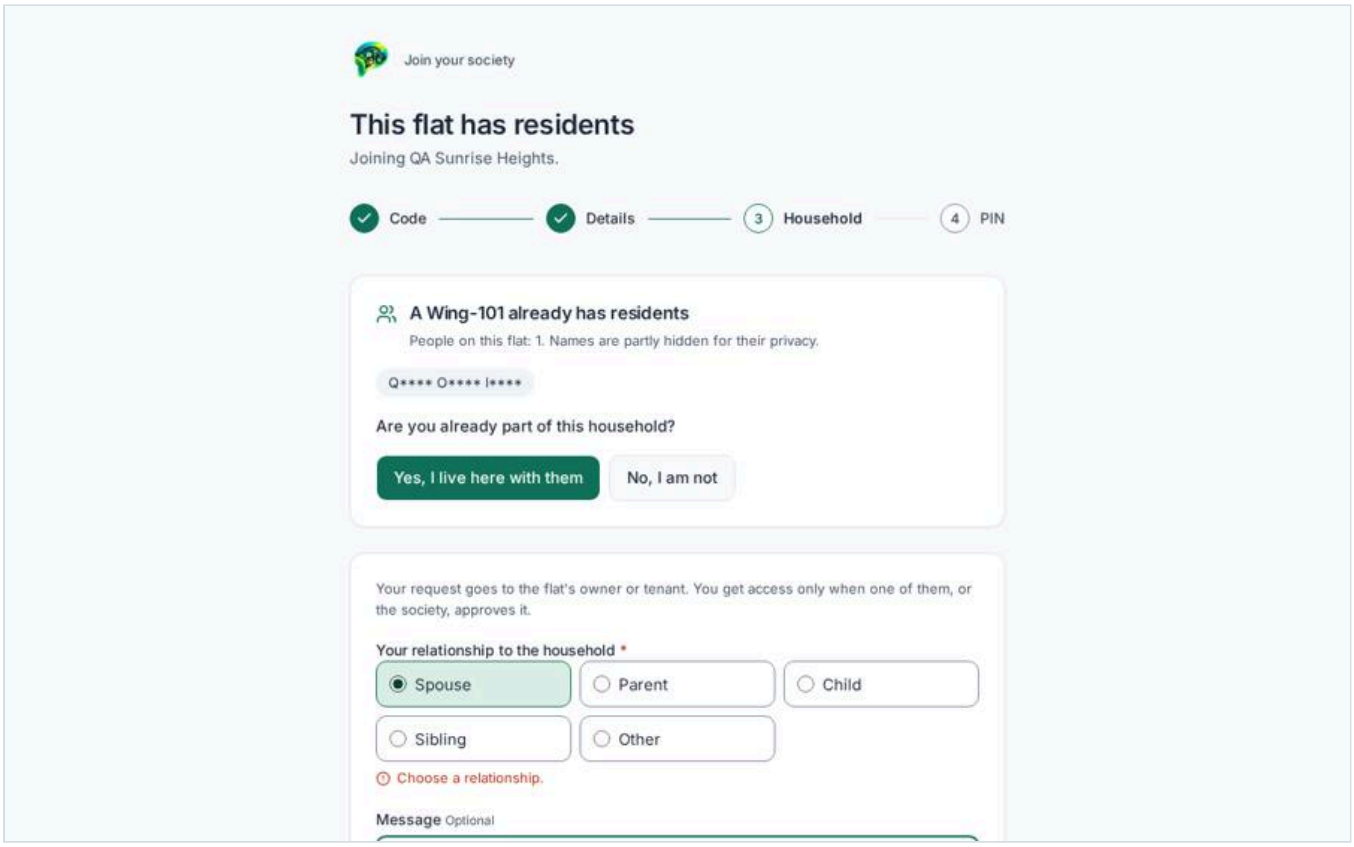
onboarding-flat-picker-1280.png



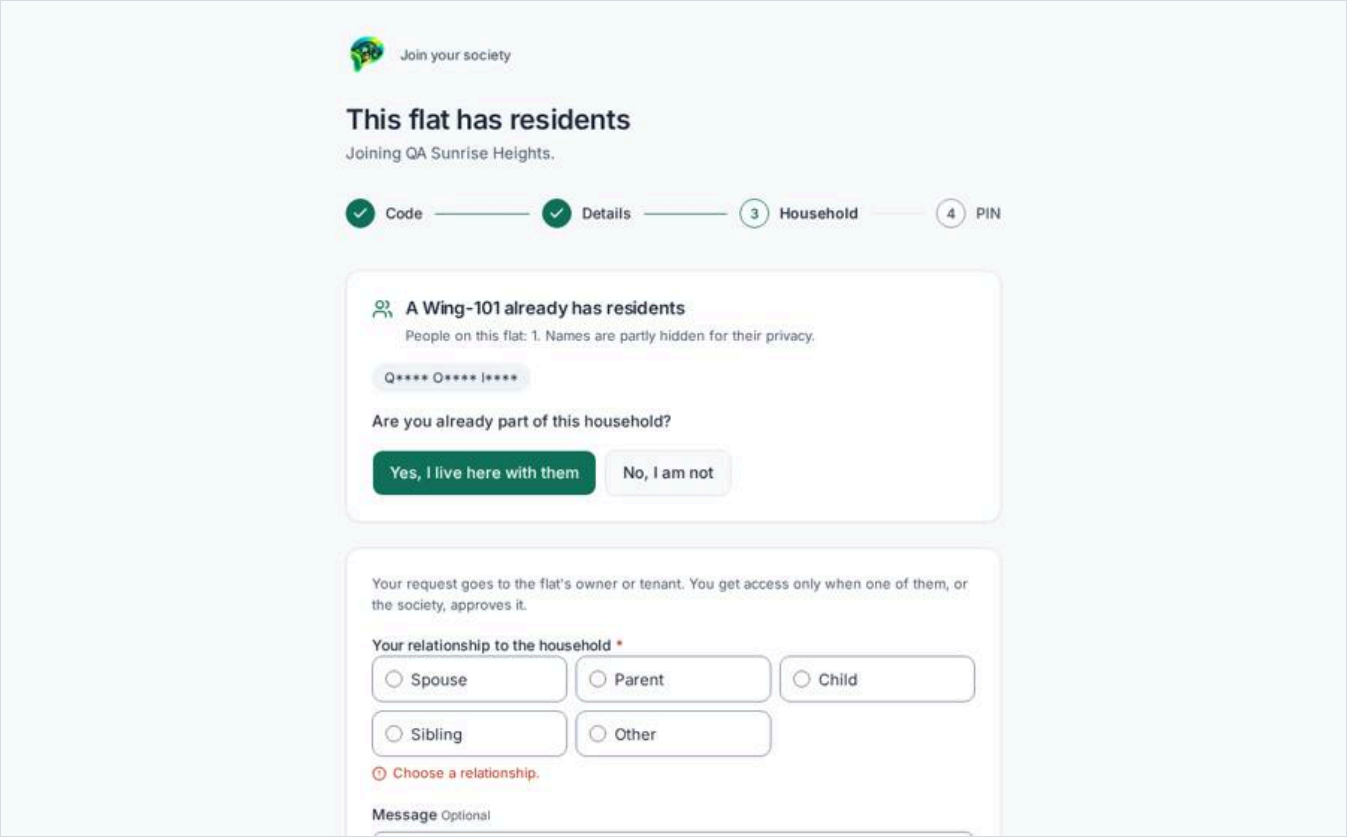
onboarding-household-after-send-1280.png



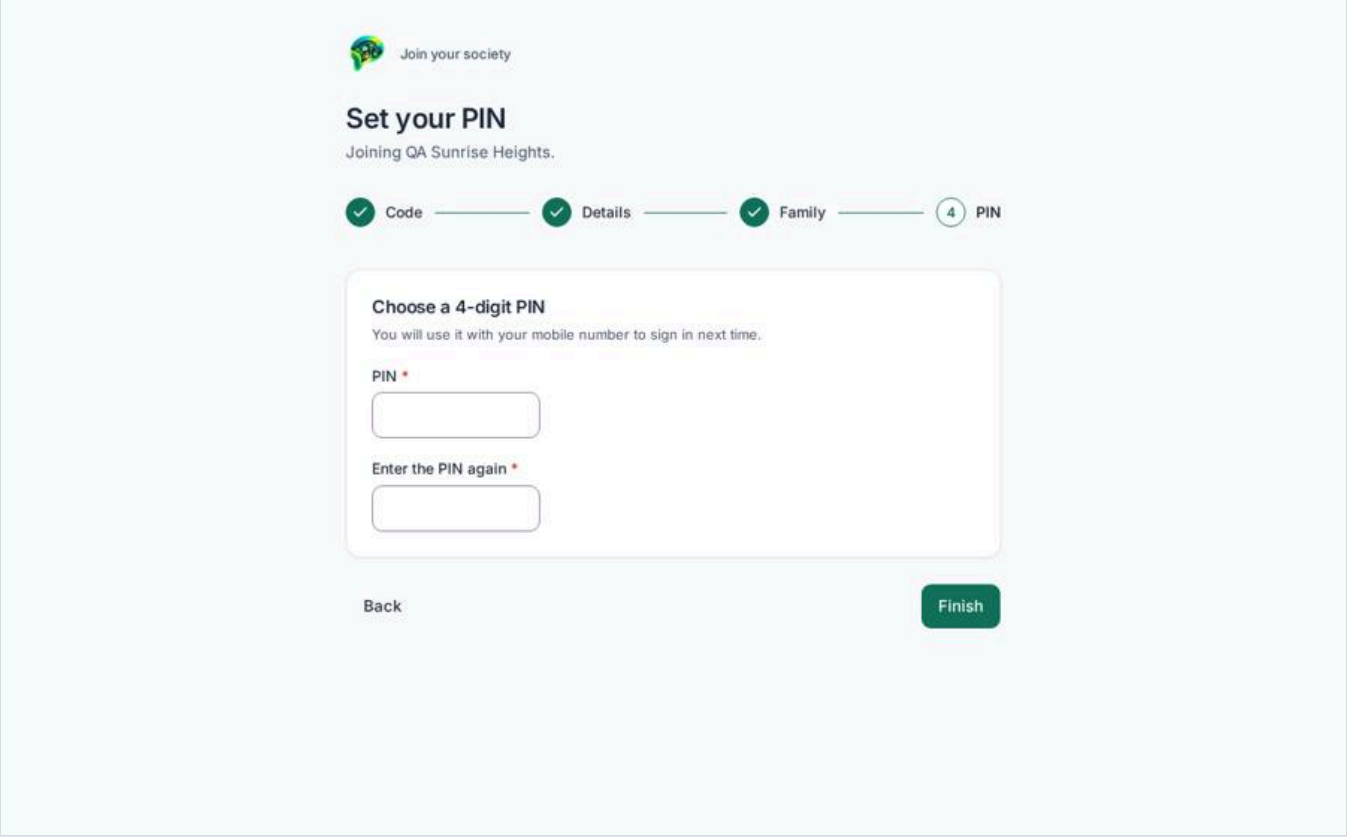
onboarding-household-found-1280.png



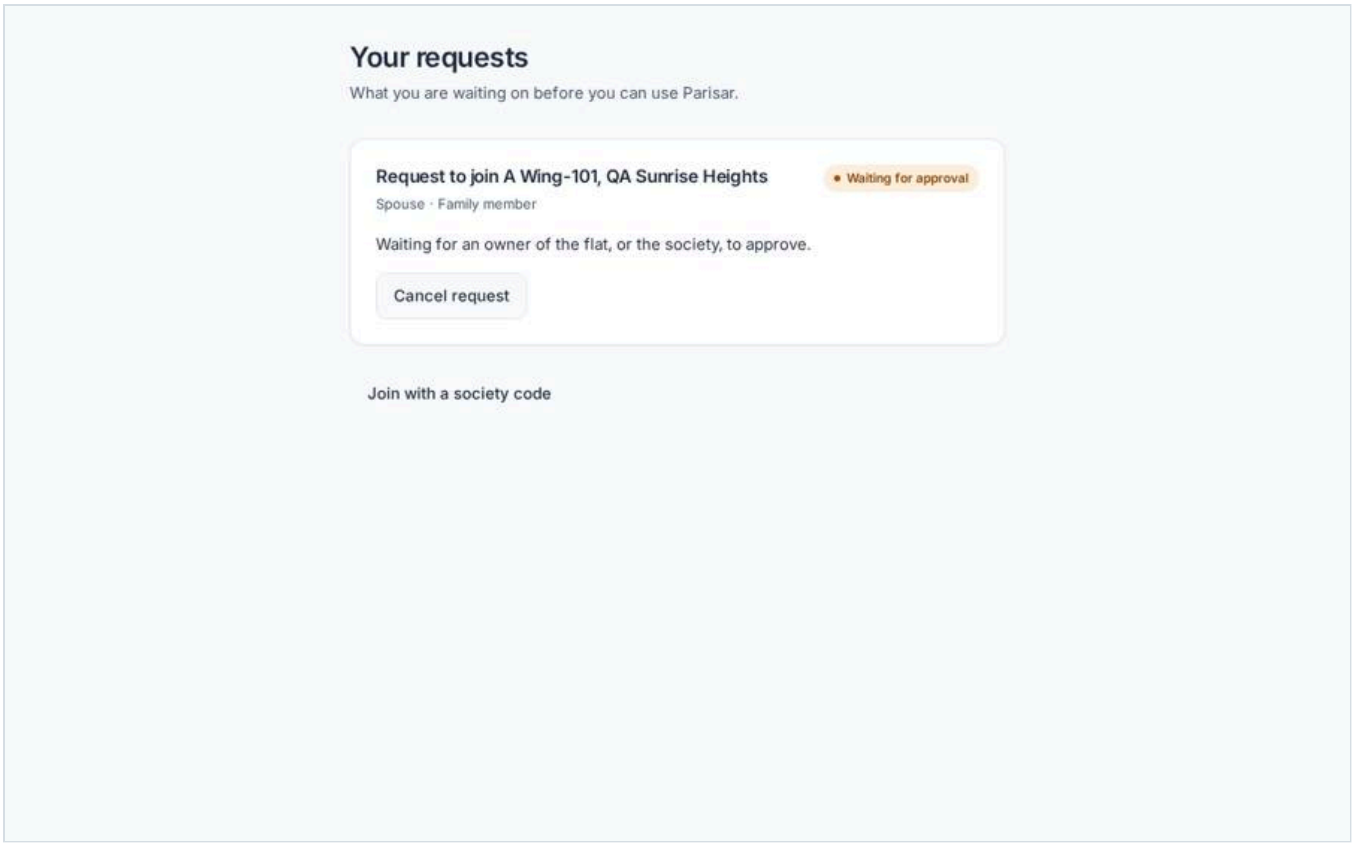
onboarding-household-request-filled-1280.png



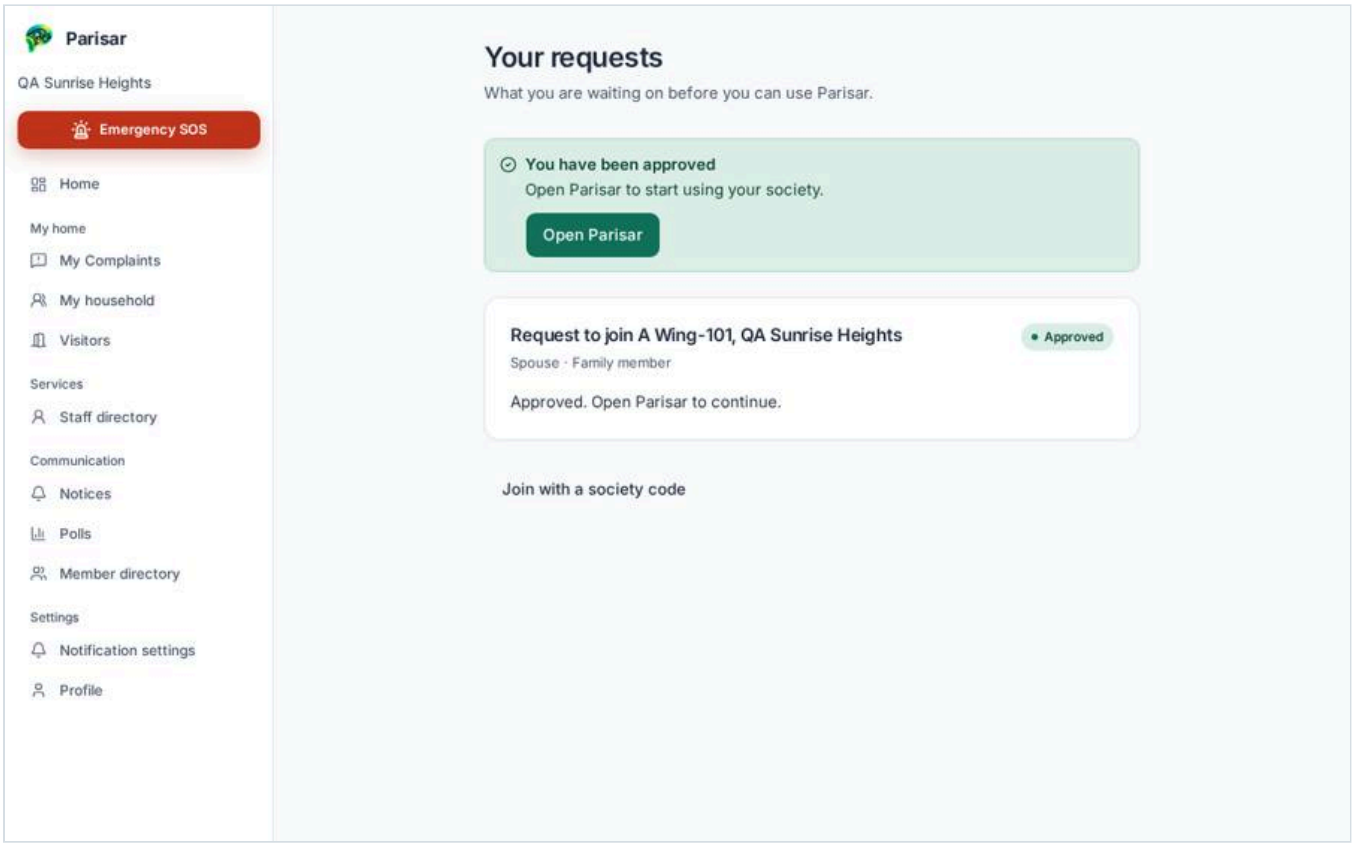
onboarding-household-validation-1280.png



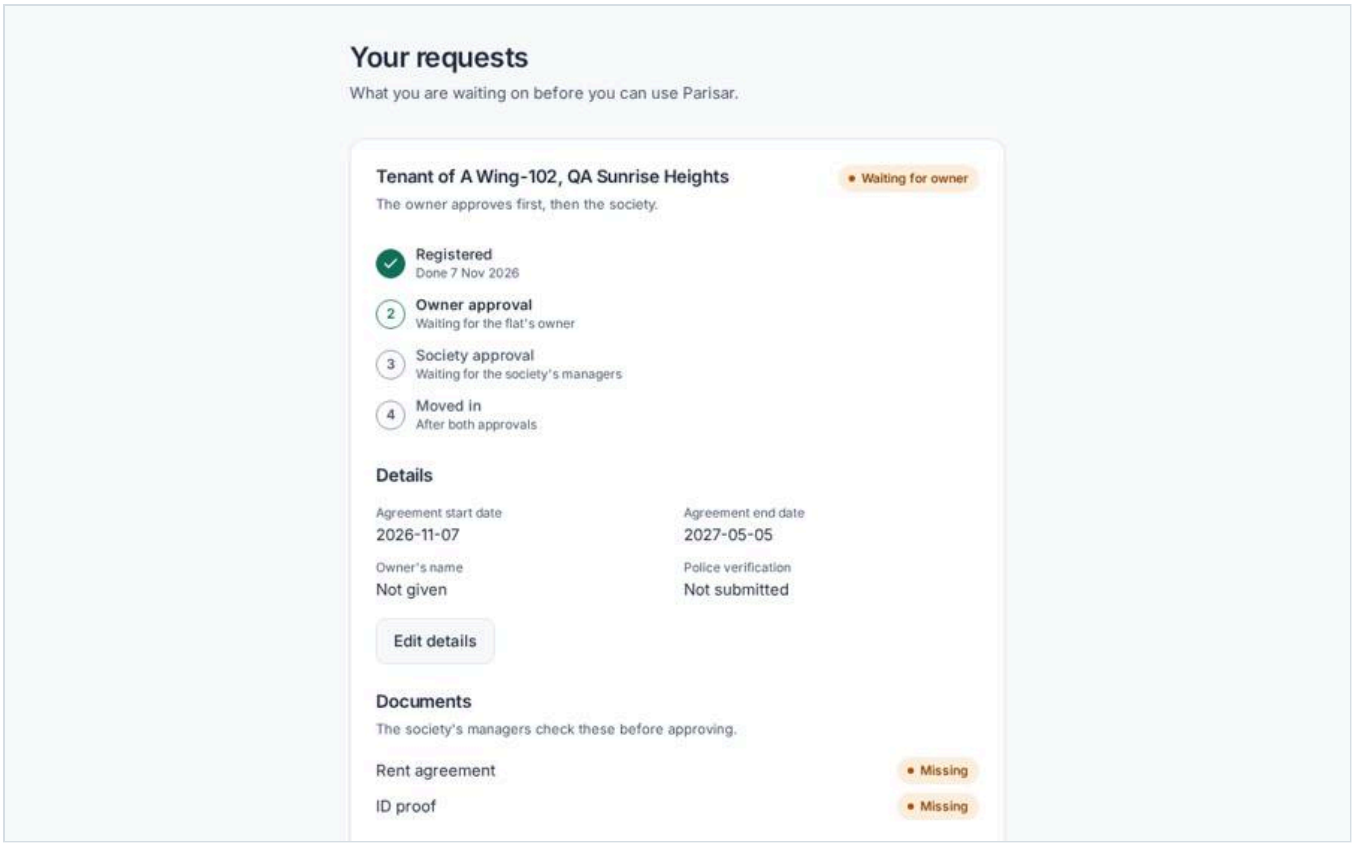
onboarding-pin-1280.png



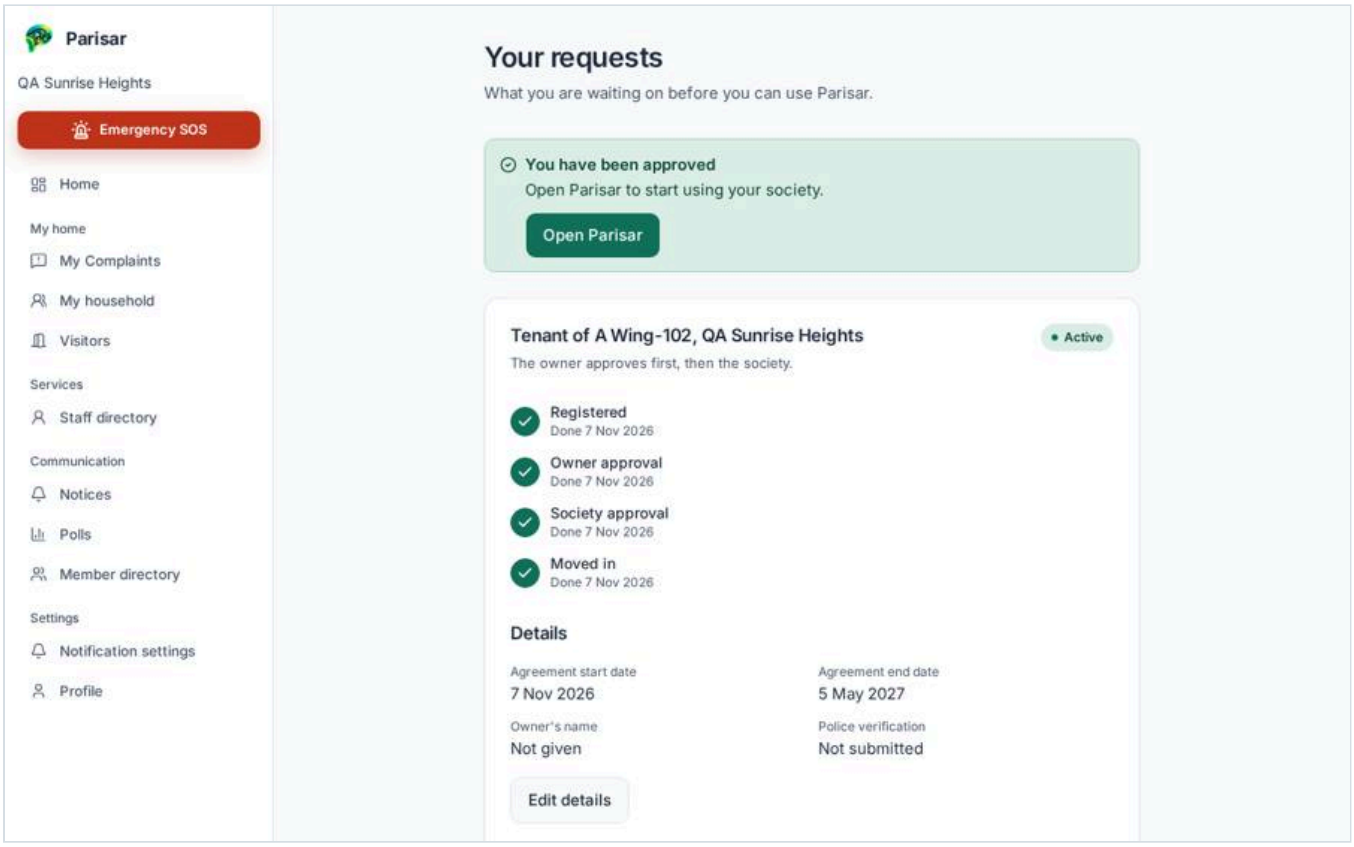
onboarding-status-household-1280.png



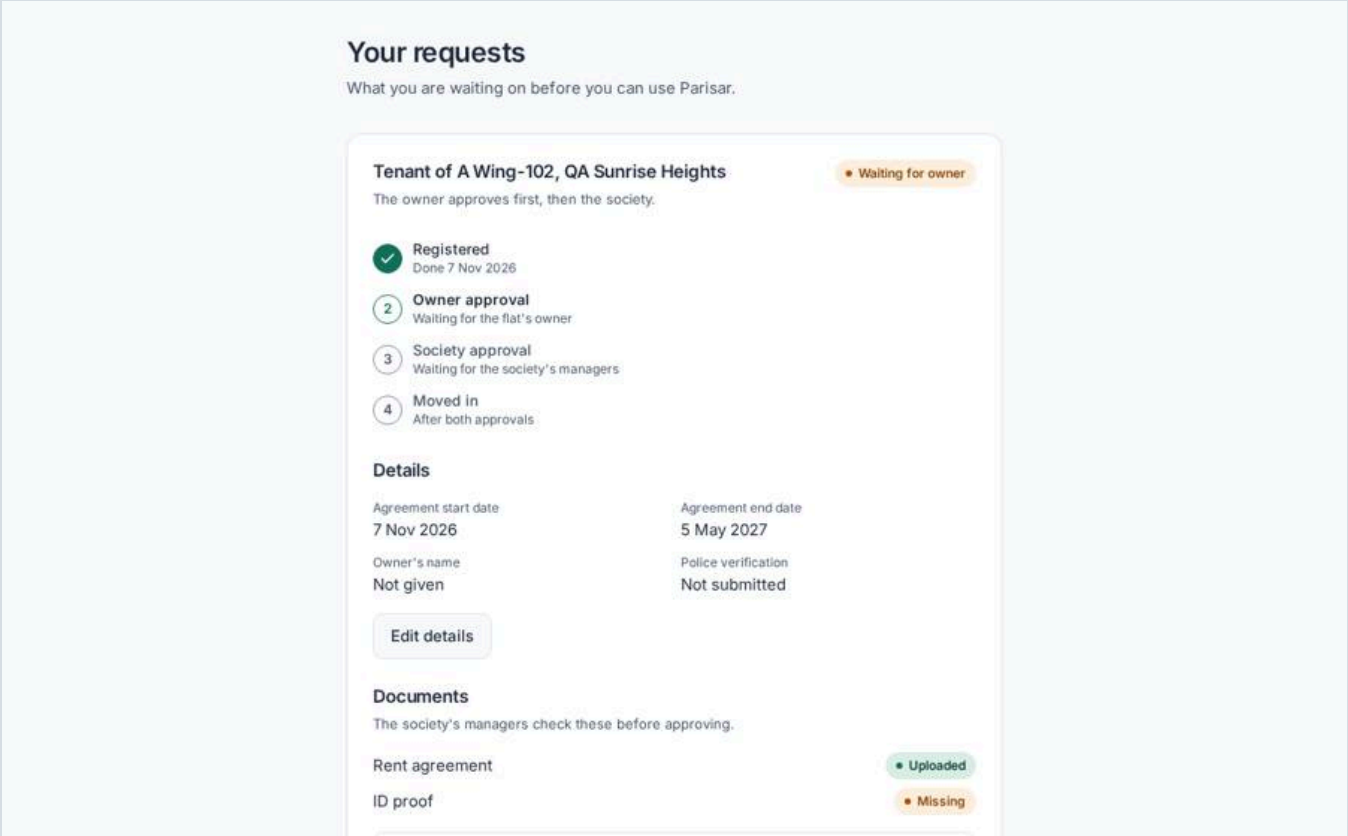
onboarding-status-household-approved-1280.png



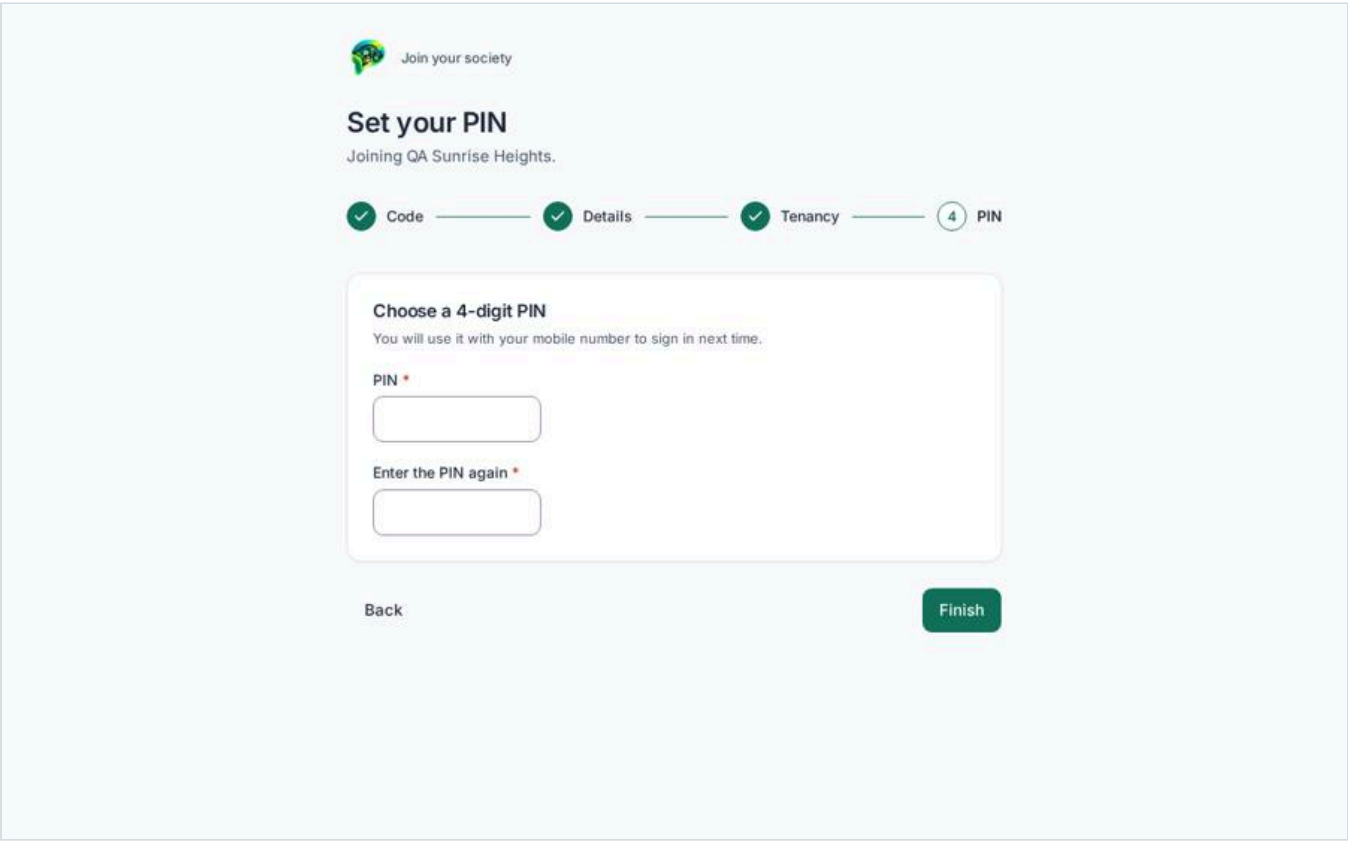
onboarding-status-tenant-1280.png



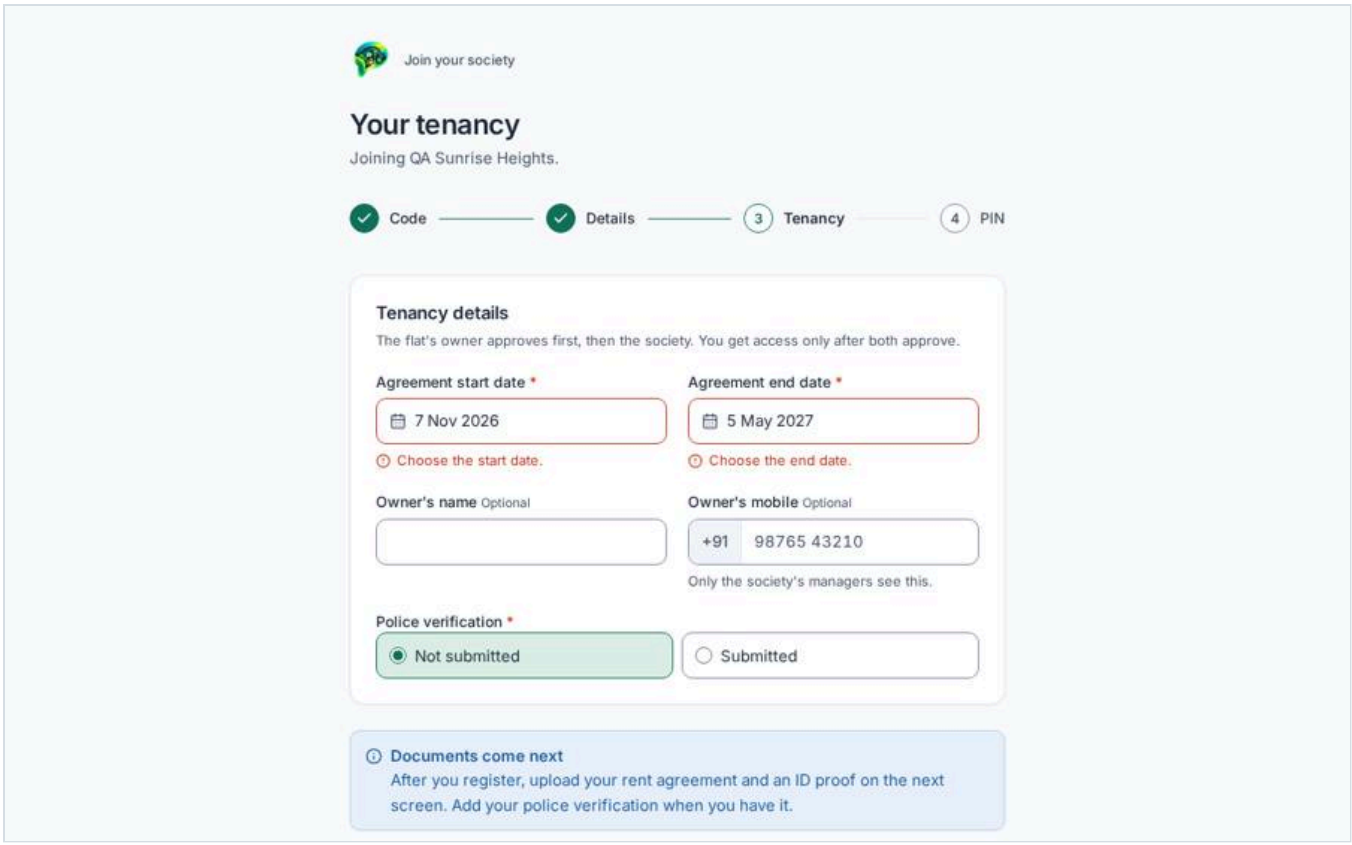
onboarding-status-tenant-approved-1280.png



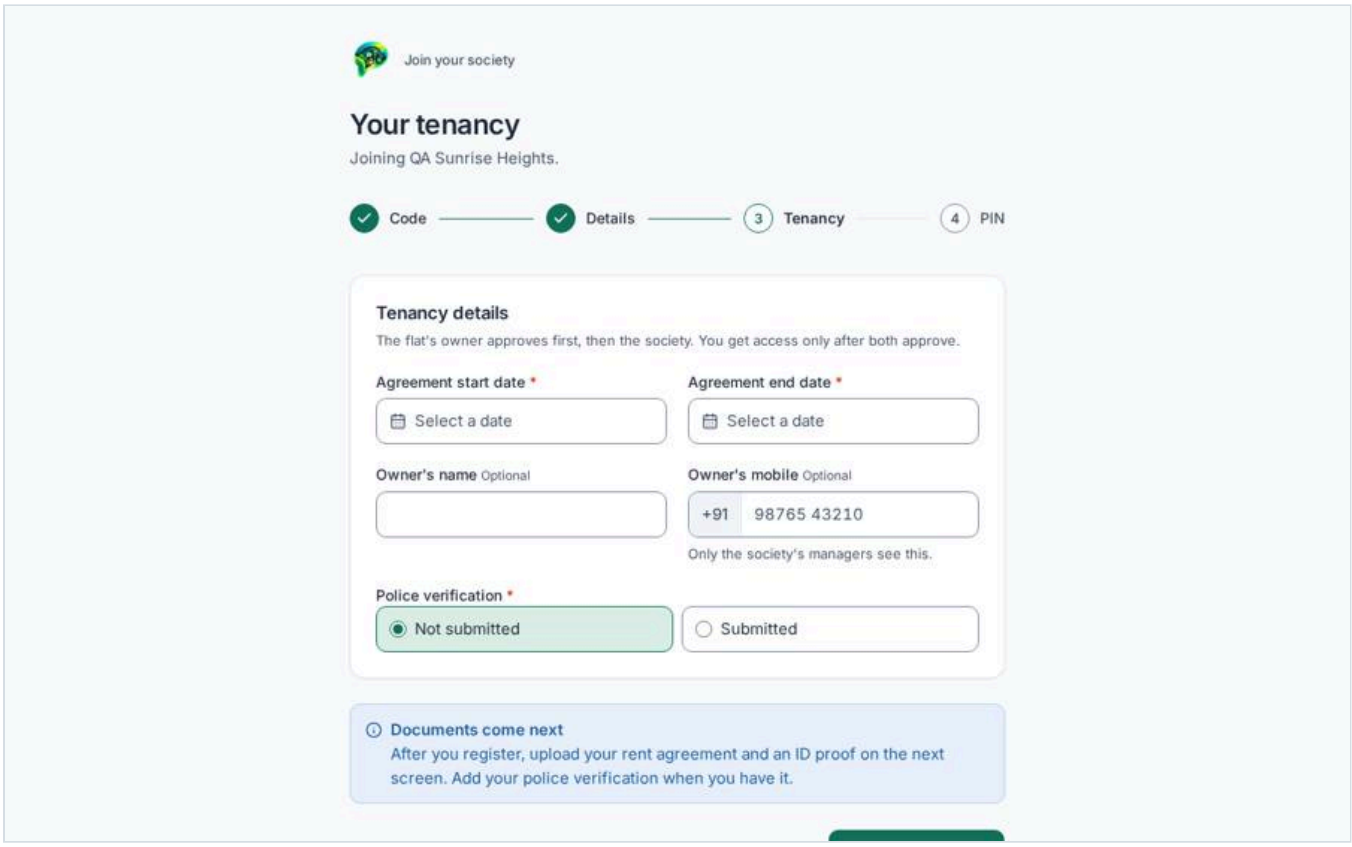
onboarding-status-tenant-doc-1280.png



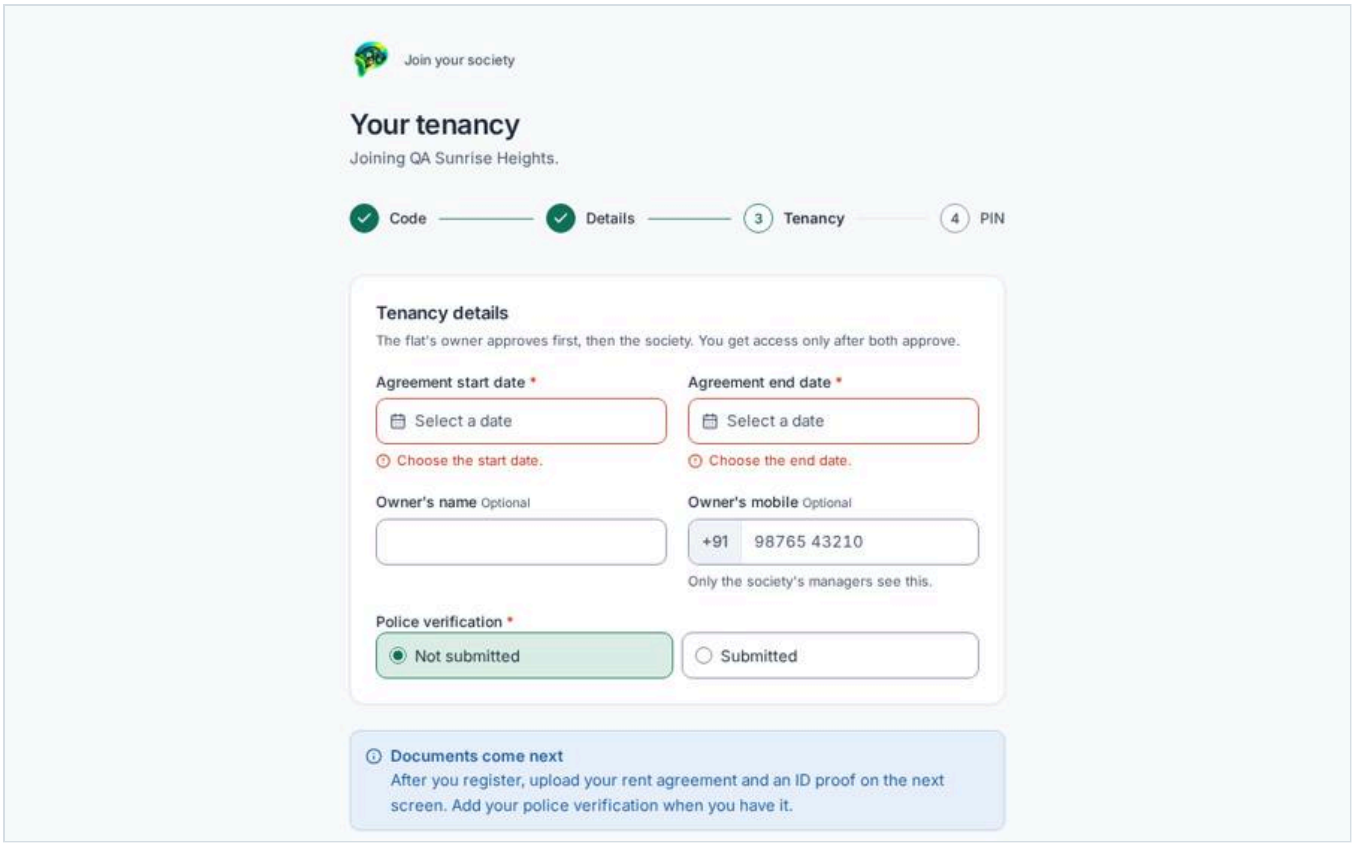
onboarding-tenant-after-register-1280.png



onboarding-tenant-filled-1280.png

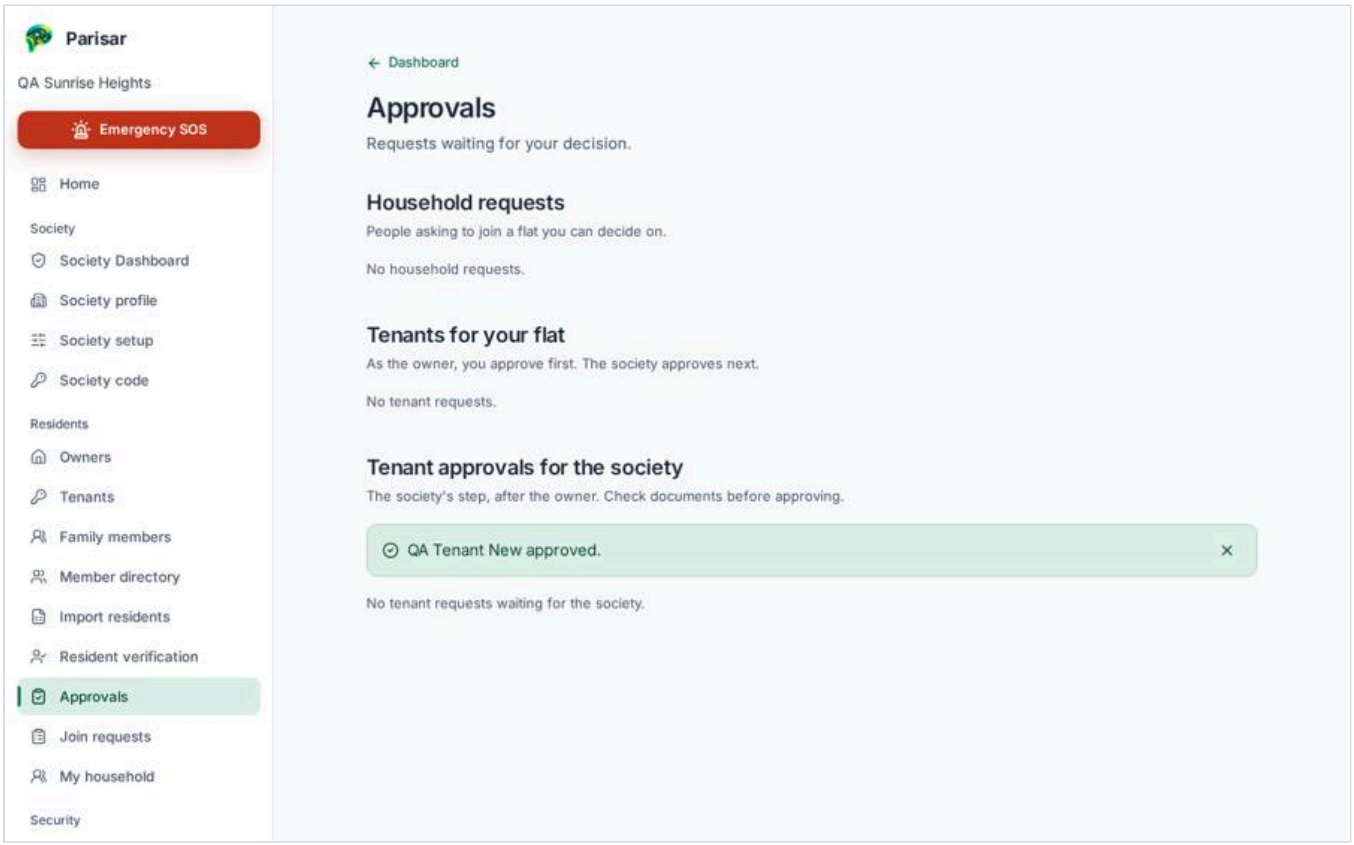


onboarding-tenant-step-1280.png

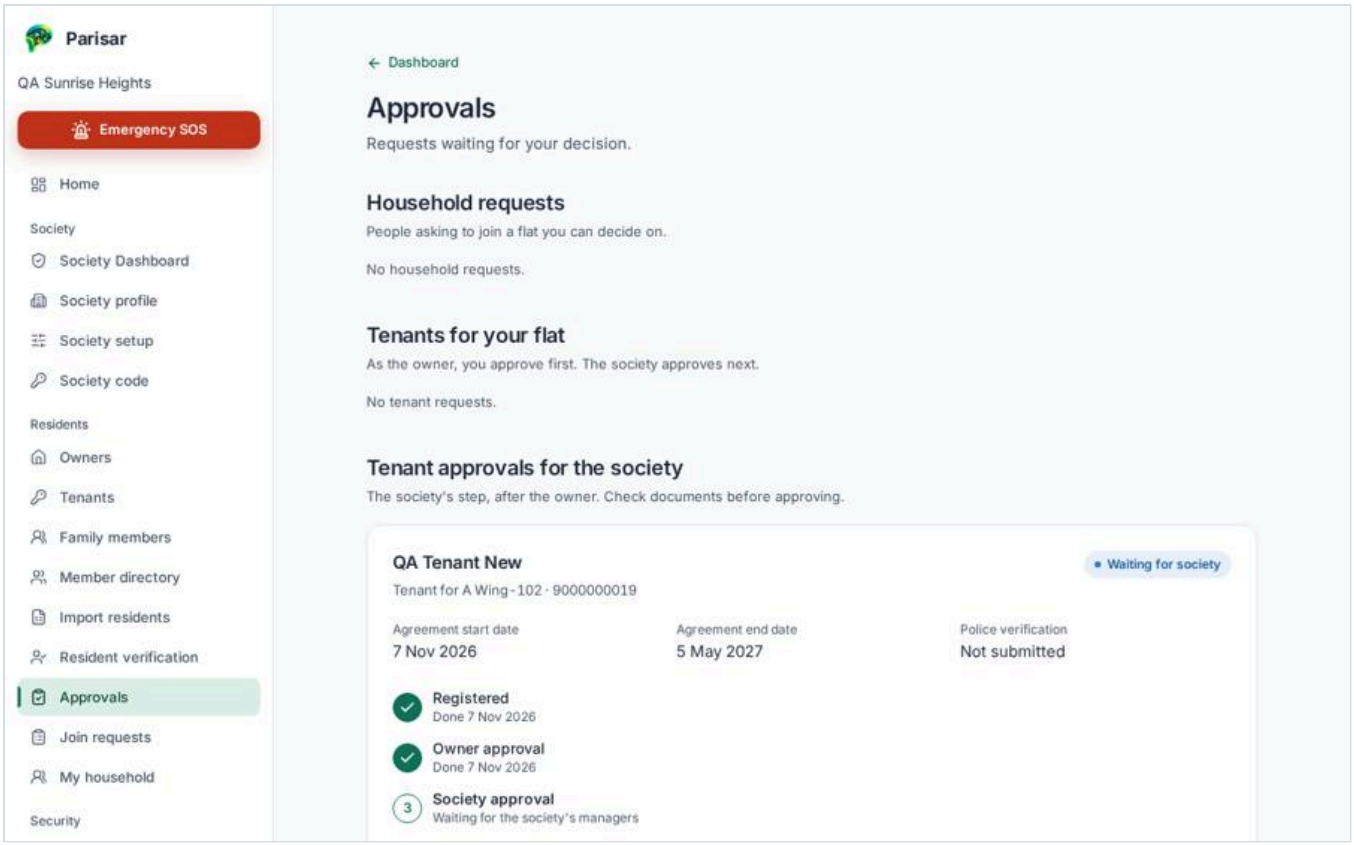


onboarding-tenant-validation-1280.png

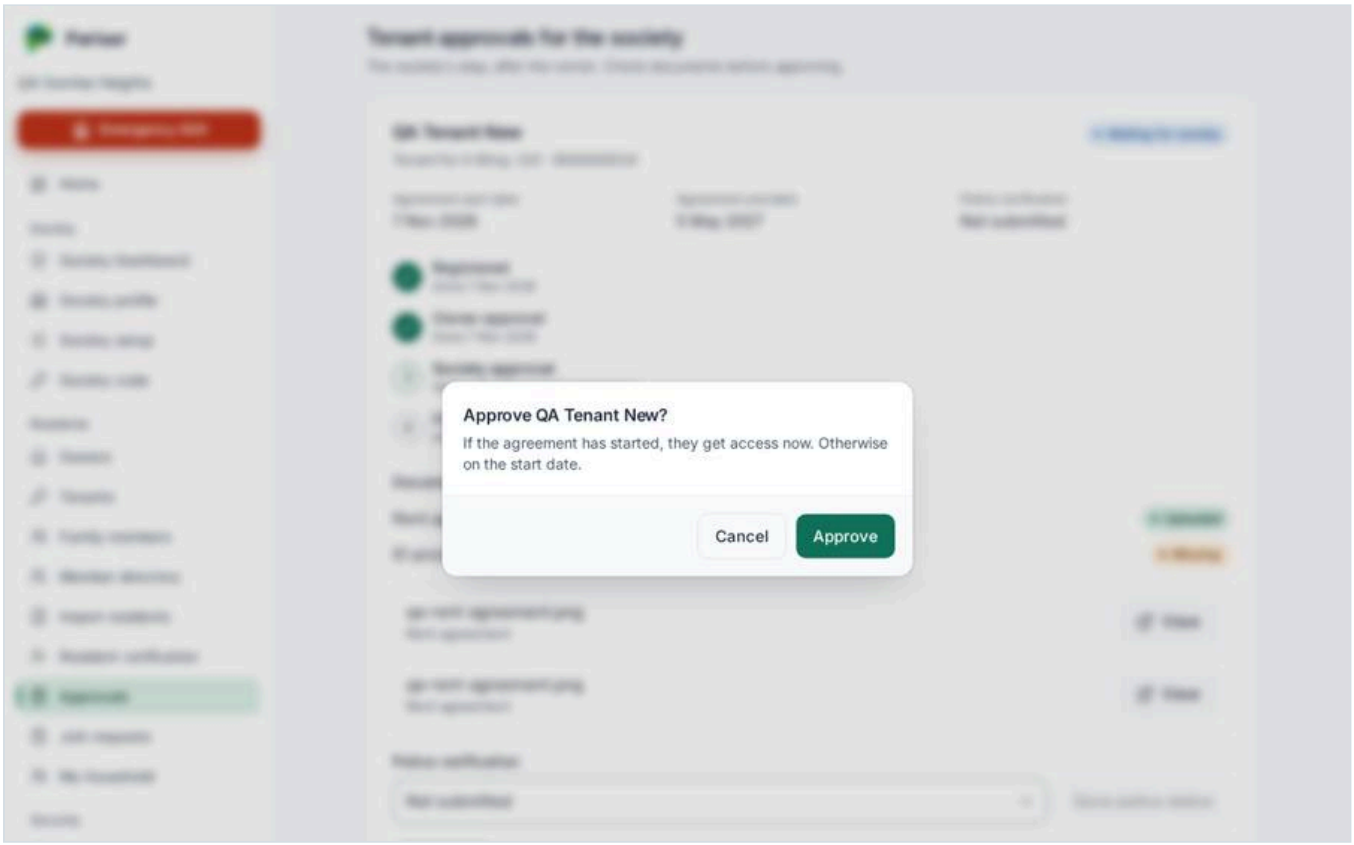
Approvals



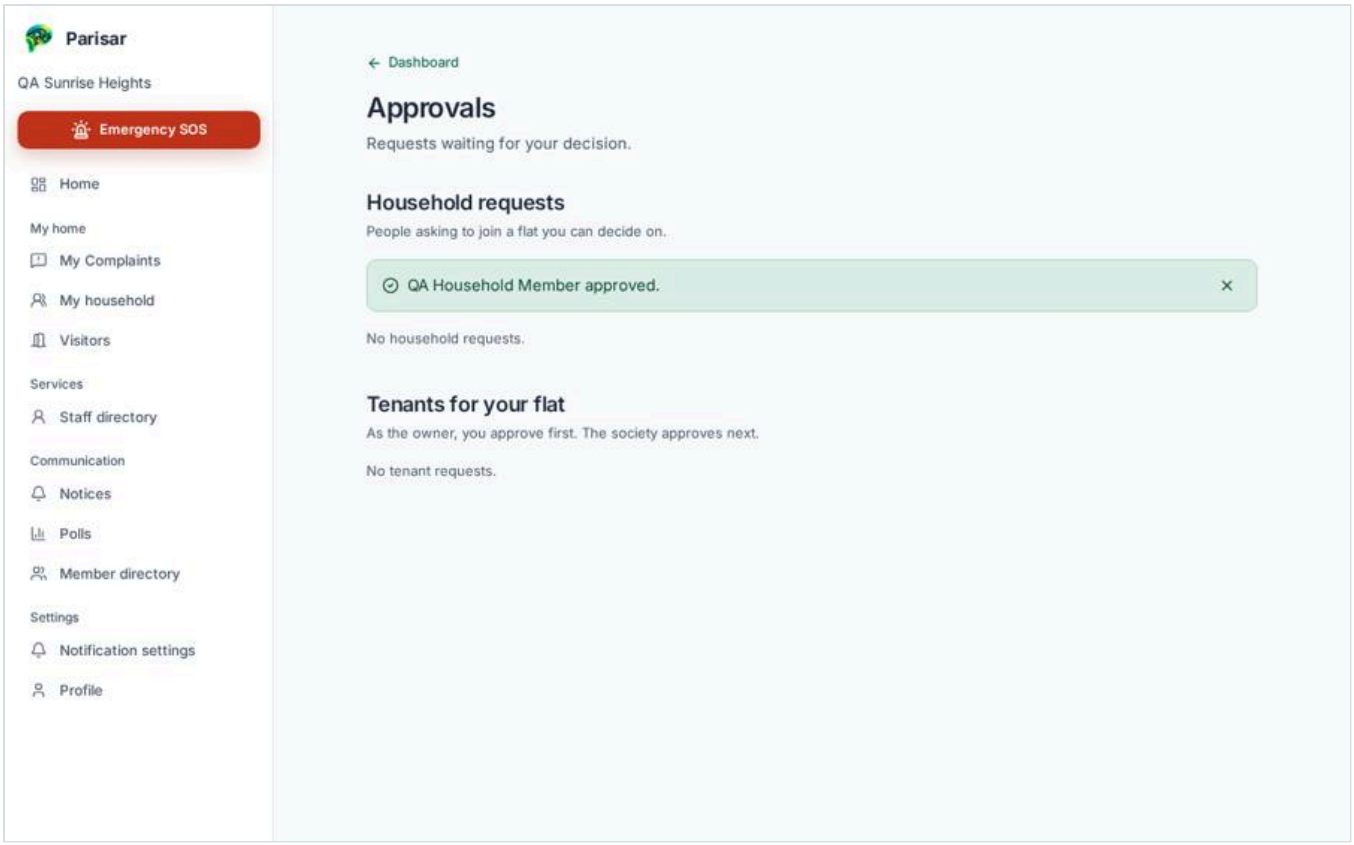
approvals-authority-after-1280.png



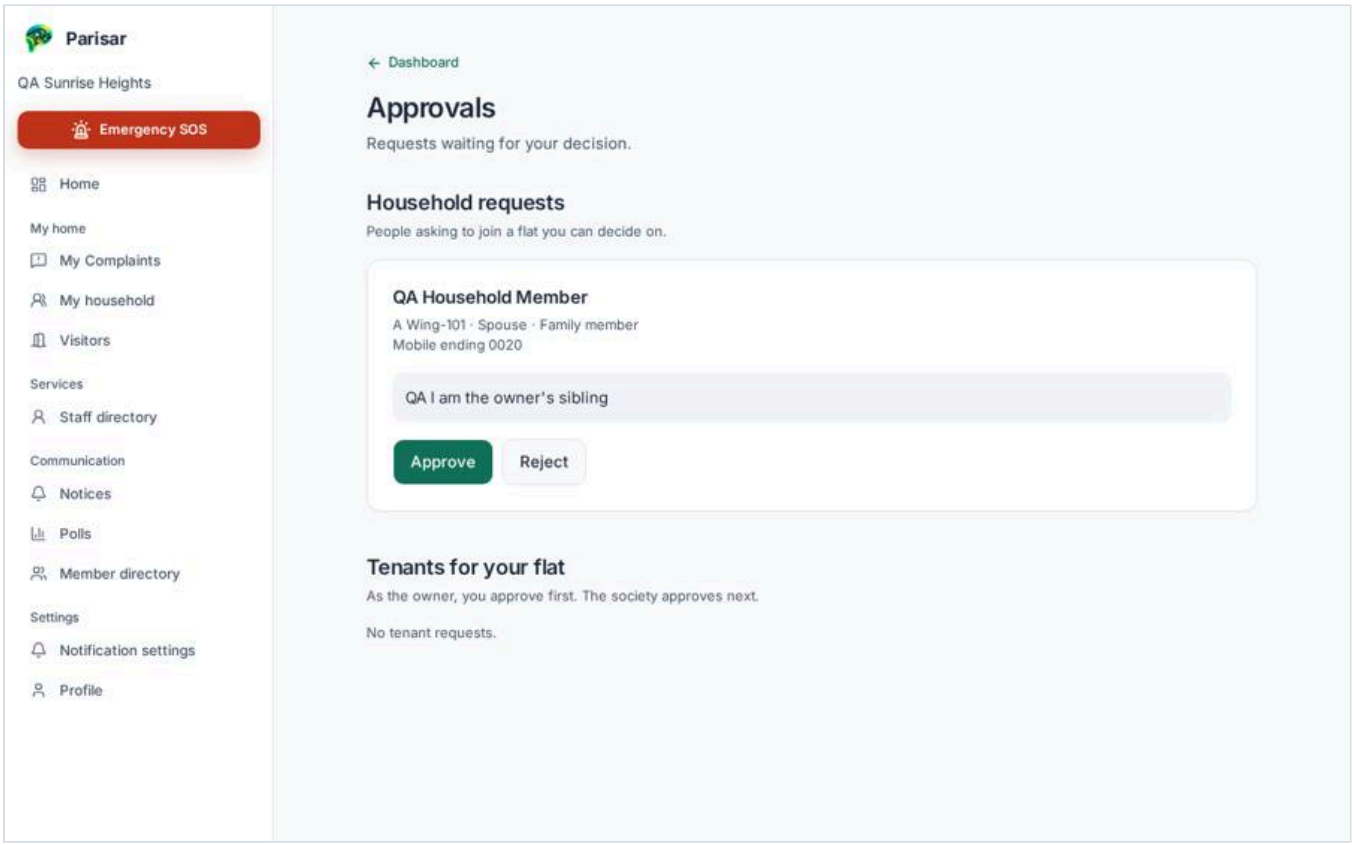
approvals-authority-before-1280.png



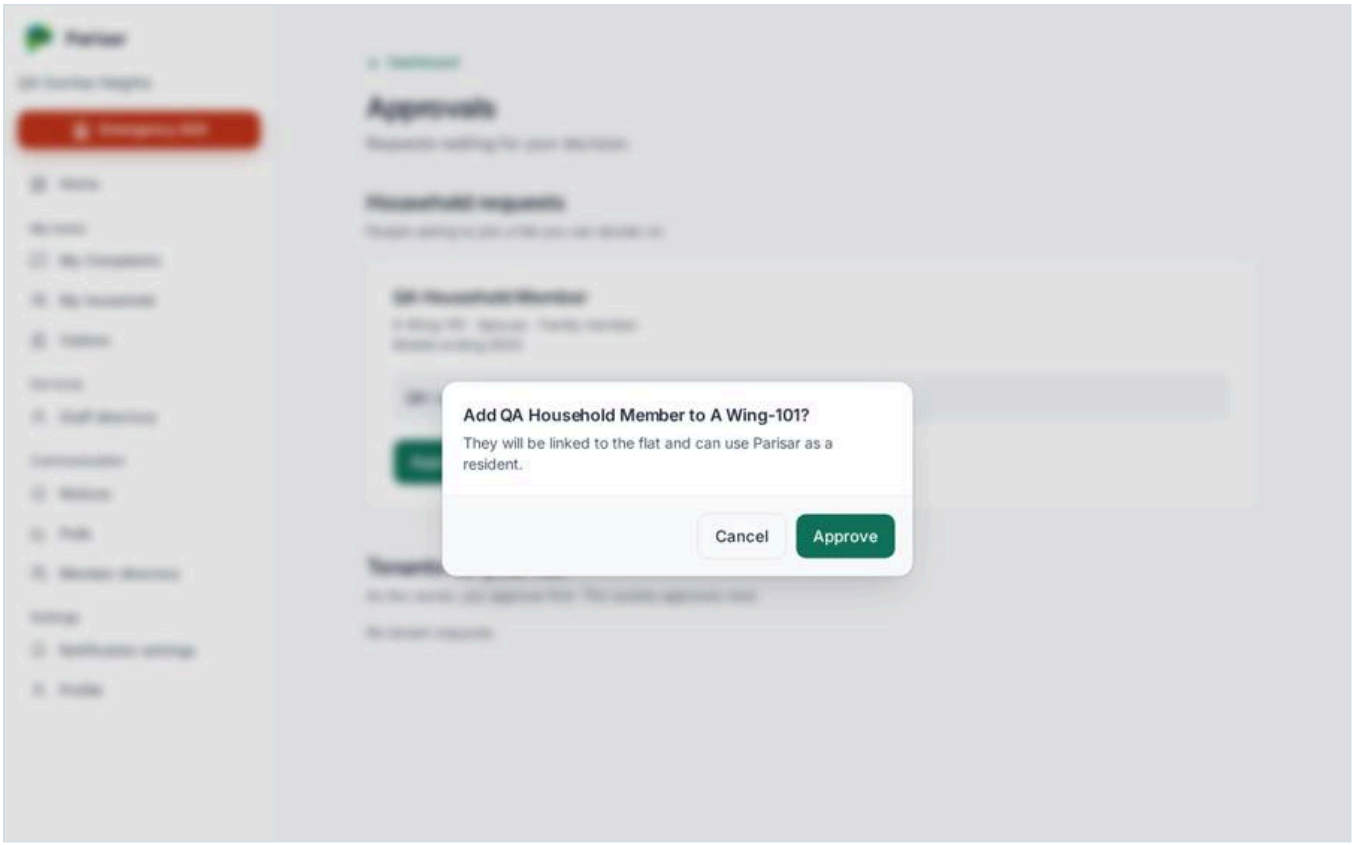
approvals-authority-confirm-1280.png



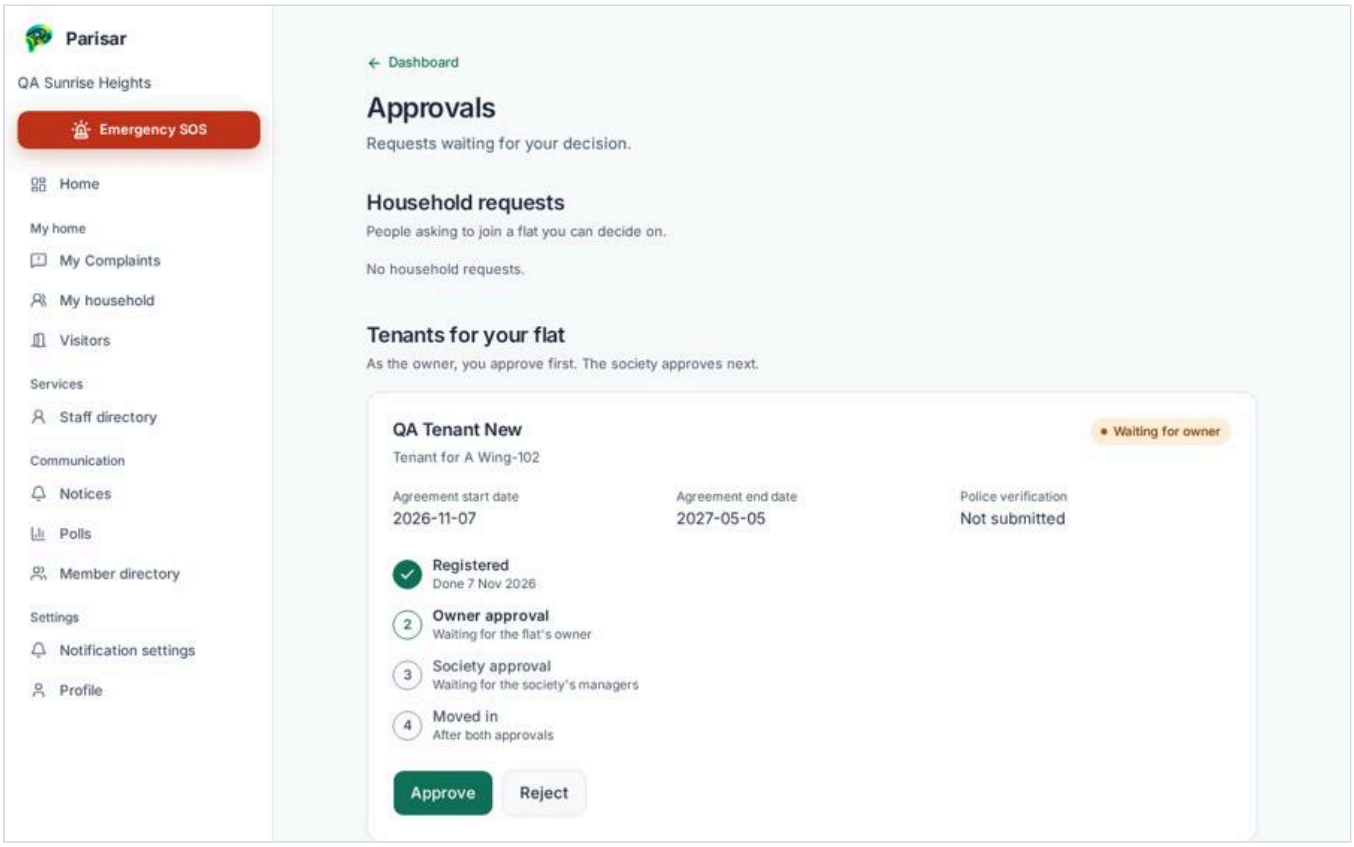
approvals-household-owner-after-1280.png



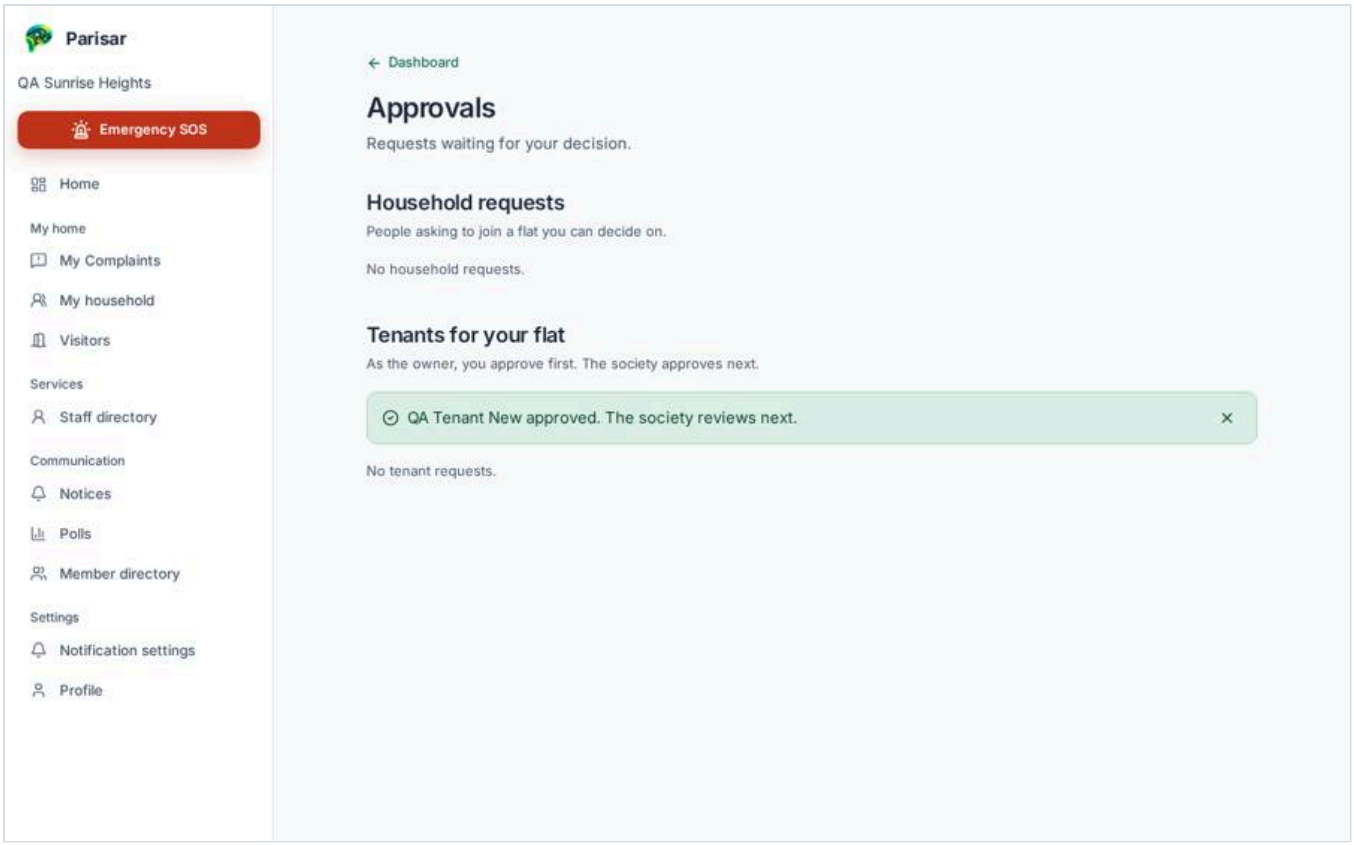
approvals-household-owner-before-1280.png



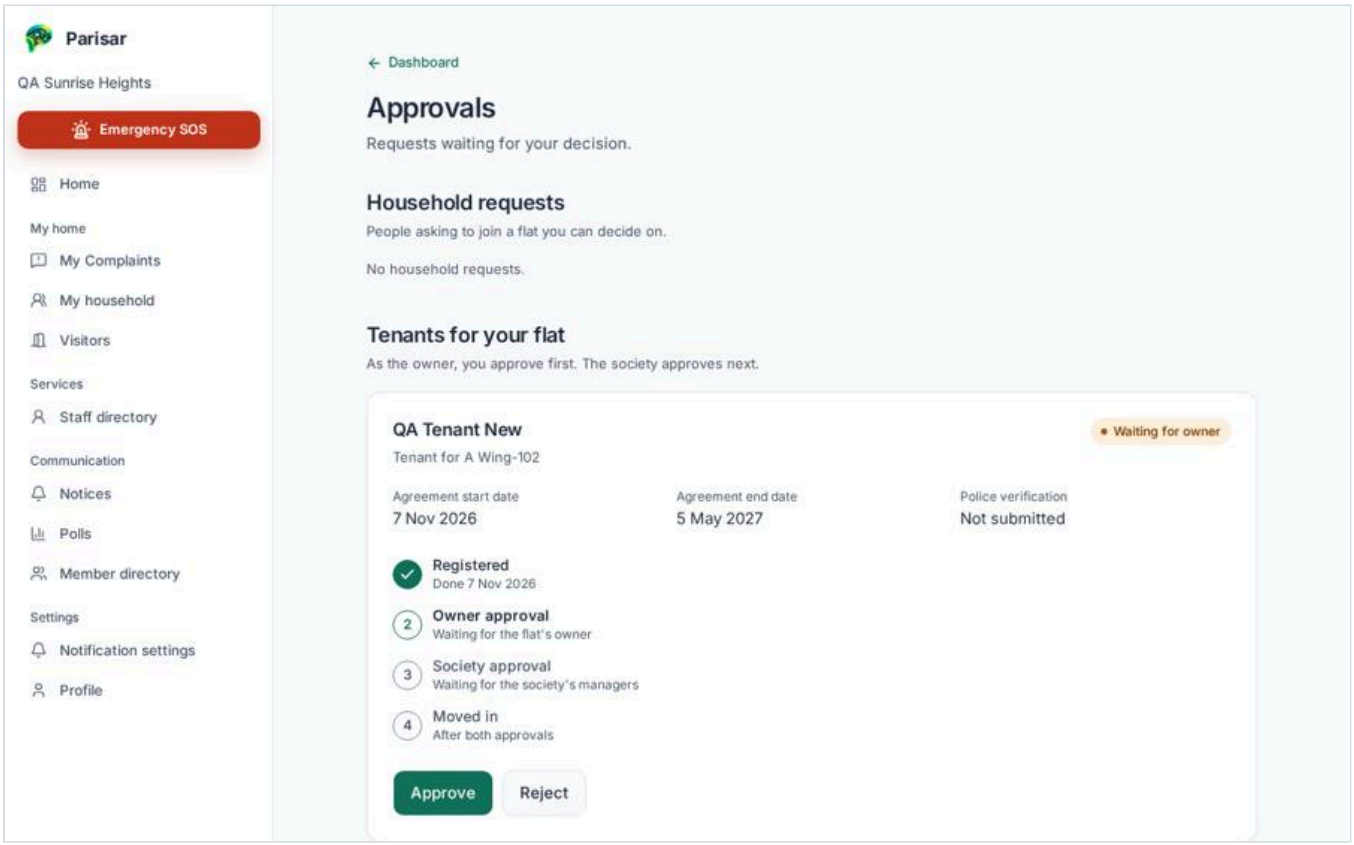
approvals-household-owner-confirm-1280.png



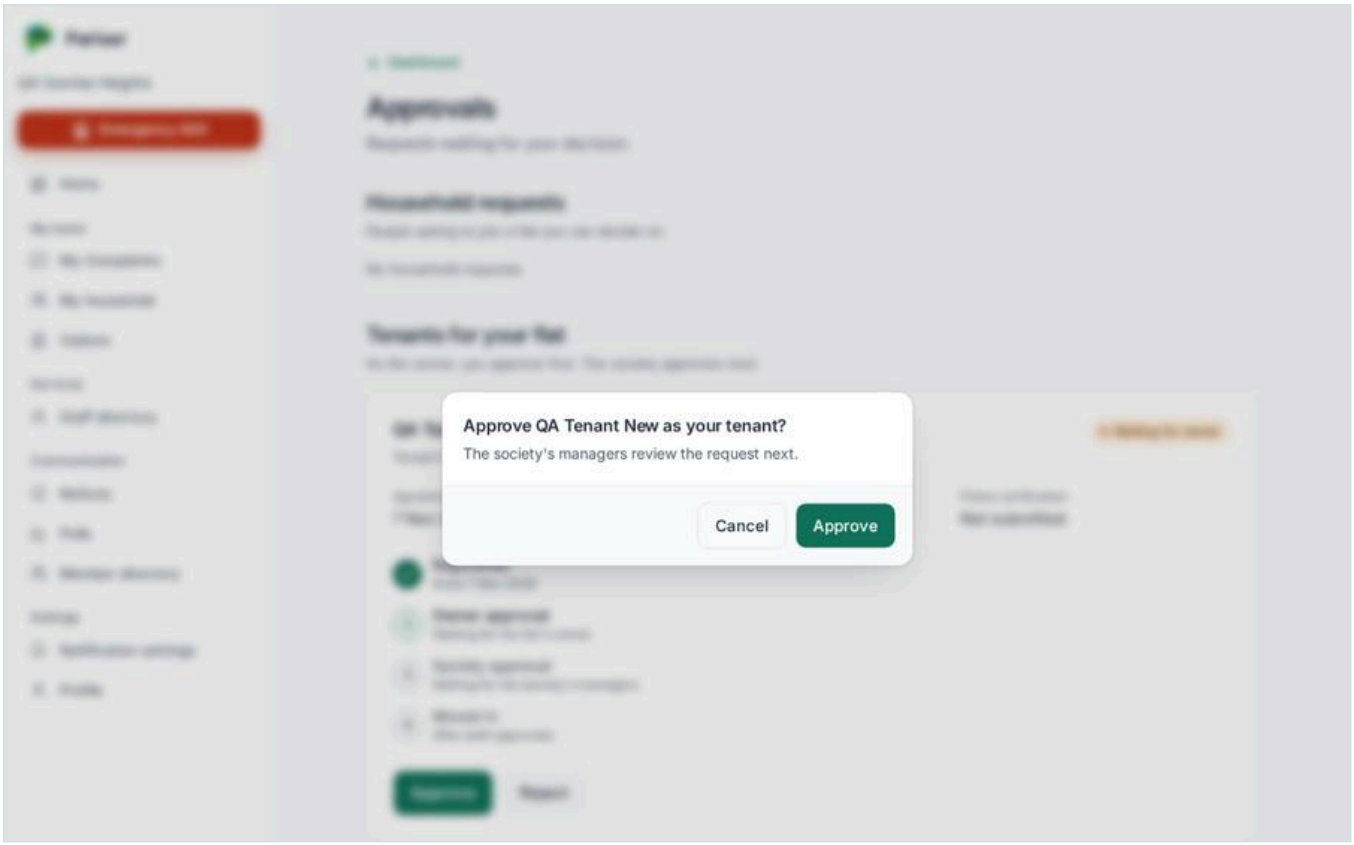
approvals-owner-1280.png



approvals-owner-after-1280.png

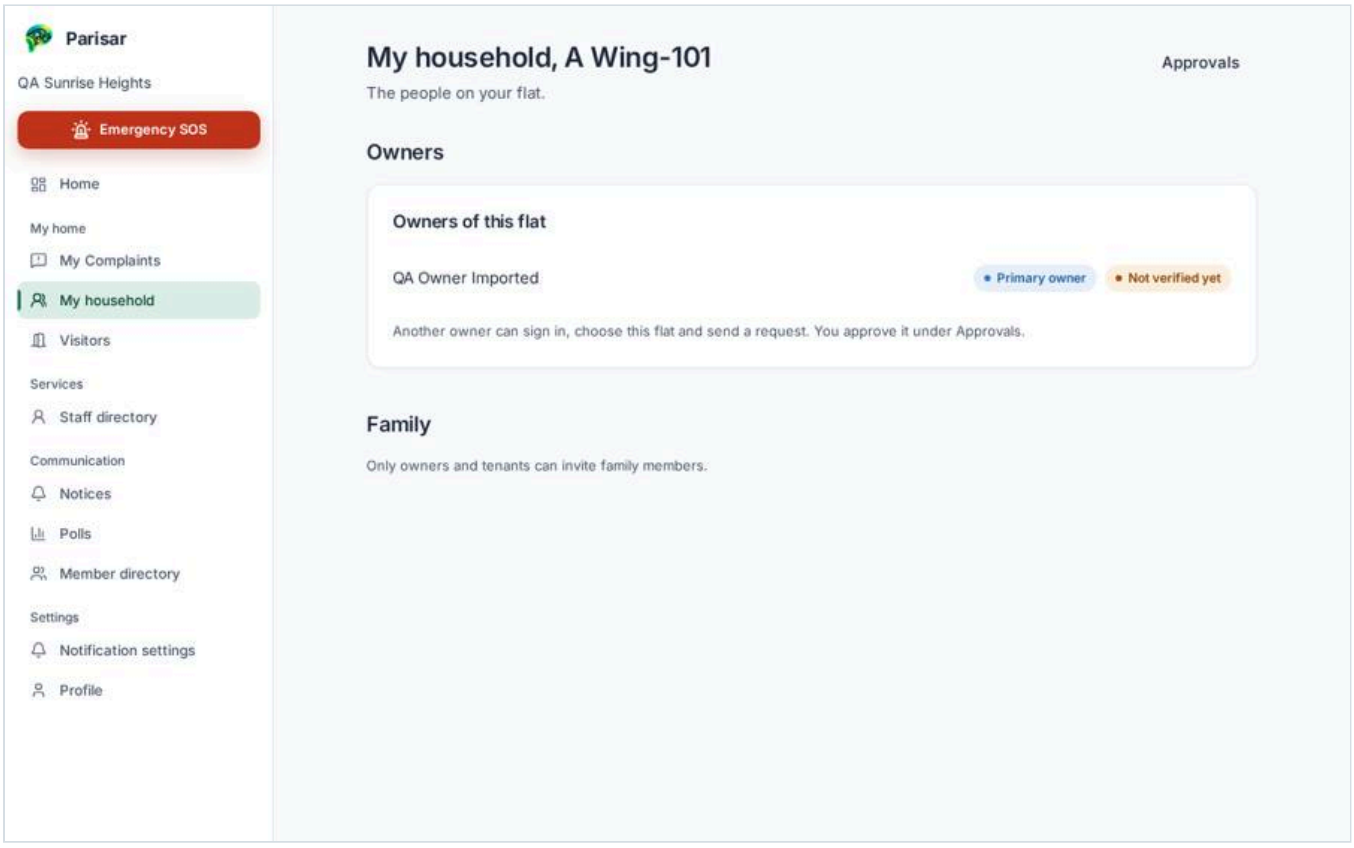


approvals-owner-before-1280.png

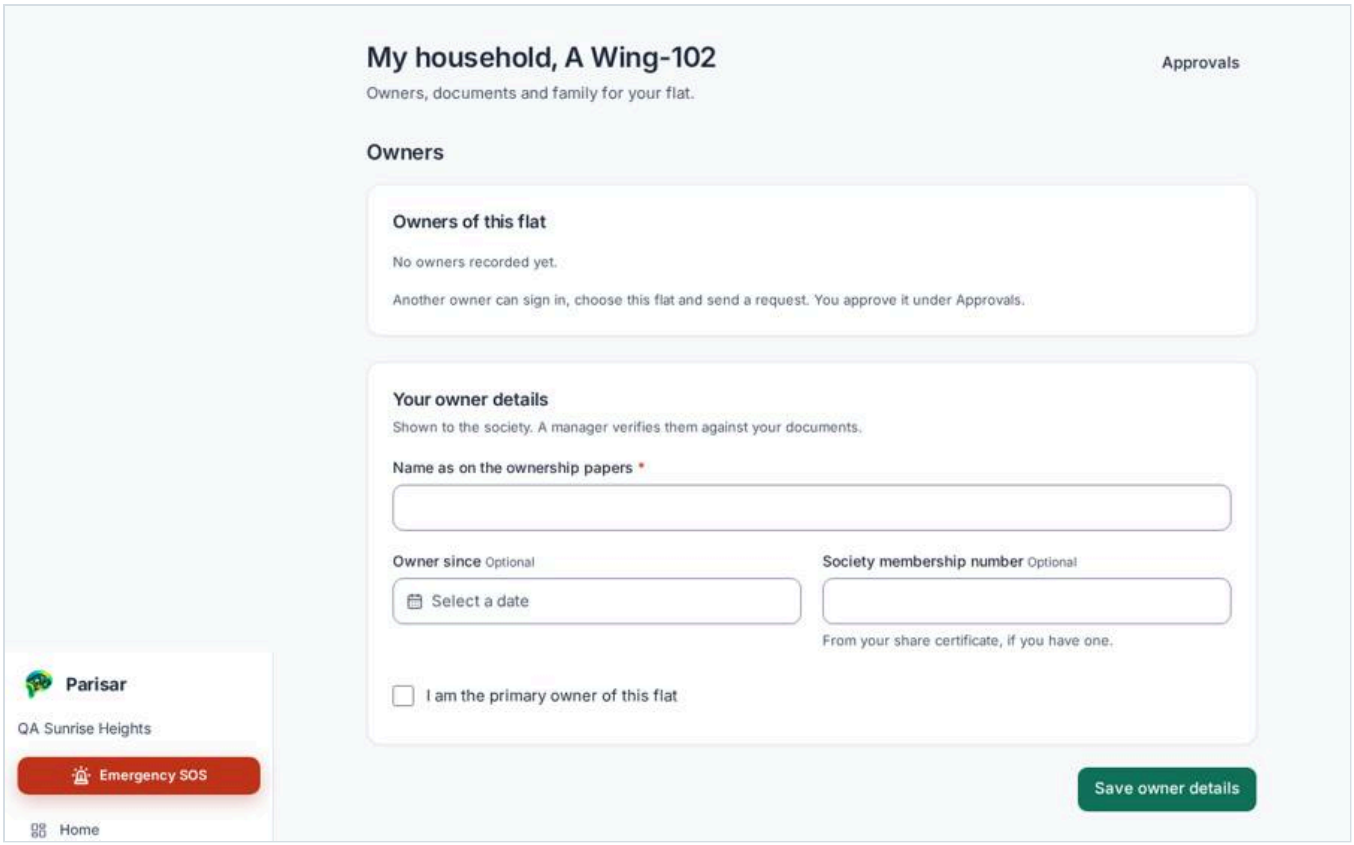


approvals-owner-confirm-1280.png

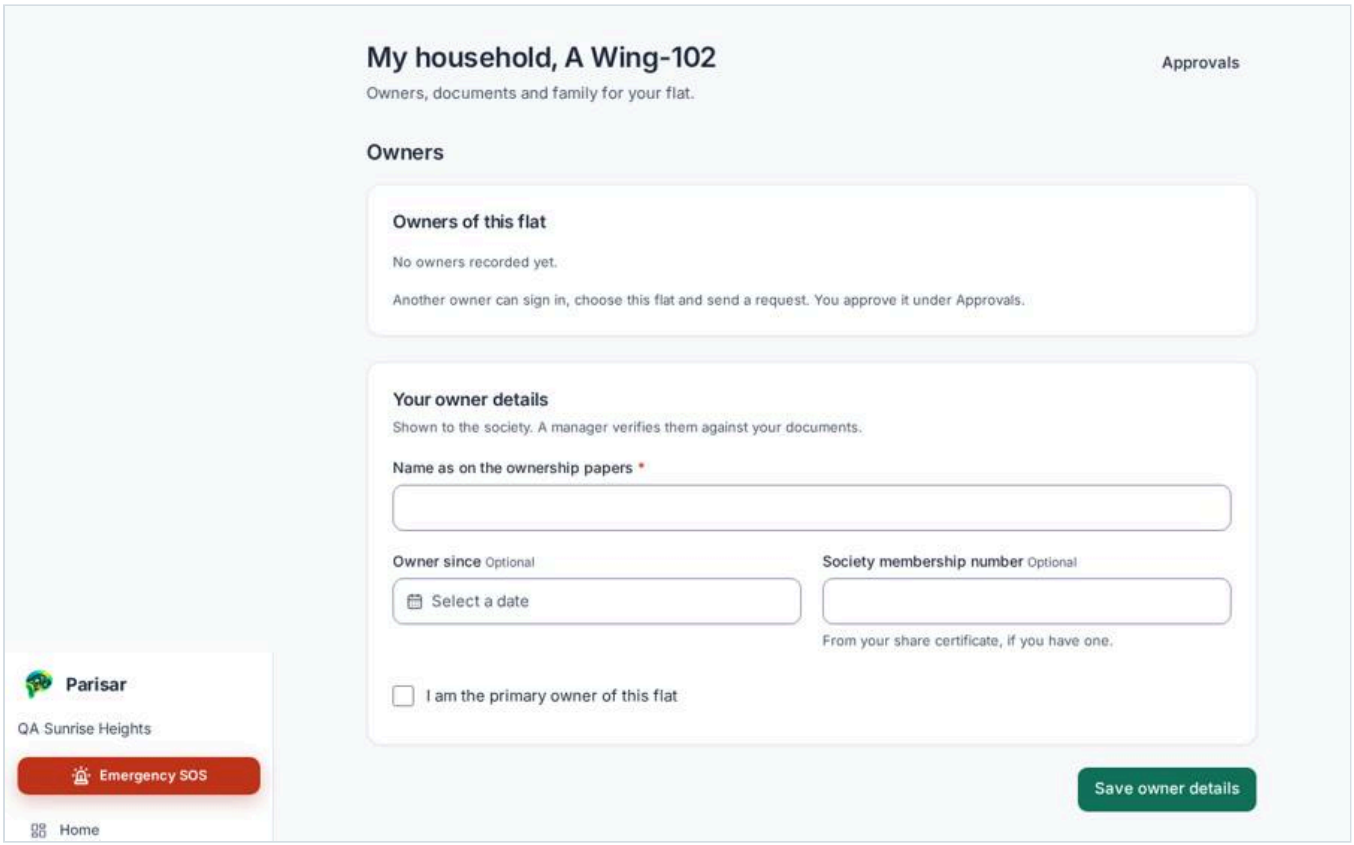
Same-flat household



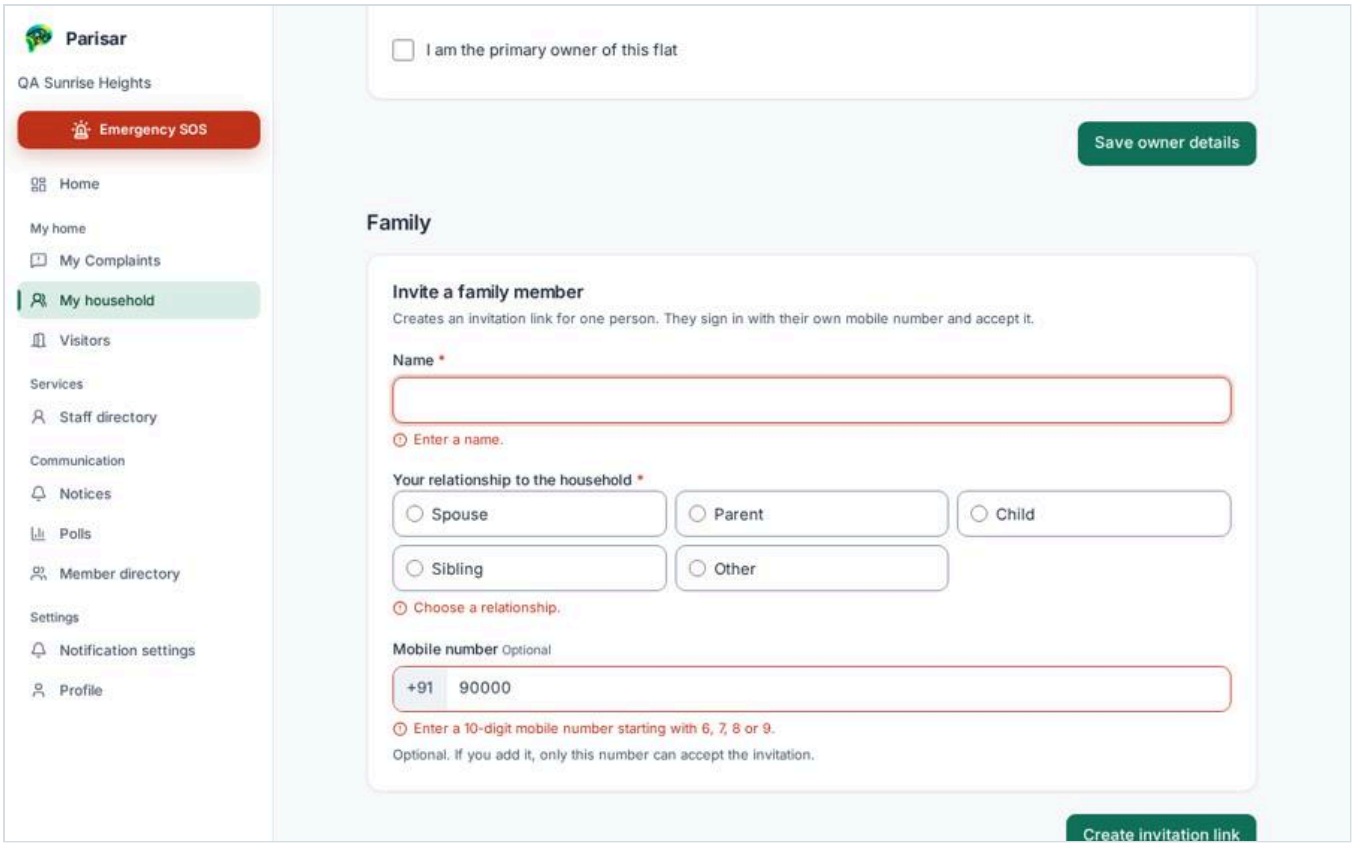
household-family-member-1280.png



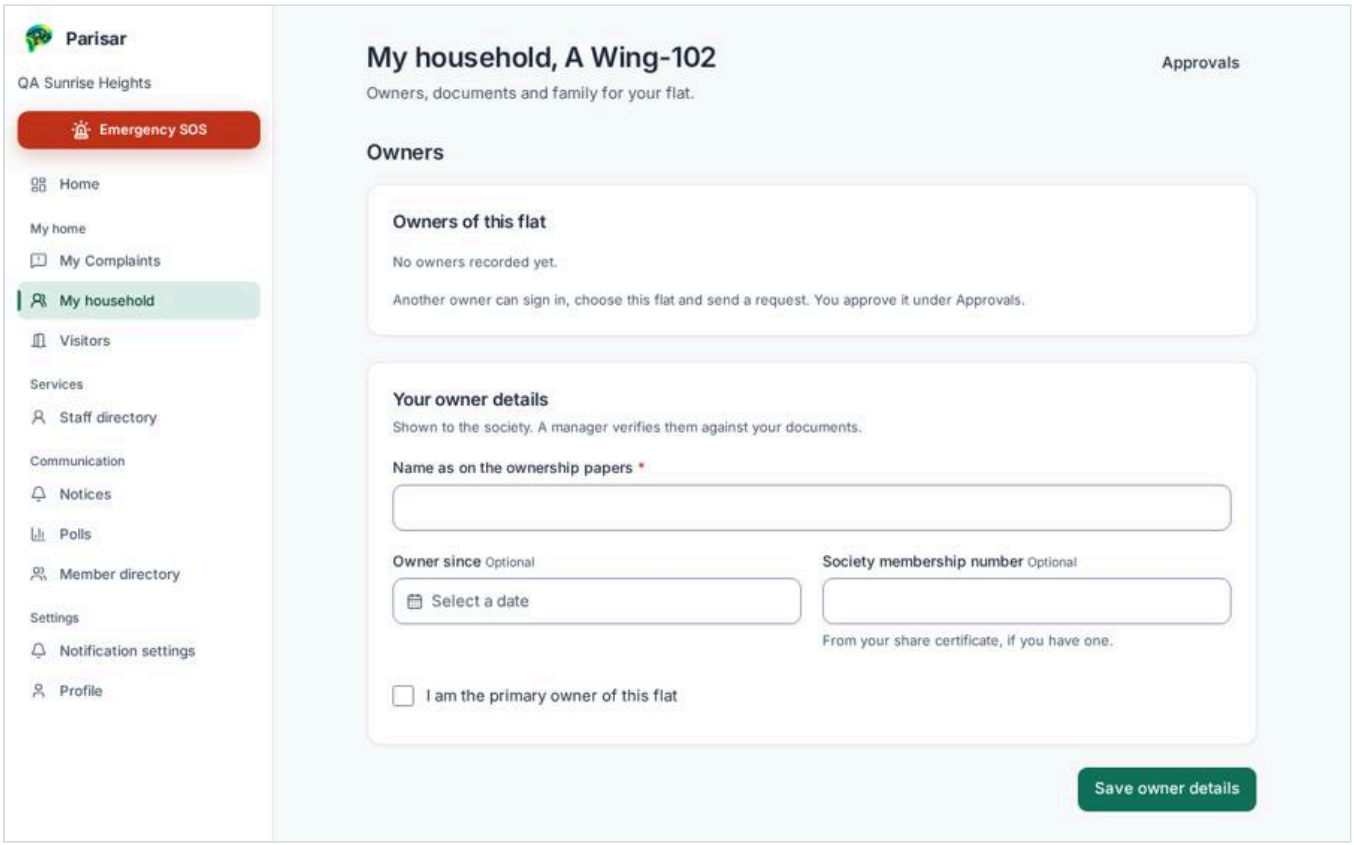
household-invite-created-1280.png



household-invite-validation-1280.png

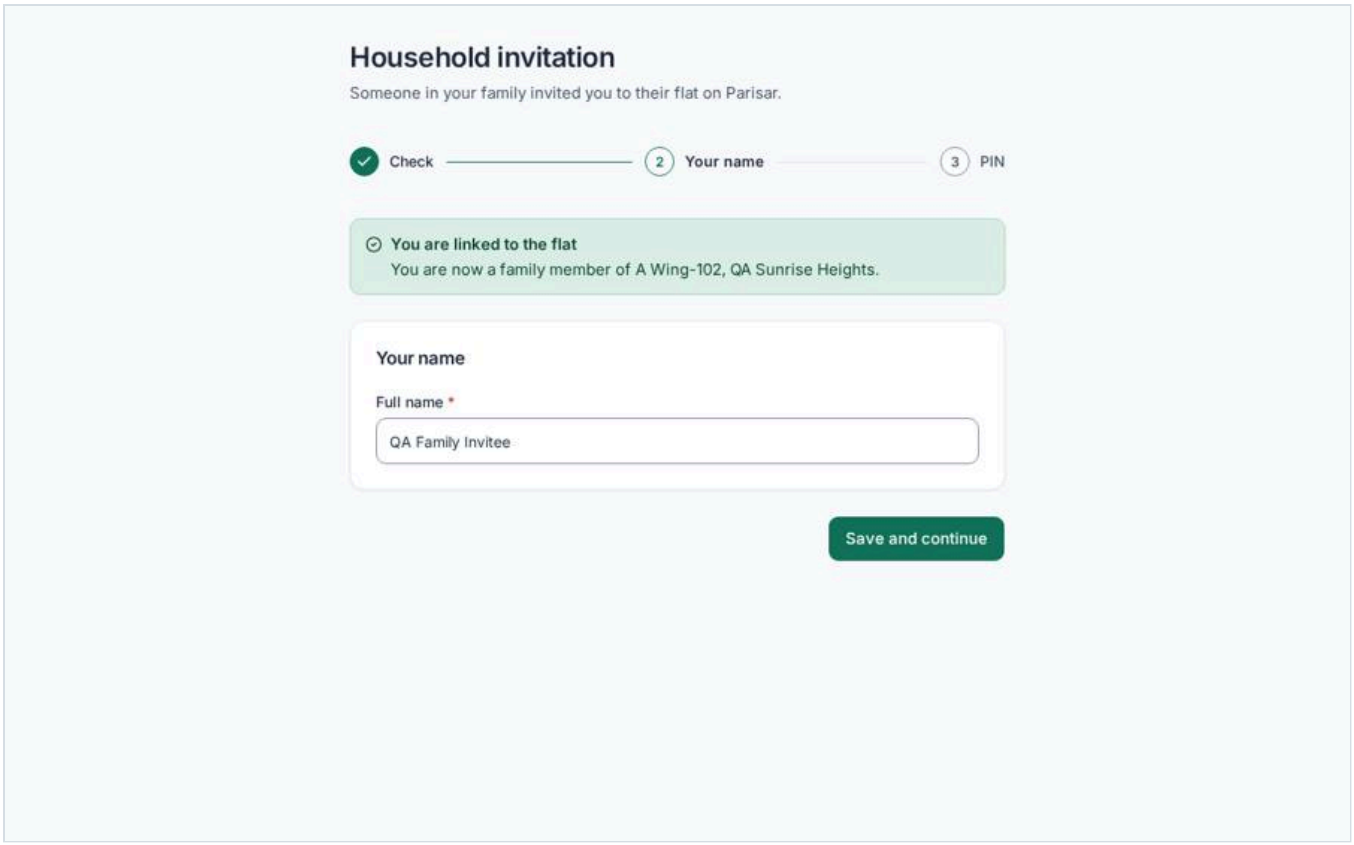


household-invite-validation-phone-1280.png

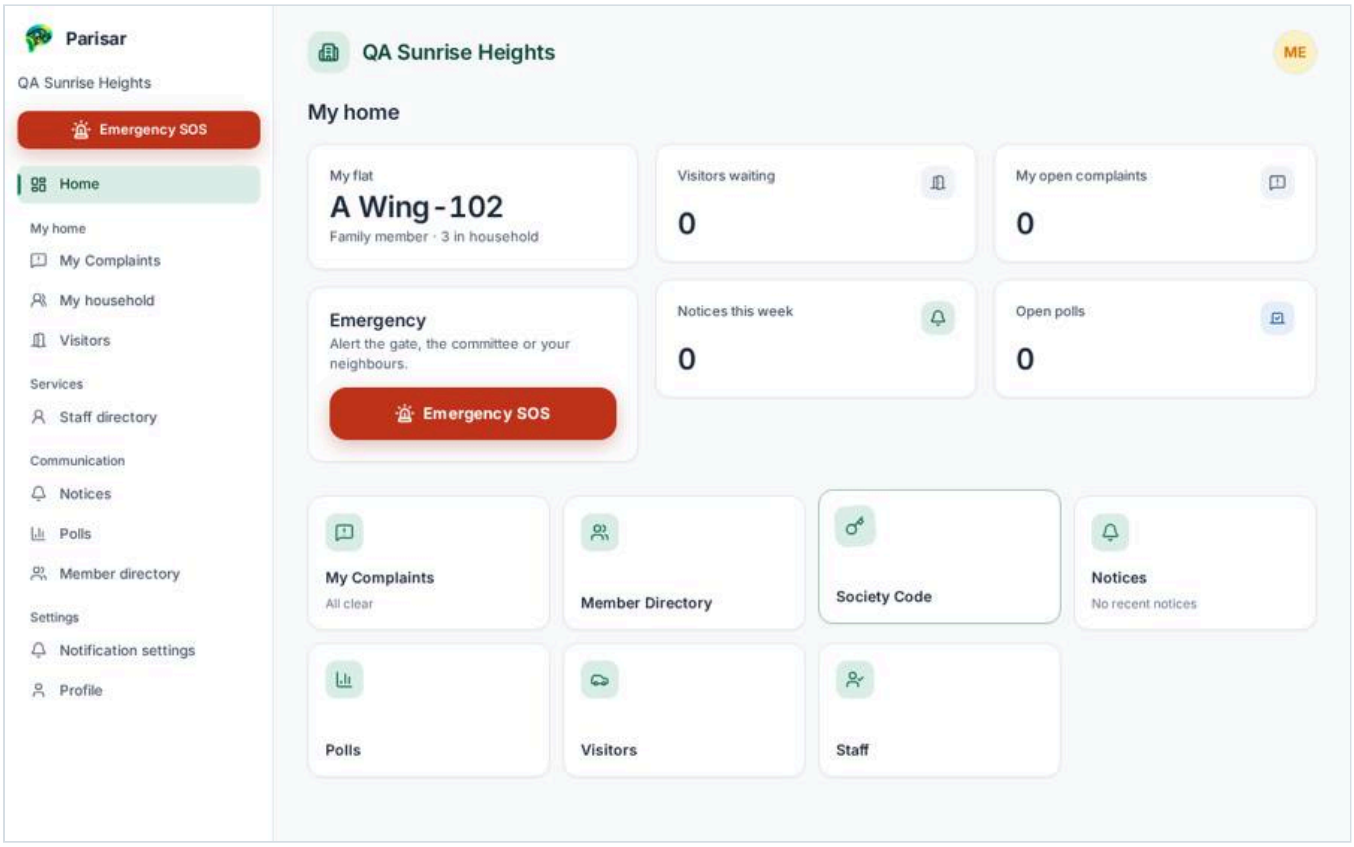


household-owner-1280.png

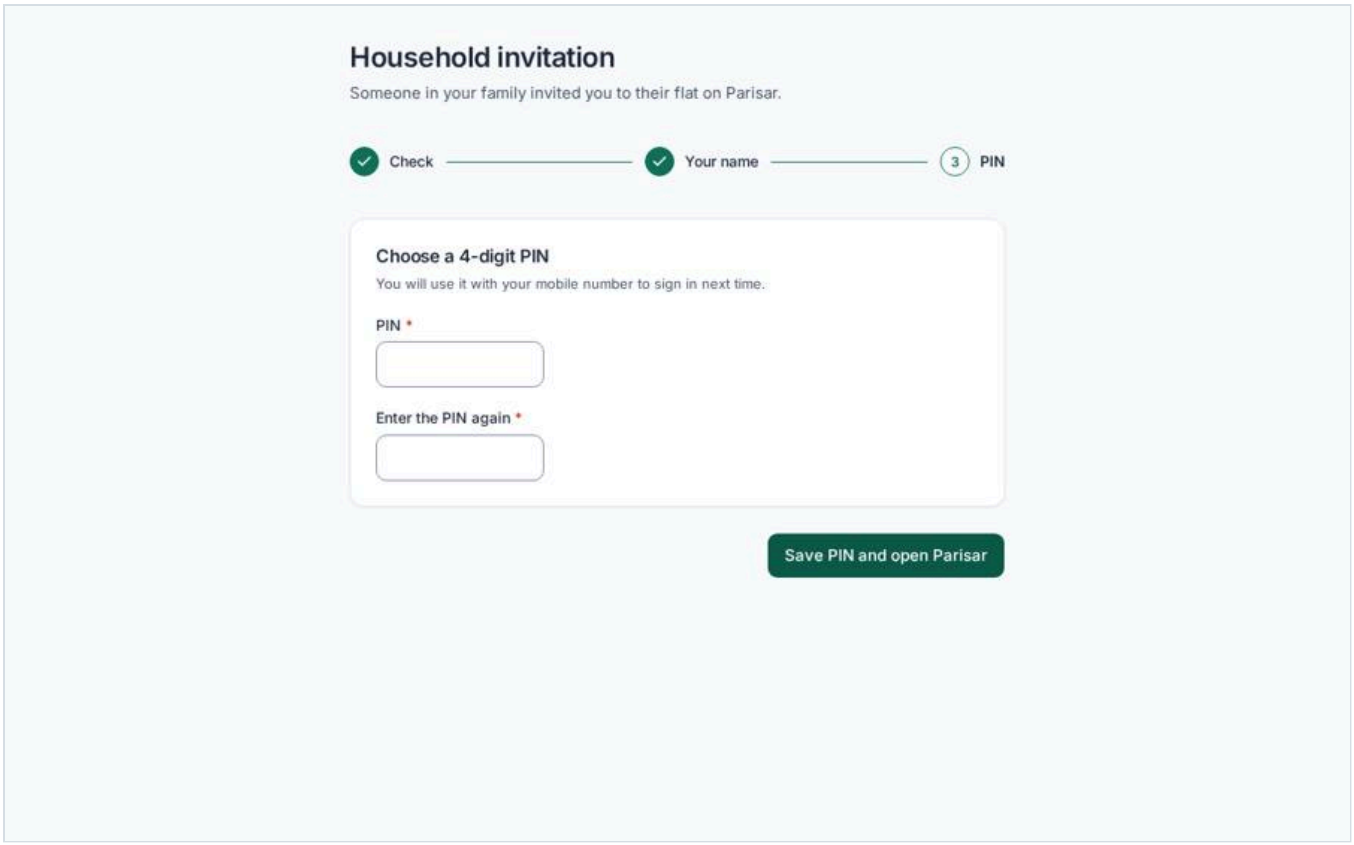
Family invite



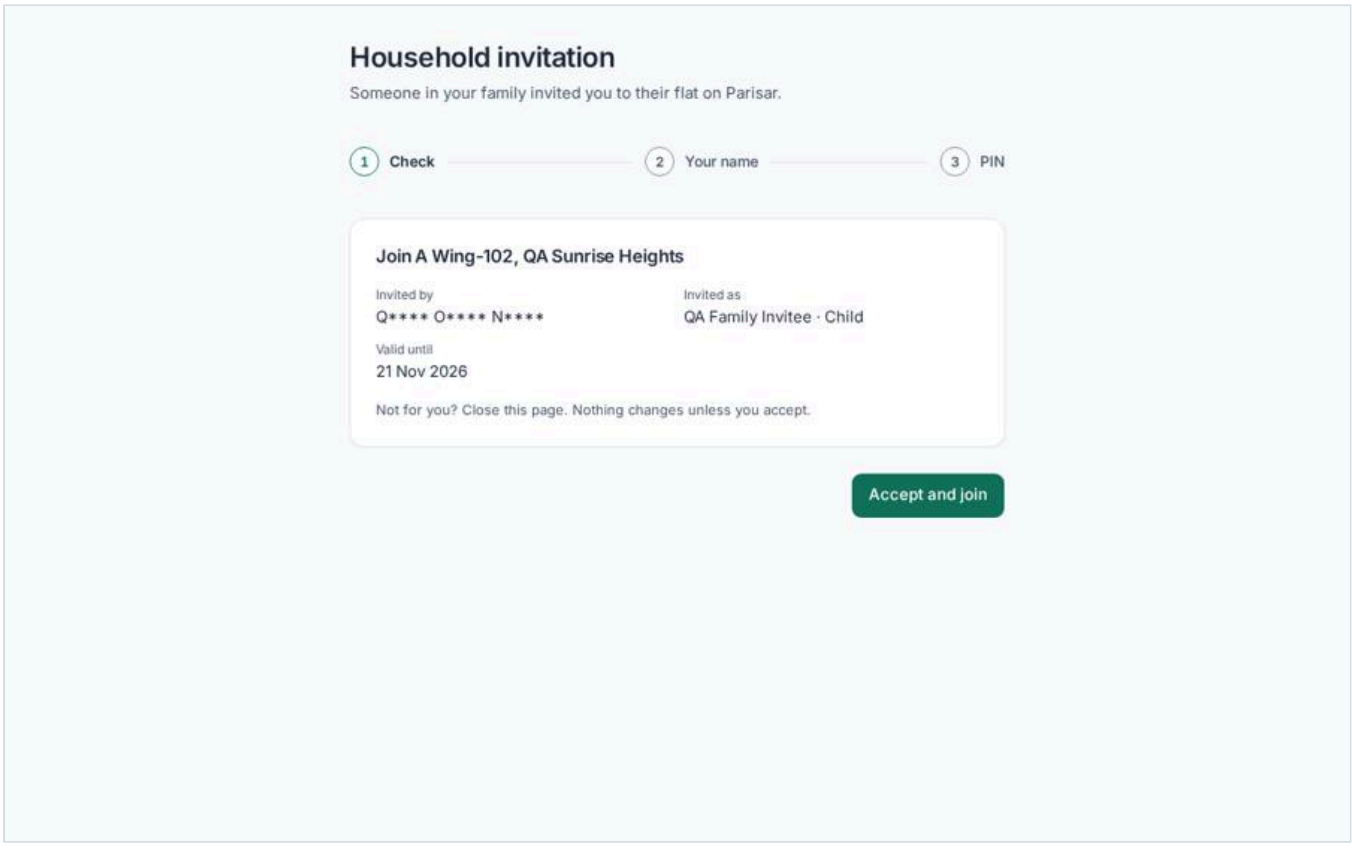
invite-accept-after-accept-1280.png



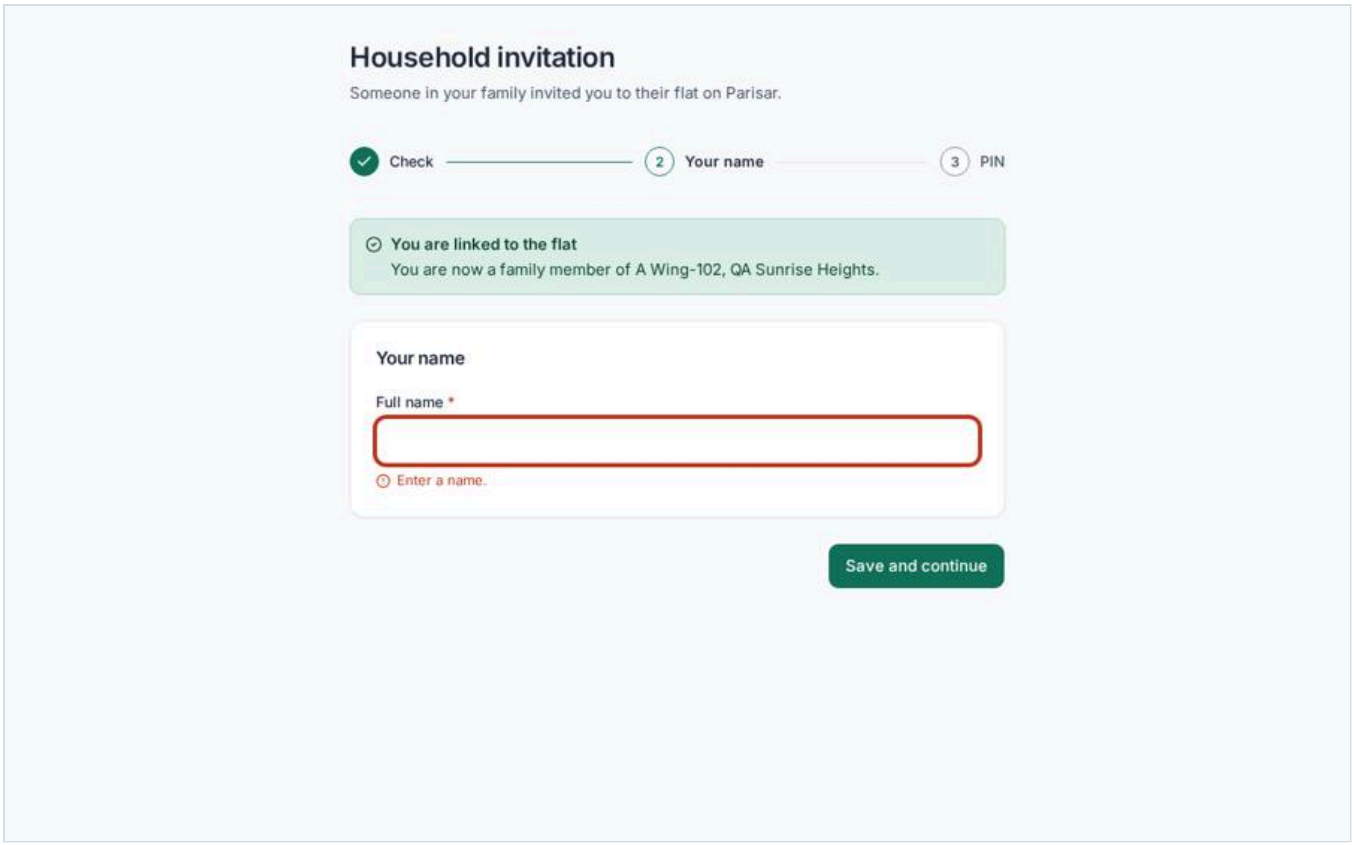
invite-accept-final-1280.png



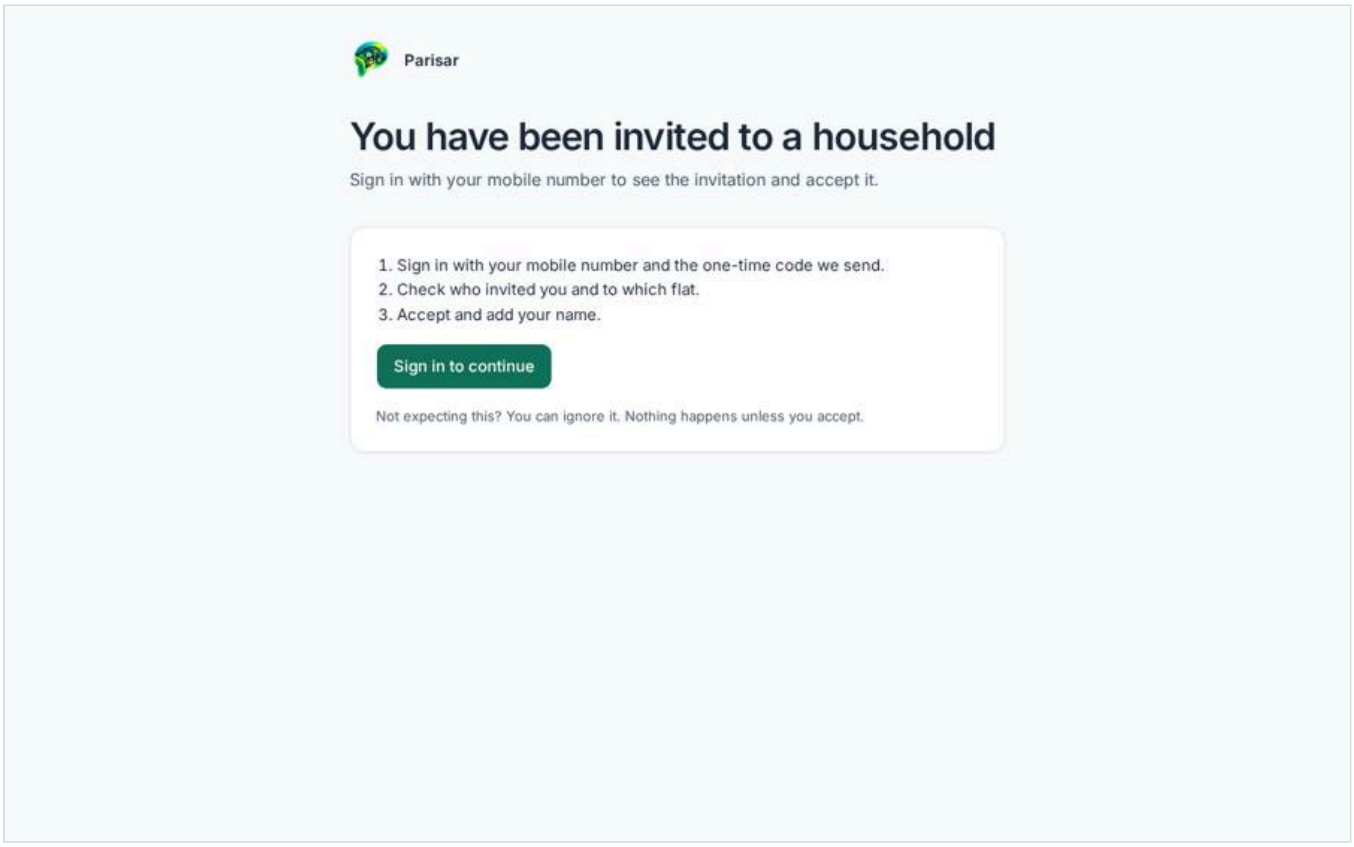
invite-accept-pin-1280.png



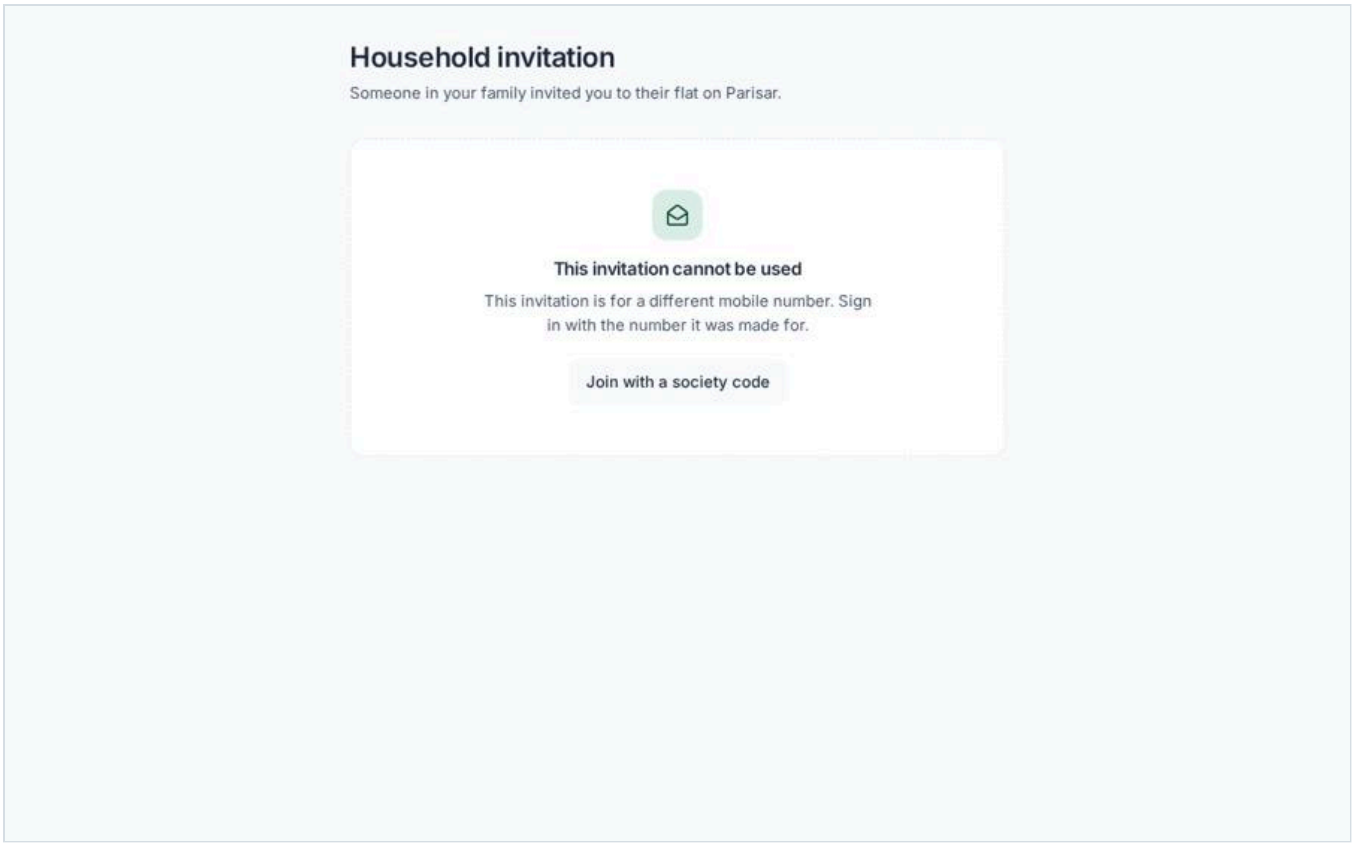
invite-accept-preview-1280.png



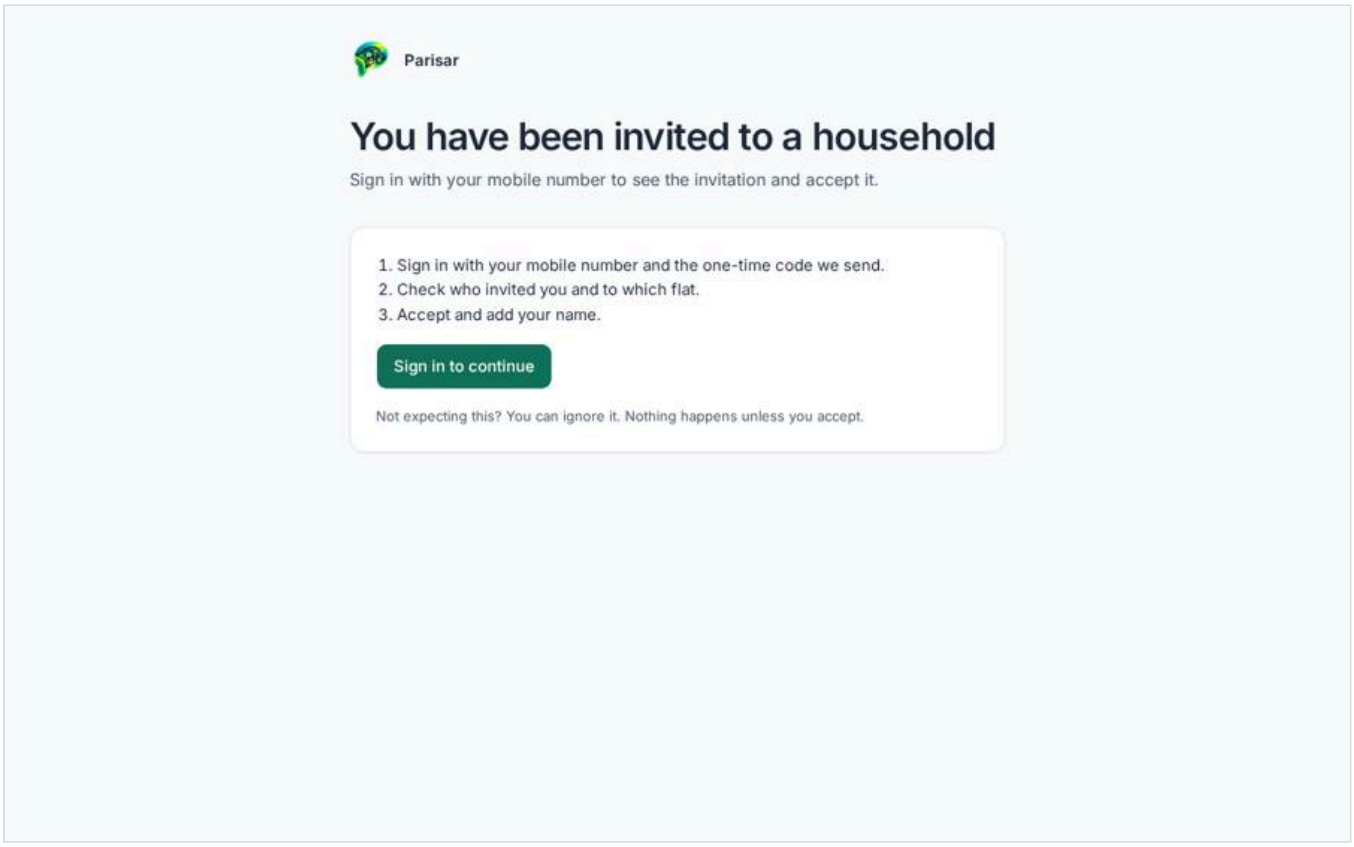
invite-accept-profile-validation-1280.png



invite-accept-public-1280.png

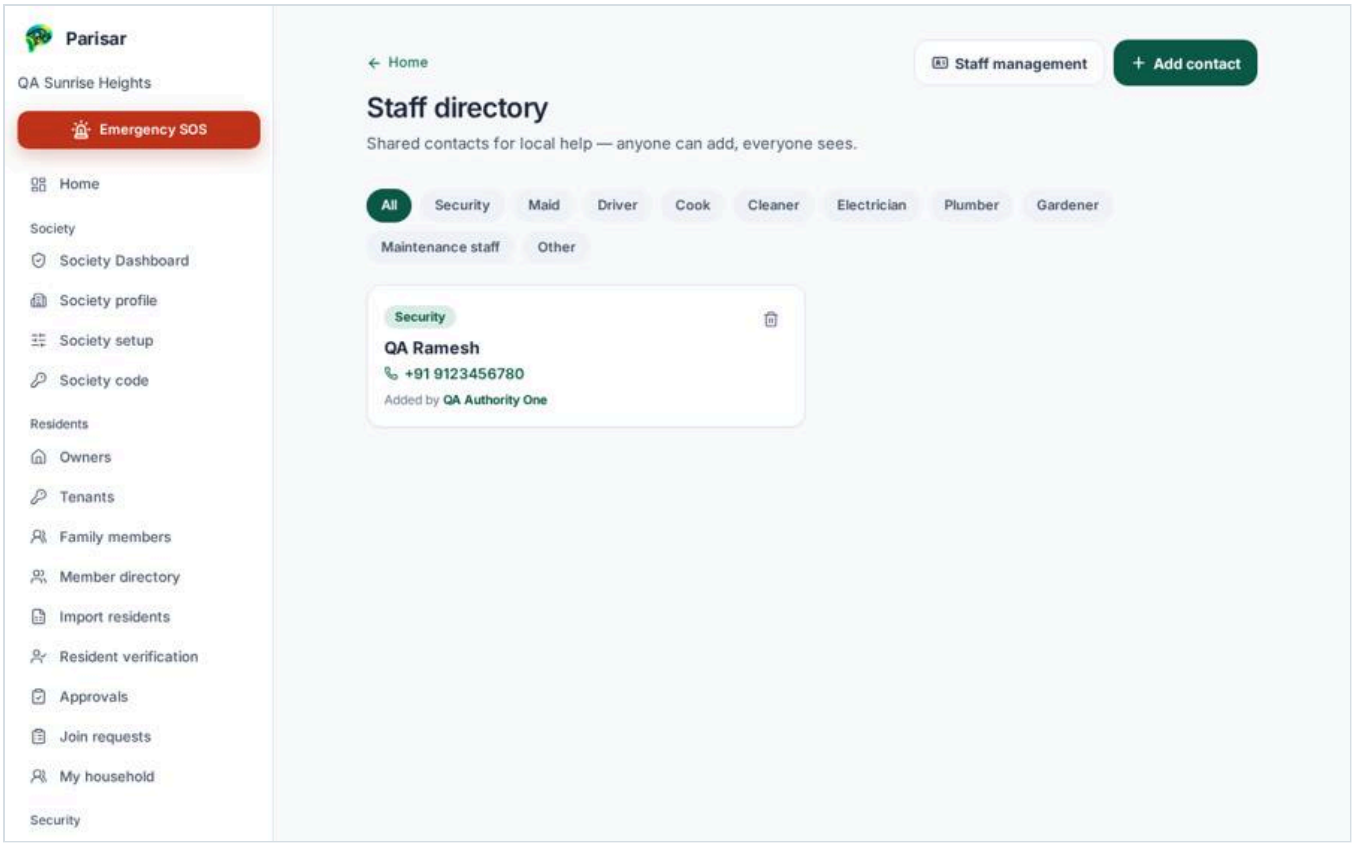


invite-wrongphone-preview-1280.png

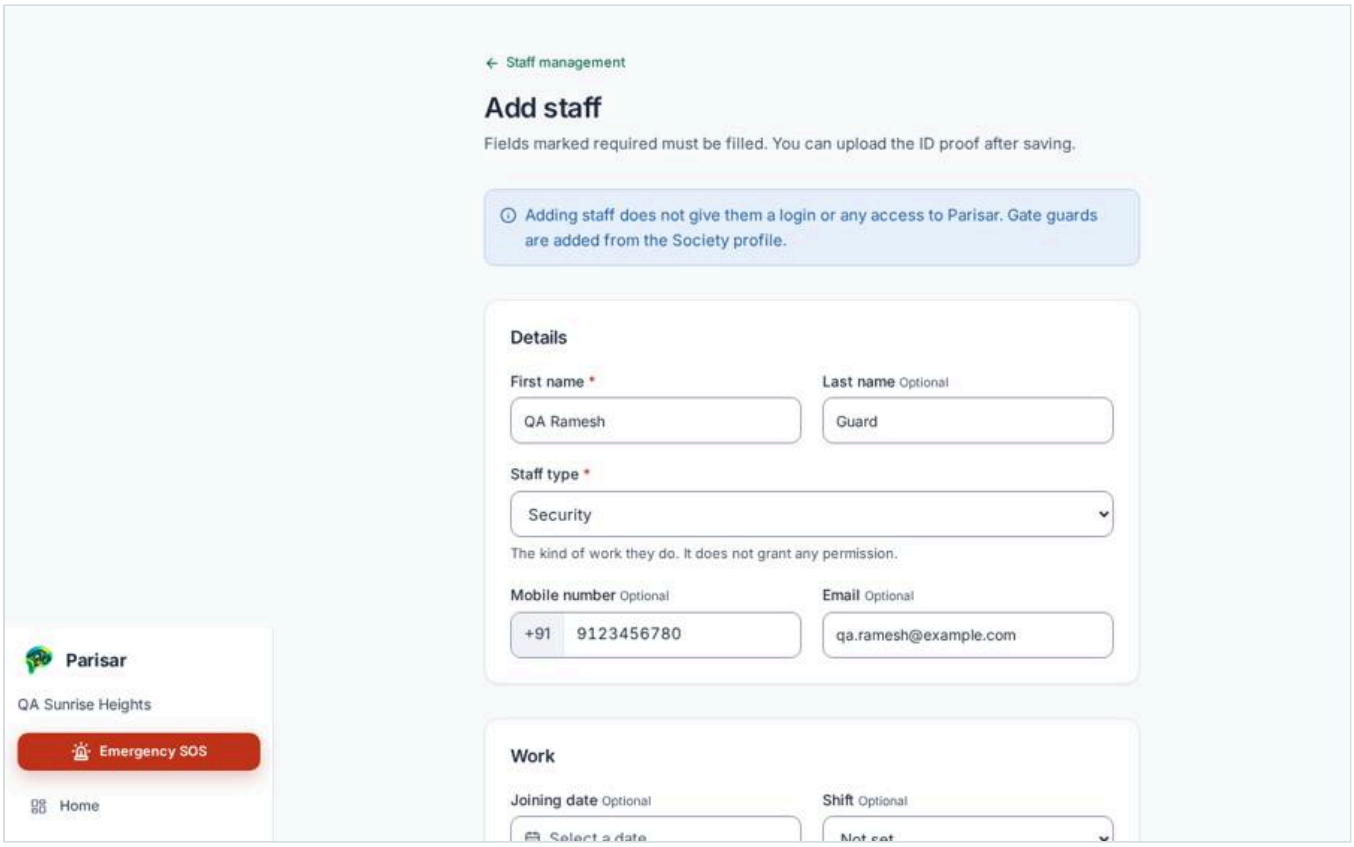


invite-wrongphone-public-1280.png

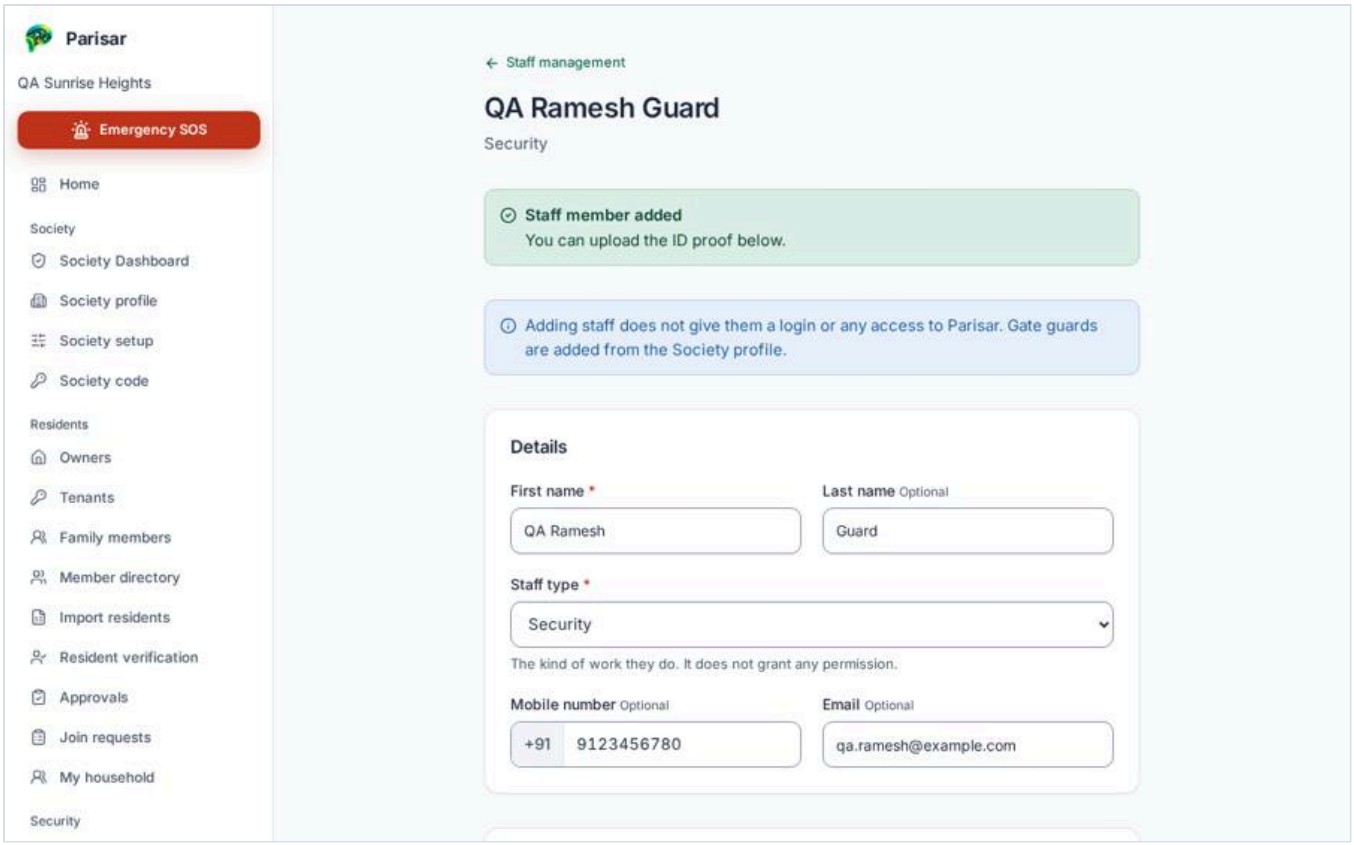
Staff Management



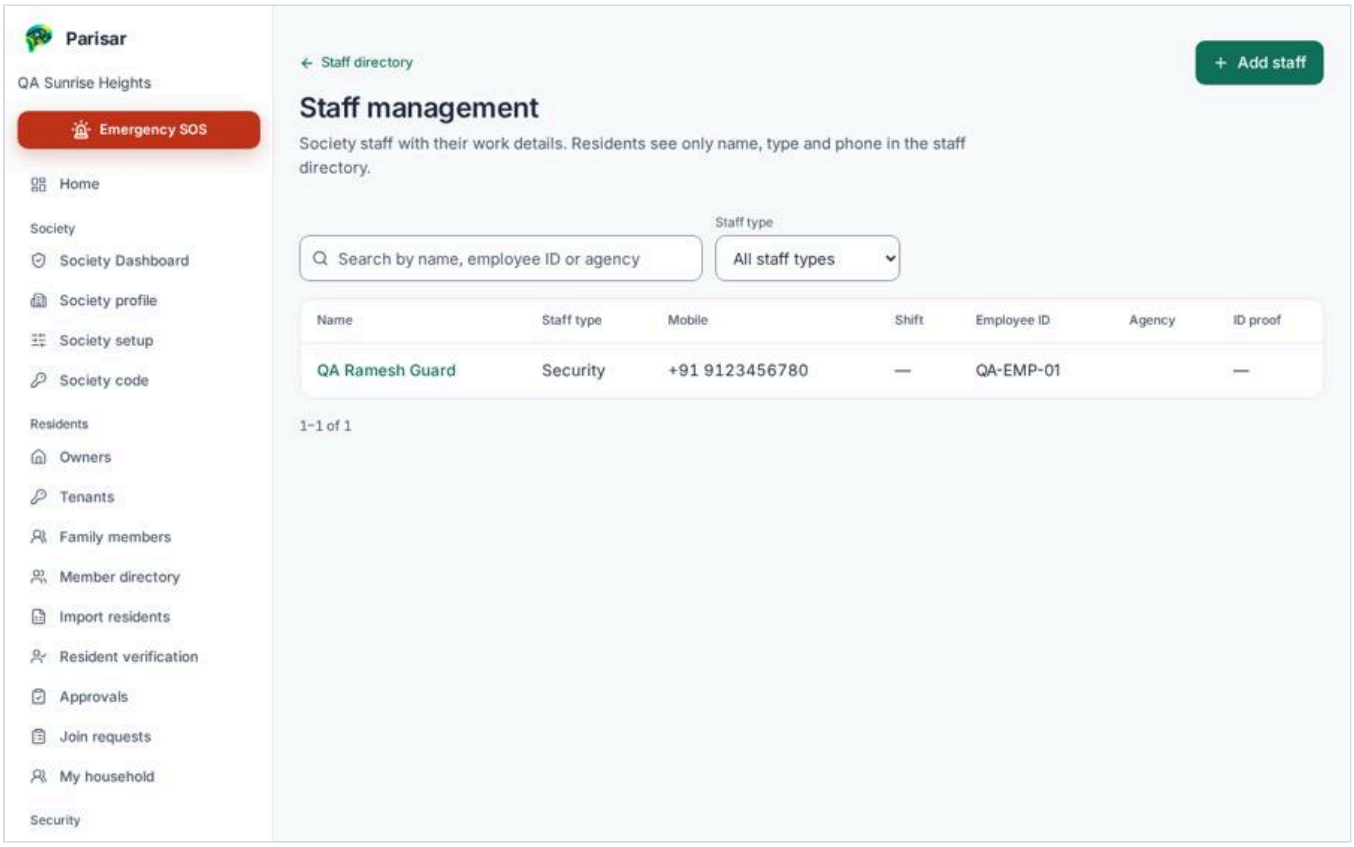
staff-directory-1280.png



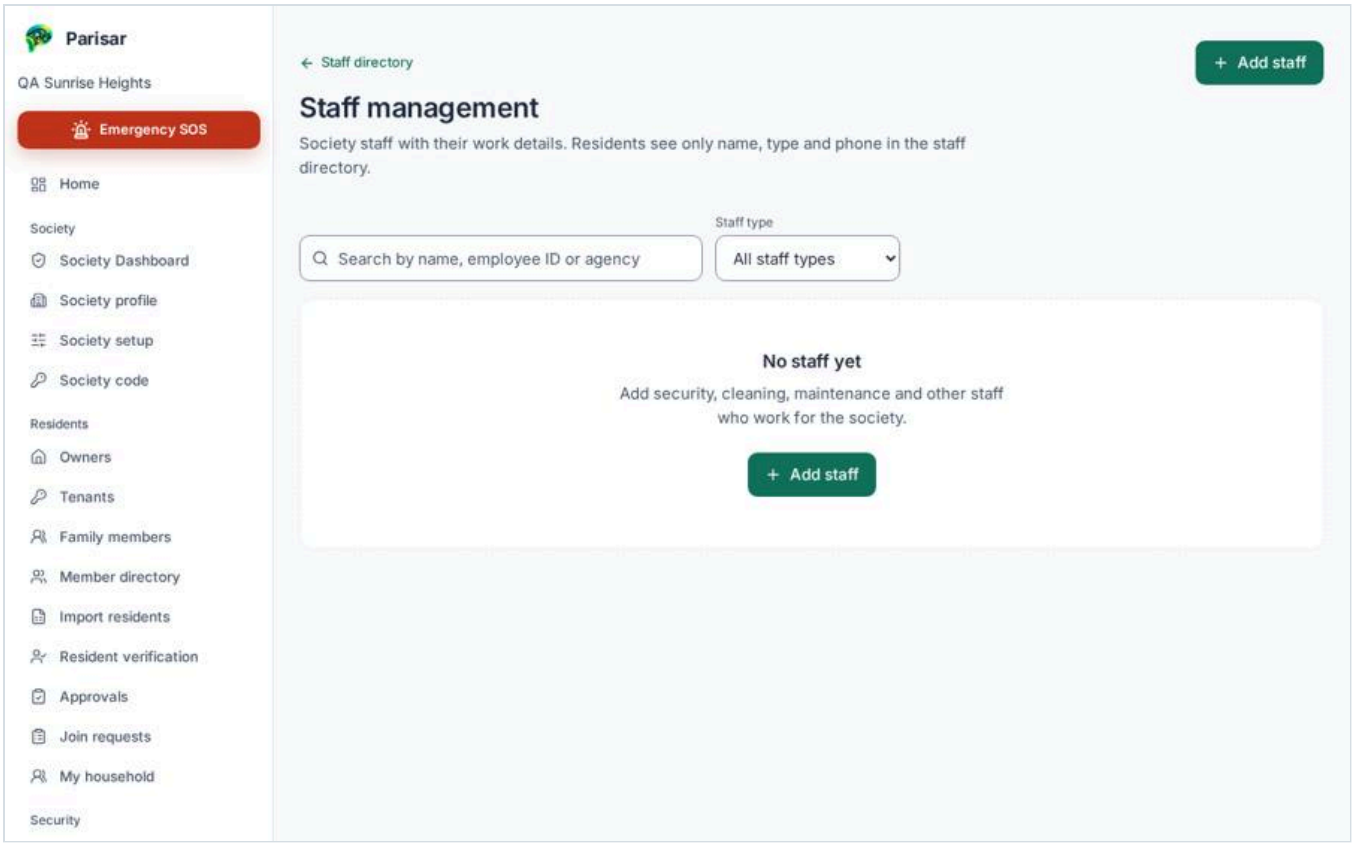
staff-manage-created-1280.png



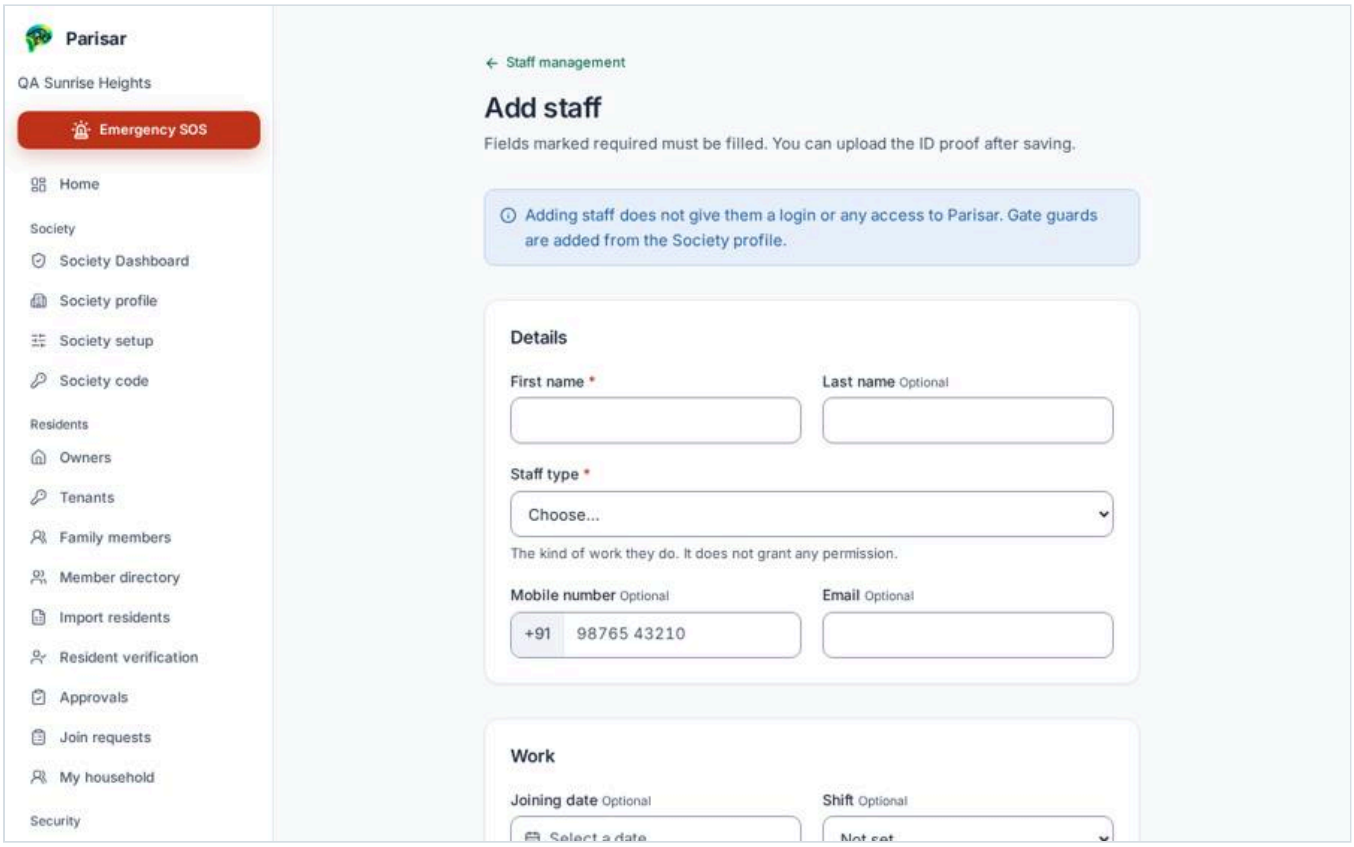
staff-manage-detail-created-1280.png



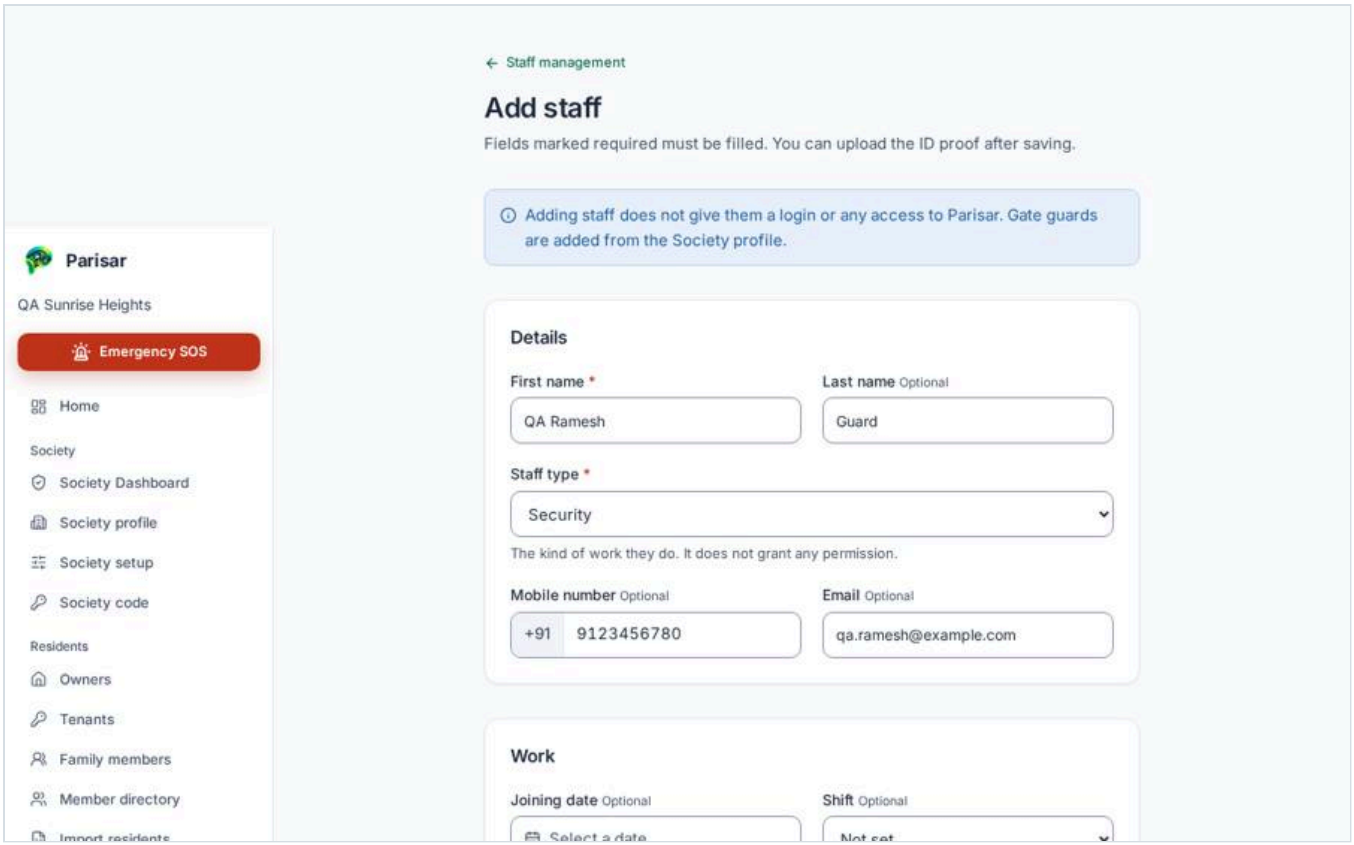
staff-manage-list-1280.png



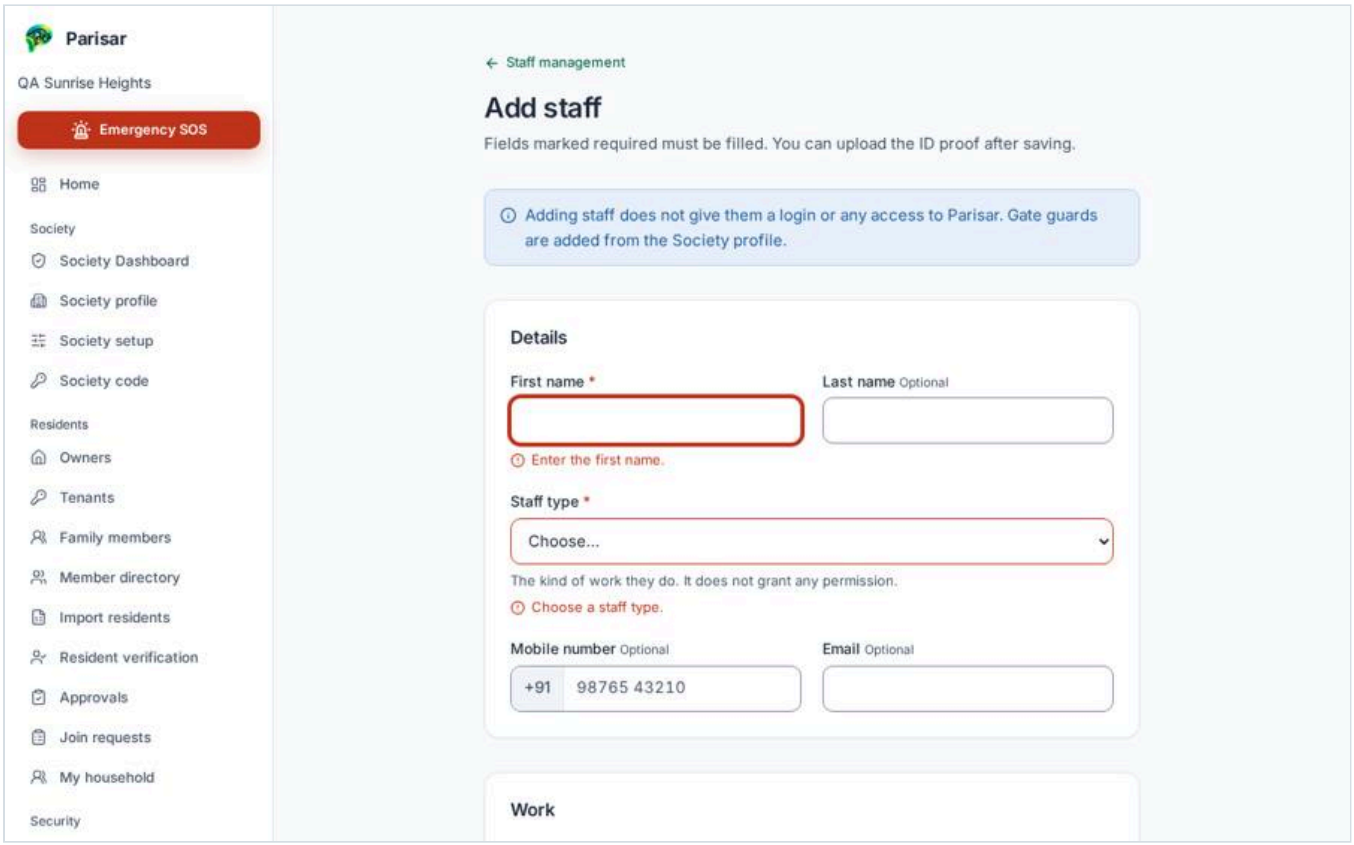
staff-manage-list-empty-1280.png



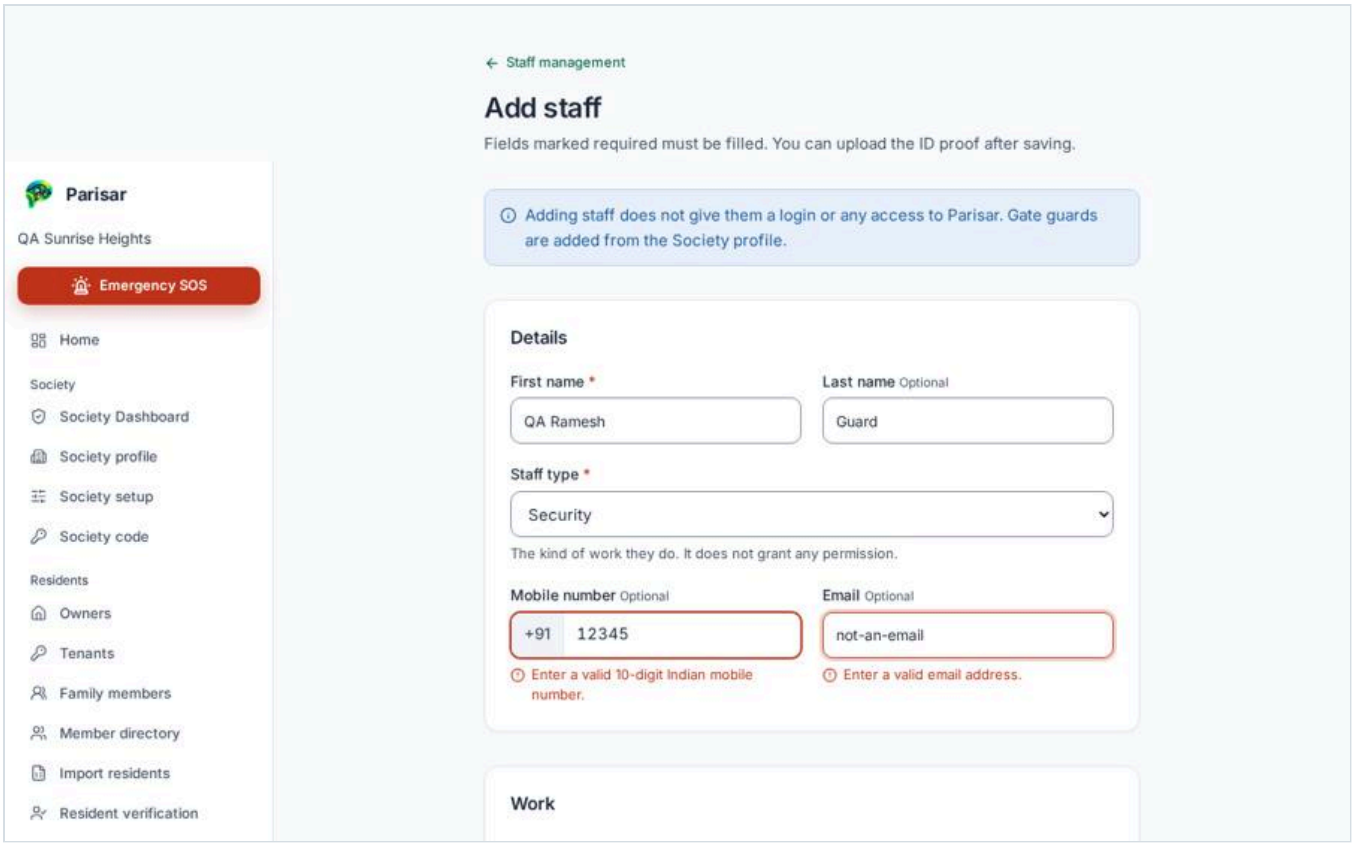
staff-manage-new-1280.png



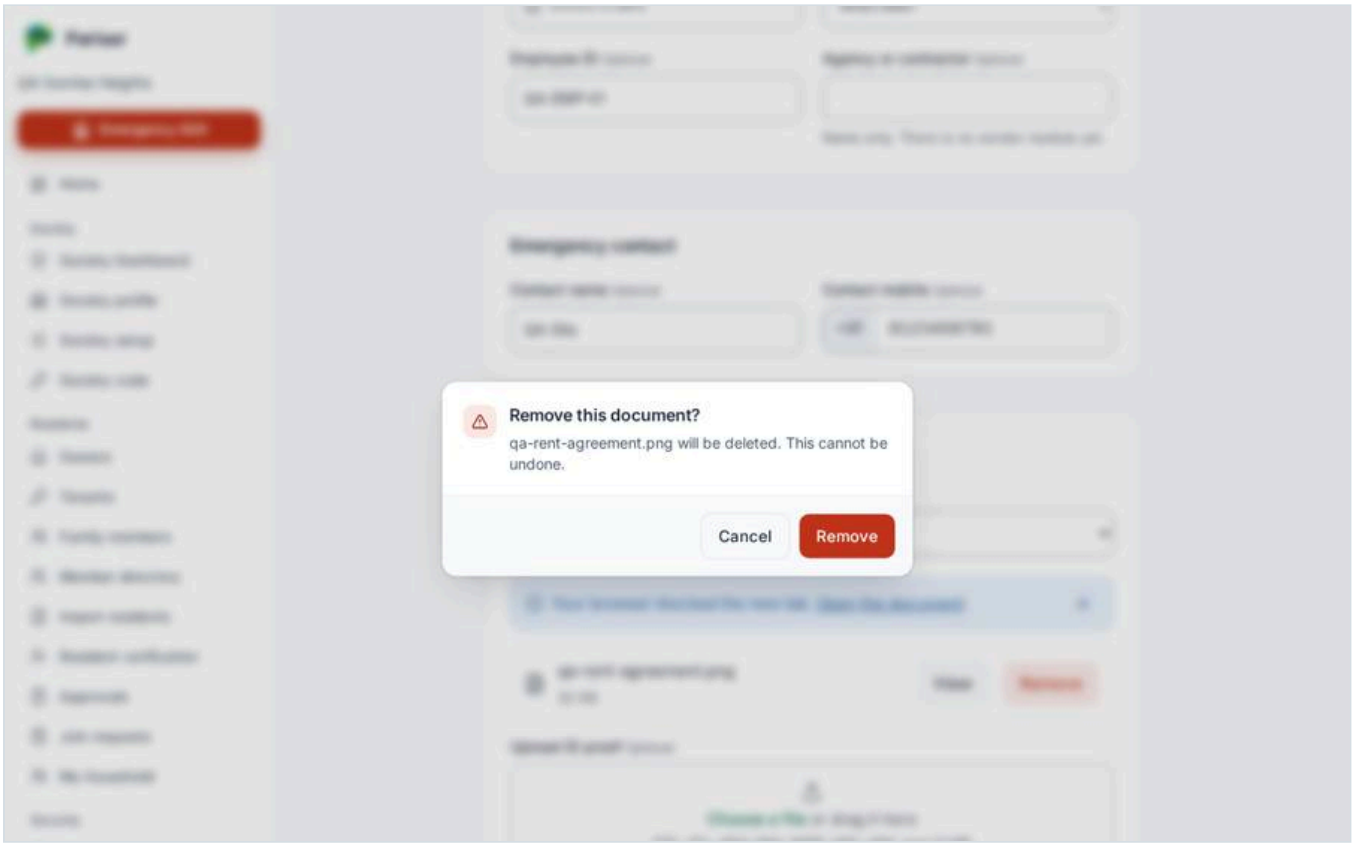
staff-manage-new-filled-1280.png



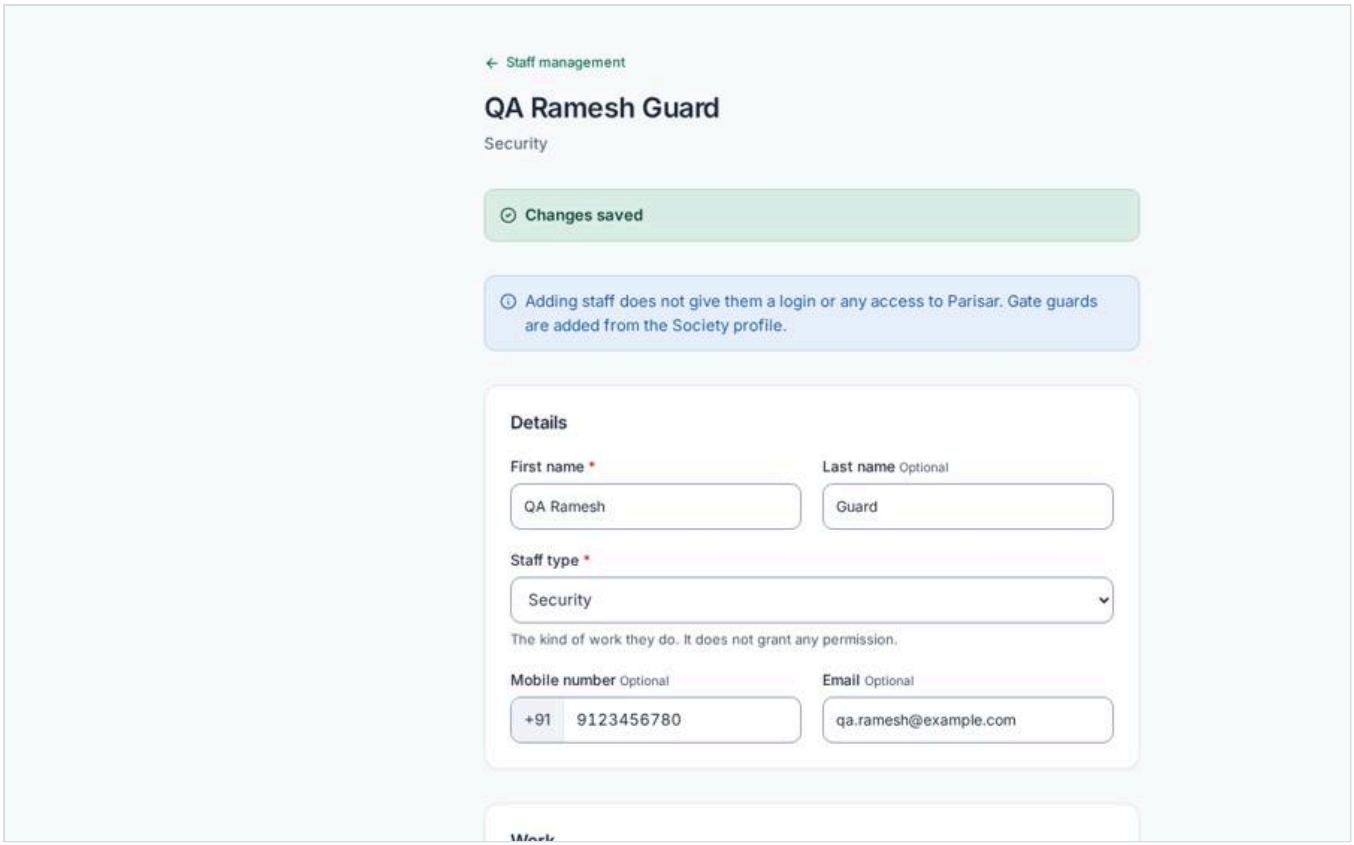
staff-manage-new-validation-1280.png



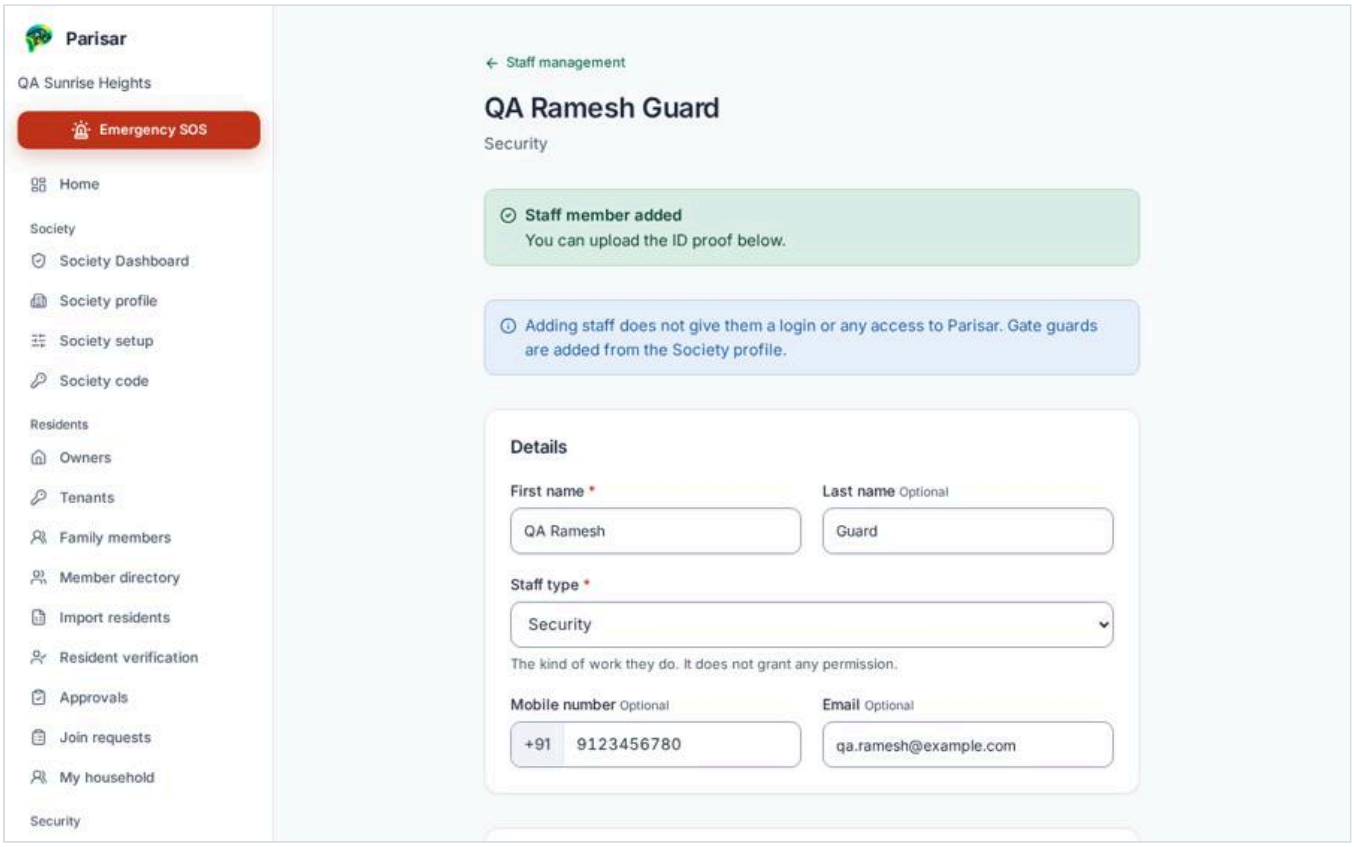
staff-manage-new-validation2-1280.png



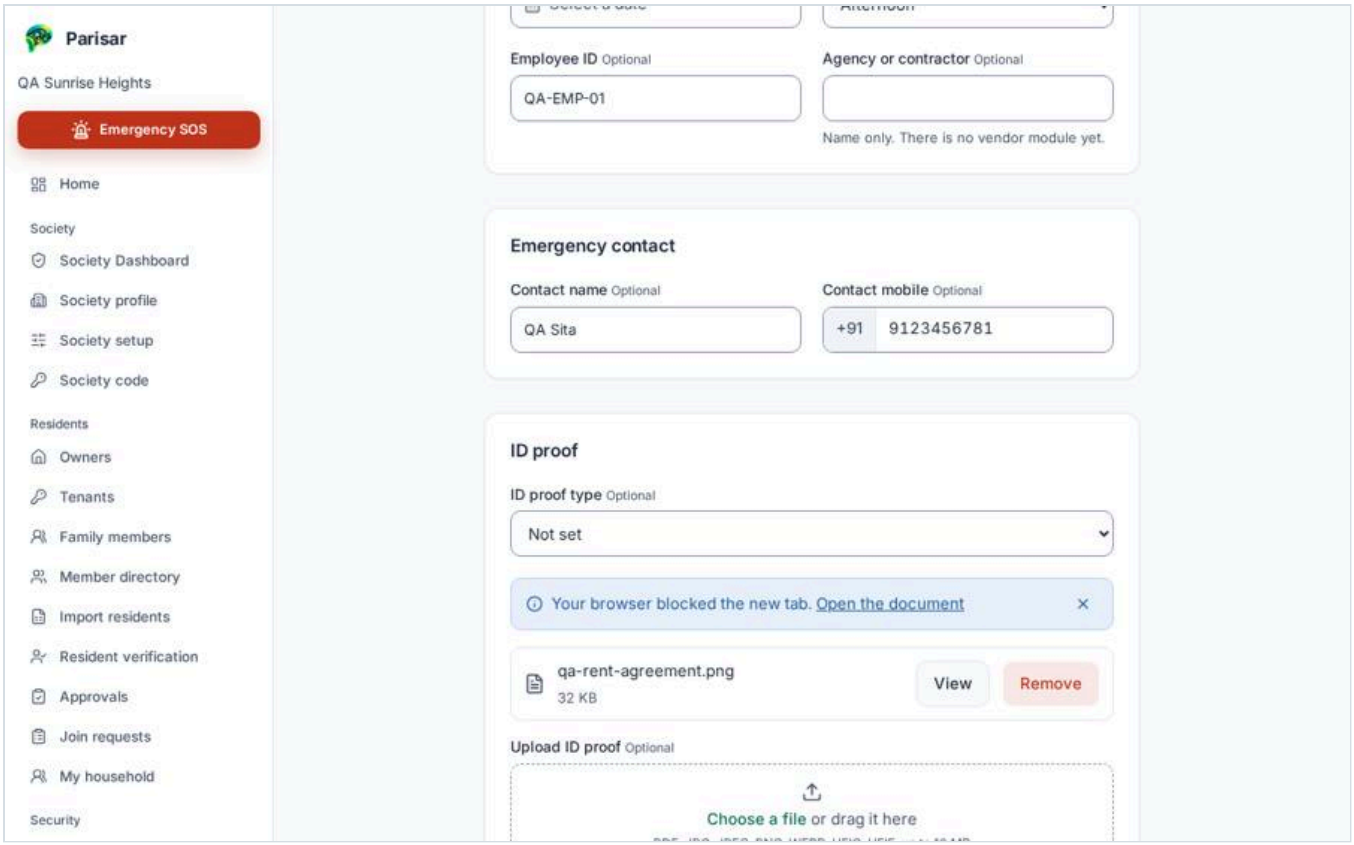
staff-manage-proof-remove-confirm-1280.png



staff-manage-proof-removed-1280.png

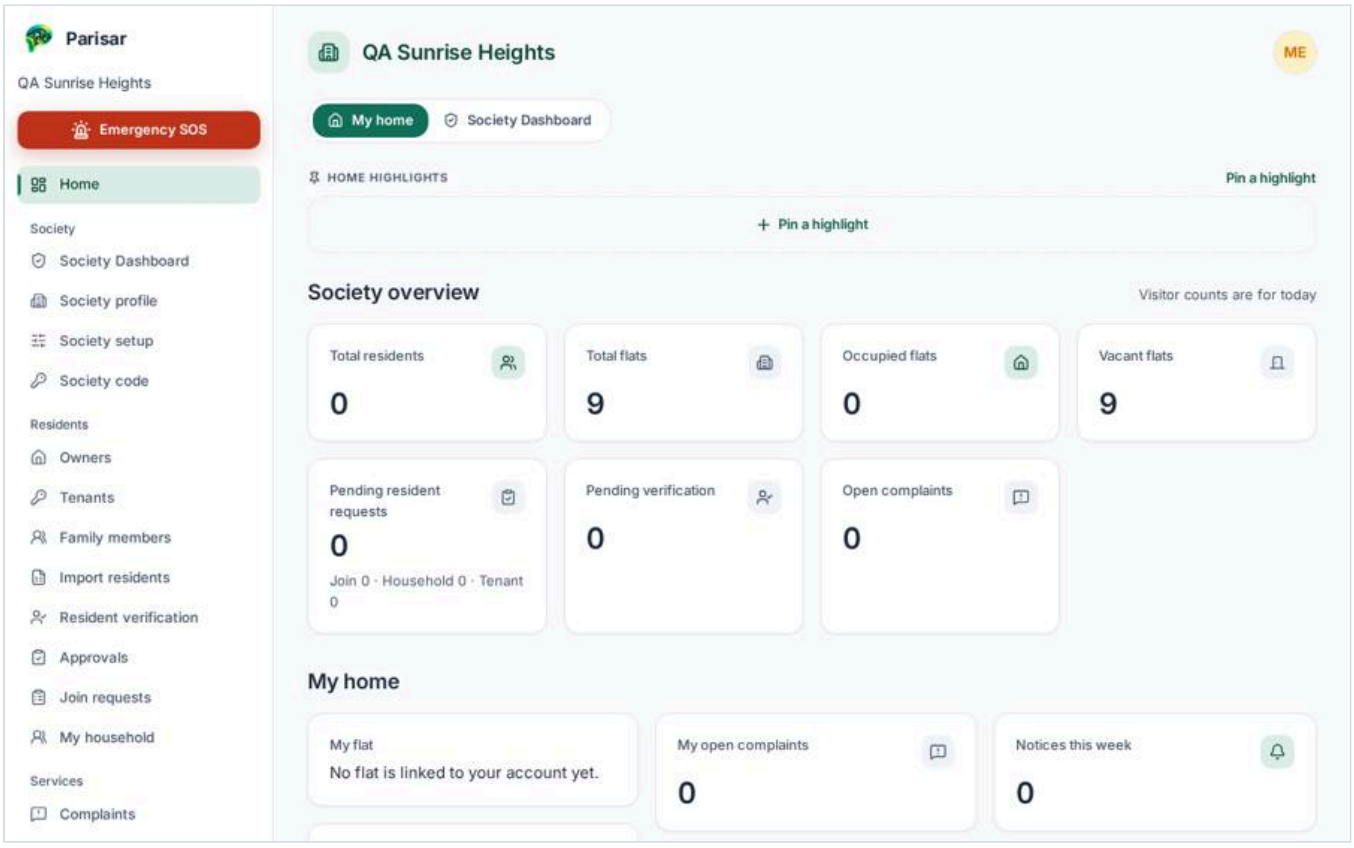


staff-manage-proof-uploaded-1280.png

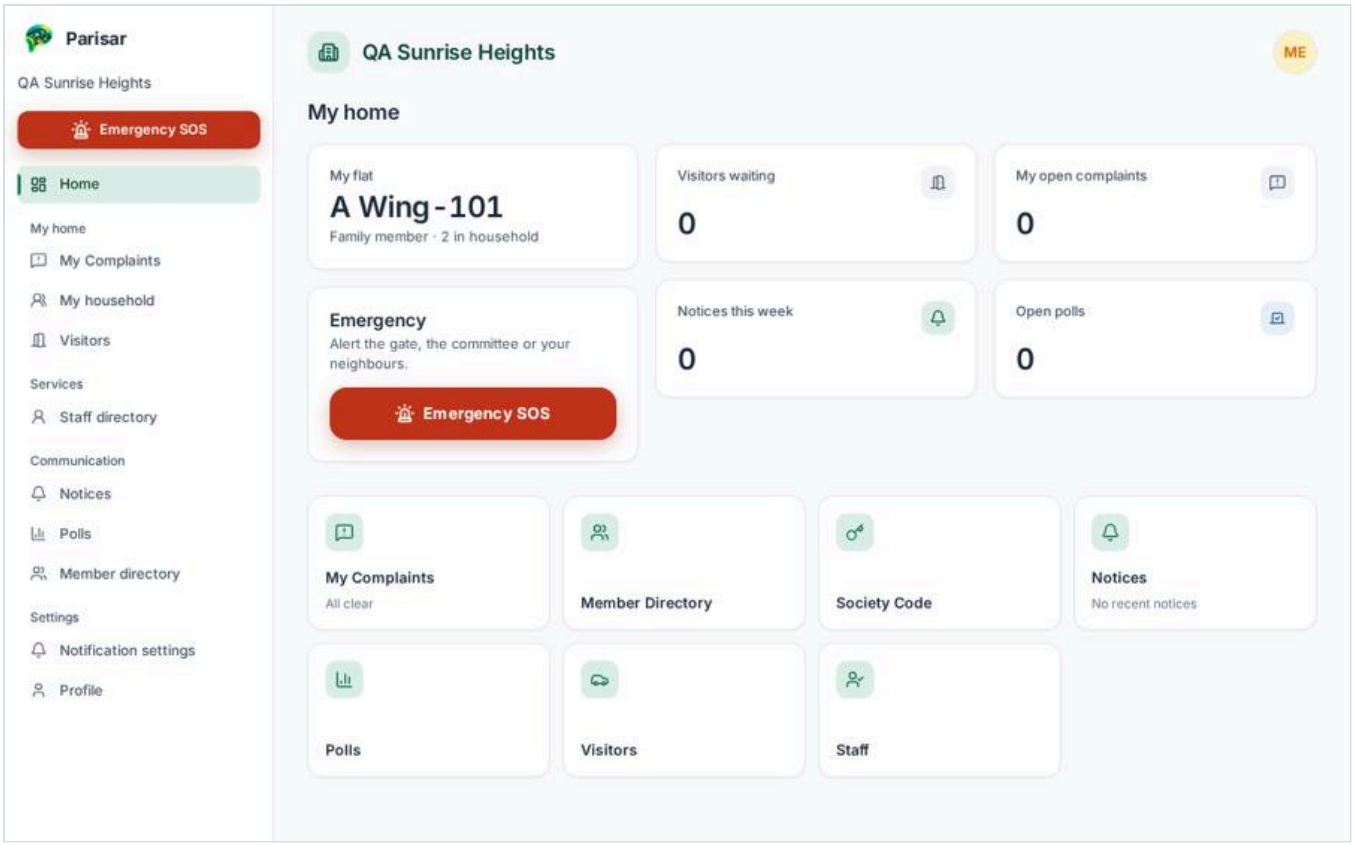


staff-manage-updated-1280.png

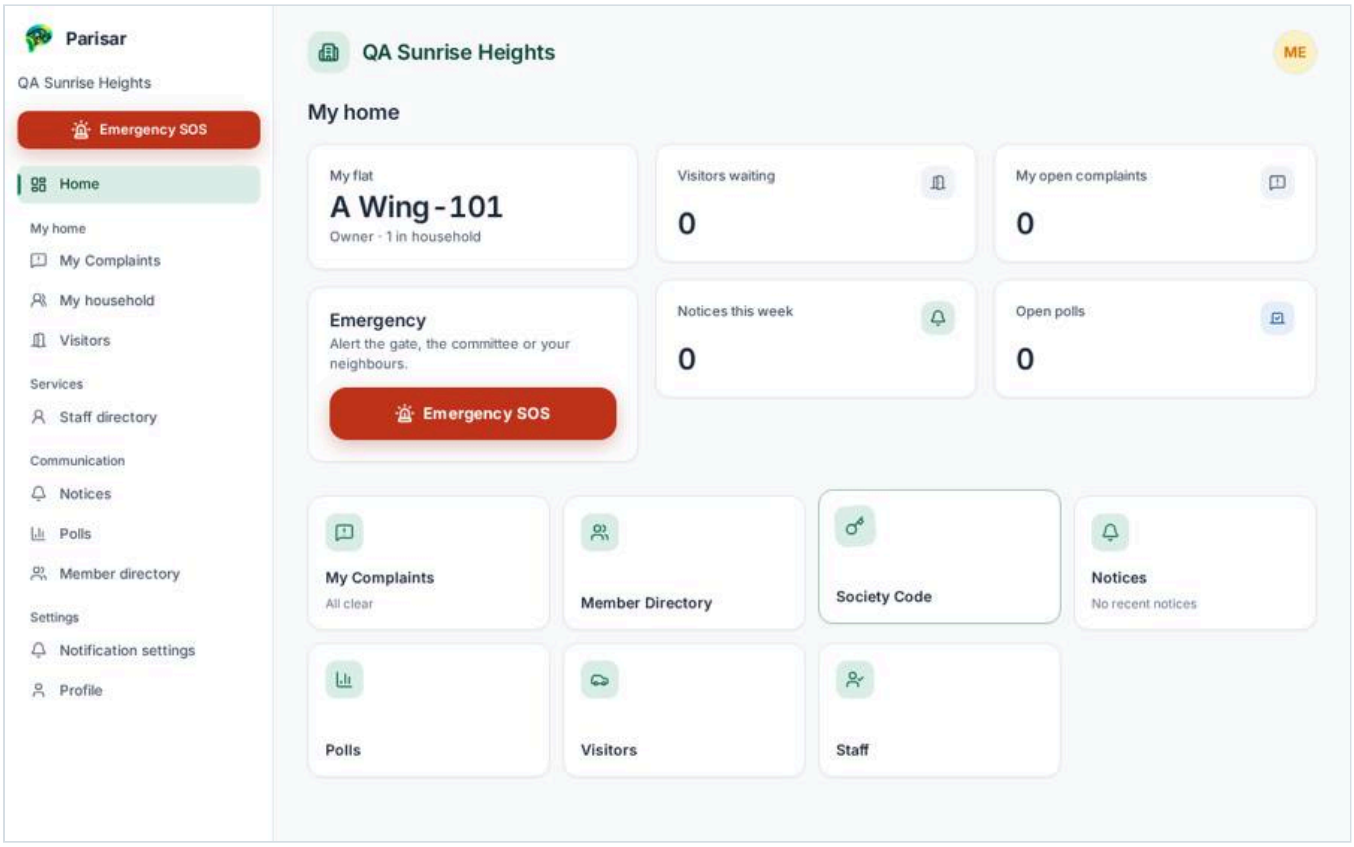
Dashboards



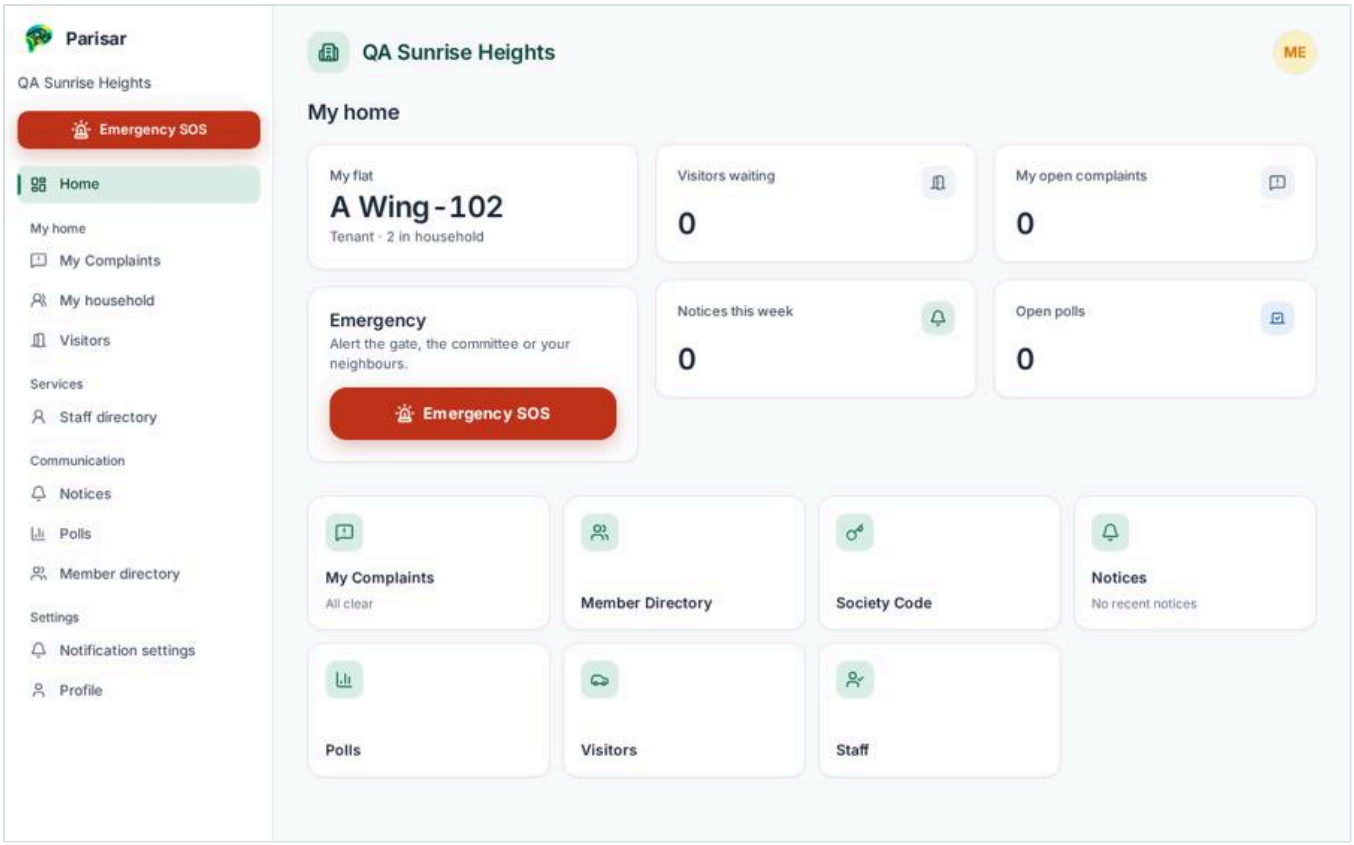
dashboard-authority-1280.png



dashboard-family-member-1280.png

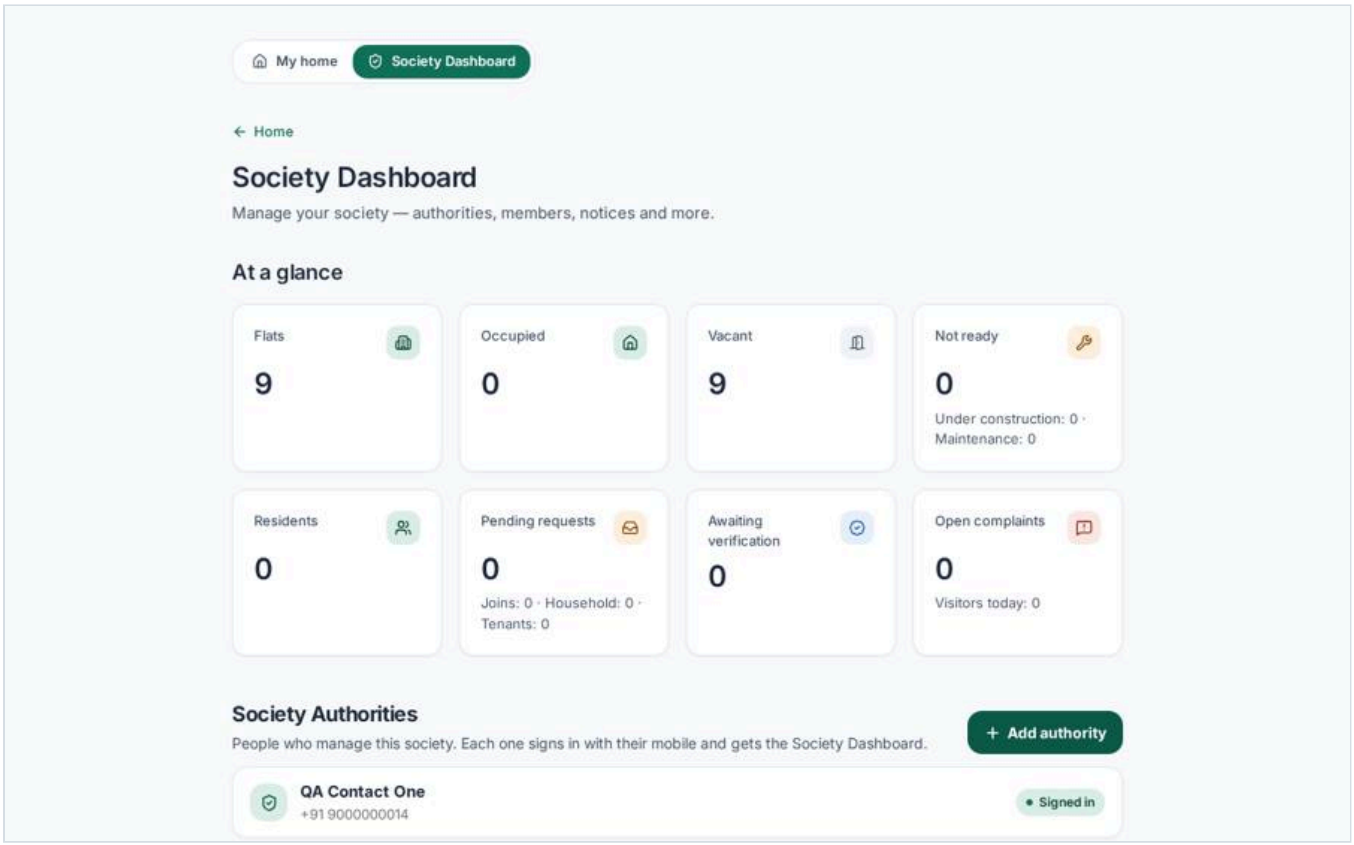


dashboard-owner-1280.png



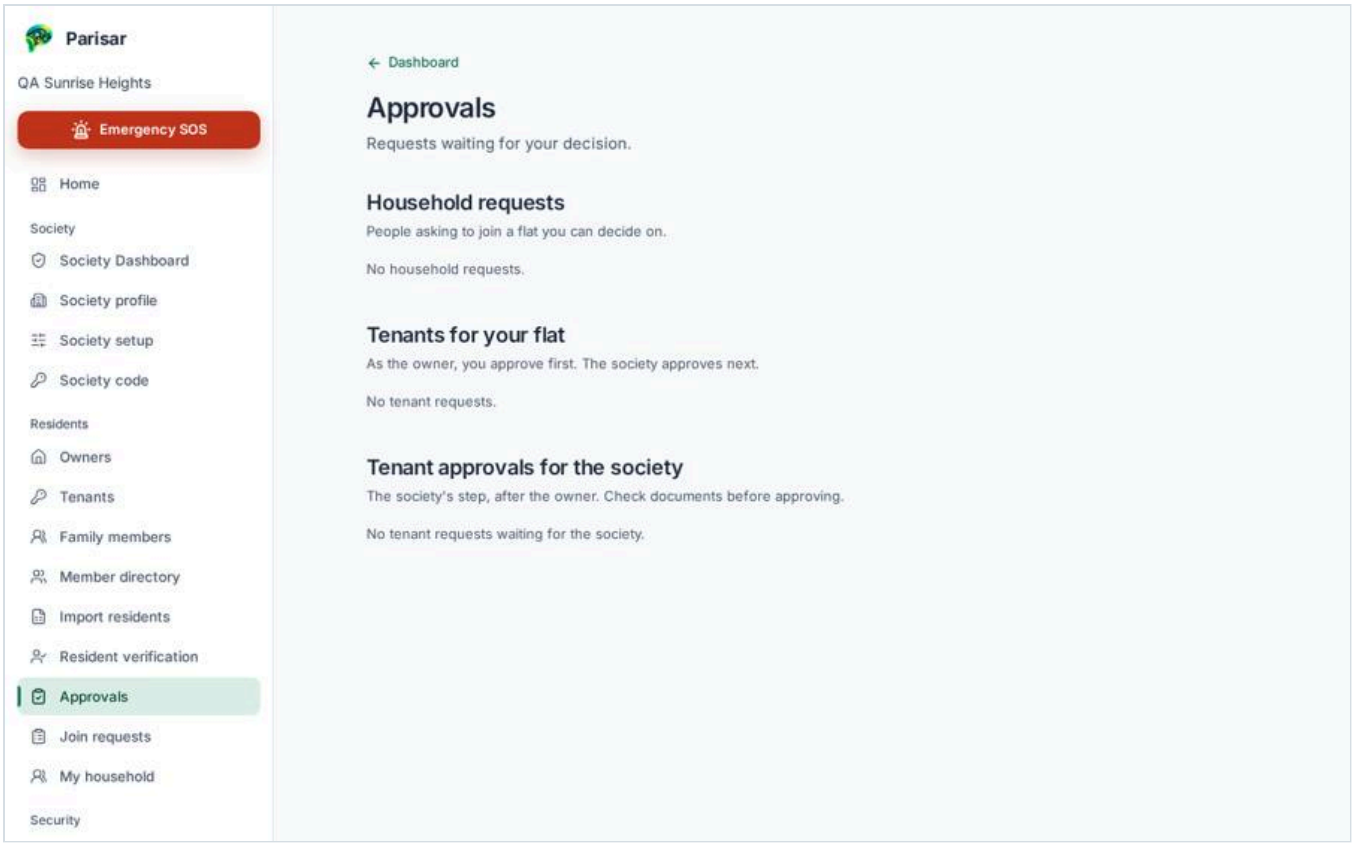
dashboard-tenant-1280.png

Society Dashboard

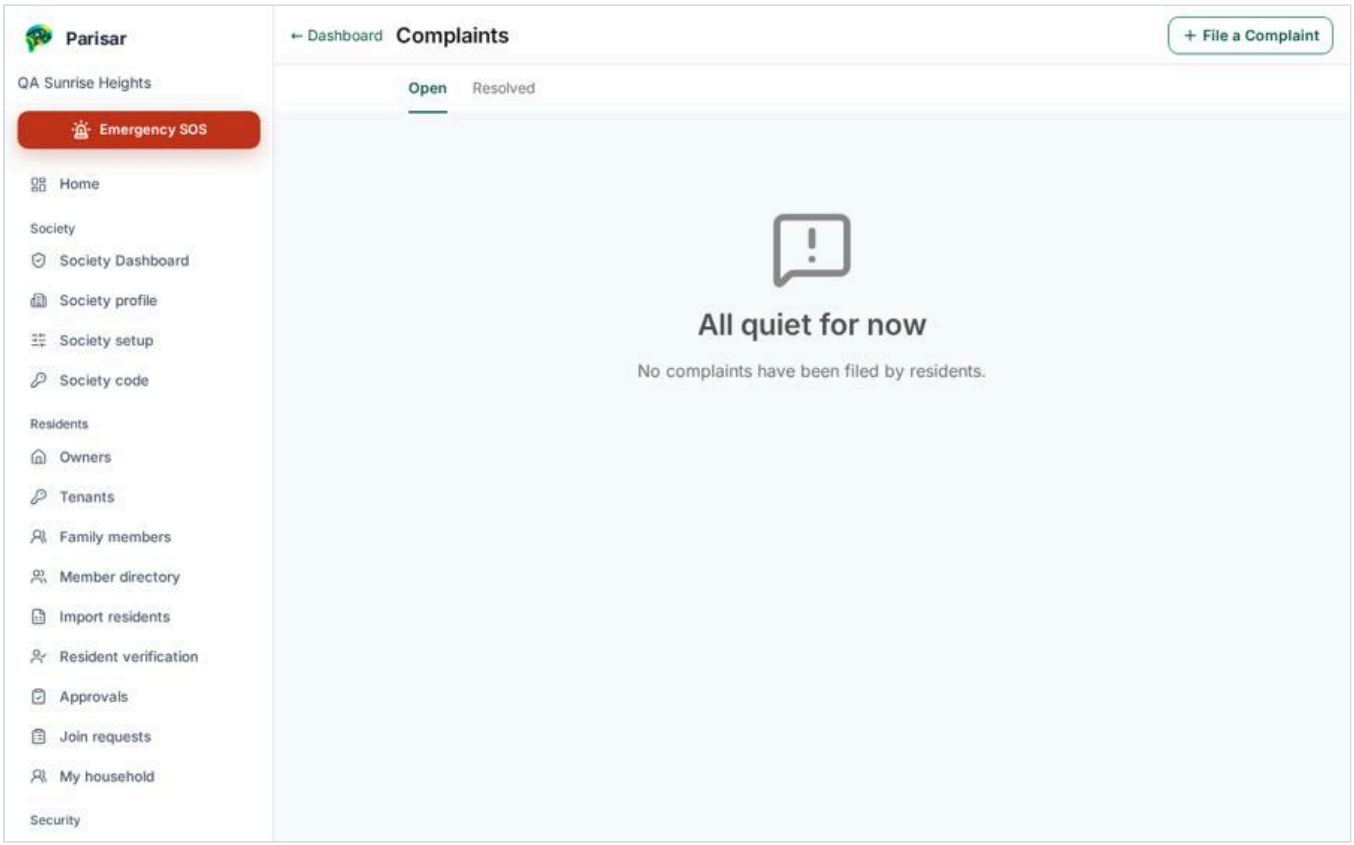


society-dashboard-1280.png

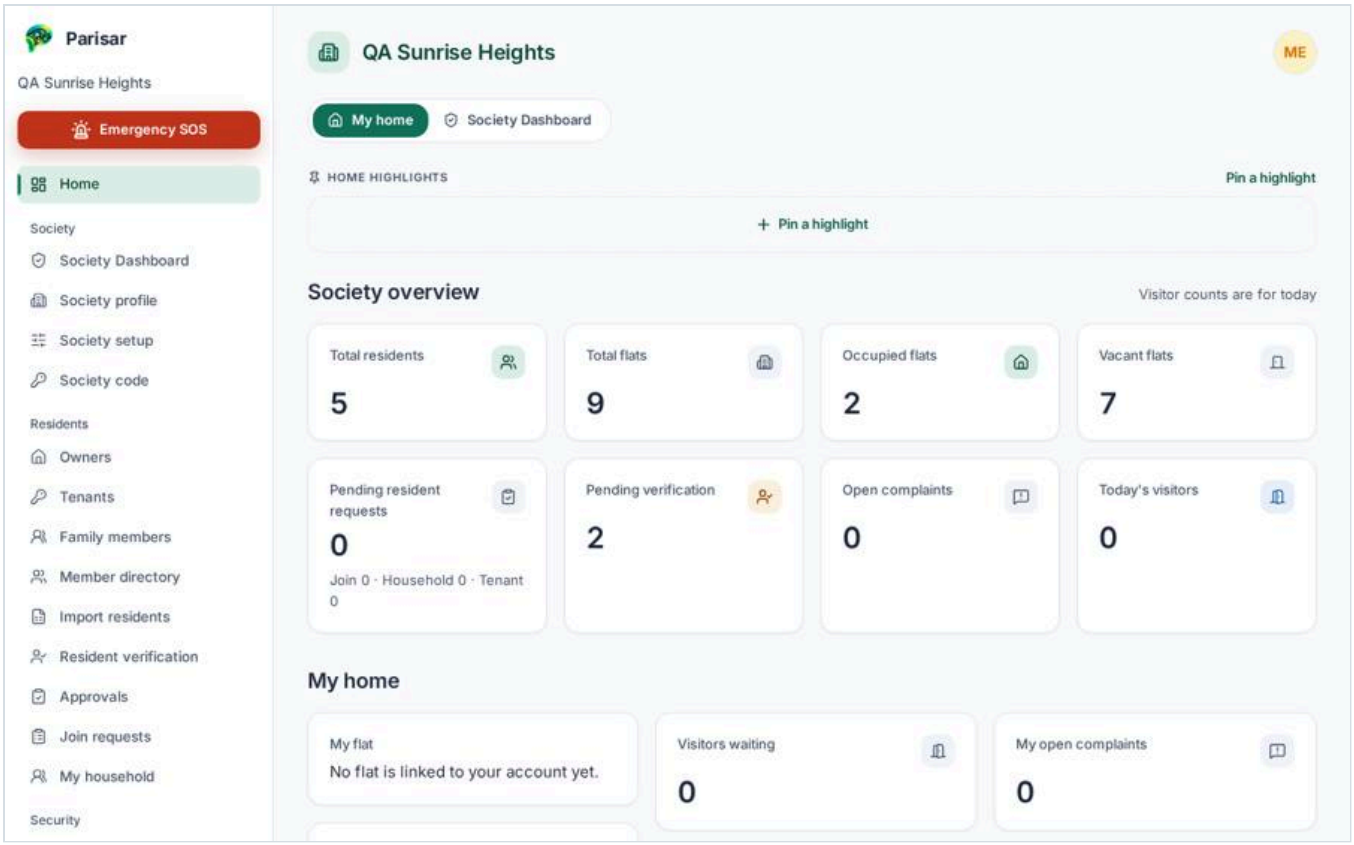
Role walkthrough (authority)



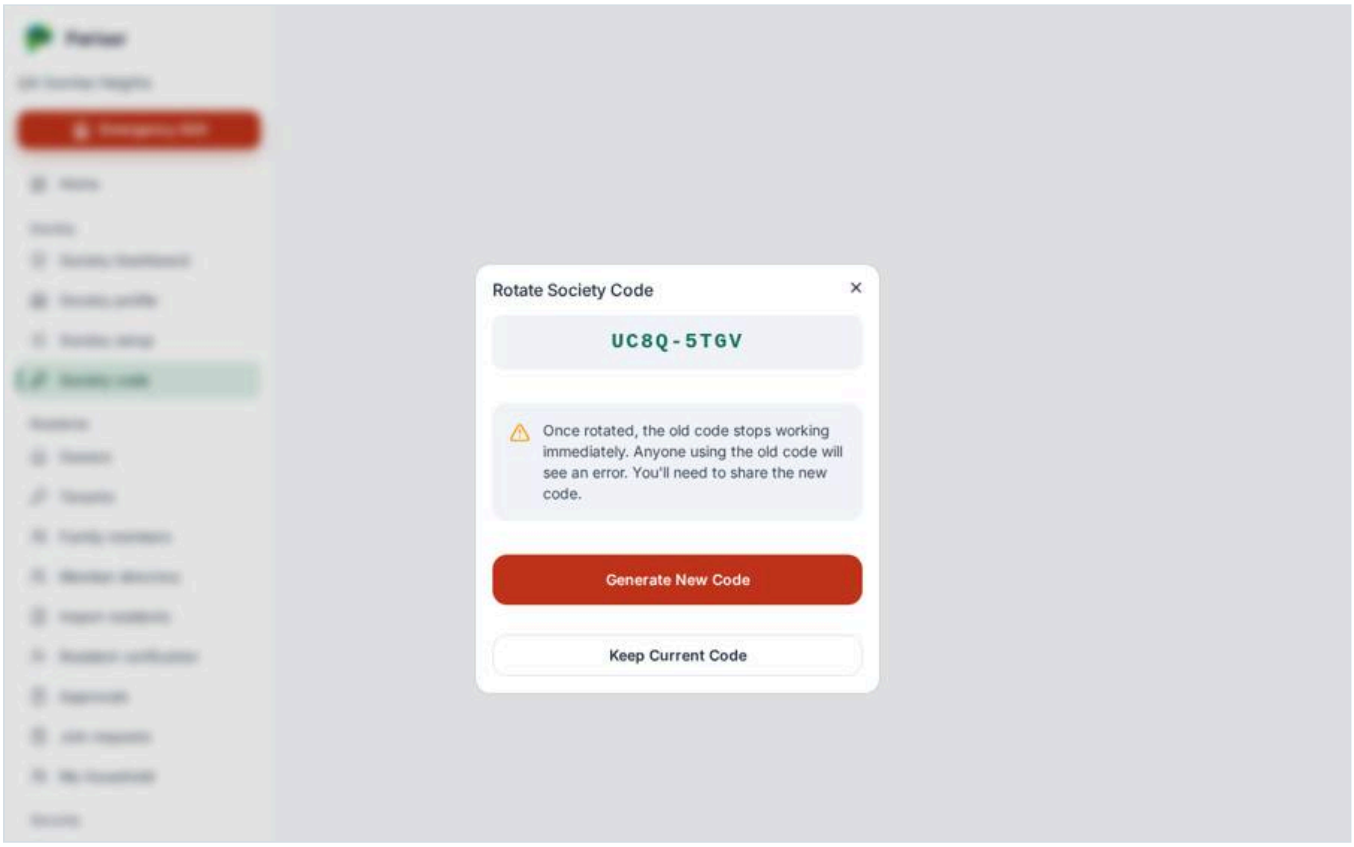
role-auth1-approvals-1280.png



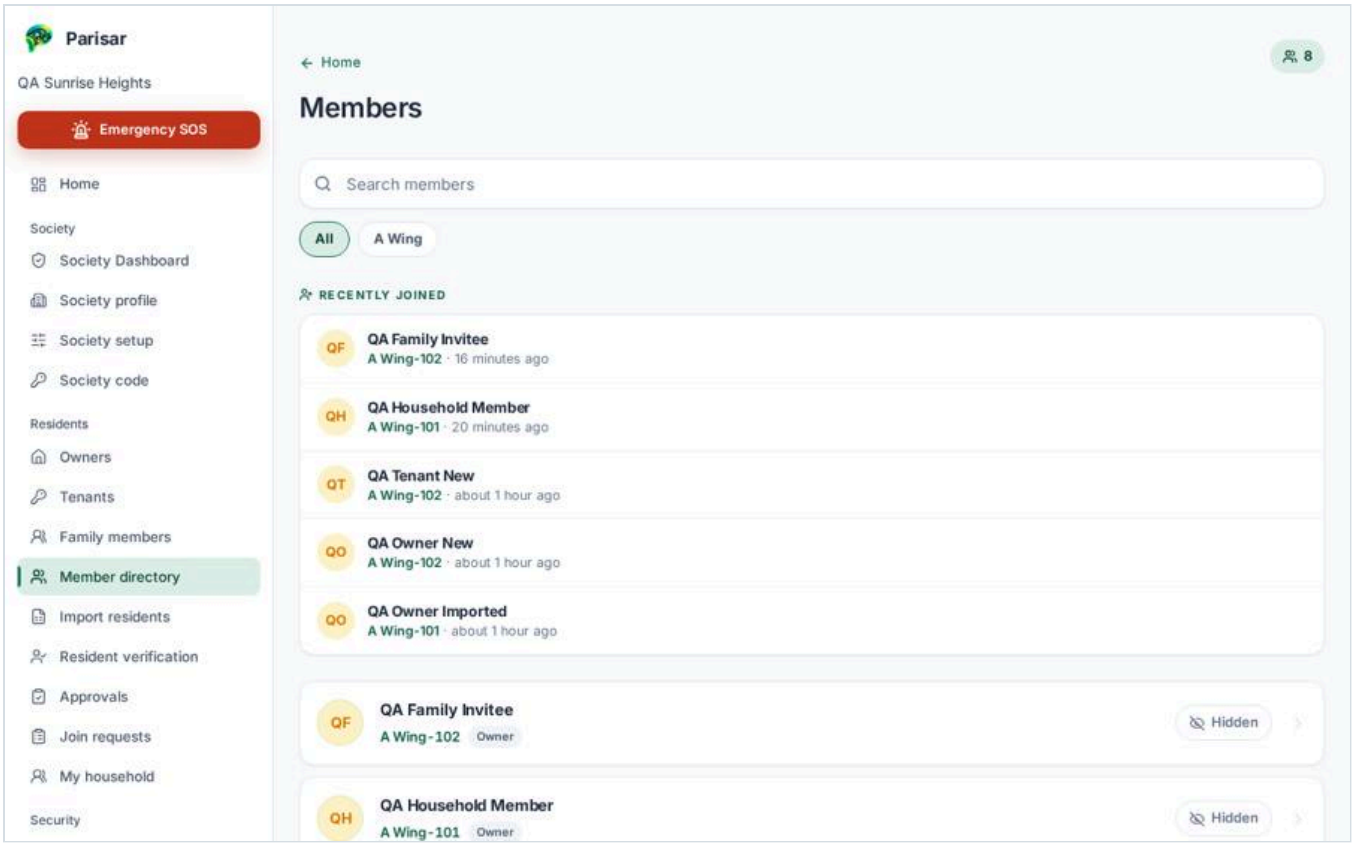
role-auth1-complaints-1280.png



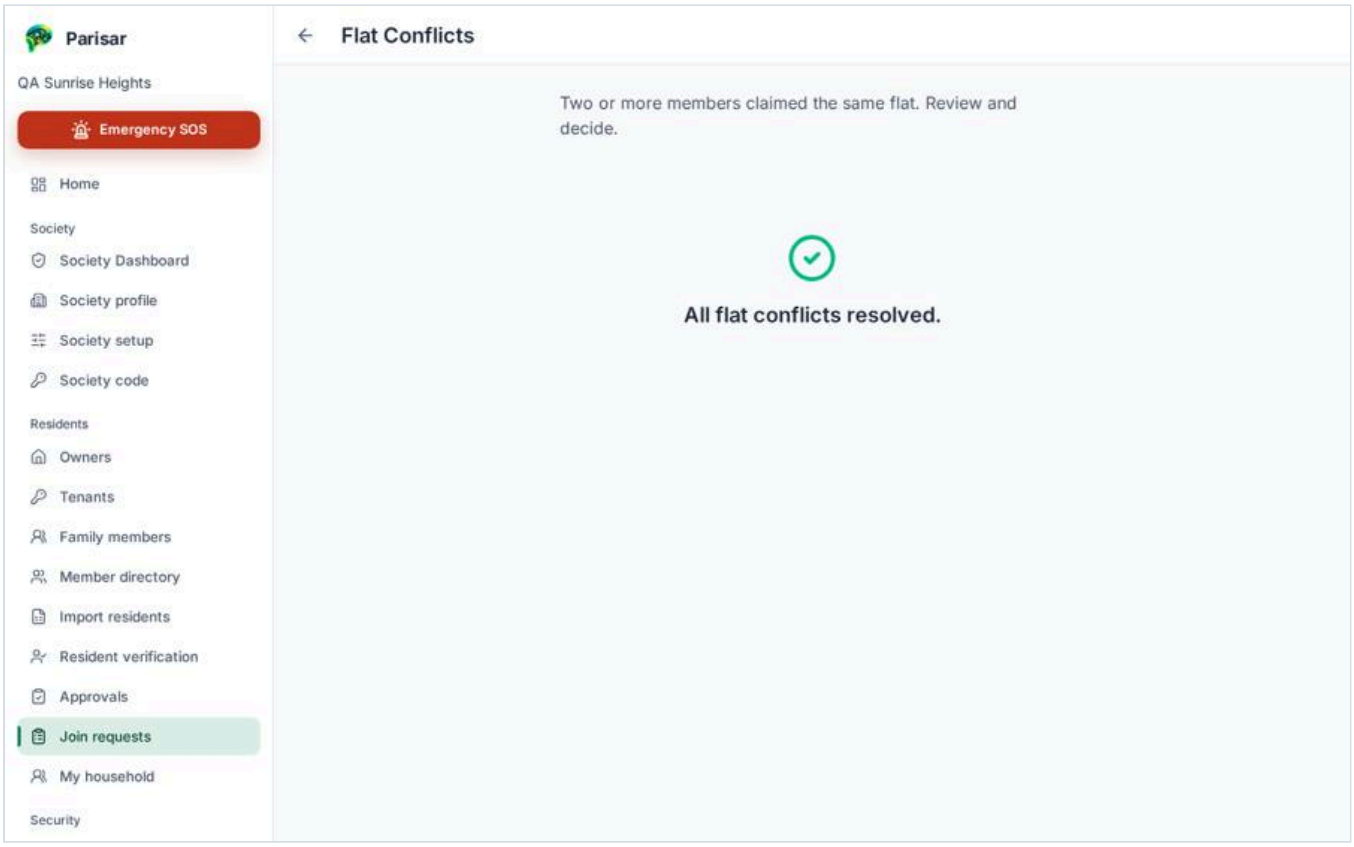
role-auth1-dashboard-1280.png



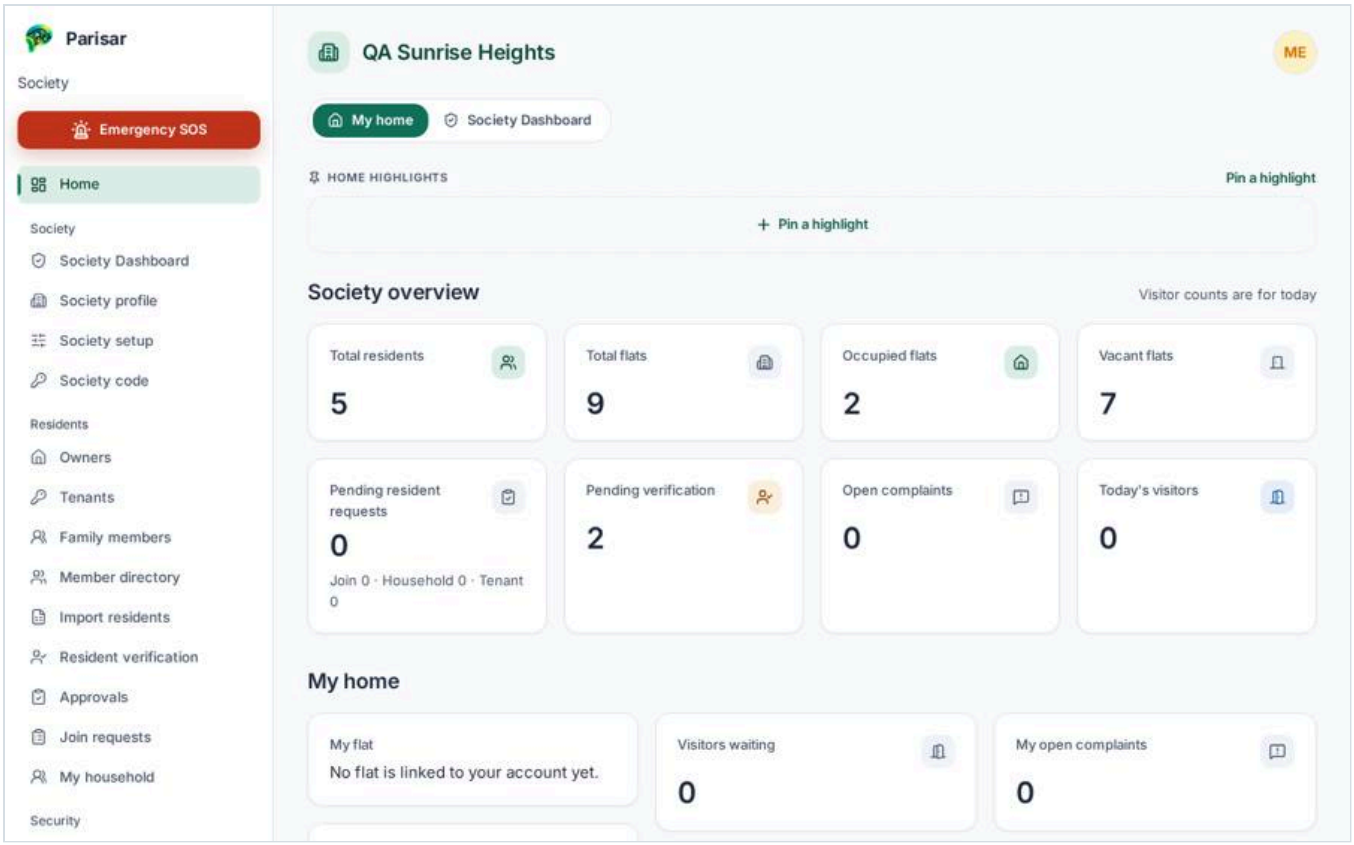
role-auth1-dashboard_code-rotation-1280.png



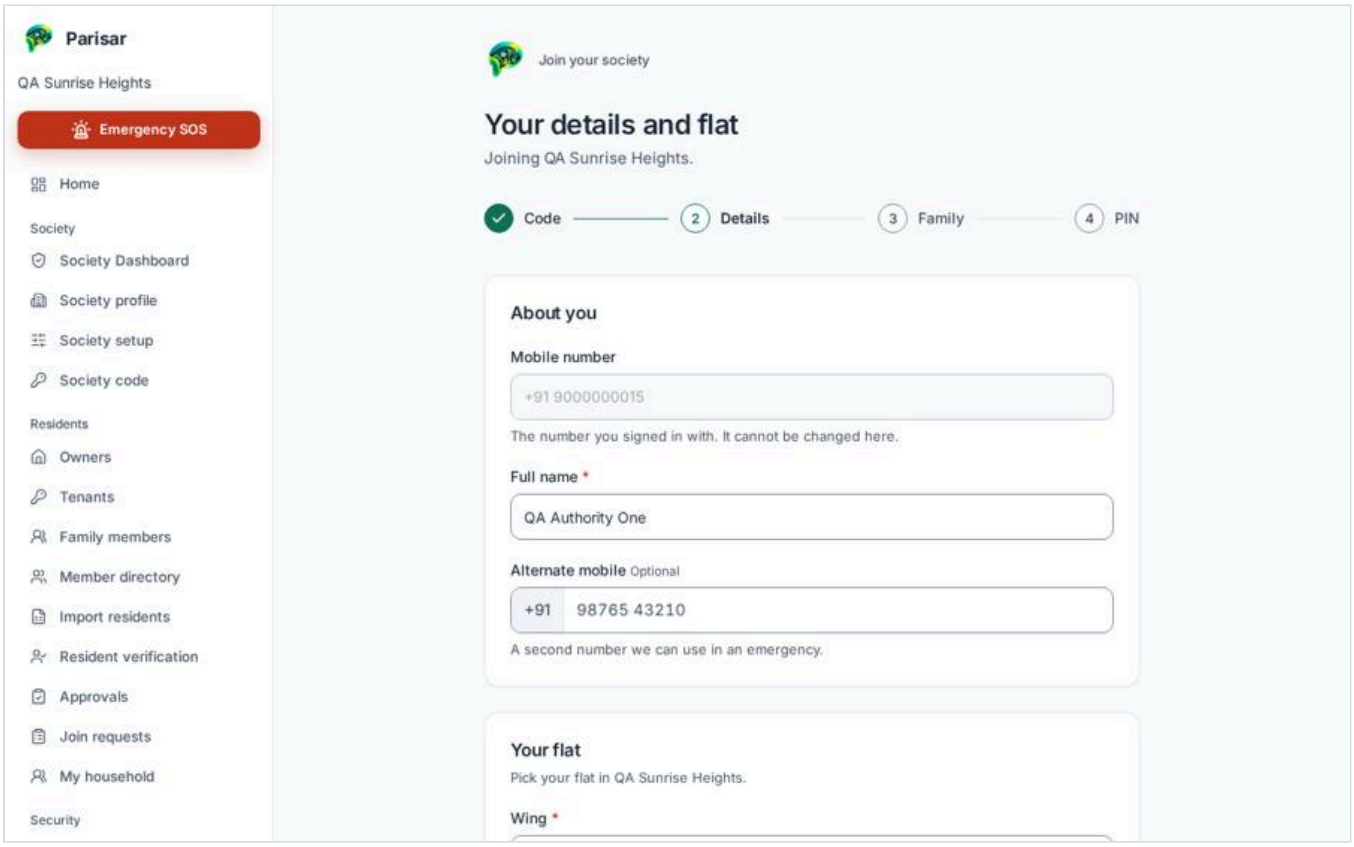
role-auth1-dashboard_directory-1280.png



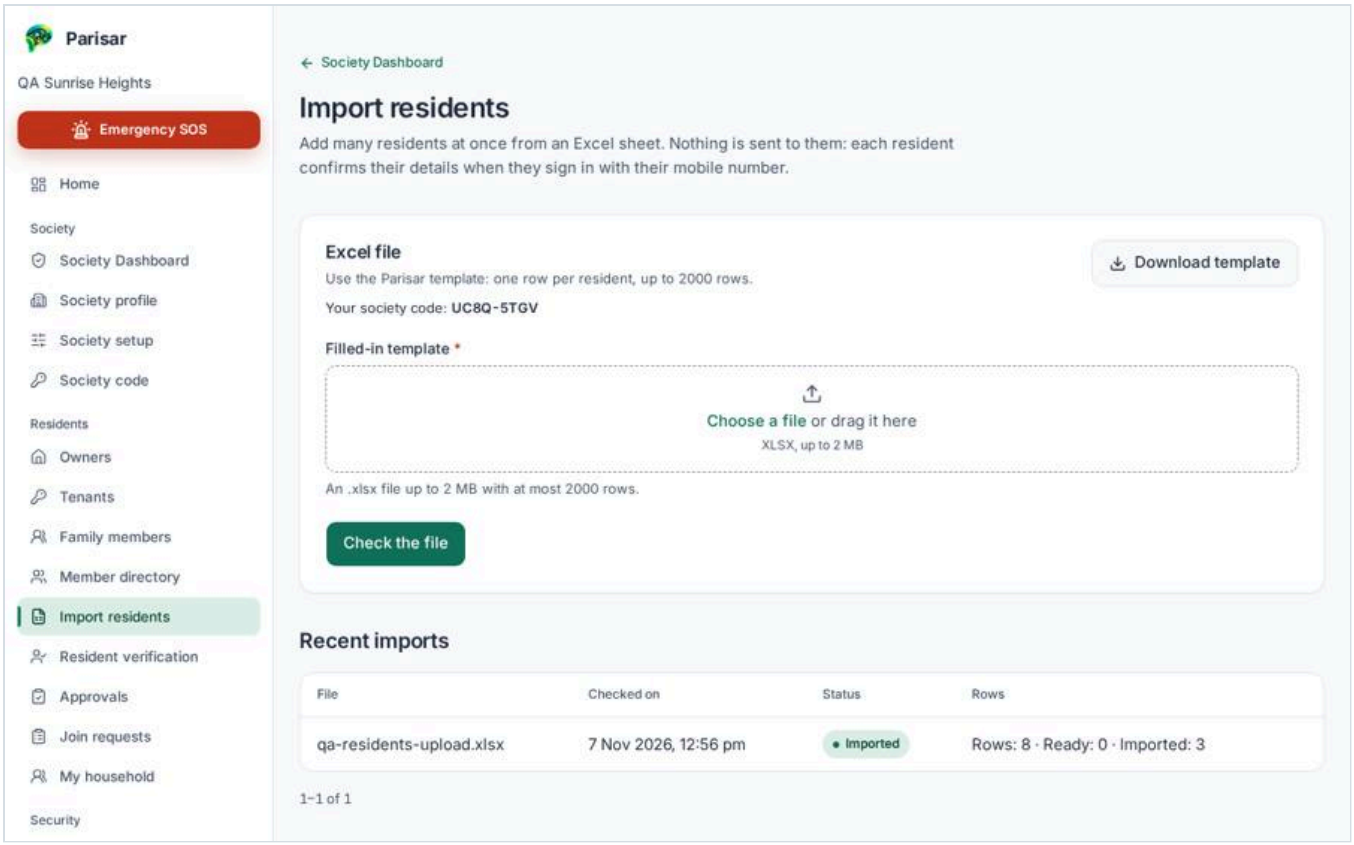
role-auth1-dashboard_review-queue-1280.png



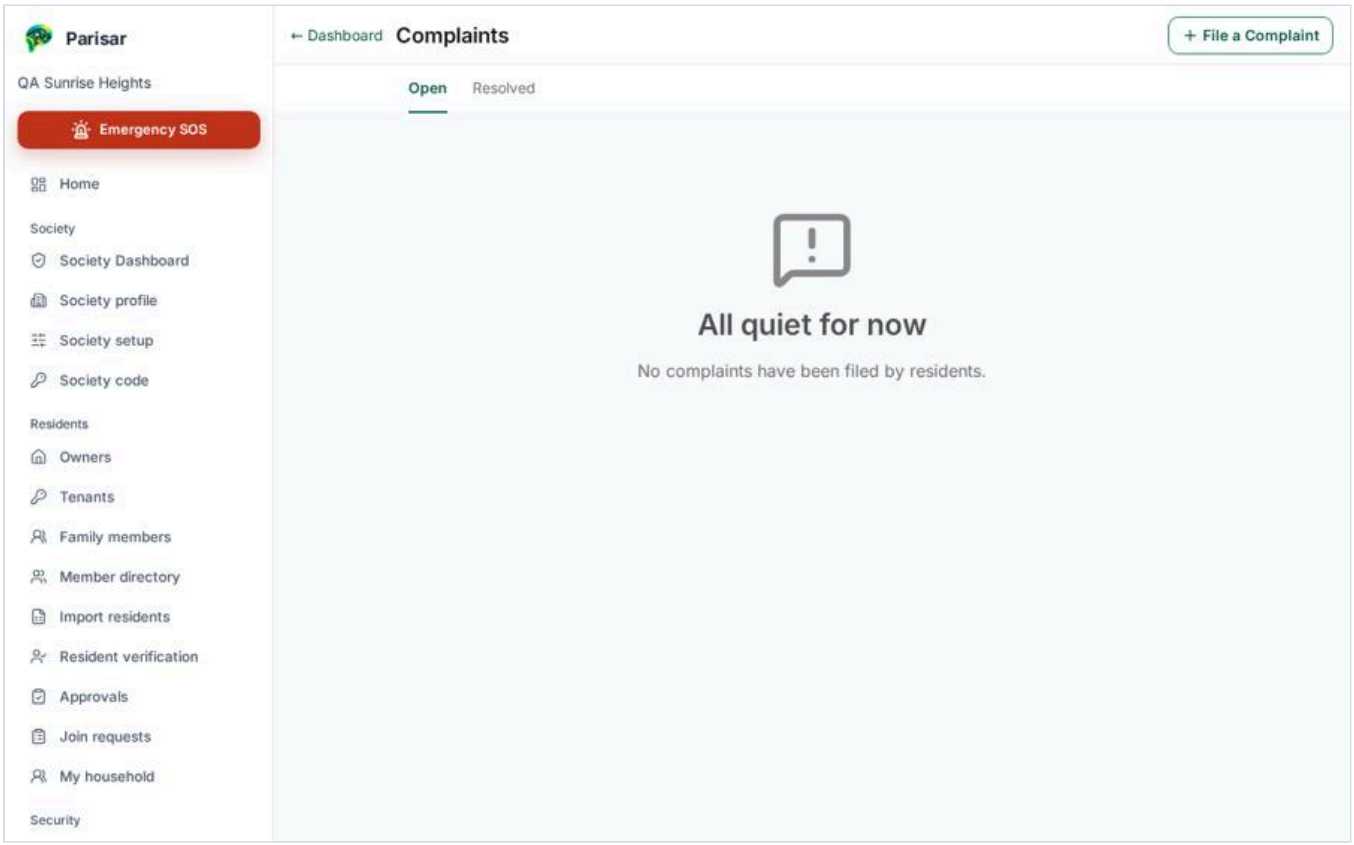
role-auth1-home-1280.png



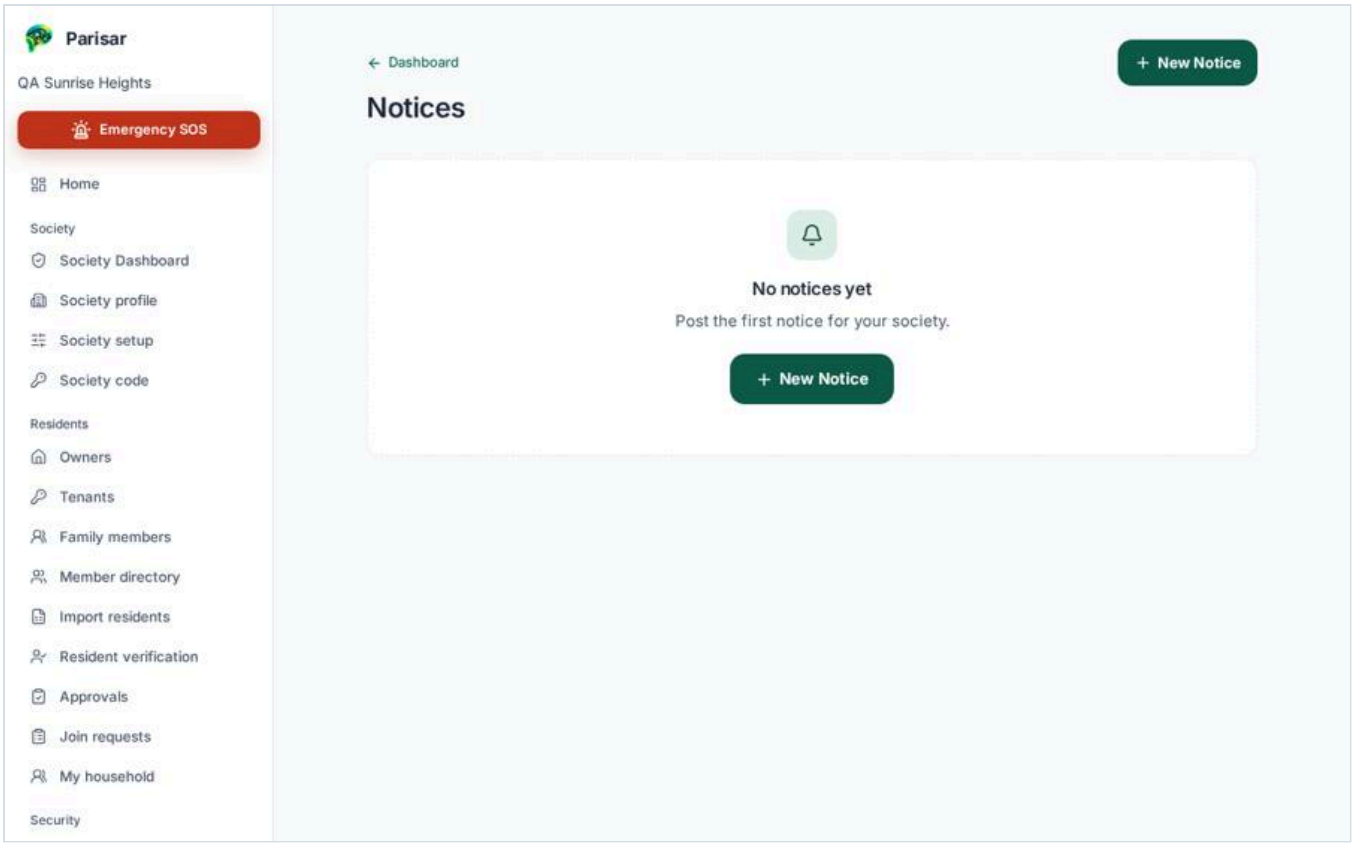
role-auth1-household-1280.png



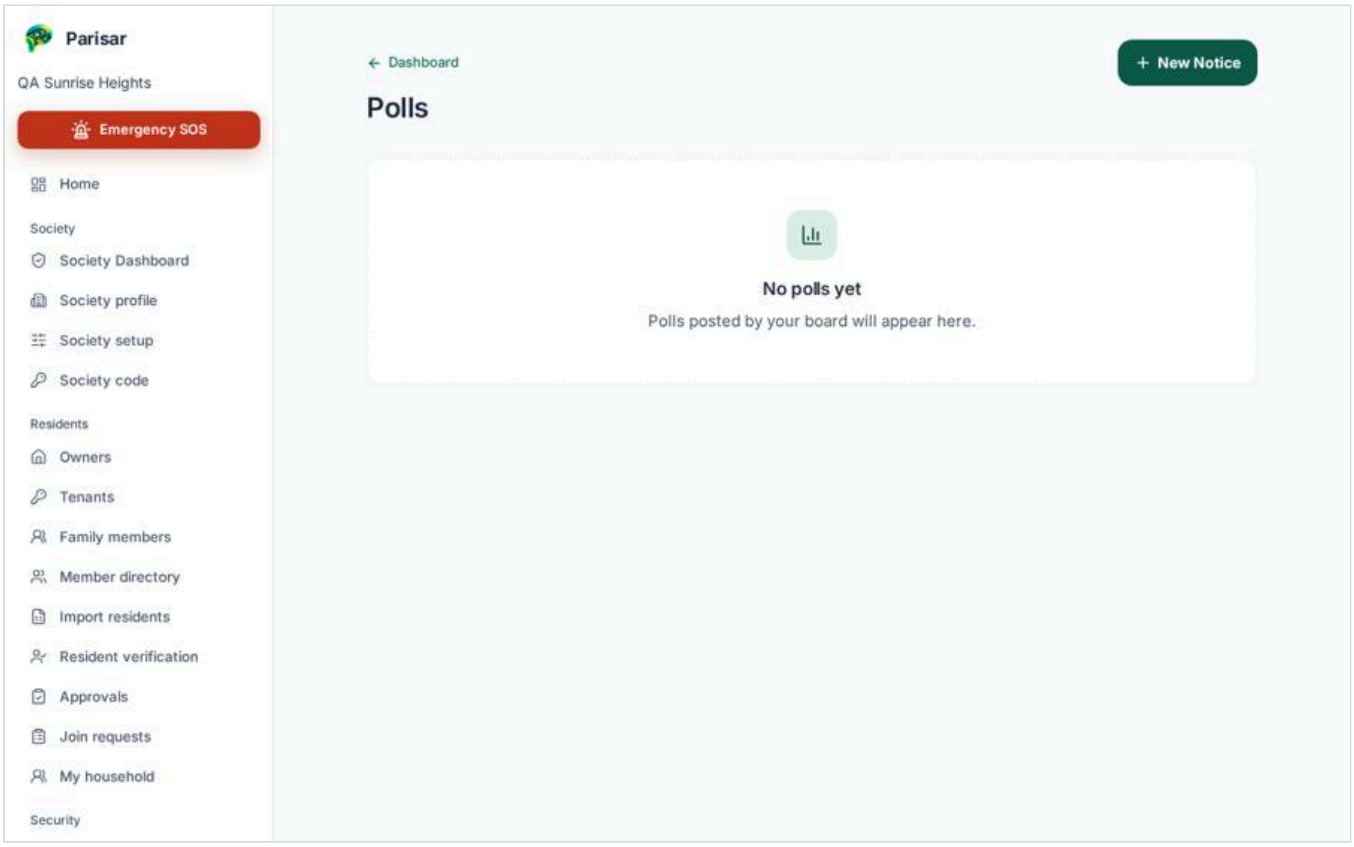
role-auth1-import-1280.png



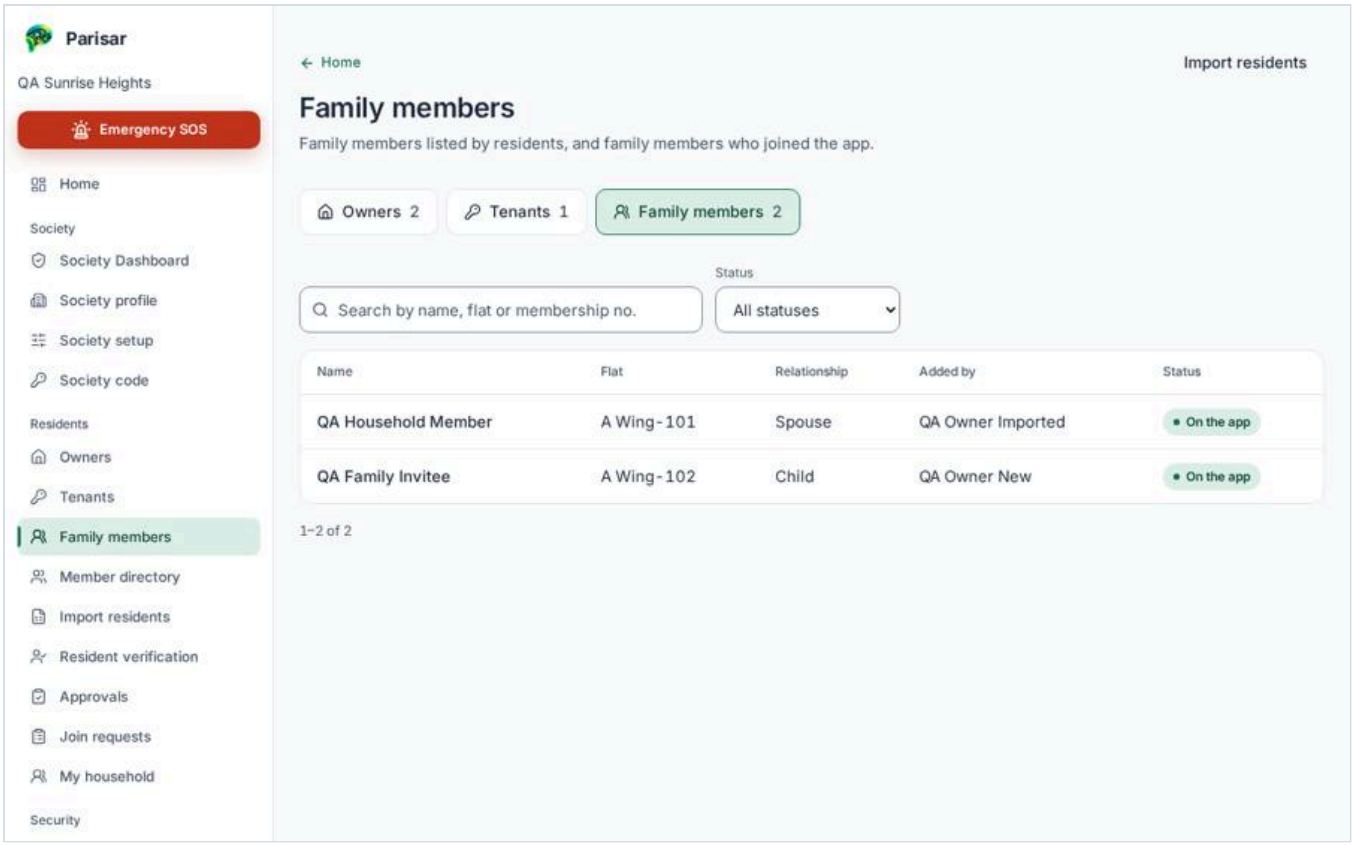
role-auth1-my-complaints-1280.png



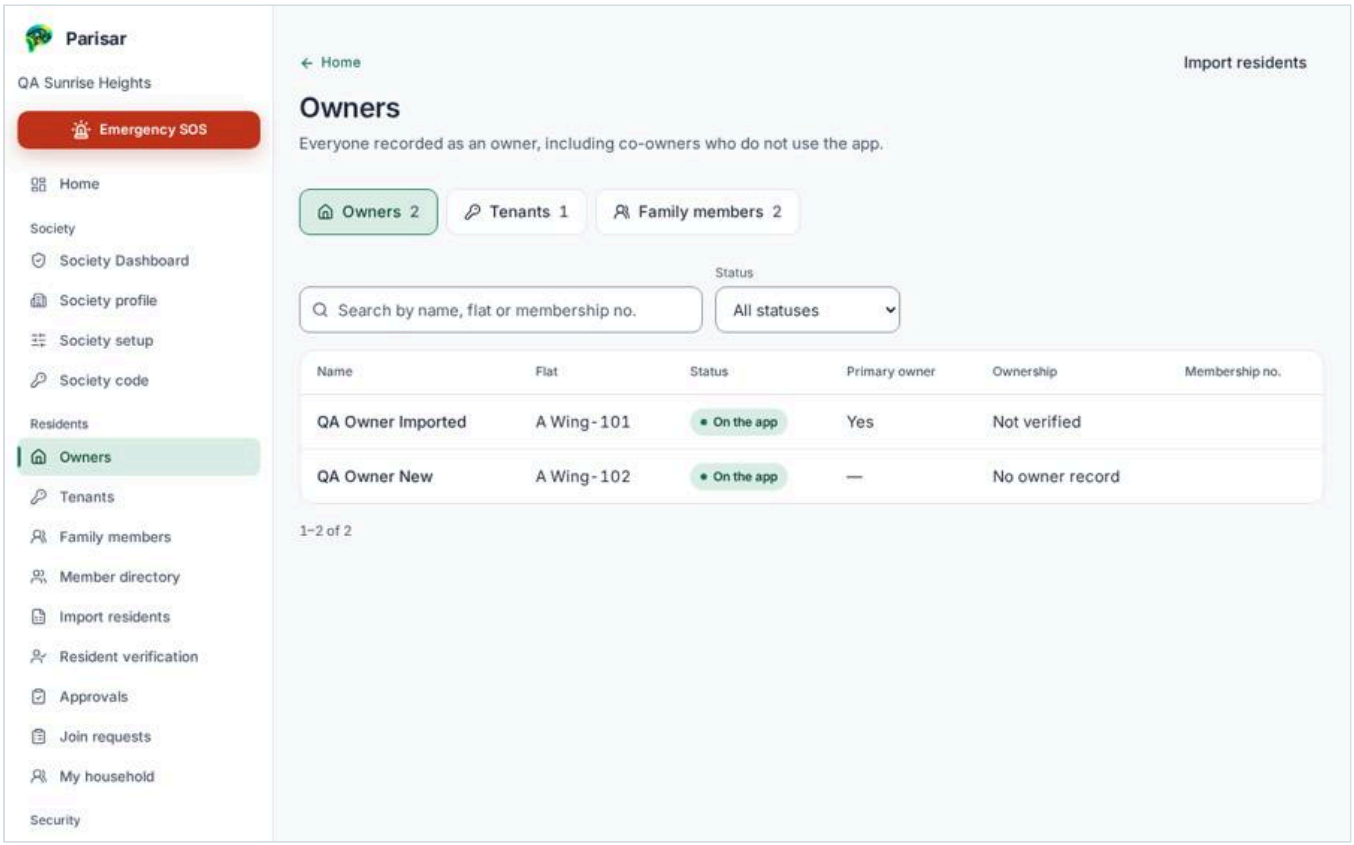
role-auth1-notices-1280.png



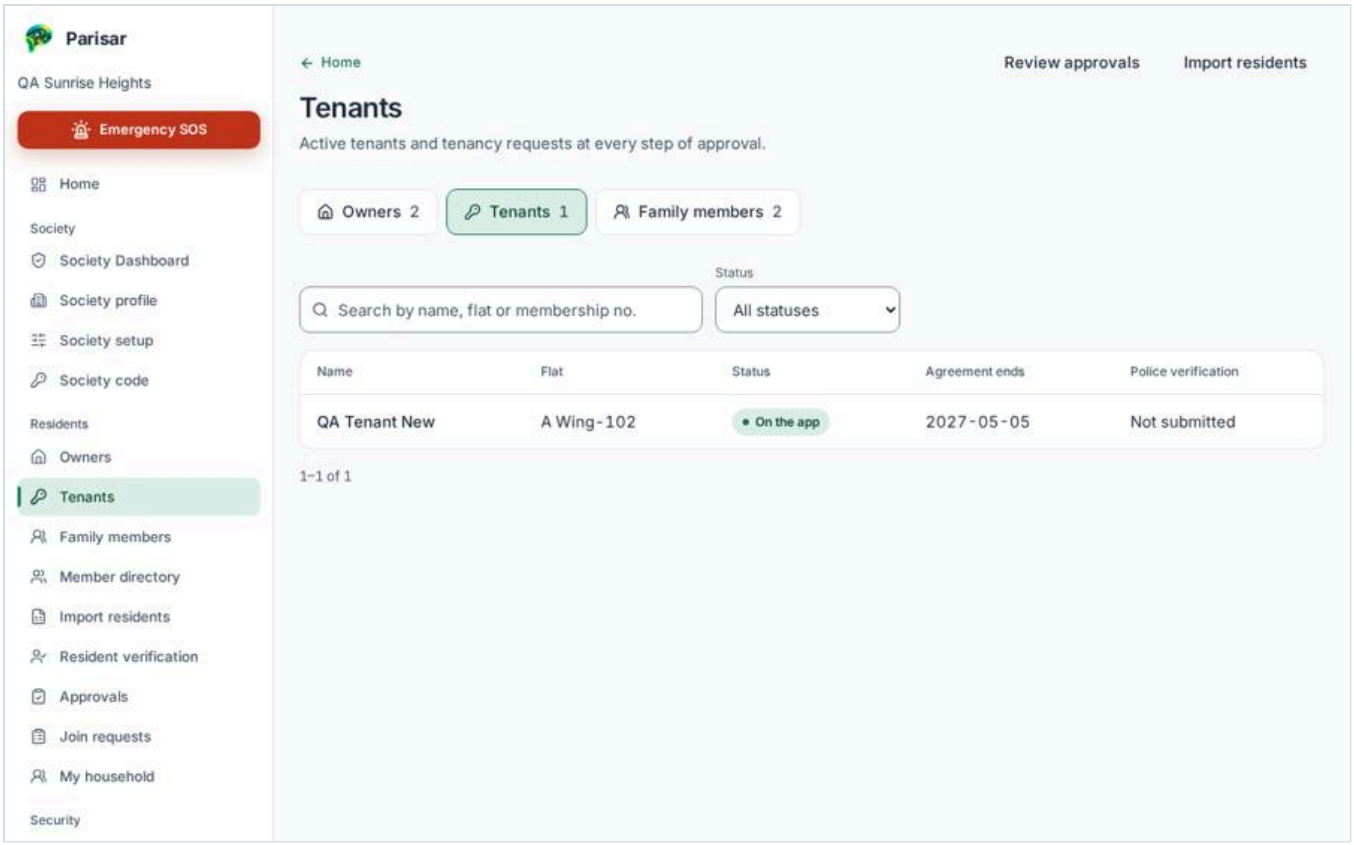
role-auth1-polls-1280.png



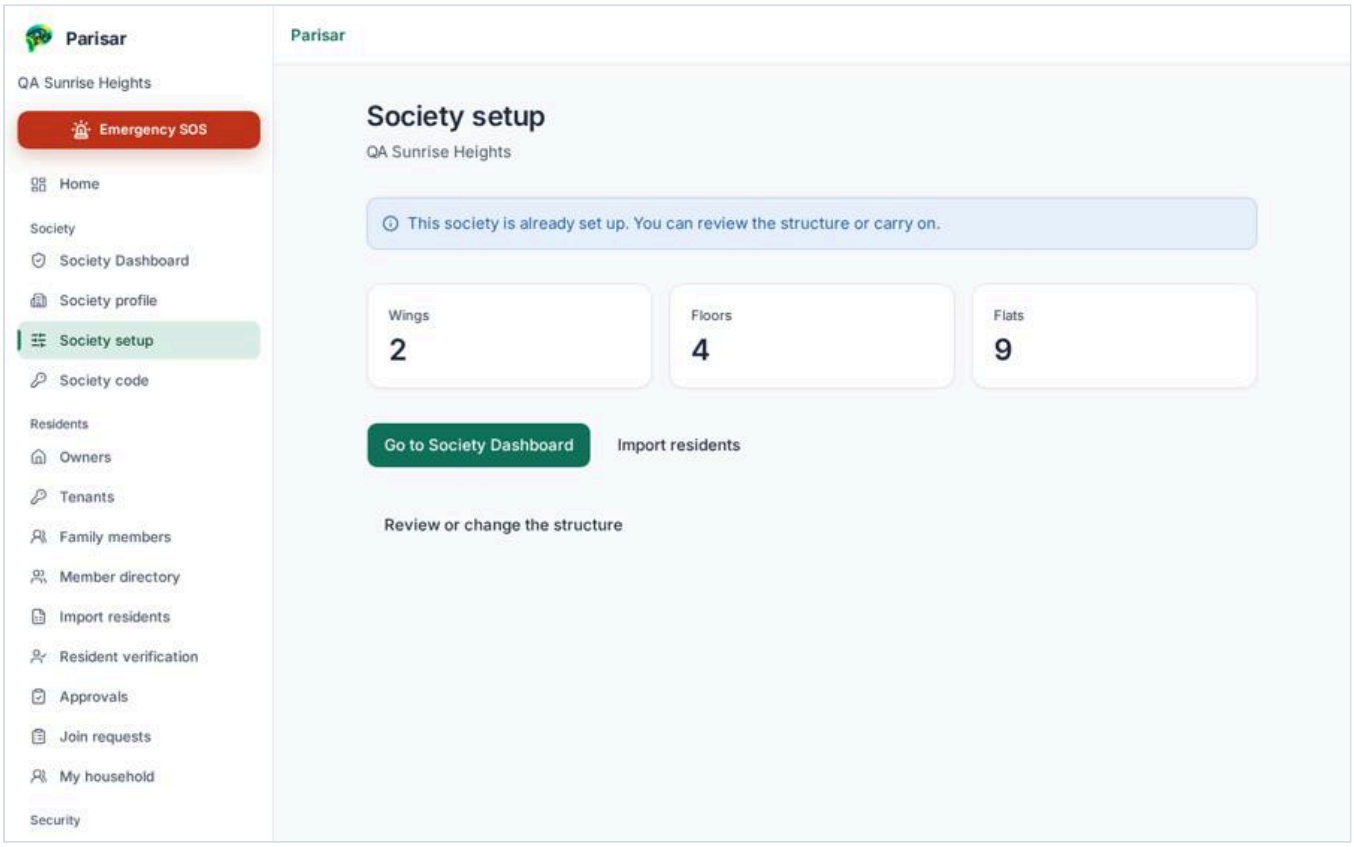
role-auth1-residents_family-1280.png



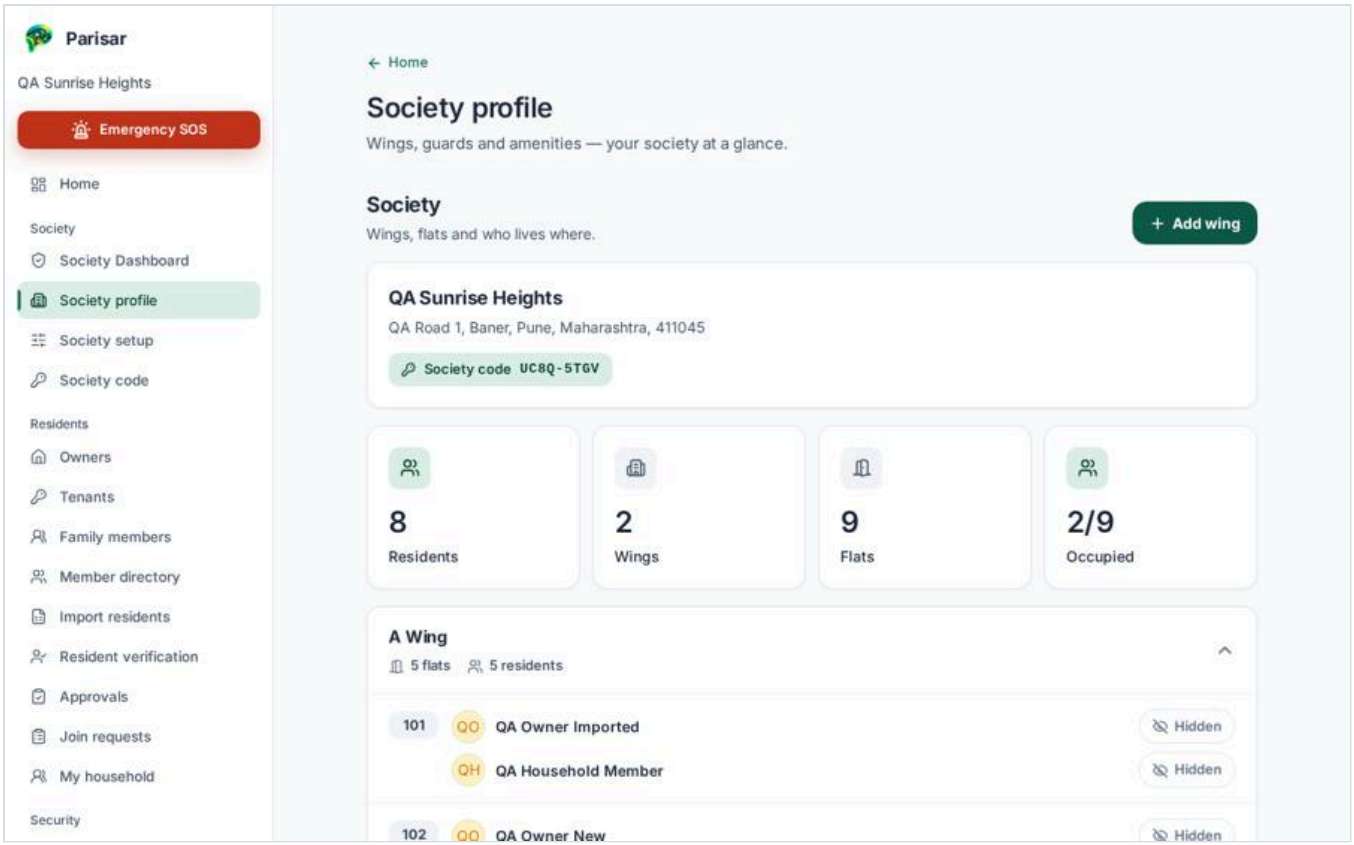
role-auth1-residents_owners-1280.png



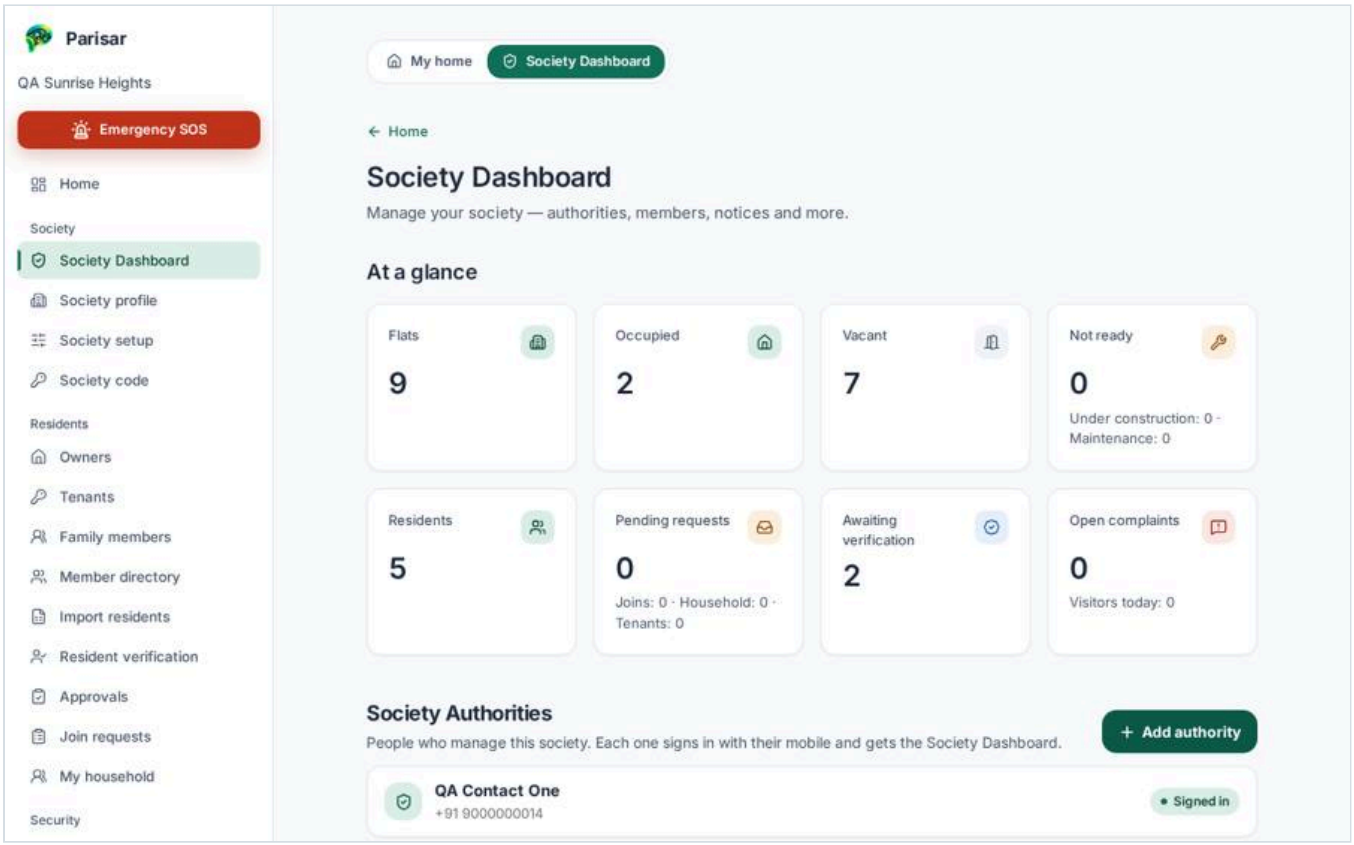
role-auth1-residents_tenants-1280.png



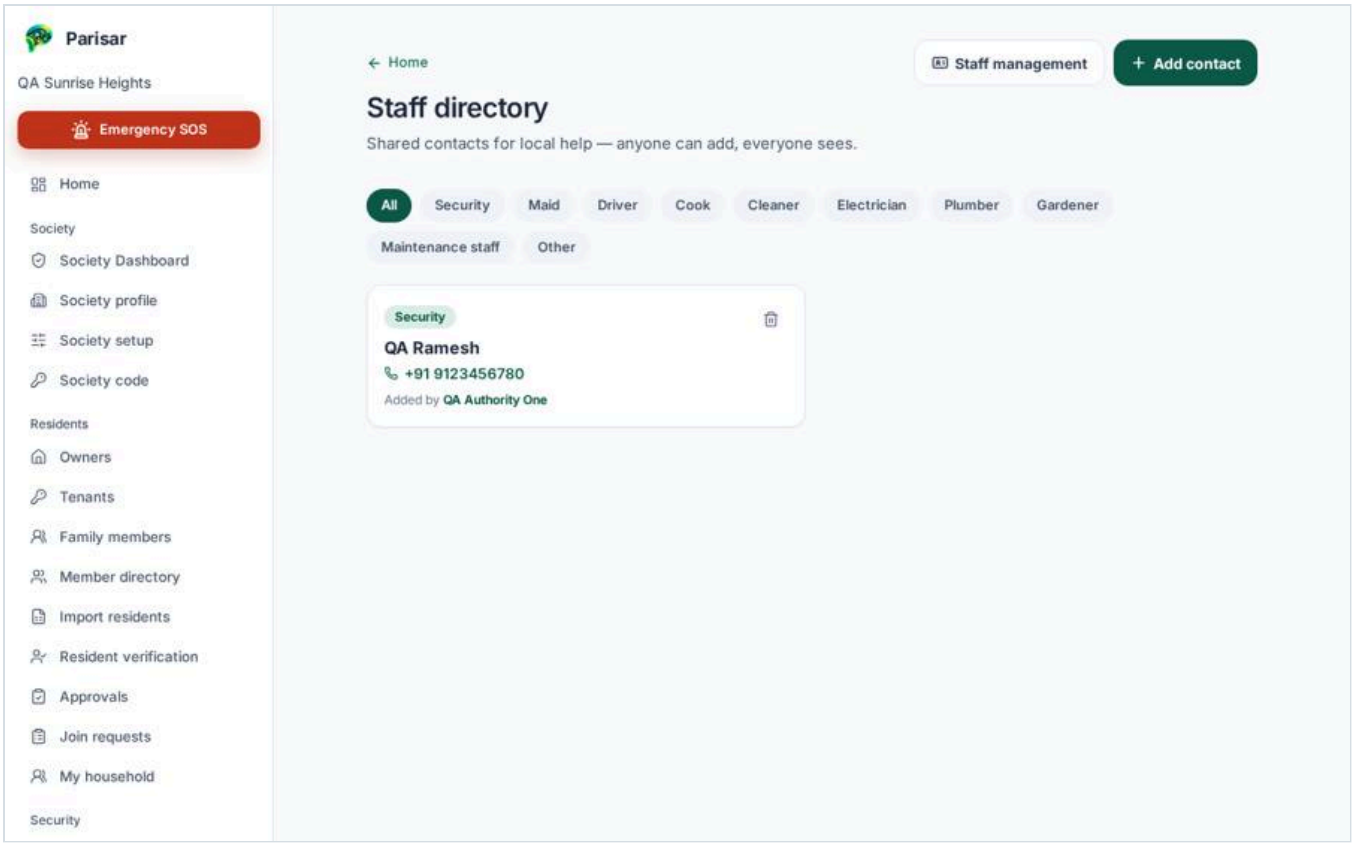
role-auth1-setup-1280.png



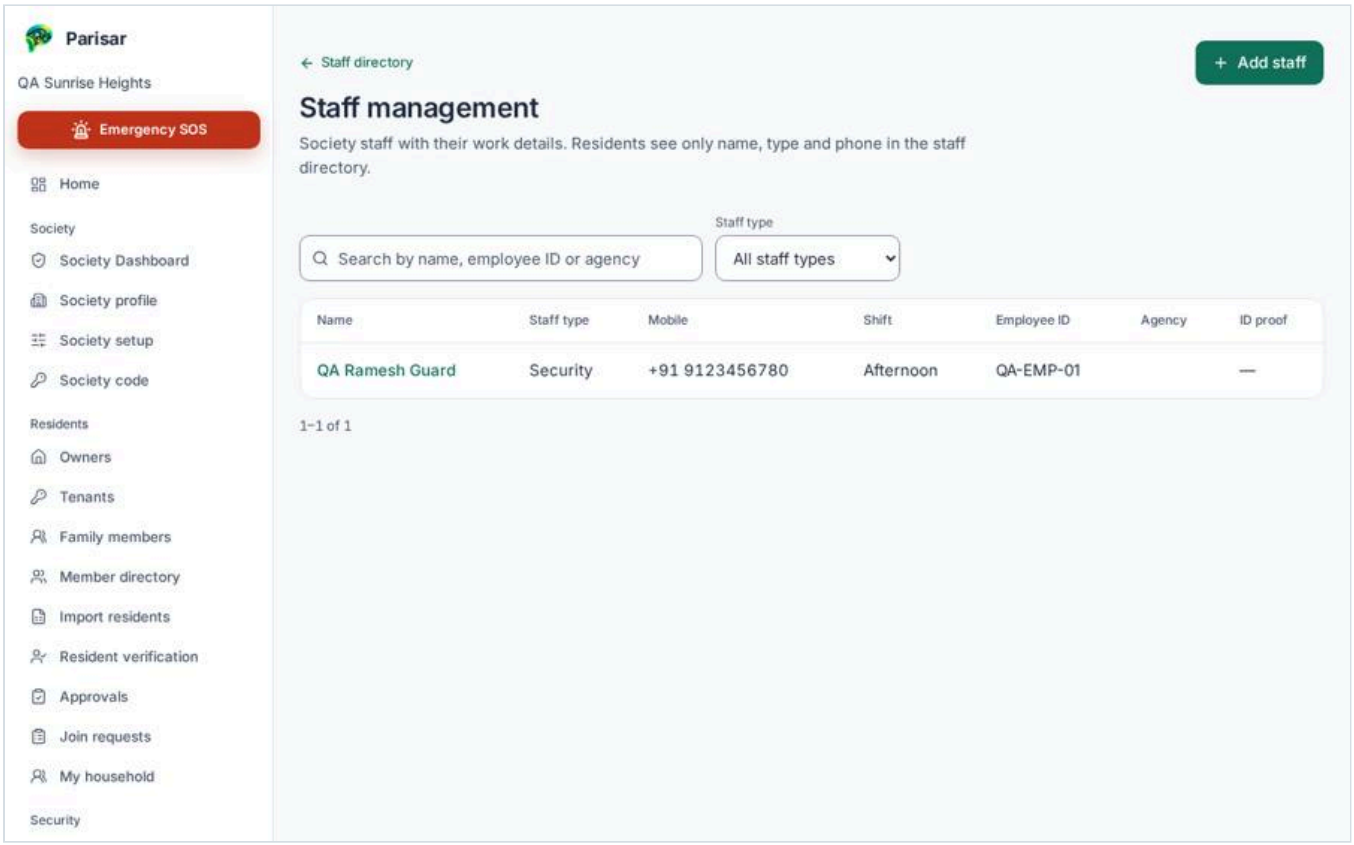
role-auth1-society-1280.png



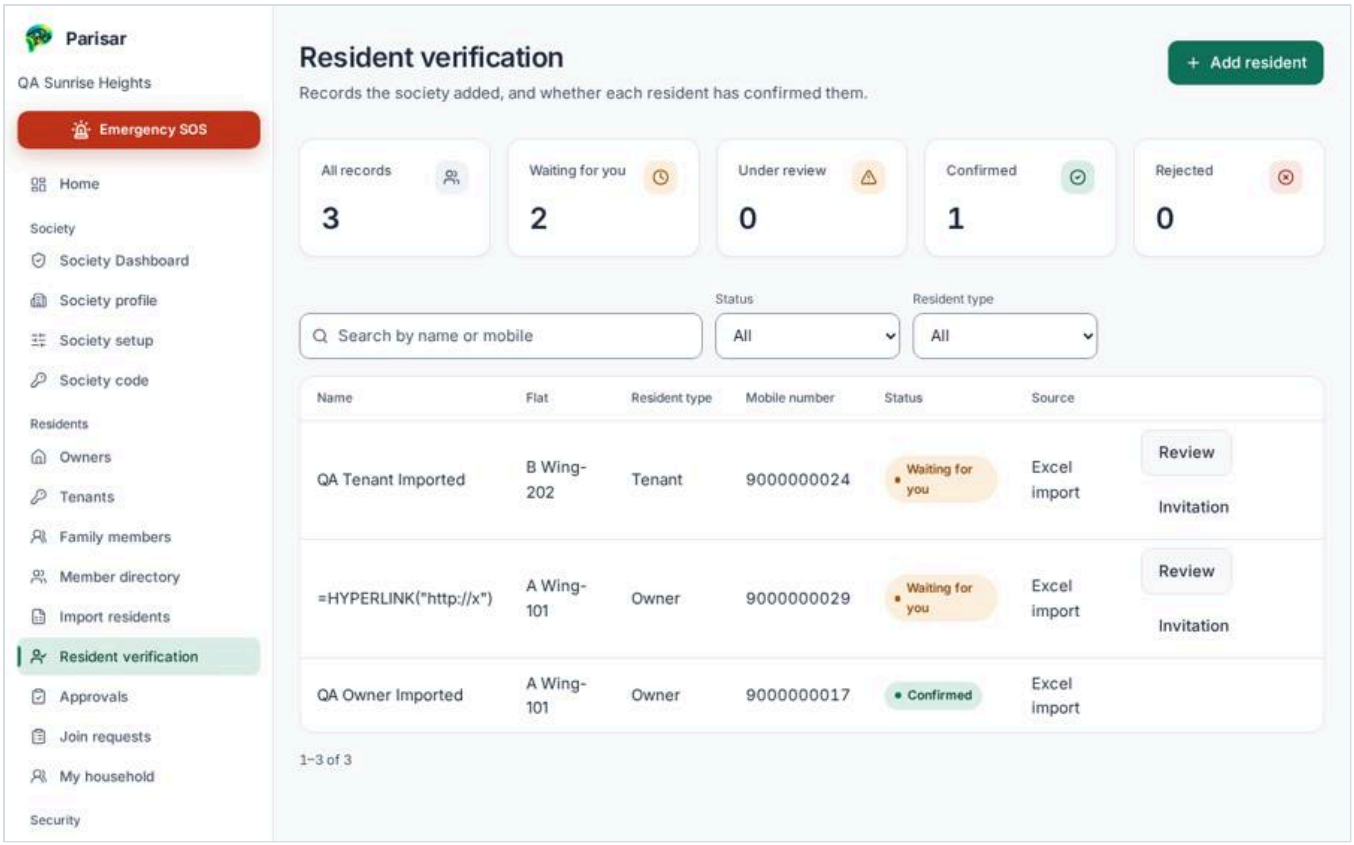
role-auth1-society-dashboard-1280.png



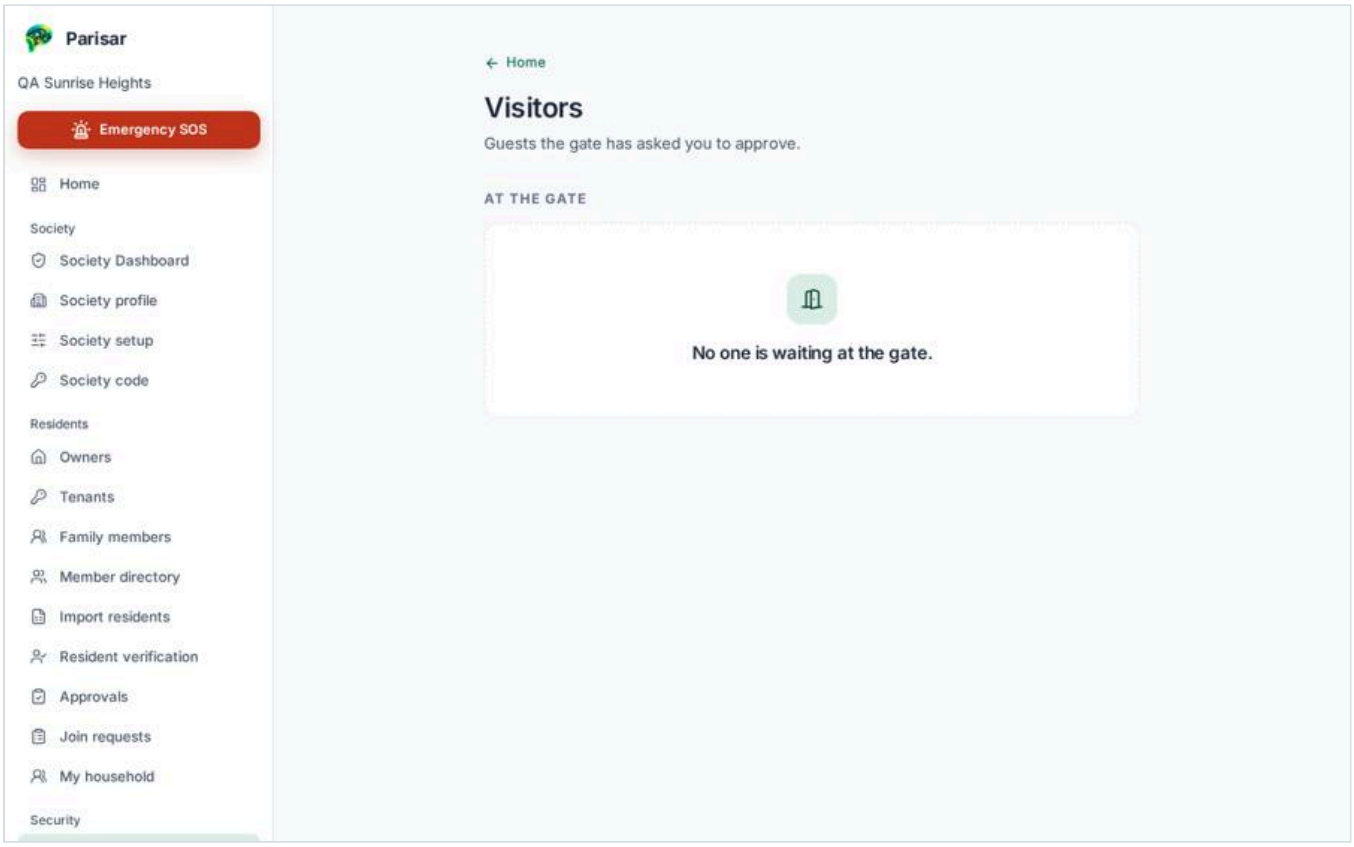
role-auth1-staff-1280.png



role-auth1-staff_manage-1280.png



role-auth1-verification_admin-1280.png



role-auth1-visitors-1280.png